

Комплексна система захисту інформації

Повний каталог заходів із
захисту інформації (950)

Зміст

Зміст

Анотація

Повний каталог (Bible) — містить абсолютно всі заходи, посилення та субконтролі згідно з повним скоупом НД ТЗІ КСЗІ.

1. АС

Клас заходів захисту АС — УПРАВЛІННЯ ДОСТУПОМ

Цей клас зосереджується на обмеженні доступу до інформаційних систем, ресурсів та функцій лише для авторизованих користувачів, програм і пристроїв.

Перелік заходів захисту: Політика та процедури управління доступом (АС-1); Управління обліковими записами (АС-2); Автоматизоване управління обліковими записами системи (АС-2(1)); Деактивація облікових записів (АС-2(3)); Дії при автоматизованому аудиті (АС-2(4)); Вихід із системи за відсутності активності (АС-2(5)); Динамічне управління привілеями (АС-2(6)); Схеми, засновані на ролях (АС-2(7)); Динамічне управління обліковими записами (АС-2(8)); Обмеження на використання спільних та групових облікових записів (АС-2(9)); Зміна даних спільних і групових облікових записів (АС-2(10)); Умови використання (АС-2(11)); Моніторинг нетипового використання облікових записів (АС-2(12)); Деактивація облікових записів осіб з високим рівнем ризику (АС-2(13)); Забезпечення доступу (АС-3); Обмежений доступ до привілейованих функцій (АС-3(1)); Подвійна авторизація (АС-3(2)); Мандатне управління доступом (АС-3(3)); Дискреційне управління доступом (АС-3(4)); Інформація щодо безпеки (АС-3(5)); Захист інформації користувача та системи (АС-3(6)); Управління доступом на основі ролей (АС-3(7)); Анулювання прав доступу (АС-3(8)); КЕРОВАНА ПЕРЕДАЧА (ПУБЛІКАЦІЯ) ІНФОРМАЦІЇ (АС-3(9)); Перегляд аудитом механізмів контролю доступу (АС-3(10)); Обмеження доступу до спеціальної інформації (АС-3(11)); Встановлення та забезпечення доступу до застосунків (АС-3(12)); Управління доступом на основі атрибутів (АС-3(13)); Індивідуальний доступ (АС-3(14)); Дискреційний та обов'язковий доступ (АС-3(15)); Управління інформаційними потоками (АС-4); Атрибути безпеки об'єкту (АС-4(1)); Домени оброб- (АС-4(2)); Управління інформаційними потоками управління інформаційним потоком (АС-4(3)); Управління потоком зашифрованої інформації (АС-4(4)); Вбудовування типів даних (АС-4(5)); Метадані (АС-4(6)); Механізми одностороннього потоку (АС-4(7)); Управління інформаційними політики безпеки (АС-4(8)); Перевірки, що проводить персонал (АС-4(9)); Активація та деактивація фільтрів політики безпеки (АС-4(10)); Конфігурація фільтрів політики безпеки (АС-4(11)); Ідентифікатори типу даних (АС-4(12)); Декомпозиція на відповідні політиці субкомпоненти (АС-4(13)); Обмеження фільтра політики безпеки (АС-4(14)); Виявлення несанкціонованої інформації (АС-4(15)); Передача інформації про взаємопов'язані системи (АС-4(16)); Прив'язка атрибуту безпеки (АС-4(18)); Перевірка метаданих (АС-4(19)); Затверджені рішення (АС-4(20)); Фізичне та логічне відділення інформаційних потоків (АС-4(21)); Єдиний доступ (АС-4(22)); Модифікована інформація, яка не підлягає оприлюдненню (АС-4(23)); Управління інформаційними нормалізований формат (АС-4(24)); Очищення даних (АС-4(25)); Дії з фільтрації аудиту (АС-4(26)); Управління інформаційними потоками кові/незалежні фільтруючі механізми (АС-4(27)); Лінійні фільтрувальні канали (АС-4(28)); Управління інформаційними ханізмів оркестровки (АС-4(29)); Механізми фільтрації з використанням кількох процесів (АС-4(30)); Запобігання спробам передачі вмісту, який не

пройшов перевірку фільтрації (АС-4(31)); Вимоги до процесу передачі інформації (АС-4(32)); Розмежування обов'язків (АС-5); Мінімізація повноважень (АС-6); Авторизований доступ до функцій безпеки (АС-6(1)); Непривілейований доступ до незахищених функцій (АС-6(2)); Роздільні домени обробки (АС-6(4)); Привілейовані облікові записи (АС-6(5)); Привілейований доступ користувачами, що не належать до організації (АС-6(6)); Перегляд повноважень користувача (АС-6(7)); Рівні привілеїв для виконання коду (АС-6(8)); Аудит використання привілейованих функцій (АС-6(9)); Заборона непривілейованим користувачам виконувати привілейовані функції (АС-6(10)); Невдалі спроби входу в систему (АС-7); Автоматичне блокування облікового запису (АС-7(1)); Очищення або стирання мобільного пристрою (АС-7(2)); Обмеження на спроби біометричного входу (АС-7(3)); Використання альтернативного фактора (АС-7(4)); Попередження про використання системи (АС-8); СПОВІЩЕННЯ ПРО ПОПЕРЕДНІЙ ВХІД (ДОСТУП) (АС-9); Невдалі спроби входу до системи (АС-9(1)); Успішні та невдалі спроби входу до системи (АС-9(2)); Повідомлення про зміни в обліковому записі (АС-9(3)); СПОВІЩЕННЯ ПРО ПОПЕРЕДНІЙ ВХІД (ДОСТУП) – ДОДАТКОВА ІНФОРМАЦІЯ ПРО ВХІД (АС-9(4)); Управління паралельною сесією (АС-10); Блокування пристрою (АС-11); Приховані дисплеї (АС-11(1)); Припинення сеансу (АС-12); Ініційоване користувачем блокування (АС-12(1)); Повідомлення про припинення сеансу (АС-12(2)); Застережне повідомлення про те, що час сесії добігає кінця (АС-12(3)); Управління доступом (АС-13); Дозволені дії без ідентифікації або автентифікації (АС-14); Дозволені дії без ідентифікації необхідне використання (АС-14(1)); Автоматизоване маркування (АС-15); Атрибути безпеки та приватності (АС-16); Динамічне пов'язання атрибутів (АС-16(1)); Зміна значень атрибутів авторизованими особами (АС-16(2)); Підтримка системою пов'язання атрибутів (АС-16(3)); Пов'язання атрибутів авторизованими особами (АС-16(4)); Відображення атрибутів на пристроях виведення (АС-16(5)); Підтримка пов'язання атрибутів організацією (АС-16(6)); Послідовна інтерпретація атрибутів (АС-16(7)); Техніки та технології пов'язання атрибутів (АС-16(8)); Перепризначення атрибутів (АС-16(9)); Конфігурація атрибутів уповноваженими особами (АС-16(10)); Віддалений доступ (АС-17); Автоматизований моніторинг та управління (АС-17(1)); Захист конфіденційності та цілісності за допомогою шифрування (АС-17(2)); Керовані точки контролю доступу (АС-17(3)); Привілейовані команди та доступ (АС-17(4)); Моніторинг для неавторизованих підключень (АС-17(5)); Захист інформації (АС-17(6)); Додатковий захист для доступу до функцій безпеки (АС-17(7)); Деактивація незахищених протоколів мережі (АС-17(8)); Відключення або деактивація доступу (АС-17(9)); (10) автентифікація віддалених команд (АС-17(10)); Бездротовий доступ (АС-18); Автентифікація та шифрування (АС-18(1)); Бездротовий підключень (АС-18(2)); Відключення бездротової мережі (АС-18(3)); Бездротовий доступ стувачами (АС-18(4)); Антени та рівень потужності передачі (АС-18(5)); Контроль доступу для мобільних пристроїв (АС-19); Використання письмових та портативних пристроїв для зберігання даних (АС-19(1)); Використання персональних портативних пристроїв зберігання даних (АС-19(2)); Використання портативних пристроїв зберігання даних з неідентифікованим власником (АС-19(3)); Обмеження для засекреченої інформації (АС-19(4)); Повне шифрування пристроїв та сховищ інформації (АС-19(5)); Використання зовнішніх систем (АС-20); Обмеження на авторизоване використання (АС-20(1)); Переносні пристрої зберігання даних (АС-20(2)); Системи та компоненти, що не знаходяться у власності організації (АС-20(3)); Пристрої для зберігання даних, які можуть мати доступ до мережі (АС-20(4)); Портативні пристрої для зберігання даних – заборона використання (АС-20(5)); Розповсюдження інформації (АС-21); Автоматична підтримка ухвалення рішень (АС-21(1)); Розповсюдження інформації (АС-21(2)); Публічно доступний контент (АС-22); Захист від несанкціонованого інтелектуального аналізу даних (АС-23); Рішення щодо управління доступом (АС-24); Інформація про передачу авторизованого доступу (АС-24(1)); Відсутність ідентифікації користувача або процесу, що діє від імені користувача (АС-24(2)); Диспетчер доступу (АС-25).

1.1. ПОЛІТИКА ТА ПРОЦЕДУРИ УПРАВЛІННЯ ДОСТУПОМ (АС-1)

a. Розробити, задокументувати та поширити [Призначення: серед визначеного організацією персоналу або ролей]:

1. 2. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політики контролю доступу, яка:

(a) містить мету, сферу застосування, ролі, відповідальність, зобов'язання керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliances);

(b) відповідає чинному законодавству, нормативним документам, директивам, нормам, політикам, стандартам і керівним документам. Процедури, що сприяють реалізації політики управління доступом і відповідних заходів управління доступом.

b. Призначити на посаду [Призначення: визначену організацією посадову особу] для управління, документування і розповсюдження політики та процедур контролю доступом.

c. Переглянути та оновити:

1. поточну політику управління доступом [Призначення: з визначеною організацією частотою] та [Призначення: події, визначені організацією];

2. поточні процедури управління доступом [Призначення: з визначеною організацією частотою] та [Завдання: події, визначені організацією].

No: 1

Name: ac_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюється політика контролю доступу

No: 2

Name: ac_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури контролю доступу

No: 3

Name: ac_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 4

Name: ac_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами контролю доступу

No: 5

Name: ac_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика контролю доступу

No: 6

Name: ac_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, які вимагають перегляду та оновлення поточної політики контролю доступу

No: 7

Name: ac_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури контролю доступу

1.2. УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ (АС-2)

- a. Визначити та задокументувати типи облікових записів системи, дозволених для використання в ІС для підтримки цілей, завдань, функцій і процесів організації.
- b. Призначити менеджерів облікових записів для управління системними обліковими записами.
- c. Створити умови для групового та рольового членства.
- d. Визначити авторизованих користувачів інформаційної системи, членство в групі та ролі, а також дозволи доступу (наприклад, привілеї) та інші атрибути (за потреби) для кожного облікового запису.
- e. Вимагати схвалення [Призначення: визначеною організацією відповідальною особою або роллю] запитів на створення облікових записів системи.
- f. Створювати, активувати, змінювати, деактивувати та видаляти системні облікові записи відповідно до [Призначення: визначених організацією політики, процедур та умов].
- g. Впровадити моніторинг використання облікових записів системи.
- h. Повідомляти адміністраторів облікових записів у межах [Призначення: визначеного організації часового періоду для кожної ситуації]:
 1. коли облікові записи більше не потрібні;
 2. коли користувачі звільнені чи переведені;
 3. коли використовуються індивідуальні системи або наявні зміни, які потребують нових знань.
- i. Авторизувати доступ до системи на основі:
 1. Дійсної авторизації доступу.
 2. Передбачуваного використання системи.
 3. Інших атрибутів, що вимагаються організацією.
- j. Проводити перегляд облікових записів на відповідність вимогам управління обліковими записами з [Призначення: визначеною організацією частотою].
- k. Впровадити процес повторного випуску облікових даних спільного/групового облікового запису (якщо він буде розгорнутий), коли особи виходять з групи.
- l. Узгодити процеси управління обліковими записами з процесами звільнення та переводу (передачі повноважень) персоналу.

No: 1

Name: ac_2_odp_09

Type: integer

Default: 24

Визначено передумови та критерії членства в групах і ролях; визначено атрибути (за необхідності) для кожного облікового запису; визначено персонал або ролі, необхідні для затвердження запитів на створення облікових записів; визначено політику, процедури, передумови та критерії створення, активації, зміни, деактивації та видалення облікових записів; визначено персонал або ролі, які мають бути повідомлені; визначено період часу, протягом якого адміністратори облікових записів повинні бути повідомлені про те, що облікові записи більше не потрібні; визначено термін, протягом якого необхідно повідомляти адміністраторів облікових записів про звільнення або переведення користувачів; визначено період часу, протягом якого необхідно повідомляти

адміністраторів облікових записів про зміни у використанні системи або необхідність знати про зміни для окремої особи; визначено атрибути, необхідні для авторизації доступу до системи (за потреби); AC-02_ODP[10] AC-02a.[01] AC-02a.[02] AC-02b AC-02c AC-02d.01 AC-02d.02 AC-02d.03[01] AC-02d.03[02] AC-02e AC-02f.[01] AC-02f.[02] AC-02f.[03] AC-02f.[04] AC-02f.[05] AC-02g AC-02h.01 AC-02h.02 AC-02h.03 AC-02i.01 AC-02i.02 AC-02i.03 визначено періодичність перегляду облікових записів; визначено та задокументовано типи облікових записів, дозволених для використання в системі; визначено та задокументовано типи облікових записів, які заборонено використовувати в системі; призначені менеджери облікових записів; необхідні умови та критерії для членства в групах та ролях; визначено авторизованих користувачів системи; вказано приналежність до групи або ролі; для кожного облікового запису вказуються повноваження доступу (тобто привілеї); атрибути (за необхідності) вказуються для кожного облікового запису; для запитів на створення облікових записів потрібні схвалення від персоналу або ролей; облікові записи створюються відповідно до політики, процедур, передумов та критеріїв; облікові записи активуються відповідно до політики, процедур, передумов та критеріїв; облікові записи змінюються відповідно до політики, процедур, передумов та критеріїв; облікові записи деактивуються відповідно до політики, процедур, передумов та критеріїв; облікові записи видаляються відповідно до політики, процедур, передумов та критеріїв; контролюється використання облікових записів; адміністратори облікових записів та персонал або ролі отримують повідомлення протягом періоду часу, коли облікові записи більше не потрібні; адміністратори облікових записів та персонал або ролі отримують повідомлення протягом періоду часу, коли користувачі звільнені чи переведені; адміністратори облікових записів та персонал або ролі отримують повідомлення протягом періоду часу, коли використовуються індивідуальні системи або наявні зміни, які потребують нових знань. доступ до системи здійснюється на підставі дійсної авторизації доступу; доступ до системи авторизується на основі передбачуваного використання системи; доступ до системи авторизовано на основі атрибутів (за необхідності); AC-02j AC-02k.[01] AC-02k.[02] AC-02l.[01] AC-02l.[02] облікові записи переглядаються на відповідність вимогам управління обліковими записами частота; створено процес повторного випуску облікових даних спільного доступу або групових облікових записів (якщо вони розгорнуті), коли користувачів вилучено з групи; впроваджено процес повторного випуску облікових даних спільного доступу або групових облікових записів (якщо вони розгорнуті), коли користувачів вилучено з групи; процеси управління обліковими записами узгоджуються з процесами звільнення персоналу; процеси управління обліковими записами узгоджуються з процесами переведення персоналу

1.2.1. АВТОМАТИЗОВАНЕ УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ СИСТЕМИ (АС-2(1))

Використовувати автоматизовані системними обліковими записами. механізми для підтримки управління

No: 1

Name: ac_2_1_01

Type: string

Default: "автоматизований засіб моніторингу"

Управління обліковими записами системи підтримується за допомогою автоматизовані механізми

No: 2

Name: ac_2_1_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для підтримки управління обліковими записами системи

1.2.2. ДЕАКТИВАЦІЯ ОБЛІКОВИХ ЗАПИСІВ (АС-2(3))

Автоматично деактивувати облікові записи коли: а) їх строк дії минув; б) вони більше не пов'язані з користувачем; с) вони порушують організаційну політику; d) вони були неактивними впродовж [Призначення: визначеного організацією періоду часу].

No: 1

Name: ac_2_3_b

Type: list

Default: ["admin", "security_officer"]

Облікові записи деактивуються протягом часового періоду, коли облікові записи більше не пов'язані з користувачем або фізичною особою

No: 2

Name: ac_2_3_d

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Облікові записи відключено протягом часового періоду, коли облікові записи порушують політику організації; облікові записи деактивуються протягом , якщо вони були неактивними протягом

No: 3

Name: ac_2_3_odp_01

Type: integer

Default: 30

Визначено період часу, протягом якого необхідно деактивувати облікові записи

No: 4

Name: ac_2_3_odp_02

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено період часу неактивності, після закінчення якого облікові записи будуть деактивовані; АС-02(03)(а) облікові записи деактивуються протягом часового періоду, коли термін дії облікових записів минув

1.2.3. ДІЇ ПРИ АВТОМАТИЗОВАНОМУ АУДИТІ (АС-2(4))

Проводити автоматизований аудит створення, модифікації, деактивації та видалення облікових записів і сповіщення про дії. ПРИ активації,

No: 1

Name: ac_2_4_01

Type: string

Default: nil

Створення облікового запису автоматично аудитується

No: 2

Name: ac_2_4_02

Type: string

Default: nil

Модифікація облікового запису автоматично аудитується

No: 3

Name: ac_2_4_03

Type: string

Default: nil

Активація облікового запису автоматично аудитується

No: 4

Name: ac_2_4_04

Type: string

Default: nil

Деактивація облікового запису автоматично аудитується

No: 5
Name: ac_2_4_05
Type: string
Default: nil

Видалення облікового запису автоматично аудитується

1.2.4. ВИХІД ІЗ СИСТЕМИ ЗА ВІДСУТНОСТІ АКТИВНОСТІ (АС-2(5))

Вимагати від користувачів виходити із системи, коли [Призначення: вичерпано визначений організацією періоду часу очікування або опис того, коли необхідно вийти із системи].

No: 1
Name: ac_2_5_01
Type: integer
Default: 30

Користувачі повинні виходити з системи, коли період очікуваної бездіяльності або опис часу, коли потрібно вийти з системи

No: 2
Name: ac_2_5_odp
Type: integer
Default: 30

Визначено часовий період очікуваної бездіяльності або опис, коли потрібно вийти з системи

1.2.5. ДИНАМІЧНЕ УПРАВЛІННЯ ПРИВІЛЕЯМИ (АС-2(6))

Реалізувати такі можливості динамічного управління привілеями: [Призначення: визначений організацією перелік можливостей динамічного управління привілеями].

No: 1
Name: ac_2_6_01
Type: string
Default: nil

Реалізовано можливості динамічного управління привілеями

No: 2
Name: ac_2_6_odp
Type: string
Default: nil

Визначено можливості динамічного управління привілеями

1.2.6. СХЕМИ, ЗАСНОВАНІ НА РОЛЯХ (АС-2(7))

а) Створювати й адмініструвати привілейовані облікові записи користувачів відповідно до схеми доступу на основі ролей (role-based), яка реалізує дозволений доступ до системи та призначення привілеїв для ролей. б) Проводити моніторинг призначення привілейованих ролей. в) Відстежувати зміни ролей або атрибутів. г) Скасовувати доступ, коли призначені привілейовані ролі більше не потрібні.

No: 1
Name: ac_2_7_b

Type: string

Default: nil

Проводиться моніторинг призначення привілейованих ролей або атрибутів

No: 2

Name: ac_2_7_c

Type: string

Default: nil

Відстежуються зміни ролей або атрибутів

No: 3

Name: ac_2_7_d

Type: list

Default: ["admin", "security_officer"]

Доступ скасовується, коли призначені привілейовані ролі більше не потрібні.0

No: 4

Name: ac_2_7_odp

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {схема доступу на основі ролей; схема доступу на основі атрибутів}

1.2.7. ДИНАМІЧНЕ УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ (АС-2(8))

Створювати, активувати, управляти та деактивувати [Призначення: системні облікові записи, визначені організацією] динамічно.

No: 1

Name: ac_2_8_01

Type: string

Default: nil

УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ - ДИНАМІЧНЕ УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ
МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: ac_2_8_02

Type: string

Default: nil

Облікові записи системи активуються динамічно

No: 3

Name: ac_2_8_03

Type: string

Default: nil

Облікові записи системи активуються динамічно

No: 4

Name: ac_2_8_04

Type: string

Default: nil

Облікові записи системи деактивуються динамічно

No: 5
Name: ac_2_8_odp
Type: string
Default: nil

Визначено облікові записи системи, які динамічно створюються, активуються, управляються та деактивуються

1.2.8. ОБМЕЖЕННЯ НА ВИКОРИСТАННЯ СПІЛЬНИХ ТА ГРУПОВИХ ОБЛІКОВИХ ЗАПИСІВ (АС-2(9))

Використовувати лише ті спільні та групові облікові записи, які відповідають [Призначення: визначеним організацією умовам для створення спільних та групових облікових записів].

No: 1
Name: ac_2_9_01
Type: list
Default: []

Використання спільних та групових облікових записів дозволено лише за умови дотримання умов

No: 2
Name: ac_2_9_odp
Type: list
Default: []

Визначено умови створення спільних та групових облікових записів

1.2.9. ЗМІНА ДАНИХ СПІЛЬНИХ І ГРУПОВИХ ОБЛІКОВИХ ЗАПИСІВ (АС-2(10))

No: 1
Name: ac_2_10_01
Type: string
Default: nil

УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ - ЗМІНА ДАНИХ СПІЛЬНИХ І ГРУПОВИХ ОБЛІКОВИХ ЗАПИСІВ [Вилучено: включено до АС-02(k)]

1.2.10. УМОВИ ВИКОРИСТАННЯ (АС-2(11))

Забезпечити дотримання [Призначення: обставин та/або умов використання, визначених організацією] для [Призначення: визначених організацією облікових записів системи].

No: 1
Name: ac_2_11_01
Type: list
Default: []

Обставини та/або умови використання для облікових записів системи застосовуються

No: 2
Name: ac_2_11_odp_01
Type: list
Default: []

Визначено обставини та/або умови використання визначених облікових записів системи

No: 3
 Name: ac_2_11_odp_02
 Type: string
 Default: nil

Визначені облікові записи системи, що підлягають виконанню обставин та/або умов використання

1.2.11. МОНИТОРИНГ НЕТИПОВОГО ВИКОРИСТАННЯ ОБЛІКОВИХ ЗАПИСІВ (АС-2(12))

а) Проводити моніторинг облікових записів системи на [Призначення: визначене організацією нетипове використання]. б) Повідомляти про нетипове використання облікових записів системи [Призначення: визначеного організацією персоналу або ролей].

No: 1
 Name: ac_2_12_a
 Type: list
 Default: []

Облікові записи системи відстежуються на предмет обставини та/або умови використання

No: 2
 Name: ac_2_12_b
 Type: list
 Default: ["admin", "security_officer"]

Про визначені обставини та/або умови використання системних облікових записів повідомляється персонал або ролі

No: 3
 Name: ac_2_12_odp_01
 Type: list
 Default: []

Визначено обставини та/або умови використання, для яких необхідно здійснювати моніторинг облікових записів системи

No: 4
 Name: ac_2_12_odp_02
 Type: list
 Default: ["admin", "security_officer"]

Визначено персонал або ролі, яким належить повідомляти про визначені обставини та/або умови використання

1.2.12. ДЕАКТИВАЦІЯ ОБЛІКОВИХ ЗАПИСІВ ОСІБ З ВИСОКИМ РІВНЕМ РИЗИКУ (АС-2(13))

Деактивувати облікові записи користувачів, які становлять значний ризик, у межах [Призначення: визначеного організацією періоду часу] після виявлення ризику.

No: 1
 Name: ac_2_13_01
 Type: integer
 Default: 30

Облікові записи користувачів деактивуються протягом періоду часу з моменту виявлення значних ризиків

No: 2
 Name: ac_2_13_odp_01

Type: integer

Default: 30

Визначено період часу, протягом якого необхідно деактивувати облікові записи фізичних осіб, які становлять значний ризик

No: 3

Name: ac_2_13_odp_02

Type: string

Default: nil

Визначено значні ризики, що призводять до деактивації облікових записів

1.3. ЗАБЕЗПЕЧЕННЯ ДОСТУПУ (АС-3)

Застосовувати затверджені повноваження для логічного доступу до інформації та ресурсів системи відповідно до чинної політики (правил) управління доступом.

No: 1

Name: ac_3_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Затверджені повноваження на логічний доступ до інформації та ресурсів системи виконуються відповідно до чинних політик(правил) управління доступом

1.3.1. ОБМЕЖЕНИЙ ДОСТУП ДО ПРИВІЛЕЙОВАНИХ ФУНКЦІЙ (АС-3(1))

No: 1

Name: ac_3_1_01

Type: string

Default: nil

ЗАБЕЗПЕЧЕННЯ ДОСТУПУ - ОБМЕЖЕНИЙ ДОСТУП ДО ПРИВІЛЕЙОВАНИХ ФУНКЦІЙ [Вилучено: включено до складу АС-06]

1.3.2. ПОДВІЙНА АВТОРИЗАЦІЯ (АС-3(2))

Забезпечити подвійну авторизацію для [Призначення: визначених організацією привілейованих команд та/або інших дій, визначених організацією].

No: 1

Name: ac_3_2_01

Type: string

Default: nil

Подвійна авторизація застосовується для привілейованих команд та/або інших дій

No: 2

Name: ac_3_2_odp

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено привілейовані команди та/або інші дії, що потребують подвійної авторизації

1.3.3. МАНДАТНЕ УПРАВЛІННЯ ДОСТУПОМ (АС-3(3))

Застосовувати [Призначення: визначену організацією мандатну (mandatory) політику управління доступом] щодо всіх суб'єктів і об'єктів доступу, у яких політика:

- (а) одноманітно застосовується для всіх суб'єктів і об'єктів у межах системи;
- (б) вказує, що суб'єкт, якому було надано доступ до інформації, обмежений у виконанні будь-якої з таких дій:
- (с) (1) передача інформації неавторизованим суб'єктам або об'єктам; (2) надання іншим суб'єктам привілеїв; (3) зміна одного чи декількох атрибутів безпеки суб'єкта, об'єкта, системи або компонентів системи; (4) вибір атрибутів безпеки та значень атрибутів, які повинні бути пов'язані з новоствореними або зміненими об'єктами; (5) зміна правил, що регулюють управління доступом; має бути вказано, що [Призначення: визначеним організацією суб'єктам] можуть бути явно надані [Призначення: визначені організацією привілеї], так що вони не обмежуються будь-яким з перелічених вище обмежень.

No: 1

Name: ac_3_3_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Мандатна політика контролю доступу застосовується до набору охоплених суб'єктів, зазначених у політиці

No: 2

Name: ac_3_3_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Мандатна політика контролю доступу застосовується до набору охоплених об'єктів, зазначених у політиці

No: 3

Name: ac_3_3_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Мандатна політика контролю доступу застосовується одноманітно до всіх суб'єктів системи

No: 4

Name: ac_3_3_a_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Мандатна політика контролю доступу застосовується одноманітно до всіх об'єктів системи; АС-03(03)(b)(01) мандатна політика контролю доступу та мандатна політика контролю доступу, які визначають, що суб'єкт, якому надано доступ до інформації, зобов'язаний не передавати інформацію неавторизованим суб'єктам або об'єктам; АС-03(03)(b)(02) мандатна політика контролю доступу та мандатна політика контролю доступу, які визначають, що суб'єкт, якому надано доступ до інформації, обмежений у наданні своїх привілеїв іншим суб'єктам; АС-03(03)(b)(03) мандатна політика контролю доступу та мандатна політика контролю доступу, які визначають, що суб'єкт, якому надано доступ до інформації, не може змінювати один або декілька атрибутів безпеки (визначених політикою) суб'єктів, об'єктів, системи або компонентів системи; АС-03(03)(b)(04) мандатна політика контролю доступу та мандатна політика контролю доступу, які визначають, що суб'єкт, якому надано доступ до інформації, обмежений у виборі атрибутів безпеки та значень атрибутів (визначених політикою), що повинні бути пов'язані з новостворюваними або зміненими об'єктами; АС-03(03)(b)(05) мандатна політика контролю доступу та мандатна політика контролю доступу, які визначають, що суб'єкт, якому надано доступ до інформації, не має права змінювати правила, що регулюють управління доступом

No: 5

Name: ac_3_3_c

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Мандатна політика контролю доступу та мандатна політика контролю доступу, які визначають, що суб'єктам можуть бути явно надані привілеї таким чином, щоб вони не були обмежені будь-якою визначеною підмножиною (або всіма) з наведених вище обмежень

No: 6

Name: ac_3_3_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено мандатну політику контролю доступу, що застосовується до набору охоплених суб'єктів

No: 7

Name: ac_3_3_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено мандатну політику контролю доступу, що застосовується до набору охоплених об'єктів

No: 8

Name: ac_3_3_odp_03

Type: string

Default: nil

Визначені суб'єкти, яким явно надаються привілеї

No: 9

Name: ac_3_3_odp_04

Type: string

Default: nil

Визначено привілеї, які мають бути прямо надані суб'єктам

1.3.4. ДИСКРЕЦІЙНЕ УПРАВЛІННЯ ДОСТУПОМ (АС-3(4))

Застосовувати [Призначення: визначену організацією дискреційну політику управління доступом] щодо визначених суб'єктів і об'єктів доступу, для яких політика визначає, що суб'єкт, якому було надано доступ до інформації, може виконати одну чи більше з таких дій:

- (a) передача інформацію будь-яким іншим суб'єктам чи об'єктам;
- (b) призначення своїх привілеїв іншим суб'єктам;
- (c) зміна атрибутів безпеки суб'єктів, об'єктів, систем або компонентів системи;
- (d) вибір атрибутів безпеки, які будуть пов'язані з новоствореними або переглянутими об'єктами;
- (e) зміна правил, що регулюють управління доступом.

No: 1

Name: ac_3_4_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика управління доступом застосовується до набору охоплених суб'єктів, зазначених у політиці

No: 2

Name: ac_3_4_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика управління доступом застосовується до набору охоплених об'єктів, зазначених у політиці

No: 3

Name: ac_3_4_a

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика управління доступом та дискреційна політика управління доступом застосовуються, коли політика визначає, що суб'єкт, якому надано доступ до інформації, може передавати інформацію будь-яким іншим суб'єктам або об'єктам

No: 4

Name: ac_3_4_b

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика управління доступом та дискреційна політика управління доступом застосовуються, коли політика визначає, що суб'єкт, якому надано доступ до інформації, може надавати свої привілеї іншим суб'єктам

No: 5

Name: ac_3_4_c

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика управління доступом та дискреційна політика управління доступом застосовуються, коли політика визначає, що суб'єкт, якому надано доступ до інформації, може змінювати атрибути безпеки суб'єктів, об'єктів, системи або компонентів системи

No: 6

Name: ac_3_4_d

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика управління доступом та дискреційна політика управління доступом застосовуються там, де політика визначає, що суб'єкт, якому надано доступ до інформації, може вибирати атрибути безпеки, які будуть пов'язані з новоствореними або переглянутими об'єктами

No: 7

Name: ac_3_4_e

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика управління доступом та дискреційна політика управління доступом застосовуються, коли політика визначає, що суб'єкт, якому надано доступ до інформації, може змінювати правила управління доступом

No: 8

Name: ac_3_4_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено дискреційну політику управління доступом, яка застосовується до набору охоплених суб'єктів

No: 9

Name: ac_3_4_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено дискреційну політику управління доступом, яка застосовується до набору охоплених об'єктів

1.3.5. ІНФОРМАЦІЯ ЩОДО БЕЗПЕКИ (АС-3(5))

Запобігати доступу до [Призначення: інформації щодо безпеки, яка визначена організацією], за винятком випадків, коли наявні безпечні неробочі стани системи.

No: 1

Name: ac_3_5_01

Type: string

Default: nil

Доступ до інформації щодо безпеки заборонено, за винятком випадків, коли наявні безпечні неробочі стани системи

No: 2

Name: ac_3_5_odp

Type: string

Default: nil

Визначено інформацію щодо безпеки, доступ до якої заборонено, за винятком випадків, коли наявні безпечні неробочі стани системи

1.3.6. ЗАХИСТ ІНФОРМАЦІЇ КОРИСТУВАЧА ТА СИСТЕМИ (АС-3(6))

No: 1

Name: ac_3_6_01

Type: string

Default: nil

ЗАБЕЗПЕЧЕННЯ ДОСТУПУ - ЗАХИСТ ІНФОРМАЦІЇ КОРИСТУВАЧА ТА СИСТЕМИ [Вилучено: Включено в МР-04 та SC-28]. АС-03(07) ЗАБЕЗПЕЧЕННЯ ДОСТУПУ - УПРАВЛІННЯ ДОСТУПОМ НА ОСНОВІ РОЛЕЙ

1.3.7. УПРАВЛІННЯ ДОСТУПОМ НА ОСНОВІ РОЛЕЙ (АС-3(7))

Застосовувати політику управління доступом на основі ролей щодо визначених суб'єктів і об'єктів та управління доступом на основі [Призначення: визначених організацією ролей та користувачів, уповноважених приймати такі ролі].

No: 1

Name: ac_3_7_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Політика управління доступом на основі ролей застосовується до визначених суб'єктів

No: 2

Name: ac_3_7_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Політика управління доступом на основі ролей застосовується до визначених об'єктів

No: 3

Name: ac_3_7_03

Type: list

Default: ["admin", "security_officer"]

Доступ контролюється на основі ролей та користувачів, яким дозволено приймати такі ролі

No: 4

Name: ac_3_7_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено ролі, на яких базується управління доступом

No: 5

Name: ac_3_7_odp_02

Type: string

Default: nil

Визначено користувачів, уповноважених на прийняття ролей (визначених у AC-03(07)_ODP[01])

1.3.8. АНУЛЮВАННЯ ПРАВ ДОСТУПУ (АС-3(8))

Здійснювати анулювання прав доступу в результаті змін атрибутів безпеки суб'єктів і об'єктів на основі [Призначення: визначених організацією правил, що регулюють терміни скасування прав доступу].

No: 1

Name: ac_3_8_01

Type: string

Default: nil

Здійснюється анулювання прав доступу в результаті зміни атрибутів безпеки суб'єктів на основі правил

No: 2

Name: ac_3_8_02

Type: string

Default: nil

Здійснюється анулювання прав доступу в результаті зміни атрибутів безпеки об'єктів на основі правил

No: 3

Name: ac_3_8_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено правила, що регулюють терміни скасування дозволів на доступ

1.3.9. КЕРОВАНА ПЕРЕДАЧА (ПУБЛІКАЦІЯ) ІНФОРМАЦІЇ (АС-3(9))

Передавати (публікувати) інформацію за межами встановленої межі системи можливо, якщо: а) Приймальна [Призначення: визначена організацією система або компонент системи] забезпечує [Призначення: визначені організацією заходи безпеки]; б) [Призначення: визначені організацією заходи безпеки] використовуються для підтвердження відповідності інформації, призначеної для керованих передач (публікації).

No: 1

Name: ac_3_9_a

Type: string

Default: nil

Інформація випускається за межі системи, тільки якщо отримуюча система або компонент системи забезпечує заходи захисту

No: 2

Name: ac_3_9_b

Type: string

Default: nil

Інформація публікується за межами системи, тільки якщо заходи захисту використовуються для перевірки відповідності інформації, призначеної для публікації

1.3.10. ПЕРЕГЛЯД АУДИТОМ МЕХАНІЗМІВ КОНТРОЛЮ ДОСТУПУ (АС-3(10))

Застосувати перегляд аудитом механізмів автоматизованого управління доступу при [Призначення: визначених організацією умовах] [Призначення: визначеними організацією ролями].

No: 1

Name: ac_3_10_01

Type: string

Default: nil

За умов застосовується перегляд аудитом механізмів автоматизованого контролю доступу за допомогою ролей

No: 2

Name: ac_3_10_odp_01

Type: list

Default: []

Визначено умови, за яких можна застосовувати перегляд аудитом механізмів автоматизованого управління доступом

No: 3

Name: ac_3_10_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено ролі, яким дозволено використовувати перегляд аутот механізмів автоматизованого управління доступом

1.3.11. ОБМЕЖЕННЯ ДОСТУПУ ДО СПЕЦІАЛЬНОЇ ІНФОРМАЦІЇ (АС-3(11))

Обмежити прямий доступ до сховищ даних, що містять [Призначення: визначені організацією типи інформації].

No: 1

Name: ac_3_11_01

Type: string

Default: nil

Обмежено доступ до сховищ даних, що містять типи інформації

1.3.12. ВСТАНОВЛЕННЯ ТА ЗАБЕЗПЕЧЕННЯ ДОСТУПУ ДО ЗАСТОСУНКІВ (АС-3(12))

а) Вимагати від застосунків встановити в процесі інсталяції доступ до таких застосунків системи і функцій: [Призначення: визначених організацією програм та функції системи];
 б) Впровадити механізм примусового застосування, щоб запобігти доступу, відмінному від заявленого. с) Схвалити зміни доступу після початкового встановлення застосунків.

No: 1

Name: ac_3_12_a

Type: string

Default: nil

У процесі інсталяції програми повинні встановити доступ до таких системних застосунків і функцій системи: програм та функції системи

No: 2
 Name: ac_3_12_b
 Type: string
 Default: nil

Передбачено механізм примусового застосування запобігання несанкціонованому доступу

No: 3
 Name: ac_3_12_c
 Type: string
 Default: nil

Зміни доступу після первинної інсталяції програми схвалено

No: 4
 Name: ac_3_12_odp
 Type: string
 Default: nil

Визначено програми та функції системи, яким необхідно встановити права доступу

1.3.13. УПРАВЛІННЯ ДОСТУПОМ НА ОСНОВІ АТРИБУТІВ (АС-3(13))

Здійснювати політику управління доступу на основі атрибутів (attribute-based) для визначених суб'єктів і об'єктів доступу й управляти доступом на основі [Призначення: визначених організацією атрибутів для ухвалення рішень про доступ].

No: 1
 Name: ac_3_13_1
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Політика управління доступом на здійснюється до визначених суб'єктів; основі атрибутів АС-03(13)[2] політика управління доступом на здійснюється до визначених об'єктів; основі атрибутів

No: 2
 Name: ac_3_13_3
 Type: string
 Default: nil

Доступ контролюється на основі атрибутів

No: 3
 Name: ac_3_13_odp
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Визначено атрибути для визначення прав доступу

1.3.14. ІНДИВІДУАЛЬНИЙ ДОСТУП (АС-3(14))

Надайте [Призначення: механізми, визначені організацією], щоб дозволити особам мати доступ до певних елементів їх особистої інформації: [Призначення: елементи, визначені організацією]

No: 1
 Name: ac_3_14_01
 Type: list
 Default: ["admin", "security_officer"]

Механізми надаються для того, щоб дозволити особам мати доступ до елементів їхньої персональної інформації

No: 2

Name: ac_3_14_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено механізми, що дозволяють фізичним особам мати доступ до елементів їхньої персональної інформації

No: 3

Name: ac_3_14_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено елементи інформації, що ідентифікує особу, до якої мають доступ фізичні особи

1.3.15. ДИСКРЕЦІЙНИЙ ТА ОБОВ'ЯЗКОВИЙ ДОСТУП (АС-3(15))

(а) Застосовувати [Призначення: визначену організацією політику обов'язкового контролю доступу] до набору охоплених суб'єктів і об'єктів, указаних у політиці;

(б) Застосування [Призначення: визначена організацією дискреційна політика контролю доступу] до набору охоплених суб'єктів і об'єктів, указаних у політиці.

No: 1

Name: ac_3_15_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Політика обов'язкового контролю доступу застосовується до набору охоплених суб'єктів, зазначених у політиці

No: 2

Name: ac_3_15_a_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Політика обов'язкового контролю доступу застосовується до набору охоплених об'єктів, зазначених у політиці

No: 3

Name: ac_3_15_b_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика контролю доступу застосовується до набору суб'єктів, зазначених у політиці

No: 4

Name: ac_3_15_b_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика контролю доступу застосовується до набору об'єктів, зазначених у політиці

No: 5

Name: ac_3_15_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено обов'язкову політику контролю доступу, яка застосовується до набору суб'єктів, зазначених у політиці

No: 6

Name: ac_3_15_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено обов'язкову політику контролю доступу, яка застосовується до набору об'єктів, зазначених у політиці

No: 7

Name: ac_3_15_odp_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено дискреційну політику контролю доступу, яка застосовується до набору суб'єктів, зазначених у політиці

No: 8

Name: ac_3_15_odp_04

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено дискреційну політику контролю доступу, яка застосовується до набору об'єктів, зазначених у політиці

1.4. УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ (АС-4)

Застосувати затверджені повноваження для управління потоком інформації всередині системи та між пов'язаними системами на основі [Призначення: визначеними організацією політиками управління інформаційним потоком].

No: 1

Name: ac_4_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Затверджені повноваження застосовуються для контролю потоку інформації всередині системи та між підключеними системами на основі політики управління інформаційними потоками

No: 2

Name: ac_4_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політики управління інформаційними потоками всередині системи та між підключеними системами

1.4.1. АТРИБУТИ БЕЗПЕКИ ОБ'ЄКТУ (АС-4(1))

Використовувати [Призначення: визначені організацією атрибути безпеки], пов'язані з [Призначення: визначеними організацією інформацією, джерелами та об'єктами призначення], щоб запровадити [Призначення: визначену організацією політику управління потоками інформації] як основу для ухвалення рішень щодо управління потоками.

No: 1

Name: ac_4_1_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Атрибути безпеки, пов'язані з об'єктами інформації, джерела об'єктів та об'єктами призначення, використовуються для забезпечення виконання політик управління інформаційними потоками як основи для прийняття

рішень щодо управління потоками

No: 2

Name: ac_4_1_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Атрибути конфіденційності, пов'язані з об'єктами інформації, джерела об'єктів та об'єктами призначення, використовуються для забезпечення виконання політик управління інформаційними потоками як основи для прийняття рішень щодо управління потоками

No: 3

Name: ac_4_1_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено атрибути безпеки, які будуть пов'язані з інформацією, джерелом та об'єктами призначення

No: 4

Name: ac_4_1_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено атрибути конфіденційності, які будуть пов'язані з інформацією, джерелом та об'єктами призначення

No: 5

Name: ac_4_1_odp_03

Type: string

Default: nil

Визначено об'єкти інформації, які будуть пов'язані з атрибутами безпеки

No: 6

Name: ac_4_1_odp_04

Type: string

Default: nil

Визначено об'єкти інформації, які будуть пов'язані з атрибутами конфіденційності

No: 7

Name: ac_4_1_odp_05

Type: string

Default: nil

Визначено джерела об'єктів, які будуть пов'язані з атрибутами безпеки

No: 8

Name: ac_4_1_odp_06

Type: string

Default: nil

Визначено джерела об'єктів, які будуть пов'язані з атрибутами конфіденційності

No: 9

Name: ac_4_1_odp_07

Type: string

Default: nil

Визначено об'єкти призначення, які будуть пов'язані з атрибутами безпеки

No: 10

Name: ac_4_1_odp_08

Type: string

Default: nil

Визначено об'єкти призначення, які будуть пов'язані з атрибутами конфіденційності

No: 11

Name: ac_4_1_odp_09

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політику управління інформаційними потоками як основу для ухвалення рішень щодо управління потоками

1.4.2. ДОМЕНИ ОБРОБ- (АС-4(2))

Використовувати захищені домени обробки даних для забезпечення [Призначення: визначеної організацією політики управління потоками інформації] як основу для ухвалення рішень щодо управління потоками.

No: 1

Name: ac_4_2_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Захищені домени обробки використовуються для забезпечення дотримання політики управління інформаційними потоками як основи для ухвалення рішень щодо управління потоками

No: 2

Name: ac_4_2_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політики управління інформаційними потоками, які будуть застосовуватися з використанням захищених доменів обробки

1.4.3. УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ УПРАВЛІННЯ ІНФОРМАЦІЙНИМ ПОТОКОМ (АС-4(3))

Здійснювати динамічне управління потоком інформації на основі [Призначення: визначених організацією політик (правил)].

No: 1

Name: ac_4_3_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Здійснюється динамічне управління потоком інформації на основі політики управління інформаційними потоками

No: 2

Name: ac_4_3_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначені політики контролю інформаційних потоків, які необхідно впроваджувати

1.4.4. УПРАВЛІННЯ ПОТОКОМ ЗАШИФРОВАНОЇ ІНФОРМАЦІЇ (АС-4(4))

Запобігати обходу [Призначення: механізмів управління потоками, визначених організацією] зашифрованої інформації шляхом [Вибір (один або декілька): дешифрування інформації;

блокування потоку зашифрованої інформації; завершення сеансів зв'язку, що намагаються передавати зашифровану інформацію; [Призначення: визначеними організацією процедурою або методом]].

No: 1

Name: ac_4_4_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено механізми контролю інформаційних потоків, які унеможливають обхід зашифрованої інформації

No: 2

Name: ac_4_4_odp_02

Type: string

Default: "AES-256-GCM"

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {дешифрування інформації; блокування потоку зашифрованої інформації; завершення сеансів зв'язку що намагаються передавати зашифровану інформацію; визначена організацією процедура або метод}

No: 3

Name: ac_4_4_odp_03

Type: string

Default: "автоматизований засіб моніторингу"

Визначено організацією процедуру або метод, що використовується для запобігання обходу зашифрованої інформації через механізми контролю інформаційних потоків (якщо вибрано)

1.4.5. ВБУДОВУВАННЯ ТИПІВ ДАНИХ (АС-4(5))

Впровадити [Призначення: визначені організацією вбудовування типів даних в інші типи даних. обмеження] для

No: 1

Name: ac_4_5_odp

Type: string

Default: nil

Визначеного обмеження, які слід застосовувати щодо вбудовування типів даних в інші типи даних; обмеження накладаються на вбудовування типів даних у інші типи даних

1.4.6. МЕТАДАНИ (АС-4(6))

Здійснювати управління інформаційним потоком на основі [Призначення: визначених організацією метаданих].

No: 1

Name: ac_4_6_01

Type: string

Default: nil

Інформаційна система здійснює управління інформаційним потоком на основі метадани

No: 2

Name: ac_4_6_odp

Type: string

Default: nil

Визначено метадані, які слід використовувати як засіб управління інформаційним потоком

1.4.7. МЕХАНІЗМИ ОДНОСТОРОННЬОГО ПОТОКУ (АС-4(7))

Впровадити [Призначення: визначені організацією односторонні інформаційні потоки] за допомогою апаратних механізмів.

No: 1

Name: ac_4_7_01

Type: string

Default: nil

Односторонні інформаційні потоки забезпечуються за допомогою апаратних механізмів управління потоками.
ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

1.4.8. УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОЛІТИКИ БЕЗПЕКИ (АС-4(8))

а) Забезпечити контроль над потоком інформації, використовуючи [Призначення: визначені організацією фільтри безпеки або політики конфіденційності] як основу для рішень щодо керування потоком для [Призначення: визначені організацією потоки інформації]; б) [Вибір (один або кілька): Блокування; Зміна; Карантин] даних після помилки обробки фільтра відповідно до [Призначення: політика безпеки або конфіденційності, визначена організацією].

No: 1

Name: ac_4_8_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

ODP[02] визначено фільтри політики конфіденційності, які будуть використовуватися як основа для забезпечення керування інформаційними потоками

No: 2

Name: ac_4_8_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Управління інформаційними потоками здійснюється за допомогою <АС-04(08) _ODP[01] фільтр політики безпеки> як основи для прийняття рішень щодо управління потоками для <АС-04(08) _ODP[03] інформаційних потоків>; АС-04(08)(а)[01] контроль інформаційних потоків здійснюється за допомогою <АС-04(08) _ODP[02] фільтр політики конфіденційності> як основи для прийняття рішень щодо контролю потоків для <АС-04(08) _ODP[04] інформаційних потоків>

1.4.9. ПЕРЕВІРКИ, ЩО ПРОВОДИТЬ ПЕРСОНАЛ (АС-4(9))

Примусово використовувати перевірку персоналом [Призначення: потоки інформації, визначені організацією] за таких умов: [Призначення: умови, визначені організацією].

No: 1

Name: ac_4_9_01

Type: list

Default: ["admin", "security_officer"]

Перевірка персоналом використовуються для інформаційних потоків за умов

No: 2

Name: ac_4_9_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено інформаційні потоки, які потребують використання перевірки персоналом

No: 3

Name: ac_4_9_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено умови, за яких використання перевірки персоналом на інформаційні потоки має бути обов'язковим

1.4.10. АКТИВАЦІЯ ТА ДЕАКТИВАЦІЯ ФІЛЬТРІВ ПОЛІТИКИ БЕЗПЕКИ (АС-4(10))

Впровадити можливість для привілейованих адміністраторів активувати та деактивувати [Призначення: фільтри політики безпеки, що визначаються організацією] за таких умов: [Призначення: визначені організацією умови].

No: 1

Name: ac_4_10_01

Type: string

Default: nil

Привілейованим адміністраторам надано можливість активувати та деактивувати <АС-04(10) _ODP[01] фільтри безпеки> за <АС-04(10) _ODP[03] умов>

No: 2

Name: ac_4_10_02

Type: string

Default: nil

Привілейованим адміністраторам надано можливість активувати та деактивувати <АС-04(10) _ODP[02] фільтри конфіденційності> за <АС-04(10) _ODP[04] умов>

1.4.11. КОНФІГУРАЦІЯ ФІЛЬТРІВ ПОЛІТИКИ БЕЗПЕКИ (АС-4(11))

Впровадити можливість для привілейованих адміністраторів налаштувати [Призначення: визначені організацією фільтри політики безпеки] для підтримки різних політик безпеки.

No: 1

Name: ac_4_11_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Привілейованим адміністраторам надано можливість налаштовувати фільтри політики безпеки для підтримки різних політик безпеки або конфіденційності

No: 2

Name: ac_4_11_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Привілейованим адміністраторам надано можливість налаштовувати фільтри політики конфіденційності для підтримки різних політик безпеки або конфіденційності

No: 3

Name: ac_4_11_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено фільтри політики безпеки, які привілейовані адміністратори можуть налаштовувати для підтримки різних політик безпеки та конфіденційності

No: 4

Name: ac_4_11_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено фільтри політики конфіденційності, які привілейовані адміністратори можуть налаштовувати для підтримки різних політик безпеки та конфіденційності

1.4.12. ІДЕНТИФІКАТОРИ ТИПУ ДАНИХ (АС-4(12))

При передачі інформації між різними захищеними доменами використовувати [Призначення: визначені організацією ідентифікатори типів даних] для перевірки даних, необхідних для ухвалення рішень щодо інформаційного потоку.

No: 1

Name: ac_4_12_odp

Type: string

Default: nil

Визначено ідентифікатори типів даних, які будуть використовуватися для перевірки даних, необхідних для ухвалення рішень щодо інформаційних потоків; АС-04(12) при передачі інформації між різними доменами безпеки, ідентифікатори типів даних використовуються для перевірки даних, необхідних для ухвалення рішень щодо інформаційних потоків

1.4.13. ДЕКОМПОЗИЦІЯ НА ВІДПОВІДНІ ПОЛІТИЦІ СУБКОМПОНЕНТИ (АС-4(13))

При передачі інформації між різними захищеними доменами здійснювати декомпозицію інформації на [Призначення: визначені організацією субкомпоненти, що відповідають політиці] для представлення в механізмах реалізації політики.

No: 1

Name: ac_4_13_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

При передачі інформації між різними доменами безпеки інформація розкладається на субкомпоненти політики для подання механізмам забезпечення дотримання політики

No: 2

Name: ac_4_13_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено субкомпоненти політики, на які слід розкласти інформацію для подання до механізмів реалізації політики

1.4.14. ОБМЕЖЕННЯ ФІЛЬТРА ПОЛІТИКИ БЕЗПЕКИ (АС-4(14))

При передачі інформації між різними захищеними доменами реалізувати [Призначення: визначені організацією фільтри політики безпеки], що вимагають повного переліку форматів, які обмежують структуру та зміст даних.

No: 1

Name: ac_4_14_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

При передачі інформації між різними захищеними доменами, реалізовані фільтри політики безпеки вимагають повністю перелічених форматів, які обмежують структуру та вміст даних

No: 2

Name: ac_4_14_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

При передачі інформації між різними захищеними доменами, реалізовані фільтри політики конфіденційності вимагають повністю перелічених форматів, які обмежують структуру та вміст даних

No: 3

Name: ac_4_14_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено фільтри політики конфіденційності, які вимагають повного переліку форматів, що обмежують структуру та вміст даних

1.4.15. ВИЯВЛЕННЯ НЕСАНКЦІОНОВАНОЇ ІНФОРМАЦІЇ (АС-4(15))

При передачі інформації між різними захищеними доменами перевіряти інформацію на наявність [Призначення: визначеної організацією несанкціонованої інформації] та забороняти передачу такої інформації відповідно до [Призначення: визначеної організацією політики безпеки].

No: 1

Name: ac_4_15_01

Type: string

Default: nil

При передачі інформації між різними доменами безпеки інформація перевіряється на наявність <АС- 04(15)_ODP[01] несанкціонованої інформації>

No: 2

Name: ac_4_15_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

При передачі інформації між різними доменами безпеки забороняється передача несанкціонованої інформації відповідно до політики безпеки

No: 3

Name: ac_4_15_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

При передачі інформації між різними доменами безпеки забороняється передача несанкціонованої інформації відповідно до політики конфіденційності

No: 4

Name: ac_4_15_odp_01

Type: string

Default: nil

Визначено несанкціоновану інформацію, яку потрібно виявляти

No: 5

Name: ac_4_15_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політику безпеки, яка вимагає заборонити передачу несанкціонованої інформації між різними доменами безпеки (якщо вибрано)

No: 6

Name: ac_4_15_odp_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політику конфіденційності, яка вимагає заборонити передачу визначеної організацією несанкціонованої інформації між різними доменами безпеки (якщо вибрано)

1.4.16. ПЕРЕДАЧА ІНФОРМАЦІЇ ПРО ВЗАЄМОПОВ'ЯЗАНІ СИСТЕМИ (АС-4(16))

No: 1

Name: ac_4_16_01

Type: string

Default: nil

УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ - ПЕРЕДАЧА ІНФОРМАЦІЇ ПРО ВЗАЄМОПОВ'ЯЗАНІ СИСТЕМИ [Вилучено: Включено в АС-04]

1.4.17. ПРИВ'ЯЗКА АТРИБУТУ БЕЗПЕКИ (АС-4(18))

No: 1

Name: ac_4_18_01

Type: string

Default: nil

УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ - ПРИВ'ЯЗКА АТРИБУТУ БЕЗПЕКИ [Вилучено: Включено в АС-16]

1.4.18. ПЕРЕВІРКА МЕТАДАНИХ (АС-4(19))

Під час передачі інформації між різними захищеними доменами застосовувати до метаданих ту ж політику безпеки фільтрації, що й для корисних даних.

No: 1

Name: ac_4_19_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

При передачі інформації між різними доменами безпеки, фільтри політики безпеки реалізовано на метаданих

No: 2

Name: ac_4_19_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

При передачі інформації між різними доменами безпеки, фільтри політики конфіденційності реалізовано на метаданих

No: 3

Name: ac_4_19_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено фільтри політики безпеки, які буде застосовано до метаданих (якщо вибрано)

No: 4

Name: ac_4_19_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено фільтри політики конфіденційності, які буде застосовано до метаданих (якщо вибрано)

1.4.19. ЗАТВЕРДЖЕНІ РІШЕННЯ (АС-4(20))

Впровадити [Призначення: визначені організацією рішення про схвалені конфігурації] для керування потоком [Призначення: інформації, визначеної організацією] через захищені домени.

No: 1

Name: ac_4_20_01

Type: string

Default: nil

УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ - ЗАТВЕРДЖЕНІ РІШЕННЯ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: ac_4_20_odp_01

Type: string

Default: nil

Визначені рішення про схвалені конфігурації для керування потоками інформації через захищені домени

No: 3

Name: ac_4_20_odp_02

Type: string

Default: nil

Визначено інформацію, якою потрібно керувати, коли вона проходить через захищені домени

1.4.20. ФІЗИЧНЕ ТА ЛОГІЧНЕ ВІДДІЛЕННЯ ІНФОРМАЦІЙНИХ ПОТОКІВ (АС-4(21))

Відокремлювати потоки інформації логічно або фізично, використовуючи [Призначення: визначені організацією механізми та/або методи] для досягнення [Призначення: визначеного організацією необхідного поділу за типами інформації].

No: 1

Name: ac_4_21_02

Type: string

Default: nil

Інформаційні потоки логічно розділені за допомогою механізмів та/або методів для виконання необхідних розділень; інформаційні потоки фізично розділені за допомогою механізмів та/або методів для виконання розділень>; <АС-04(21)_ODP[03] необхідних

No: 2

Name: ac_4_21_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено механізми та/або методи, що використовуються для логічного розділення інформаційних потоків (якщо вибрано)

No: 3

Name: ac_4_21_odp_02

Type: string

Default: "автоматизований засіб моніторингу"

Визначено механізми та/або методи, що використовуються для фізичного розділення інформаційних потоків (якщо вибрано)

No: 4

Name: ac_4_21_odp_03

Type: string

Default: nil

Визначено необхідні поділи за типами інформації

1.4.21. ЄДИНИЙ ДОСТУП (АС-4(22))

Забезпечити доступ з одного пристрою до обчислювальних платформ, застосунків або даних, що розташовуються в декількох різних захищених доменах, одночасно запобігаючи передачі будь-якого потоку інформації між різними захищеними доменами.

No: 1

Name: ac_4_22_01

Type: integer

Default: 30

Доступ забезпечується з одного пристрою до обчислювальних платформ, застосунків або даних, що розташовуються в декількох різних захищених доменах, одночасно запобігаючи передачі інформації між різними захищеними доменами

1.4.22. МОДИФІКОВАНА ІНФОРМАЦІЯ, ЯКА НЕ ПІДЛЯГАЄ ОПРИЛЮДНЕННЮ (АС-4(23))

Під час передачі інформації між різними доменами безпеки змінюйте інформацію, яка не підлягає оприлюдненню, реалізувавши [Призначення: визначена організацією дія модифікації]

No: 1

Name: ac_4_23_odp

Type: string

Default: nil

Визначено дію модифікації, що застосовується до інформації, яка не підлягає оприлюдненню; АС-04(23) при передачі інформації між доменами безпеки інформація, що не підлягає оприлюдненню, модифікується шляхом реалізації дія модифікації

1.4.23. УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ НОРМАЛІЗОВАНИЙ ФОРМАТ (АС-4(24))

Під час передачі інформації між різними доменами безпеки аналізуйте вхідні дані у внутрішньому нормалізованому форматі та повторно генеруйте дані, щоб вони відповідали призначеній специфікації.

No: 1
 Name: ac_4_24_1
 Type: string
 Default: nil

При передачі інформації між різними доменами безпеки вхідні дані розбираються у внутрішній, нормалізований формат

No: 2
 Name: ac_4_24_2
 Type: string
 Default: nil

При передачі інформації між різними доменами безпеки дані регенеруються, щоб відповідати їхній специфікації

1.4.24. ОЧИЩЕННЯ ДАНИХ (АС-4(25))

Під час передачі інформації між різними доменами безпеки очищуйте дані, щоб мінімізувати [Вибір (один або кілька): доставка зловмисного вмісту, керування та керування зловмисним кодом, доповнення зловмисного коду та стеганографічно закодовані дані; витік конфіденційної інформації] відповідно до [Призначення: політика, визначена організацією].

No: 1
 Name: ac_4_25_odp_01
 Type: string
 Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {доставка шкідливого коду, керування та контроль шкідливого коду, доповнення шкідливого коду та даних, закодованих стеганографією; витік конфіденційної інформації}

No: 2
 Name: ac_4_25_odp_02
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Визначено політику очищення даних

1.4.25. ДІЇ З ФІЛЬТРАЦІЇ АУДИТУ (АС-4(26))

Під час передачі інформації між різними доменами безпеки записуйте та перевіряйте дії фільтрації вмісту та результати для інформації, що фільтрується.

No: 1
 Name: ac_4_26_01
 Type: list
 Default: ["login", "logout", "failed_attempt"]

При передачі інформації між різними доменами безпеки дії з фільтрації вмісту фіксуються і перевіряються

No: 2
 Name: ac_4_26_02
 Type: string
 Default: nil

При передачі інформації між різними доменами безпеки, результати для інформації, що фільтрується, записуються і перевіряються

1.4.26. УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ КОВІ/НЕЗАЛЕЖНІ ФІЛЬТРУЮЧІ МЕХАНІЗМИ (АС-4(27))

НАДЛИШКОВІ/НЕЗАЛЕЖНІ ФІЛЬТРУЮЧІ МЕХАНІЗМИ Під час передачі інформації між різними доменами безпеки впроваджуйте рішення фільтрації вмісту, які забезпечують надлишкові та незалежні механізми фільтрації для кожного типу даних.

No: 1

Name: ac_4_27_01

Type: integer

Default: 30

Під час передачі інформації між системами безпеки впроваджені рішення для фільтрації контенту забезпечують надлишкові та незалежні механізми фільтрації для кожного типу даних

1.4.27. ЛІНІЙНІ ФІЛЬТРУВАЛЬНІ КАНАЛИ (АС-4(28))

Під час передачі інформації між різними доменами безпеки запровадьте конвеєр лінійного фільтрування вмісту, який забезпечується дискреційним і обов'язковим контролем доступу.

No: 1

Name: ac_4_28_01

Type: string

Default: nil

При передачі інформації між доменами безпеки реалізовано лінійний конвеєр фільтрації контенту, який забезпечується дискретними та обов'язковими засобами контролю доступу

1.4.28. УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ХАНІЗМІВ ОРКЕСТРОВКИ (АС-4(29))

Під час передачі інформації між різними доменами безпеки використовуйте механізми оркестровки фільтрів вмісту, щоб забезпечити:

- Механізми фільтрації вмісту успішно завершують виконання без помилок;
- Дії фільтрації вмісту виконуються в правильному порядку та відповідають [Призначення: політика, визначена організацією]

No: 1

Name: ac_4_29_a

Type: string

Default: "автоматизований засіб моніторингу"

При передачі інформації між доменами безпеки використовуються механізми оркестрування фільтрації контенту, які гарантують, що механізми фільтрації контенту успішно завершать виконання без помилок

No: 2

Name: ac_4_29_b_01

Type: list

Default: ["login", "logout", "failed_attempt"]

При передачі інформації між доменами безпеки використовуються механізми оркестрування фільтрації контенту, які гарантують, що дії з фільтрації контенту відбуваються в правильному порядку

No: 3

Name: ac_4_29_b_02

Type: list

Default: ["login", "logout", "failed_attempt"]

При передачі інформації між доменами безпеки використовуються механізми оркестрування фільтрації контенту, які гарантують, що дії з фільтрації контенту відповідають політиці.

No: 4

Name: ac_4_29_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політику щодо дій з фільтрації контенту

1.4.29. МЕХАНІЗМИ ФІЛЬТРАЦІЇ З ВИКОРИСТАННЯМ КІЛЬКОХ ПРОЦЕСІВ (АС-4(30))

Під час передачі інформації між різними доменами безпеки реалізуйте механізми фільтрації вмісту за допомогою кількох процесів.

No: 1

Name: ac_4_30_01

Type: string

Default: "автоматизований засіб моніторингу"

При передачі інформації між доменами безпеки реалізовані механізми контент-фільтрації з використанням декількох процесів. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

1.4.30. ЗАПОБІГАННЯ СПРОБАМ ПЕРЕДАЧІ ВМІСТУ, ЯКИЙ НЕ ПРОЙШОВ ПЕРЕВІРКУ ФІЛЬТРАЦІЇ (АС-4(31))

Під час передачі інформації між різними доменами безпеки запобігайте передачі вмісту, який не пройшов перевірку фільтрації до домену-одержувача.

No: 1

Name: ac_4_31_01

Type: string

Default: nil

При передачі інформації між різними доменами безпеки запобігається передача вмісту який не пройшов фільтрацію

1.4.31. ВИМОГИ ДО ПРОЦЕСУ ПЕРЕДАЧІ ІНФОРМАЦІЇ (АС-4(32))

Під час передачі інформації між різними доменами безпеки, процес, який передає інформацію між конвеєрами фільтрації:

- a. не фільтрує вміст повідомлення;
- b. перевіряє метадані фільтрації;
- c. забезпечує успішне завершення фільтрації вмісту, пов'язаного з метаданими фільтрації; і
- d. передає вміст до цільового фільтруючого конвеєра.

Немає параметрів для цього контролю.

1.5. РОЗМЕЖУВАННЯ ОBOB'ЯЗКІВ (АС-5)

- a. Розмежувати і документувати [Призначення: визначені організацією обов'язки окремих осіб].
- b. Установити правила авторизації доступу для підтримки розмежування обов'язків.

No: 1

Name: ac_5_odp

Type: string

Default: nil

Визначено обов'язки осіб, які потребують розмежування; АС-05[a] обов'язки осіб визначені та задокументовані; АС-05[b] визначено права авторизації доступу до системи для підтримки розмежування обов'язків

1.6. МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ (АС-6)

Впровадити принцип мінімізації повноважень, який дозволяє користувачам (або процесам, що діють від імені користувачів) здійснювати лише такі авторизовані звернення, які необхідні для виконання визначених завдань відповідно до цілей (призначення, місії) організації та функцій.

No: 1

Name: ac_6_01

Type: string

Default: nil

Застосовується принцип мінімізації повноважень, який дозволяє користувачам (або процесам, що діють від імені користувачів) здійснювати лише такі авторизовані звернення, які необхідні для виконання поставлених завдань організації

1.6.1. АВТОРИЗОВАНИЙ ДОСТУП ДО ФУНКЦІЙ БЕЗПЕКИ (АС-6(1))

No: 1

Name: ac_6_1_a_01

Type: string

Default: nil

Авторизовано доступ для осіб та ролей до функцій безпеки (розгорнуті на апаратному забезпеченні)

No: 2

Name: ac_6_1_a_02

Type: string

Default: nil

Авторизовано доступ для осіб та ролей до функцій безпеки (розгорнуті на програмному забезпеченні)

No: 3

Name: ac_6_1_a_03

Type: string

Default: nil

Авторизовано доступ для осіб та ролей до функцій безпеки (розгорнуті на мікропрограмному забезпеченні)

No: 4

Name: ac_6_1_b

Type: string

Default: nil

Авторизовано доступ для осіб та ролей до інформації

No: 5

Name: ac_6_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначені особи або ролі з авторизованим доступом до функцій безпеки та інформації, що має відношення до безпеки

No: 6

Name: ac_6_1_odp_02

Type: string

Default: nil

Визначені функції безпеки (розгорнуті в апаратному забезпеченні) для авторизованого доступу

No: 7

Name: ac_6_1_odp_03

Type: string

Default: nil

Визначені функції безпеки (розгорнуті в програмному забезпеченні) для авторизованого доступу

No: 8

Name: ac_6_1_odp_04

Type: string

Default: nil

Визначені функції безпеки (розгорнуті в мікропрограмному забезпеченні) для авторизованого доступу

No: 9

Name: ac_6_1_odp_05

Type: string

Default: nil

Визначено інформацію, важливу для забезпечення безпеки, для авторизованого доступу

1.6.2. НЕПРИВІЛЕЙОВАНИЙ ДОСТУП ДО НЕЗАХИЩЕНИХ ФУНКЦІЙ (АС-6(2))

Вимагати від користувачів облікових записів системи або ролей, які мають доступ до [Призначення: визначених організацією функцій безпеки або інформації, що стосується безпеки], використовувати непривілейовані облікові записи чи ролі під час доступу до незахищених функцій.

No: 1

Name: ac_6_2_01

Type: list

Default: ["admin", "security_officer"]

Користувачі облікових записів (або ролей) системи з доступом до функцій безпеки або інформації, що стосується безпеки, повинні використовувати непривілейовані облікові записи або ролі під час доступу до незахищених функцій

No: 2

Name: ac_6_2_odp

Type: string

Default: nil

Визначені функції безпеки або інформація, що стосується безпеки

1.6.3. РОЗДІЛЬНІ ДОМЕНИ ОБРОБКИ (АС-6(4))

Надати окремі домени обробки даних для забезпечення більш точного розподілу повноважень користувача.

No: 1

Name: ac_6_4_01

Type: string

Default: nil

Надаються окремі домени обробки для більш тонкого розподілу повноважень користувачів

1.6.4. ПРИВІЛЕЙОВАНІ ОБЛІКОВІ ЗАПИСИ (АС-6(5))

Обмежити привілейовані облікові записи в системі згідно з [Призначення: визначеним організацією персоналом або ролями].

No: 1

Name: ac_6_5_01

Type: list

Default: ["admin", "security_officer"]

Привілейовані облікові записи в системі обмежено персонал або ролі

No: 2

Name: ac_6_5_odp

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, яким мають бути обмежені привілейовані облікові записи в системі

1.6.5. ПРИВІЛЕЙОВАНИЙ ДОСТУП КОРИСТУВАЧАМИ, ЩО НЕ НАЛЕЖАТЬ ДО ОРГАНІЗАЦІЇ (АС-6(6))

Заборонити привілейований доступ до системи користувачам, які не належать до організації.

No: 1

Name: ac_6_6_01

Type: string

Default: nil

Привілейований доступ до системи для користувачів, які не є членами організації, заборонено

1.6.6. ПЕРЕГЛЯД ПОВНОВАЖЕНЬ КОРИСТУВАЧА (АС-6(7))

а) Переглядати [Призначення: з визначеною організацією частотою] повноваження призначених для [Призначення: визначених організацією посад або класів користувачів] для перевірки необхідності таких повноважень; б) За необхідності перепризначити або зняти повноваження, правильного відображення цілей (місії) організації та потреб організації. для

No: 1

Name: ac_6_7_a

Type: integer

Default: 30

Повноваження, призначені ролям і класам, переглядаються з частотою для перевірки необхідності таких повноважень

No: 2

Name: ac_6_7_b

Type: string

Default: nil

Привілеї перепризначаються або знімаються, якщо це необхідно, для правильного відображення місії організації та потреб

No: 3

Name: ac_6_7_odp_01

Type: integer

Default: 30

Визначено частоту перегляду повноважень, призначених ролям або класам користувачів

No: 4

Name: ac_6_7_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено ролі або класи користувачів, яким призначено повноваження

1.6.7. РІВНІ ПРИВІЛЕЇВ ДЛЯ ВИКОНАННЯ КОДУ (АС-6(8))

Запобігати виконанню програмного забезпечення на рівні привілеїв вищому, ніж доступний користувачеві, який використовує програмне забезпечення [Призначення: визначене організацією програмне забезпечення].

No: 1

Name: ac_6_8_01

Type: string

Default: nil

Програмне забезпечення заборонено виконувати з вищими рівнями привілеїв, ніж у користувачів, які виконують це програмне забезпечення

1.6.8. АУДИТ ВИКОРИСТАННЯ ПРИВІЛЕЙОВАНИХ ФУНКЦІЙ (АС-6(9))

Реєструвати виконання привілейованих функцій.

No: 1

Name: ac_6_9_01

Type: string

Default: nil

Проводиться аудит виконання привілейованих функцій

1.6.9. ЗАБОРОНА НЕПРИВІЛЕЙОВАНИМ КОРИСТУВАЧАМ ВИКОНУВАТИ ПРИВІЛЕЙОВАНІ ФУНКЦІЇ (АС-6(10))

Вжити заходи для запобігання можливості виконувати привілейовані функції непривілейованими користувачами.

No: 1

Name: ac_6_10_01

Type: string

Default: nil

МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ - ЗАБОРОНА НЕПРИВІЛЕЙОВАНИМ КОРИСТУВАЧАМ ВИКОНУВАТИ ПРИВІЛЕЙОВАНІ ФУНКЦІЇ МЕТА ОЦІНКИ: Визначити, чи:

1.7. НЕВДАЛІ СПРОБИ ВХОДУ В СИСТЕМУ (АС-7)

а. Встановити обмеження на [Призначення: визначену організацією кількість] послідовних неуспішних спроб входу користувача в систему впродовж [Призначення: визначеного організацією часового періоду].

б. Автоматично виконати [Вибір (один або декілька): блокування облікового запису/вузла на [Призначення: визначений організацією часовий період]; блокування облікового запису/вузла, доки він не буде розблокований адміністратором; затримання наступної команди входу в систему за [Надання: визначеним організацією алгоритмом затримки]; виконати [Призначення: визначені організацією дії]], коли перевищено максимальну кількість невдалих спроб входу в систему.

No: 1

Name: ac_7_a

Type: integer

Default: 30

Застосовано обмеження на кількість послідовних неуспішних спроб входу користувача протягом періоду часу

No: 2

Name: ac_7_odp_01

Type: integer

Default: 30

Визначається кількість послідовних неуспішних спроб входу користувача, дозволених протягом певного періоду часу

No: 3

Name: ac_7_odp_02

Type: integer

Default: 30

Визначено період часу, яким обмежується кількість послідовних неуспішних спроб входу користувача

No: 4

Name: ac_7_odp_03

Type: string

Default: "AES-256-GCM"

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {заблокувати обліковий запис або вузол на період часу; заблокувати обліковий запис або вузол до зняття адміністратором; затримати наступний запит на вхід за алгоритмом затримки; повідомити системного адміністратора; виконати іншу дію}

No: 5

Name: ac_7_odp_04

Type: integer

Default: 30

Період часу, на який буде заблоковано обліковий запис або вузол (якщо вибрано)

No: 6

Name: ac_7_odp_05

Type: string
Default: "AES-256-GCM"

Визначено алгоритм затримки наступного запиту на вхід (якщо вибрано)

No: 7
Name: ac_7_odp_06
Type: integer
Default: 3

Інша дія, яка буде виконана після перевищення максимальної кількості невдалих спроб (якщо вибрано)

1.7.1. АВТОМАТИЧНЕ БЛОКУВАННЯ ОБЛІКОВОГО ЗАПISУ (АС-7(1))

No: 1
Name: ac_7_1_01
Type: integer
Default: 3

НЕВДАЛІ СПРОБИ ВХОДУ В СИСТЕМУ - АВТОМАТИЧНЕ БЛОКУВАННЯ ОБЛІКОВОГО ЗАПISУ
[Вилучено: Включено в АС-07]

1.7.2. ОЧИЩЕННЯ АБО СТИРАННЯ МОБІЛЬНОГО ПРИСТРОЮ (АС-7(2))

Очистити або стерти інформацію з [Призначення: визначених організацією мобільних пристроїв] на основі [Призначення: визначених організацією вимог та методик очищення чи стирання] після [Призначення: визначеної організацією кількості] послідовних невдалих спроб входу в систему з пристрою.

No: 1
Name: ac_7_2_01
Type: integer
Default: 3

Інформація очищується або стирається з мобільних пристроїв на основі вимог або методів очищення або стирання після <АС-07(02)_ODP[03 кількість]> послідовних, невдалих спроб входу на пристрій

No: 2
Name: ac_7_2_odp_01
Type: string
Default: nil

Визначено мобільні пристрої, які підлягають очищенню або стиранню інформації

No: 3
Name: ac_7_2_odp_02
Type: string
Default: nil

Визначено вимоги та методи очищення чи стирання інформації з мобільних пристроїв

No: 4
Name: ac_7_2_odp_03
Type: integer
Default: 3

Визначається кількість послідовних невдалих спроб входу в систему до того, як інформація буде очищена або стерта з мобільних пристроїв

1.7.3. ОБМЕЖЕННЯ НА СПРОБИ БІОМЕТРИЧНОГО ВХОДУ (АС-7(3))

Обмежити кількість невдалих спроб входу за допомогою біометрики [Призначення: визначена організацією кількість].

No: 1

Name: ac_7_3_01

Type: integer

Default: 3

Визначено кількість невдалих спроб входу за допомогою біометрики обмежно кількість невдалих спроб входу за допомогою біометрики

1.7.4. ВИКОРИСТАННЯ АЛЬТЕРНАТИВНОГО ФАКТОРА (АС-7(4))

а) Дозволити використання [Призначення: визначені організацією фактори автентифікації], які відрізняються від основних факторів автентифікації після перевищення визначеної організацією кількості послідовних невдалих спроб входу в систему; б) Обмежити [Призначення: визначена організацією кількість] послідовних невдалих спроб входу за допомогою використання альтернативних факторів користувачем протягом [Призначення: визначеного організацією періоду часу].

No: 1

Name: ac_7_4_a

Type: integer

Default: 30

Фактори автентифікації, які відрізняються від основних факторів автентифікації, дозволяється використовувати після перевищення кількості визначених організацією послідовних невдалих спроб входу; АС-07(04)(b) введено обмеження на послідовних невдалих спроб входу через використання користувачем альтернативних факторів протягом періоду часу

No: 2

Name: ac_7_4_odp_01

Type: string

Default: nil

Визначено фактори автентифікації, які дозволено використовувати, але які відрізняються від основних факторів автентифікації

No: 3

Name: ac_7_4_odp_02

Type: integer

Default: 3

Визначено кількість послідовних, недійсних спроб входу через використання альтернативних факторів

No: 4

Name: ac_7_4_odp_03

Type: integer

Default: 30

Визначено період часу, протягом якого користувач може спробувати увійти через альтернативні фактори

1.8. ПОПЕРЕДЖЕННЯ ПРО ВИКОРИСТАННЯ СИСТЕМИ (АС-8)

- a.
- b. Демонструвати користувачам [Призначення: визначене організацією сповіщення або банер про використання системи] перед тим, як надавати доступ до системи, що забезпечує безпеку та приватність відповідно до чинних законів, нормативних документів, наказів, директив, політик, правил, стандартів і керівних принципів, які зазначають, що:
1. користувачі здійснюють доступ до урядової системи;
 2. використання системи може контролюватися, реєструватися та підлягати аудиту;
 3. несанкціоноване використання системи забороняється та приводить до кримінальної та цивільної відповідальності;
 4. використання системи означає згоду на моніторинг і запис дій користувача. Зберігати сповіщення або банер на екрані, доки користувачі не визнають умови використання та не приймуть явних дій для входу в систему або подальшого доступу до системи.
- c. Для загальнодоступних систем:
1. демонструвати інформацію про умови використання системи [Призначення: визначені організацією умови], перш ніж надавати подальший доступ до загальнодоступної системи;
 2. демонструвати посилання, якщо такі є, на моніторинг, запис або аудит, які узгоджуються з акомодатією приватності для таких систем, які зазвичай забороняють такі дії;
 3. мати опис авторизованого використання системи.

No: 1

Name: ac_8_c_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначається сповіщення або банер про використання системи, який система буде показувати користувачам перед наданням доступу до системи; визначено умови використання системи, які система відображатиме перед наданням подальшого доступу; повідомлення про використання системи відображається користувачам перед наданням доступу до системи, яке містить повідомлення про конфіденційність і безпеку, що відповідають чинним законам, нормативним документам, наказам, директивам, політикам, правилам, стандартам і керівним принципам; у повідомленні про використання системи зазначено, що користувачі отримують доступ до урядової системи; у повідомленні про використання системи зазначено, що використання системи може контролюватися, реєструватися та підлягати аудиту; у повідомленні про використання системи зазначено, що несанкціоноване використання системи заборонено і тягне за собою кримінальну та цивільну відповідальність; у повідомленні про використання системи зазначено, що використання системи означає згоду на моніторинг і запис дій; сповіщення або банер залишається на екрані до тих пір, поки користувачі не визнають умови використання та не приймуть явні дії для входу в систему або подальшого доступу до неї; для загальнодоступних систем інформація про використання системи умови відображається перед наданням подальшого доступу до загальнодоступної системи; для загальнодоступних систем відображаються будь-які посилання на моніторинг, запис або аудит, які узгоджуються з положеннями про конфіденційність таких систем, що зазвичай забороняють ці види діяльності; для загальнодоступних систем додається опис авторизованого використання системи

1.9. СПОВІЩЕННЯ ПРО ПОПЕРЕДНІЙ ВХІД (ДОСТУП) (АС-9)

Сповіщати користувача після успішного входу (доступу) до системи про дату та час останнього входу (доступу).

No: 1

Name: ac_9_01

Type: integer

Default: 30

Система повідомляє користувача при успішному вході (доступі) до системи про дату та час останнього входу (доступу)

1.9.1. НЕВДАЛІ СПРОБИ ВХОДУ ДО СИСТЕМИ (АС-9(1))

No: 1

Name: ac_9_1_01

Type: integer

Default: 3

Система сповіщає користувача після успішного входу / доступу про кількість невдалих спроб входу / доступу з моменту останнього успішного входу / доступу

1.9.2. УСПІШНІ ТА НЕВДАЛІ СПРОБИ ВХОДУ ДО СИСТЕМИ (АС-9(2))

Сповіщати користувача, після успішного входу/доступу до системи про кількість [Вибір: успішних спроб доступу/входу; невдалих спроб входу/доступу; обидва варіанти] за [Призначення: визначений організацією період часу].

No: 1

Name: ac_9_2_01

Type: integer

Default: 30

Після успішного входу в систему користувач отримує повідомлення про кількість ЗНАЧЕННЯ ВИБРАНОГО ПАРАМЕТРА протягом періоду часу

No: 2

Name: ac_9_2_odp_01

Type: integer

Default: 3

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {успішних спроб доступу/входу; невдалих спроб входу/доступу; обидва варіанти}

No: 3

Name: ac_9_2_odp_02

Type: integer

Default: 30

Визначається період часу, протягом якого система повідомляє користувача про кількість успішних спроб входу в систему, невдалих спроб входу або про обидва випадки

1.9.3. ПОВІДОМЛЕННЯ ПРО ЗМІНИ В ОБЛІКОВОМУ ЗАПИСІ (АС-9(3))

Сповіщати користувача, після успішного входу/доступу, про внесення змін до [Призначення: певних характеристик/параметрів облікового запису користувача, визначених організацією] протягом [Призначення: визначеного організацією періоду часу].

No: 1

Name: ac_9_3_01

Type: integer

Default: 30

Визначено період часу, протягом якого система повідомляє користувача про зміни характеристик або параметрів, пов'язаних із безпекою облікового запису користувача; після успішного входу користувач отримує повідомлення про зміни характеристик або параметрів, пов'язаних із безпекою протягом періоду часу

No: 2

Name: ac_9_3_odp_01

Type: string

Default: nil

Визначено зміни характеристик або параметрів, пов'язаних із безпекою облікового запису користувача, які потребують сповіщення; AC-09(03)_ODP[02]

1.9.4. СПОВІЩЕННЯ ПРО ПОПЕРЕДНІЙ ВХІД (ДОСТУП) – ДОДАТКОВА ІНФОРМАЦІЯ ПРО ВХІД (АС-9(4))

Повідомляти користувачеві, після успішного входу/доступу, наступну додаткову інформацію: [Призначення: інформація, визначена організацією, яка повинна бути включена на додаток до дати та часу останнього входу/доступу].

No: 1

Name: ac_9_4_01

Type: string

Default: nil

Після успішного входу користувач отримує повідомлення додаткова інформація

No: 2

Name: ac_9_4_odp

Type: string

Default: nil

Визначено додаткову інформацію, про яку слід повідомити користувача

1.10. УПРАВЛІННЯ ПАРАЛЕЛЬНОЮ СЕСІЄЮ (АС-10)

Обмежити кількість одночасних сеансів для кожного [Призначення: визначеного організацією облікового запису та/або типу облікового запису] до [Призначення: визначеної організацією кількості].

No: 1

Name: ac_10_01

Type: integer

Default: 30

Кількість одночасних сеансів для кожного облікового запису та/або типів облікових записів обмежена кількістю

No: 2

Name: ac_10_odp_02

Type: integer

Default: 30

Визначено кількість одночасних сеансів, дозволених для кожного облікового запису та/або типу облікового запису

1.11. БЛОКУВАННЯ ПРИСТРОЮ (АС-11)

- а. Заборонити подальший доступ до системи шляхом ініціювання блокування пристрою після [Призначення: визначеного організацією періоду] бездіяльності або після отримання запиту від користувача.
- б. Зберігати блокування пристрою, поки користувач не відновить доступ, використовуючи встановлені процедури ідентифікації та автентифікації.

No: 1

Name: ac_11_b

Type: string

Default: nil

Блокування пристрою зберігається доти, доки користувач не відновить доступ за допомогою встановлених процедур ідентифікації та автентифікації

No: 2

Name: ac_11_odp_01

Type: integer

Default: 30

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {ініціювання блокування пристрою після періоду неактивності; вимога до користувача ініціювати блокування пристрою перед тим, як залишити систему без нагляду}

No: 3

Name: ac_11_odp_02

Type: integer

Default: 30

Часовий проміжок бездіяльності, після якого ініціюється блокування пристрою (якщо вибрано)

1.11.1. ПРИХОВАНІ ДИСПЛЕЇ (АС-11(1))

No: 1

Name: ac_11_1_01

Type: string

Default: nil

Система приховує (через блокування сеансу) інформацію, попередньо видиму на дисплеї, загальнодоступним зображенням

1.12. Припинення сеансу (АС-12)

Сеанс користувача має завершуватися автоматично після [Призначення: визначених організацією умов або тригерних подій, що вимагають припинення сеансу].

No: 1

Name: ac_12_01

Type: string

Default: nil

Сеанс користувача автоматично завершується після виконання умов або подій

No: 2

Name: ac_12_odp

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено умови або події, що вимагають припинення сеансу

1.12.1. ІНІЦІЙОВАНЕ КОРИСТУВАЧЕМ БЛОКУВАННЯ (АС-12(1))

Забезпечити можливість припинення сеансів зв'язку з ініціативи користувача, коли автентифікація використовується для отримання доступу до [Призначення: визначених організацією інформаційних ресурсів].

No: 1

Name: ac_12_1_01

Type: string

Default: nil

Для сеансів зв'язку, ініційованих користувачем, передбачено можливість виходу з системи щоразу, коли автентифікація використовується для отримання доступу до інформаційних ресурсів

1.12.2. ПОВІДОМЛЕННЯ ПРО ПРИПИНЕННЯ СЕАНСУ (АС-12(2))

Відобразити виразне повідомлення для користувача, що вказує на достовірне припинення автентифікованих сеансів зв'язку.

No: 1

Name: ac_12_2_01

Type: string

Default: nil

Користувачам буде показано явне повідомлення про завершення сеансу автентифікованого зв'язку

1.12.3. ЗАСТЕРЕЖНЕ ПОВІДОМЛЕННЯ ПРО ТЕ, ЩО ЧАС СЕСІЇ ДОБІГАЄ КІНЦЯ (АС-12(3))

Відобразити виразне повідомлення користувачам, що вказує, що сесія добігає кінця [Завдання: визначений організацією час до кінця сесії].

No: 1

Name: ac_12_3_01

Type: integer

Default: 30

Визначено час до кінця сесії для відображення користувачам; виводиться явне повідомлення користувачам про те, що сеанс завершиться у час

1.13. НАГЛЯД ТА ОГЛЯД - УПРАВЛІННЯ ДОСТУПОМ (АС-13)

No: 1

Name: ac_13_01

Type: string

Default: nil

НАГЛЯД ТА ОГЛЯД - УПРАВЛІННЯ ДОСТУПОМ [Вилучено: включено в АС-02 та АУ-06]

1.14. ДОЗВОЛЕНІ ДІЇ БЕЗ ІДЕНТИФІКАЦІЇ АБО АВТЕНТИФІКАЦІЇ (АС-14)

- a. Визначити [Призначення: дозволені організацією дії користувачів], які можуть виконуватися в системі без ідентифікації або автентифікації відповідно до завдань та функцій організації.
- b. Документувати та визначити відповідне обґрунтування в плані безпеки системи дій користувача, які не потребують ідентифікації або автентифікації.

No: 1

Name: ac_14_a

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено дії користувача, які можуть бути виконані в системі без ідентифікації або автентифікації, що відповідають місії та функціям організації

No: 2

Name: ac_14_a_02

Type: string

Default: nil

Обґрунтування дій користувачів, які не потребують ідентифікації або автентифікації, надається в плані захисту інформації

No: 3

Name: ac_14_b_01

Type: list

Default: ["login", "logout", "failed_attempt"]

Дії користувачів, які не потребують ідентифікації або автентифікації, задокументовані в плані захисту інформації

No: 4

Name: ac_14_odp

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено дії користувача, які можуть бути виконані в системі без ідентифікації або автентифікації

1.14.1. ДОЗВОЛЕНІ ДІЇ БЕЗ ІДЕНТИФІКАЦІЇ НЕОБХІДНЕ ВИКОРИСТАННЯ (АС-14(1))

No: 1

Name: ac_14_1_01

Type: list

Default: ["login", "logout", "failed_attempt"]

ДОЗВОЛЕНІ ДІЇ БЕЗ ІДЕНТИФІКАЦІЇ НЕОБХІДНЕ ВИКОРИСТАННЯ АБО АВТЕНТИФІКАЦІЇ - [Вилучено: включено до АС-14]

1.15. АВТОМАТИЗОВАНЕ МАРКУВАННЯ (АС-15)

No: 1

Name: ac_15_01

Type: string

Default: nil

АВТОМАТИЗОВАНЕ МАРКУВАННЯ [Вилучено: включено до МР-03]

1.16. АТРИБУТИ БЕЗПЕКИ ТА ПРИВАТНОСТІ (АС-16)

а. Визначити засоби для асоціювання (пов'язання) [Призначення: визначених організацією типів атрибутів безпеки та приватності], що приймають [Призначення: визначені організацією значення атрибутів безпеки та приватності] з інформацією, яка зберігається, обробляється та/або передається.

б. Пов'язані атрибути безпеки та приватності мають створюватися і зберігатися разом з інформацією.

с. Встановити дозволені [Призначення: визначені організацією атрибути безпеки] для [Призначення: систем, визначених організацією].

д. Визначити дозволені [Призначення: визначені організацією значення або діапазони] для кожного з встановлених атрибутів безпеки та приватності.

No: 1

Name: ac_16_c_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено типи атрибутів безпеки, які мають бути пов'язані зі значеннями атрибутів безпеки для інформації, що зберігається, обробляється та/або передається; визначено значення атрибутів конфіденційності для типів атрибутів конфіденційності; визначено системи, для яких мають бути встановлені дозволені атрибути безпеки; визначено системи, для яких мають бути встановлені дозволені атрибути конфіденційності; визначено атрибути безпеки, визначені як частина АС-16(а), які дозволені для систем; визначено атрибути конфіденційності, визначені як частина АС-16(а), які дозволені для систем; визначено значення атрибутів або діапазони для встановлених атрибутів; визначено частоту, з якою слід переглядати атрибути безпеки на предмет відповідності; визначено частоту, з якою слід переглядати атрибути конфіденційності на предмет відповідності; надано засоби для асоціювання типів атрибутів безпеки зі значеннями атрибутів безпеки для інформації, що зберігається, обробляється та/або передається надано засоби для асоціювання типів атрибутів конфіденційності зі значеннями атрибутів конфіденційності для інформації, що зберігається, обробляється та/або передається виникають зв'язки з атрибутами; зв'язки атрибутів зберігаються разом з інформацією; на основі атрибутів, визначених у АС-16_ODP[01] для систем, встановлюються наступні дозволені атрибути безпеки: атрибути безпеки; на основі атрибутів, визначених у АС-16_ODP[02] для систем, встановлюються наступні дозволені атрибути приватності: атрибути конфіденційності ; АС-16(d)

No: 2

Name: ac_16_f_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено наступні допустимі значення або діапазони атрибутів для кожного з встановлених атрибутів: значення або діапазони атрибутів; проводиться аудит змін до атрибутів; атрибути безпеки перевіряються на відповідність частота; атрибути конфіденційності перевіряються на відповідність частота

No: 3

Name: ac_16_odp_02

Type: string

Default: nil

Визначено типи атрибутів конфіденційності, які мають бути пов'язані зі значеннями атрибутів конфіденційності для інформації, що зберігається, обробляється та/або передається

No: 4

Name: ac_16_odp_03

Type: string

Default: nil

Визначено значення атрибутів безпеки для типів атрибутів безпеки

1.16.1. ДИНАМІЧНЕ ПОВ'ЯЗАННЯ АТРИБУТІВ (АС-16(1))

No: 1

Name: ac_16_1_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Атрибути безпеки динамічно пов'язуються з об'єктами відповідно до наведених нижче політик безпеки під час створення та комбінування інформації: політики безпеки

No: 2

Name: ac_16_1_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Атрибути конфіденційності динамічно пов'язуються з суб'єктами відповідно до наведених нижче політик конфіденційності під час створення та комбінування інформації: політики конфіденційності

No: 3

Name: ac_16_1_04

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Атрибути конфіденційності динамічно пов'язуються з об'єктами відповідно до наведених нижче політик конфіденційності під час створення та комбінування інформації: політики конфіденційності

No: 4

Name: ac_16_1_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено суб'єкти, з якими атрибути безпеки повинні динамічно пов'язуватися при створенні та комбінуванні інформації

No: 5

Name: ac_16_1_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено об'єкти, з якими атрибути безпеки повинні динамічно пов'язуватися при створенні та комбінуванні інформації

No: 6

Name: ac_16_1_odp_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначені суб'єкти, з якими атрибути конфіденційності повинні динамічно пов'язуватися при створенні та комбінуванні інформації

No: 7

Name: ac_16_1_odp_04

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначені об'єкти, з якими атрибути конфіденційності повинні динамічно пов'язуватися при створенні та комбінуванні інформації

No: 8

Name: ac_16_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політики безпеки, що вимагають динамічного пов'язування атрибутів безпеки з суб'єктами та об'єктами

No: 9

Name: ac_16_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політики конфіденційності, що вимагають динамічного пов'язування атрибутів безпеки з суб'єктами та об'єктами; АС-16(01)[01] атрибути безпеки динамічно пов'язуються з суб'єктами відповідно до наведених нижче політик безпеки під час створення та комбінування інформації: політики безпеки

1.16.2. ЗМІНА ЗНАЧЕНЬ АТРИБУТІВ АВТОРИЗОВАНИМИ ОСОБАМИ (АС-16(2))

Надати уповноваженим особам (або процесам, що діють від імені фізичних осіб) можливість визначати або змінювати значення відповідних атрибутів безпеки та приватності.

No: 1

Name: ac_16_2_02

Type: string

Default: nil

Мають можливість визначати або змінювати значення пов'язаних з ними атрибутів конфіденційності

1.16.3. ПІДТРИМКА СИСТЕМОЮ ПОВ'ЯЗАННЯ АТРИБУТІВ (АС-16(3))

ПОВ'ЯЗАННЯ АТРИБУТІВ Підтримати пов'язання та цілісність [Призначення: визначених організацією атрибутів безпеки та приватності] з [Призначення: визначених організацією суб'єктів і об'єктів].

No: 1

Name: ac_16_3_01

Type: string

Default: nil

Підтримується зв'язок та цілісність атрибутів безпеки з суб'єктами

No: 2

Name: ac_16_3_02

Type: string

Default: nil

Підтримується зв'язок та цілісність атрибутів безпеки з об'єктами

No: 3

Name: ac_16_3_03

Type: string

Default: nil

Підтримується зв'язок та цілісність атрибутів конфіденційності з суб'єктами

No: 4

Name: ac_16_3_04

Type: string

Default: nil

Підтримується зв'язок та цілісність атрибутів конфіденційності з об'єктами; ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

No: 5

Name: ac_16_3_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено атрибути безпеки, які потребують підтримки асоціацій та цілісності

No: 6

Name: ac_16_3_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено атрибути конфіденційності, які потребують підтримки асоціації та цілісності

No: 7

Name: ac_16_3_odp_03

Type: string

Default: nil

Визначено суб'єкти, які потребують об'єднання та збереження цілісності атрибутів безпеки, що належать до таких суб'єктів

No: 8

Name: ac_16_3_odp_04

Type: string

Default: nil

Визначено об'єкти, які потребують об'єднання та збереження цілісності атрибутів безпеки, що належать до таких об'єктів

No: 9

Name: ac_16_3_odp_05

Type: string

Default: nil

Визначено суб'єктів, які потребують об'єднання та збереження цілісності атрибутів конфіденційності щодо таких суб'єктів

No: 10

Name: ac_16_3_odp_06

Type: string

Default: nil

Визначено об'єктів, які потребують об'єднання та збереження цілісності атрибутів конфіденційності щодо таких об'єктів

1.16.4. ПОВ'ЯЗАННЯ АТРИБУТІВ АВТОРИЗОВАНИМИ ОСОБАМИ (АС-16(4))

Впровадити можливість пов'язувати [Призначення: визначені організацією атрибути безпеки та приватності] з [Призначення: визначеними організацією суб'єктами та об'єктами] уповноваженими особами (або процесами, що діють від імені фізичних осіб).

No: 1

Name: ac_16_4_03

Type: list

Default: ["admin", "security_officer"]

Визначено атрибути безпеки, які пов'язуються з суб'єктами уповноваженими особами (або процесами, що діють від імені осіб); визначено атрибути безпеки, які пов'язуються з об'єктами уповноваженими особами (або процесами, що діють від імені осіб); визначено атрибути конфіденційності, які пов'язуються з суб'єктами уповноваженими особами (або процесами, що діють від імені осіб); визначено атрибути конфіденційності, які пов'язуються з об'єктами уповноваженими особами (або процесами, що діють від імені осіб); визначено суб'єкти, що потребують пов'язання атрибутів безпеки з уповноваженими особами (або процесами, що діють від імені осіб); визначено об'єкти, що потребують пов'язання атрибутів безпеки з уповноваженими особами (або процесами, що діють від імені осіб); визначено суб'єкти, що потребують пов'язання атрибутів конфіденційності з уповноваженими особами (або процесами, що діють від імені осіб); визначено об'єкти, що потребують пов'язання атрибутів конфіденційності з уповноваженими особами (або процесами, що діють від імені осіб); уповноважені особи (або процеси, що діють від імені осіб) мають можливість пов'язувати атрибути безпеки з суб'єктами; уповноважені особи (або процеси, що діють від імені осіб) мають можливість пов'язувати атрибути безпеки з об'єктами; уповноважені особи (або процеси, що діють від імені осіб) мають можливість пов'язувати атрибути конфіденційності з АС-16(04)[04] суб'єктами; уповноважені особи (або процеси, що діють від імені осіб) мають можливість пов'язувати атрибути конфіденційності з об'єктами

1.16.5. ВІДОБРАЖЕННЯ АТРИБУТІВ НА ПРИСТРОЯХ ВИВЕДЕННЯ (АС-16(5))

Відображати атрибути безпеки та приватності в зручній для людини формі для кожного об'єкту, який система передає на пристрої виведення, щоб ідентифікувати [Призначення: визначені організацією спеціальні інструкції щодо поширення, обробки чи наступного розподілу інформації], використовуючи [Призначення: визначену організацією ідентифікацію, у зручній для людини формі про стандартні угоди про присвоєння імен].

No: 1

Name: ac_16_5_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Для кожного об'єкта, який система передає на пристрої виведення, визначено спеціальні інструкції щодо поширення, обробки чи розподілу, які мають використовуватися; визначено стандартні угоди про ідентифікацію атрибутів безпеки та конфіденційності, які повинні відображатися в зручній для читання формі на кожному об'єкті, який система передає на пристрої виводу; атрибути безпеки відображаються у формі, зручній для читання людиною, на кожному об'єкті, який система передає на пристрої виводу для ідентифікації інструкцій з використанням угод про іменування; атрибути конфіденційності відображаються у формі, зручній для читання людиною, на кожному об'єкті, який система передає на пристрої виводу для ідентифікації інструкцій з використанням угод про іменування

1.16.6. ПІДТРИМКА ПОВ'ЯЗАННЯ АТРИБУТІВ ОРГАНІЗАЦІЄЮ (АС-16(6))

Вимагати від персоналу пов'язувати та підтримувати асоціацію [Призначення: визначених організацією атрибутів безпеки та приватності] з [Призначенням: визначеними організацією суб'єктами та об'єктами] відповідно до [Призначення: визначеної організацією політики безпеки та приватності].

No: 1

Name: ac_16_6_01

Type: list

Default: ["admin", "security_officer"]

Персонал зобов'язаний пов'язувати та підтримувати зв'язок атрибутів безпеки з суб'єктами відповідно до політик безпеки; АС-16(06)[02] персонал зобов'язаний пов'язувати та підтримувати зв'язок атрибутів безпеки з об'єктами відповідно до політик безпеки

No: 2

Name: ac_16_6_03

Type: list

Default: ["admin", "security_officer"]

Персонал зобов'язаний пов'язувати та підтримувати зв'язок атрибутів конфіденційності з суб'єктами відповідно до політик безпеки

No: 3

Name: ac_16_6_04

Type: list

Default: ["admin", "security_officer"]

Персонал зобов'язаний пов'язувати та підтримувати зв'язок атрибутів конфіденційності з об'єктами відповідно до політик безпеки

No: 4

Name: ac_16_6_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено атрибути безпеки, які будуть пов'язані з суб'єктами

No: 5

Name: ac_16_6_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено атрибути безпеки, які будуть пов'язані з об'єктами

No: 6

Name: ac_16_6_odp_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено атрибути конфіденційності, які будуть пов'язані з суб'єктами

No: 7

Name: ac_16_6_odp_04

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено атрибути конфіденційності, які будуть пов'язані з об'єктами

No: 8

Name: ac_16_6_odp_05

Type: string

Default: nil

Визначені суб'єкти, які будуть пов'язані з атрибутами безпеки

No: 9

Name: ac_16_6_odp_06

Type: string

Default: nil

Визначені об'єкти, які будуть пов'язані з атрибутами безпеки

No: 10

Name: ac_16_6_odp_07

Type: string

Default: nil

Визначені суб'єкти, які будуть пов'язані з атрибутами конфіденційності

No: 11

Name: ac_16_6_odp_08

Type: string

Default: nil

Визначені об'єкти, які будуть пов'язані з атрибутами конфіденційності

No: 12

Name: ac_16_6_odp_09

Type: list

Default: ["admin", "security_officer"]

Політики безпеки, які вимагають від персоналу пов'язувати та підтримувати зв'язок атрибутів безпеки та конфіденційності з суб'єктами та об'єктами

No: 13

Name: ac_16_6_odp_10

Type: list

Default: ["admin", "security_officer"]

Політики конфіденційності, які вимагають від персоналу пов'язувати та підтримувати зв'язок атрибутів безпеки та конфіденційності з суб'єктами та об'єктами

1.16.7. ПОСЛІДОВНА ІНТЕРПРЕТАЦІЯ АТРИБУТІВ (АС-16(7))

Забезпечити послідовну інтерпретацію атрибутів безпеки та приватності, що передаються між розподіленими компонентами системи.

No: 1

Name: ac_16_7_02

Type: string

Default: nil

Забезпечується послідовна інтерпретація атрибутів безпеки, що передаються між розподіленими компонентами системи. забезпечується послідовна інтерпретація атрибутів конфіденційності, що передаються між розподіленими компонентами системи

1.16.8. ТЕХНІКИ ТА ТЕХНОЛОГІЇ ПОВ'ЯЗАННЯ АТРИБУТІВ (АС-16(8))

ПОВ'ЯЗАННЯ АТРИБУТІВ Реалізація [Призначення: методи та технології, визначені організацією] для пов'язування атрибутів безпеки та конфіденційності з інформацією.

No: 1

Name: ac_16_8_01

Type: string

Default: nil

Методи та технології застосовуються для пов'язування атрибутів безпеки з інформацією

No: 2

Name: ac_16_8_02

Type: string

Default: nil

Методи та технології застосовуються для пов'язування атрибутів конфіденційності з інформацією

No: 3

Name: ac_16_8_odp_01

Type: string

Default: nil

Визначено методи та технології, які необхідно застосувати для пов'язання інформації з атрибутами безпеки

No: 4

Name: ac_16_8_odp_02

Type: string

Default: nil

Визначено методи та технології, які необхідно застосувати для пов'язання інформації з атрибутами конфіденційності

1.16.9. ПЕРЕПРИЗНАЧЕННЯ АТРИБУТІВ (АС-16(9))

Перепризначення атрибутів безпеки та приватності, пов'язаних з інформацією, здійснювати лише за допомогою механізмів перегляду, перевірених з використанням [Призначення: визначених організацією технік або процедур].

No: 1

Name: ac_16_9_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Атрибути безпеки, пов'язані з інформацією, перепризначаються за допомогою техніки або процедури; атрибути конфіденційності, пов'язані з інформацією, перепризначаються за допомогою техніки або процедури

No: 2

Name: ac_16_9_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено техніки або процедури, що використовуються для перепризначення атрибутів безпеки

No: 3

Name: ac_16_9_odp_02

Type: string

Default: "автоматизований засіб моніторингу"

Визначено техніки або процедури, що використовуються для перепризначення атрибутів конфіденційності

1.16.10. КОНФІГУРАЦІЯ АТРИБУТІВ УПОВНОВАЖЕНИМИ ОСОБАМИ (АС-16(10))

Надати уповноваженим особам можливість визначати або змінювати тип і значення атрибутів безпеки та приватності, доступних для пов'язання із суб'єктами та об'єктами.

No: 1

Name: ac_16_10_02

Type: list

Default: ["admin", "security_officer"]

Уповноваженим особам надається можливість визначати або змінювати тип і значення атрибутів безпеки, доступних для пов'язання з суб'єктами та об'єктами; уповноваженим особам надається можливість визначати або змінювати тип і значення атрибутів конфіденційності, доступних для пов'язання з суб'єктами та об'єктами

1.17. ВІДДАЛЕНИЙ ДОСТУП (АС-17)

a. Встановити та задокументувати обмеження на використання, вимоги до конфігурації/підключення та рекомендації щодо здійснення кожного типу віддаленого доступу.

b. Авторизувати віддалений доступ до системи, перш ніж будуть дозволені такі підключення.

No: 1

Name: ac_17_a_02

Type: string

Default: nil

Для кожного типу дозволеного віддаленого доступу встановлені та задокументовані вимоги до конфігурації/підключення

No: 2

Name: ac_17_a_03

Type: string

Default: nil

Для кожного типу дозволеного віддаленого доступу встановлені та задокументовані рекомендації

No: 3

Name: ac_17_b

Type: string

Default: nil

Кожен тип віддаленого доступу до системи авторизується перед тим, як дозволити такі підключення

1.17.1. АВТОМАТИЗОВАНИЙ МОНІТОРИНГ ТА УПРАВЛІННЯ (АС-17(1))

No: 1

Name: ac_17_1_01

Type: string

Default: nil

Проводиться моніторинг методами віддаленого доступу

No: 2
Name: ac_17_1_02
Type: string
Default: nil

Проводиться управління методами віддаленого доступу

1.17.2. ЗАХИСТ КОНФІДЕНЦІЙНОСТІ ТА ЦІЛІСНОСТІ ЗА ДОПОМОГОЮ ШИФРУВАННЯ (АС-17(2))

No: 1
Name: ac_17_2_01
Type: string
Default: "AES-256-GCM"

ВІДДАЛЕНИЙ ДОСТУП - ЗАХИСТ КОНФІДЕНЦІЙНОСТІ ТА ЦІЛІСНОСТІ ЗА ДОПОМОГОЮ ШИФРУВАННЯ МЕТА ОЦІНКИ: Визначте, чи інформаційна система криптографічні механізми

1.17.3. КЕРОВАНІ ТОЧКИ КОНТРОЛЮ ДОСТУПУ (АС-17(3))

No: 1
Name: ac_17_3_01
Type: string
Default: nil

Віддалений доступ маршрутизується через авторизовані та керовані точки контролю доступу до мережі

1.17.4. ПРИВІЛЕЙОВАНІ КОМАНДИ ТА ДОСТУП (АС-17(4))

No: 1
Name: ac_17_4_a_01
Type: string
Default: nil

Виконання привілейованих команд за допомогою віддаленого доступу дозволено лише для наступних потреб: потреби

No: 2
Name: ac_17_4_a_02
Type: string
Default: nil

Доступ до інформації, важливої для безпеки, за допомогою віддаленого доступу дозволяється лише для наступних потреб: потреби

No: 3
Name: ac_17_4_b
Type: string
Default: nil

Обґрунтування віддаленого доступу задокументовано в плані захисту інформації

No: 4
Name: ac_17_4_odp_01
Type: string
Default: nil

Визначено потреби, що потребують виконання привілейованих команд за допомогою віддаленого доступу; AC-17(04)_ODP[02] визначено потреби, що вимагають доступу до інформації, що стосується безпеки, за допомогою віддаленого доступу

1.17.5. МОНІТОРИНГ ДЛЯ НЕАВТОРИЗОВАНИХ ПІДКЛЮЧЕНЬ (АС-17(5))

No: 1

Name: ac_17_5_01

Type: string

Default: nil

ВІДДАЛЕНИЙ ДОСТУП - МОНІТОРИНГ ДЛЯ НЕАВТОРИЗОВАНИХ ПІДКЛЮЧЕНЬ [Вилучено: Включено в CI-04]

1.17.6. ЗАХИСТ ІНФОРМАЦІЇ (АС-17(6))

No: 1

Name: ac_17_6_01

Type: string

Default: "автоматизований засіб моніторингу"

Інформація про механізми віддаленого доступу захищена від неавторизованого використання та розкриття

1.17.7. ДОДАТКОВИЙ ЗАХИСТ ДЛЯ ДОСТУПУ ДО ФУНКЦІЙ БЕЗПЕКИ (АС-17(7))

Немає параметрів для цього контролю.

1.17.8. ДЕАКТИВАЦІЯ НЕЗАХИЩЕНИХ ПРОТОКОЛІВ МЕРЕЖІ (АС-17(8))

No: 1

Name: ac_17_8_01

Type: string

Default: "TLS 1.3"

ВІДДАЛЕНИЙ ДОСТУП - ДЕАКТИВАЦІЯ НЕЗАХИЩЕНИХ ПРОТОКОЛІВ МЕРЕЖІ [Вилучено: Включено в CM-07]

1.17.9. ВІДКЛЮЧЕННЯ АБО ДЕАКТИВАЦІЯ ДОСТУПУ (АС-17(9))

No: 1

Name: ac_17_9_01

Type: integer

Default: 30

Передбачена можливість відключення або деактивації віддаленого доступу до системи протягом періоду часу

No: 2

Name: ac_17_9_odp

Type: integer

Default: 30

Визначено період часу, протягом якого потрібно відключити або деактивувати віддалений доступ до системи

1.17.10. (10) АВТЕНТИФІКАЦІЯ ВІДДАЛЕНИХ КОМАНД (АС-17(10))

No: 1

Name: ac_17_10_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначені механізми аутентифікації- ють визначені віддалені команди

No: 2

Name: ac_17_10_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено механізми, реалізовані для автентифікації віддалених команд

No: 3

Name: ac_17_10_odp_02

Type: string

Default: nil

Визначено віддалені команди, які мають бути автентифіковані механізмами

1.18. БЕЗДРОТОВИЙ ДОСТУП (АС-18)

а. Установити обмеження на використання, вимоги до конфігурації/підключення та рекомендації щодо здійснення бездротового доступу.

б. Авторизувати бездротовий доступ до системи, перш ніж будуть дозволені такі підключення.

No: 1

Name: ac_18_a_01

Type: string

Default: nil

Встановлено обмеження на використання щодо здійснення бездротового доступу

No: 2

Name: ac_18_a_02

Type: string

Default: nil

Встановлено вимоги до конфігурації або підключення щодо здійснення бездротового доступу

No: 3

Name: ac_18_a_03

Type: string

Default: nil

Встановлено доступу

No: 4

Name: ac_18_b

Type: string

Default: nil

Авторизується бездротовий доступ до системи перед тим, як дозволяти такі з'єднання. рекомендації щодо здійснення бездротового

1.18.1. АВТЕНТИФІКАЦІЯ ТА ШИФРУВАННЯ (АС-18(1))

No: 1

Name: ac_18_1_02

Type: string

Default: "AES-256-GCM"

Бездротовий доступ до системи захищений за допомогою шифрування

1.18.2. БЕЗДРОТОВИЙ ПІДКЛЮЧЕНЬ (АС-18(2))

No: 1

Name: ac_18_2_01

Type: string

Default: nil

БЕЗДРОТОВИЙ ПІДКЛЮЧЕНЬ ДОСТУП - МОНИТОРИНГ НЕАВТОРИЗОВАНИХ [Вилучено: Включено в SI-04]

1.18.3. ВІДКЛЮЧЕННЯ БЕЗДРОТОВОЇ МЕРЕЖІ (АС-18(3))

No: 1

Name: ac_18_3_01

Type: string

Default: nil

Відключено, у разі відсутності необхідності у використанні, вбудовані в компоненти системи можливості бездротових мереж до їх виклику та розгортання

1.18.4. БЕЗДРОТОВИЙ ДОСТУП СТУВАЧАМИ (АС-18(4))

No: 1

Name: ac_18_4_01

Type: string

Default: nil

Встановлено користувачів, яким дозволено самостійно налаштовувати можливості бездротової мережі

No: 2

Name: ac_18_4_02

Type: string

Default: nil

Явно авторизуються визначені користувачі, яким дозволено самостійно налаштовувати можливості бездротової мережі

1.18.5. АНТЕНИ ТА РІВЕНЬ ПОТУЖНОСТІ ПЕРЕДАЧІ (АС-18(5))

No: 1

Name: ac_18_5_01

Type: string

Default: nil

Вибрано такі радіо антени, які зменшують ймовірність того, що корисні сигнали можуть прийматися за межами контрольованих організацією меж

No: 2

Name: ac_18_5_02

Type: string

Default: nil

Калібруються рівні потужності передачі, щоб зменшити ймовірність того, що корисні сигнали можуть прийматися за контрольованими організацією межами

1.19. КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ (АС-19)

а. Встановити обмеження на використання, вимоги до конфігурації, вимоги до підключення і рекомендації щодо впровадження мобільних пристроїв, контрольованих організацією.

б. Авторизувати підключення мобільних пристроїв до систем, які експлуатуються організацією.

No: 1

Name: ac_19_a_01

Type: string

Default: nil

Встановлено вимоги до конфігурації мобільних пристроїв, що контролюються організацією, в тому числі, коли такі пристрої перебувають за межами контрольованої території

No: 2

Name: ac_19_a_02

Type: string

Default: nil

Встановлюються вимоги до підключення для мобільних пристроїв, що контролюються організацією, в тому числі, коли такі пристрої знаходяться за межами контрольованої території

No: 3

Name: ac_19_a_03

Type: string

Default: nil

Розроблено рекомендації щодо впровадження для мобільних пристроїв, які контролюються організацією, в тому числі, коли такі пристрої перебувають за межами контрольованої території

No: 4

Name: ac_19_b

Type: string

Default: nil

Авторизовано підключення мобільних пристроїв до систем організації

1.19.1. ВИКОРИСТАННЯ ПИСЬМОВИХ ТА ПОРТАТИВНИЙ ПРИБОРІВ ДЛЯ ЗБЕРІГАННЯ ДАНИХ (АС-19(1))

No: 1
 Name: ac_19_1_01
 Type: string
 Default: nil

КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИБОРІВ - ВИКОРИСТАННЯ ПИСЬМОВИХ ТА ПОРТАТИВНИЙ ПРИБОРІВ ДЛЯ ЗБЕРІГАННЯ ДАНИХ [Вилучено: Включено в МР-07]

1.19.2. ВИКОРИСТАННЯ ПЕРСОНАЛЬНИХ ПОРТАТИВНИХ ПРИБОРІВ ЗБЕРІГАННЯ ДАНИХ (АС-19(2))

No: 1
 Name: ac_19_2_01
 Type: list
 Default: ["admin", "security_officer"]

КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИБОРІВ - ВИКОРИСТАННЯ ПЕРСОНАЛЬНИХ ПОРТАТИВНИХ ПРИБОРІВ ЗБЕРІГАННЯ ДАНИХ [Вилучено: Включено в МР-07]. АС-19(03) КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИБОРІВ - ВИКОРИСТАННЯ ПОРТАТИВНИХ ПРИБОРІВ ЗБЕРІГАННЯ ДАНИХ З НЕІДЕНТИФІКОВАНИМ ВЛАСНИКОМ [Вилучено: Включено в МР-07]

1.19.3. ВИКОРИСТАННЯ ПОРТАТИВНИХ ПРИБОРІВ ЗБЕРІГАННЯ ДАНИХ З НЕІДЕНТИФІКОВАНИМ ВЛАСНИКОМ (АС-19(3))

Немає параметрів для цього контролю.

1.19.4. ОБМЕЖЕННЯ ДЛЯ ЗАСЕКРЕЧЕНОЇ ІНФОРМАЦІЇ (АС-19(4))

No: 1
 Name: ac_19_4_a
 Type: list
 Default: ["admin", "security_officer"]

Використання незахищених мобільних пристроїв на об'єктах, що містять системи, які обробляють, зберігають або передають секретну інформацію, заборонено, за винятком випадків, коли на це є спеціальний дозвіл уповноваженої посадової особи; АС-19(04)(b)(01) заборона підключення незахищених мобільних пристроїв до систем з обмеженим доступом застосовується до осіб, яким уповноважена посадова особа дозволила використовувати незахищені мобільні пристрої на об'єктах, що містять системи, які обробляють, зберігають або передають інформацію з обмеженим доступом; АС-19(04)(b)(02) дозвіл уповноваженої посадової особи на підключення незахищених мобільних пристроїв до незахищених систем вимагається від осіб, яким дозволено використовувати незахищені мобільні пристрої на об'єктах, що містять системи, які обробляють, зберігають або передають інформацію з обмеженим доступом; АС-19(04)(b)(03) заборона використання внутрішніх або зовнішніх модемів чи бездротових інтерфейсів у складі незахищених мобільних пристроїв поширюється на осіб, яким уповноваженою посадовою особою дозволено використовувати незахищені мобільні пристрої під час виконання службових обов'язків, а також на осіб, які не мають права на використання таких пристроїв АС-19(04)(b)(04)[01] вибіркового огляд та перевірка незахищених мобільних пристроїв та інформації, що зберігається

на них, посадовими особами є обов'язковими; АС-19(04)(b)(04)[02] дотримання політики обробки інцидентів застосовується у разі виявлення секретної інформації під час випадкового огляду та перевірки незахищених мобільних пристроїв

No: 2

Name: ac_19_4_c

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Підключення захищених мобільних пристроїв до засекречених систем обмежено відповідно до політики безпеки

No: 3

Name: ac_19_4_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено посадових осіб із захисту інформації, відповідальних за огляд та перевірку захищених мобільних пристроїв та інформації, що зберігається на цих пристроях

No: 4

Name: ac_19_4_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політики безпеки, що обмежують підключення захищених мобільних пристроїв до засекречених систем

1.19.5. ПОВНЕ ШИФРУВАННЯ ПРИСТРОЇВ ТА СХОВИЩ ІНФОРМАЦІЇ (АС-19(5))

Немає параметрів для цього контролю.

1.20. ВИКОРИСТАННЯ ЗОВНІШНІХ СИСТЕМ (АС-20)

а. [Вибір (один або кілька): Встановіть [Призначення: умови, визначені організацією]; Визначте [Призначення: визначені організацією засоби контролю, які, як стверджується, будуть реалізовані на зовнішніх системах]], узгоджені з довірчими відносинами, встановленими з іншими організаціями, які володіють, експлуатують та/або обслуговують зовнішні системи, дозволяючи уповноваженим особам:

1. доступ до системи із зовнішніх систем;

2. обробляти, зберігати або передавати керовану організацією інформацію за допомогою зовнішніх систем;

б. Заборонити використання [Призначення: організаційно-визначені типи зовнішніх систем].

No: 1

Name: ac_20_odp_01

Type: list

Default: []

Вибрано одне або більше з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {встановити умови та положення; визначити заходи захисту}

No: 2

Name: ac_20_odp_02

Type: list

Default: []

Визначено умови та положення, що відповідають довірчим відносинам, встановленим з іншими організаціями, які володіють, експлуатують та/або обслуговують зовнішні системи (якщо вибрано)

No: 3

Name: ac_20_odp_03

Type: string

Default: nil

Визначено заходи захисту, які мають бути застосовані до зовнішніх систем відповідно до довірчих відносин, встановлених з іншими організаціями, що володіють, експлуатують та/або обслуговують зовнішні системи (якщо обрано)

No: 4

Name: ac_20_odp_04

Type: string

Default: nil

Визначено типи зовнішніх систем, заборонених до використання

1.20.1. ОБМЕЖЕННЯ НА АВТОРИЗОВАНЕ ВИКОРИСТАННЯ (AC-20(1))

No: 1

Name: ac_20_1_a

Type: list

Default: ["admin", "security_officer"]

Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після перевірки виконання заходів безпеки та конфіденційності, зазначених у політиці безпеки та конфіденційності організації, а також планів безпеки та конфіденційності (якщо такі застосовуються)

No: 2

Name: ac_20_1_b

Type: list

Default: ["admin", "security_officer"]

Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після збереження погоджених угод про підключення або обробку системи з структурою організації, на якій розміщена зовнішня система

1.20.2. ПЕРЕНОСНІ ПРИСТРОЇ ЗБЕРІГАННЯ ДАНИХ (AC-20(2))

No: 1

Name: ac_20_2_01

Type: list

Default: ["admin", "security_officer"]

Використання портативних пристроїв носіїв інформації уповноваженими особами обмежено у зовнішніх системах за допомогою обмеження

No: 2

Name: ac_20_2_odp

Type: list

Default: ["admin", "security_officer"]

Визначено обмеження на використання авторизованими особами портативних носіїв інформації у зовнішніх системах

1.20.3. СИСТЕМИ ТА КОМПОНЕНТИ, ЩО НЕ ЗНАХОДЯТЬСЯ У ВЛАСНОСТІ ОРГАНІЗАЦІЇ (АС-20(3))

No: 1

Name: ac_20_3_01

Type: string

Default: nil

Використання систем або компонентів систем, що не належать організації, для обробки, зберігання або передачі інформації, що належить організації, обмежується за допомогою обмеження

No: 2

Name: ac_20_3_odp

Type: string

Default: nil

Визначено обмеження на використання систем або компонентів систем, що не належать організації, для обробки, зберігання або передачі інформації організації

1.20.4. ПРИСТРОЇ ДЛЯ ЗБЕРІГАННЯ ДАНИХ, ЯКІ МОЖУТЬ МАТИ ДОСТУП ДО МЕРЕЖІ (АС-20(4))

No: 1

Name: ac_20_4_b

Type: string

Default: nil

Заборонено використання заборонені типи зовнішніх систем (якщо застосовно)

1.20.5. ПОРТАТИВНІ ПРИСТРОЇ ДЛЯ ЗБЕРІГАННЯ ДАНИХ – ЗАБОРОНА ВИКОРИСТАННЯ (АС-20(5))

No: 1

Name: ac_20_5_01

Type: list

Default: ["admin", "security_officer"]

Використання уповноваженими особами зовнішніх носіїв інформації, підконтрольних організації, на зовнішніх системах заборонено

1.21. РОЗПОВСЮДЖЕННЯ ІНФОРМАЦІЇ (АС-21)

а. Спростити обмін інформацією, надаючи авторизованим користувачам змогу визначати, чи відповідають повноваженням на доступ, що призначені партнерам для обміну, обмеженням доступу та повноваженням з приватності щодо інформації для [Призначення: визначених організацією обставин обміну інформацією, коли це необхідно користувачу].

б. Використовувати [Призначення: визначені організацією автоматизовані механізми або ручні процеси], щоб допомогти користувачам в ухваленні рішень щодо обміну інформацією та співпраці.

No: 1
 Name: ac_21_a
 Type: string
 Default: nil

Авторизованим користувачам дозволено визначати, чи відповідають повноваження доступу, призначені партнеру з обміну, обмеженням доступу та використання інформації для обставин обміну інформацією

No: 2
 Name: ac_21_b
 Type: string
 Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для допомоги користувачам у прийнятті рішень щодо обміну інформацією та співпраці

No: 3
 Name: ac_21_odp_01
 Type: string
 Default: nil

Визначені обставини обміну інформацією, за яких користувач повинен на власний розсуд визначати, чи відповідають повноваження доступу, надані партнеру з обміну, обмеженням доступу та використання інформації

No: 4
 Name: ac_21_odp_02
 Type: string
 Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми або ручні процеси, які допомагають користувачам у ухваленні рішень щодо обміну інформацією та співпраці

1.21.1. АВТОМАТИЧНА ПІДТРИМКА УХВАЛЕННЯ РІШЕНЬ (АС-21(1))

No: 1
 Name: ac_21_1_01
 Type: string
 Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для забезпечення виконання рішень щодо обміну інформацією уповноваженими користувачами на основі дозволів доступу партнерів з обміну та обмежень доступу до інформації, що підлягає обміну

No: 2
 Name: ac_21_1_odp
 Type: string
 Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що застосовуються для забезпечення виконання рішень про спільний доступ до інформації авторизованими користувачами

1.21.2. РОЗПОВСЮДЖЕННЯ ІНФОРМАЦІЇ (АС-21(2))

No: 1
 Name: ac_21_2_01
 Type: string
 Default: nil

Впроваджено сервіси пошуку та перевірки інформації, які застосовують е обмеження щодо обміну інформацією

No: 2

Name: ac_21_2_odp

Type: string

Default: nil

Визначено обмеження щодо обміну інформацією

1.22. ПУБЛІЧНО ДОСТУПНИЙ КОНТЕНТ (АС-22)

- a. Призначити осіб, що уповноважені на розміщення інформації в загальнодоступній системі.
- b. Навчати уповноважених осіб тому, щоб загальнодоступна інформація не містила інформацію з обмеженим доступом.
- c. Переглядати запропонований зміст інформації до публікації в загальнодоступній системі, щоб гарантувати, що там не міститься інформація з обмеженим доступом.
- d. Переглядати вміст загальнодоступної системи на предмет наявності там інформації з обмеженим доступом з [Призначення: визначеною організацією частотою]; така інформація має бути видалена в разі її виявлення.

No: 1

Name: ac_22_a

Type: list

Default: ["admin", "security_officer"]

Визначені особи уповноважені на розміщення інформації в загальнодоступній системі

No: 2

Name: ac_22_b

Type: list

Default: ["admin", "security_officer"]

Уповноважені особи проходять навчання, щоб гарантувати, що загальнодоступна інформація не містить інформацію з обмеженим доступом

No: 3

Name: ac_22_c

Type: string

Default: nil

Запропонований зміст інформації перевіряється до публікації в загальнодоступній системі, щоб гарантувати, що там не міститься інформація з обмеженим доступом

No: 4

Name: ac_22_d_01

Type: integer

Default: 30

Зміст у загальнодоступній системі перевіряється на наявність інформації з обмеженим доступом з частотою

No: 5

Name: ac_22_d_02

Type: string

Default: nil

Інформація з обмеженим доступом видаляється з загальнодоступної системи, якщо її виявлено

No: 6

Name: ac_22_odp

Type: integer

Default: 30

Визначено частоту, з якою слід переглядати вміст загальнодоступної системи на предмет наявності там інформації з обмеженим доступом

1.23. ЗАХИСТ ВІД НЕСАНКЦІОНОВАНОГО ІНТЕЛЕКТУАЛЬНОГО АНАЛІЗУ ДАНИХ (АС-23)

Використовувати [Призначення: визначені організацією техніки виявлення та попередження витоку даних] для [Призначення: визначених організацією об'єктів зберігання даних] для виявлення та захисту від несанкціонованого інтелектуального аналізу даних.

No: 1

Name: ac_23_01

Type: string

Default: "автоматизований засіб моніторингу"

Техніки використовуються для об'єктів зберігання даних для виявлення та захисту від несанкціонованого інтелектуального аналізу даних

No: 2

Name: ac_23_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено техніки виявлення та попередження витоку даних

No: 3

Name: ac_23_odp_02

Type: string

Default: nil

Визначено об'єкти зберігання даних

1.24. РІШЕННЯ ЩОДО УПРАВЛІННЯ ДОСТУПОМ (АС-24)

[Вибір: Встановити процедури; Запровадити механізми], щоб забезпечити застосування [Призначення: визначені організацією рішення щодо контролю доступу] до кожного запиту щодо доступу до виконання доступу.

No: 1

Name: ac_24_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {встановити процедури; запровадити механізми}

No: 2

Name: ac_24_odp_02

Type: string

Default: nil

Визначено рішення щодо контролю доступу, які застосовуються до кожного запиту щодо доступу до виконання доступу

1.24.1. ІНФОРМАЦІЯ ПРО ПЕРЕДАЧУ АВТОРИЗОВАНОГО ДОСТУПУ (АС-24(1))

No: 1

Name: ac_24_1_01

Type: string

Default: nil

Інформація щодо авторизації доступу передається за допомогою заходів безпеки до систем, які забезпечують ухвалення рішень щодо управління доступом. ухвалення

No: 2

Name: ac_24_1_odp_01

Type: string

Default: nil

Визначено інформацію щодо авторизації доступу, яка передається до систем, які забезпечують ухвалення рішень щодо управління доступом

No: 3

Name: ac_24_1_odp_02

Type: string

Default: nil

Визначено заходи безпеки, які слід використовувати, коли інформація про авторизацію передається до систем, що забезпечують виконання рішень щодо управління доступом

No: 4

Name: ac_24_1_odp_03

Type: string

Default: nil

Визначено системи, які забезпечують рішення щодо управління доступом

1.24.2. ВІДСУТНІСТЬ ІДЕНТИФІКАЦІЇ КОРИСТУВАЧА АБО ПРОЦЕСУ, ЩО ДІЄ ВІД ІМЕНІ КОРИСТУВАЧА (АС-24(2))

Здійснювати ухвалення рішень щодо управління доступом, засновуючись на [Призначення: визначених організацією атрибутах безпеки], які не охоплюють ідентифікацію користувача або процесу, що діє від імені користувача.

No: 1

Name: ac_24_2_01

Type: string

Default: nil

Рішення щодо управління доступом здійснюються на основі атрибутів безпеки, які не охоплюють ідентифікацію користувача або процесу, що діє від імені користувача (якщо вибрано)

No: 2

Name: ac_24_2_02

Type: string

Default: nil

Рішення щодо управління доступом здійснюються на основі атрибутів конфіденційності, які не охоплюють ідентифікацію користувача або процесу, що діє від імені користувача (якщо вибрано)

No: 3

Name: ac_24_2_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено атрибути безпеки, які не охоплюють ідентифікацію користувача або процесу, що діє від імені користувача (якщо вибрано)

No: 4

Name: ac_24_2_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено атрибути конфіденційності, які не охоплюють ідентифікацію користувача або процесу, що діє від імені користувача (якщо вибрано)

1.25. ДИСПЕТЧЕР ДОСТУПУ (АС-25)

Впровадити диспетчер доступу для [Призначення: визначеної організацією політики контролю доступу], який захищений від несанкціонованого доступу, завжди був доступний для виклику та досить компактний, щоб бути підданим аналізу й тестуванню, надійність якого може бути гарантована.

No: 1

Name: ac_25_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Реалізовано диспетчер доступу для політики контролю доступу, який захищений від несанкціонованого доступу, завжди доступний для виклику та досить компактний, щоб бути підданим аналізу й тестуванню, надійність якого може бути гарантована

No: 2

Name: ac_25_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політики контролю доступу, для яких реалізовано диспетчер доступу

2. АТ

Клас заходів захисту АТ — ОБІЗНАНІСТЬ ТА НАВЧАННЯ

Цей клас спрямований на забезпечення належного рівня знань персоналу щодо загроз інформаційній безпеці та їхніх обов'язків у цій сфері.

Перелік заходів захисту: Політика та процедури підвищення обізнаності та навчання (АТ-1); Навчання з підвищення обізнаності (АТ-2); НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ | НАВЧАННЯ ЩОДО РОЗПІЗНАВАННЯ ВНУТРІШНЬОЇ ЗАГРОЗИ; НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ | НАВЧАННЯ З ПИТАНЬ СОЦІАЛЬНОЇ ІНЖЕНЕРІЇ; Рольове навчання (АТ-3); Забезпечується підвищенням кваліфікації в галузі зайнятості та функціонування заходів захисту робочого середовища з (АТ-3(1)); Забезпечуються підготовкою

з питань застосування та експлуатації заходів (АТ-3(2)); Навчальні записи (АТ-4); Контакти з групами безпеки та асоціаціями (АТ-5); Відгуки про проведені навчання (АТ-6).

2.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ПІДВИЩЕННЯ ОБІЗНАНОСТІ ТА НАВЧАННЯ (АТ-1)

а. Розробити, задокументувати та поширити [Призначення: серед визначеного організацією персоналу або ролей]:

1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політики обізнаності та навчання у сфері забезпечення безпеки та приватності, яка:

(а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance);

(b) відповідає чинним законам, нормативним документам, директивам, нормам, політикам, стандартам та керівним документам.

2. Процедури, що сприяють реалізації політики підвищення обізнаності та професійної підготовки в галузі безпеки, приватності, а також пов'язаних з ними заходів захисту інформації та персональних даних.

б. Призначити [Призначення: визначену організацією посадову особу] для управління політикою та процедурами підвищення обізнаності та навчання у сфері забезпечення безпеки та приватності.

с. Переглядати та оновлювати:

1. Поточну політику [Призначення: частота, визначена організацією] і наступне [Призначення: події, визначені організацією];

2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].

Немає параметрів для цього контролю.

2.2. НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ (АТ-2)

Впровадити базові тренінги з підвищення обізнаності у сфері безпеки та приватності для користувачів системи (включно з менеджерами, керівниками компаній і підрядниками):

а. Забезпечити навчання грамотності з питань безпеки та конфіденційності для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників):

1. як частину початкового навчання для нових користувачів і [Призначення: частота, визначена організацією] після цього;

2. якщо цього потребують системні зміни або наступні [Призначення: події, визначені організацією].

б. Використовувати наведені нижче методи, щоб підвищити рівень безпеки та конфіденційності користувачів системи [Завдання: визначені організацією методи поінформованості];

с. Оновлювати навчання грамотності та зміст обізнаності [Завдання: частота, визначена організацією] і наступні [Завдання: події, визначені організацією];

д. Включити уроки, отримані з внутрішніх або зовнішніх інцидентів безпеки або порушень, у навчання грамотності та методи підвищення обізнаності.

No: 1

Name: at_2_b

Type: string

Default: nil

Методи застосовуються для підвищення обізнаності користувачів системи щодо безпеки та конфіденційності

No: 2

Name: at_2_c_01

Type: integer

Default: 30

Оновлюється зміст навчання грамотності та підвищення обізнаності з частотою

No: 3

Name: at_2_c_02

Type: string

Default: nil

Оновлюється зміст навчання грамотності та підвищення обізнаності після подій

No: 4

Name: at_2_d

Type: string

Default: nil

Уроки, отримані в результаті внутрішніх або зовнішніх інцидентів або порушень безпеки, включені в методи навчання та підвищення обізнаності

No: 5

Name: at_2_odp_01

Type: string

Default: "щорічно"

Визначено періодичність проведення навчання грамотності з питань безпеки для користувачів системи (в тому числі менеджерів, вищого керівництва та підрядників) після початкового тренінгу

No: 6

Name: at_2_odp_02

Type: string

Default: "щорічно"

Визначено періодичність проведення навчання грамотності з питань конфіденційності для користувачів системи (в тому числі менеджерів, вищого керівництва та підрядників) після початкового тренінгу

No: 7

Name: at_2_odp_03

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують навчання користувачів системи грамотності з питань безпеки

No: 8

Name: at_2_odp_05

Type: string

Default: nil

Визначено методи, які слід застосовувати для підвищення обізнаності користувачів системи щодо безпеки та конфіденційності

No: 9

Name: at_2_odp_06

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено частоту оновлення навчання грамотності та змісту обізнаності; AT-02_ODP[07] визначено події після яких необхідне оновлення навчання грамотності та змісту обізнаності; AT-02(a)[01][01] навчання з грамотності з питань безпеки надається користувачам системи (включаючи менеджерів, керівників вищої ланки та підрядників) як частина початкового навчання для нових користувачів; AT-02(a)[01][02] навчання з

грамотності з питань конфіденційності надається користувачам системи (включаючи менеджерів, керівників вищої ланки та підрядників) як частина початкового навчання для нових користувачів; AT-02(a)[01][03] для користувачів системи (включно з менеджерами, вищим керівництвом та підрядниками) проводиться навчання з безпеки з періодичністю після цього; AT-02(a)[01][04] для користувачів системи (включно з менеджерами, вищим керівництвом та підрядниками) проводиться навчання з конфіденційності з періодичністю після цього; AT-02(a)[02][01] тренінги з грамотності з питань безпеки проводяться для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників), коли цього вимагають зміни в системі або після подій; AT-02(a)[02][02] тренінги з грамотності з питань конфіденційності проводяться для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників), коли цього вимагають зміни в системі або після подій

No: 10

Name: at_2_odp_4

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують навчання користувачів системи грамотності з питань конфіденційності

2.2.1. НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ | НАВЧАННЯ ЩОДО РОЗПІЗНАВАННЯ ВНУТРІШНЬОЇ ЗАГРОЗИ

Ввести до програми навчання вправи з розпізнавання та виявлення потенційних індикаторів внутрішніх загроз.

No: 1

Name: at_2_2_01

Type: string

Default: nil

Введено до програми навчання вправи з розпізнавання потенційних індикаторів внутрішніх загроз

No: 2

Name: at_2_2_02

Type: string

Default: nil

Введено до програми навчання вправи з виявлення потенційних індикаторів внутрішніх загроз

2.2.2. НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ | НАВЧАННЯ З ПИТАНЬ СОЦІАЛЬНОЇ ІНЖЕНЕРІЇ

Ввести до програми навчання вправи з підвищення обізнаності щодо розпізнавання та повідомлення про потенційні та фактичні атаки, з використанням методів соціальної інженерії та інтелектуального аналізу соціальних даних.

No: 1

Name: at_2_3_01

Type: string

Default: nil

До програми навчання введено вправи з розпізнавання потенційних та фактичних випадків соціального інжинірингу

No: 2

Name: at_2_3_02

Type: string

Default: nil

До програми навчання введено вправи з повідомлення про потенційні та фактичні випадки соціального інжинірингу

No: 3

Name: at_2_3_03

Type: string

Default: nil

До програми навчання введено вправи з розпізнавання потенційних та фактичних випадків інтелектуального аналізу соціальних даних

No: 4

Name: at_2_3_04

Type: string

Default: nil

До програми навчання введено вправи з повідомлення про потенційні та фактичні випадки інтелектуального аналізу соціальних даних

2.3. РОЛЬОВЕ НАВЧАННЯ (АТ-3)

а. Забезпечити проведення навчання з питань безпеки та приватності на основі ролей для працівників з ролями та обов'язками: [Призначення: визначені організацією ролі та обов'язки]:

1. перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків і [Призначення: частота, визначена організацією] після цього;

2. коли цього потребують системні зміни.

б. Оновити навчальний контент на основі ролей [Призначення: частота, визначена організацією] і наступні [Призначення: події, визначені організацією];

с. Включіть у рольове навчання, інформацію, отриману з внутрішніх або зовнішніх інцидентів та порушень безпеки.

No: 1

Name: at_3_b_01

Type: integer

Default: 30

Оновлюється вміст навчання на основі ролей з частотою

No: 2

Name: at_3_b_02

Type: string

Default: nil

Оновлюється вміст навчання на основі ролей після подій

No: 3

Name: at_3_c

Type: string

Default: nil

Інформація отримана з внутрішніх чи зовнішніх інцидентів або порушень безпеки, включається в навчання на основі ролей

No: 4

Name: at_3_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено ролі та обов'язки для тренінгів з безпеки на основі ролей

No: 5

Name: at_3_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено ролі та обов'язки для тренінгів з конфіденційності на основі ролей

No: 6

Name: at_3_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначено частоту проведення тренінгів на основі ролей з безпеки та конфіденційності для призначеного персоналу після початкової підготовки

No: 7

Name: at_3_odp_04

Type: integer

Default: 30

Визначено частоту оновлення змісту навчання на основі ролей

No: 8

Name: at_3_odp_05

Type: list

Default: ["admin", "security_officer"]

Визначено події, які потребують оновлення змісту навчання на основі ролей; AT-03(a)[01][01] навчання з безпеки на основі ролей проводиться для ролей та обов'язків перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків; AT-03(a)[01][02] навчання з конфіденційності на основі ролей проводиться для ролей та обов'язків перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків; AT-03(a)[01][03] навчання з безпеки на основі ролей проводиться для ролей та обов'язків з частотою після цього; AT-03(a)[01][04] навчання з конфіденційності на основі ролей проводиться для ролей та обов'язків з частотою після цього; AT-03(a)[02][01] навчання з питань безпеки на основі ролей проводиться для персоналу, який виконує певні ролі та обов'язки у сфері безпеки, коли цього вимагають зміни в системі; AT-03(a)[02][02] навчання з питань конфіденційності на основі ролей проводиться для персоналу, який виконує певні ролі та обов'язки у сфері безпеки, коли цього вимагають зміни в системі

2.3.1. ЗАБЕЗПЕЧУЄТЬСЯ ПІДВИЩЕННЯМ КВАЛІФІКАЦІЙ В ГАЛУЗІ ЗАЙНЯТОСТІ ТА ФУНКЦІОНУВАННЯ ЗАХОДІВ ЗАХИСТУ РОБОЧОГО СЕРЕДОВИЩА З (АТ-3(1))

No: 1

Name: at_3_1_01

Type: list

Default: ["admin", "security_officer"]

Персонал або ролі забезпечується підвищенням кваліфікації в галузі зайнятості та функціонування заходів захисту робочого середовища з частотою

No: 2

Name: at_3_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які мають бути забезпечені початковим навчанням та підвищенням кваліфікації з питань застосування та експлуатації заходів захисту робочого середовища

No: 3

Name: at_3_1_odp_02

Type: integer

Default: 30

Визначено частоту проведення підвищення кваліфікації в галузі операцій та функціонування заходів захисту робочого середовища

2.3.2. ЗАБЕЗПЕЧУЮТЬСЯ ПІДГОТОВКОЮ З ПИТАНЬ ЗАСТОСУВАННЯ ТА ЕКСПЛУАТАЦІЇ ЗАХОДІВ (АТ-3(2))

Надати [Призначення: визначеним організацією персоналу чи ролям] з початку роботи та з [Призначення: визначеною організацією частотою] підготовку з питань застосування та експлуатації заходів фізичної безпеки.

No: 1

Name: at_3_2_01

Type: list

Default: ["admin", "security_officer"]

Персонал або ролі забезпечуються підготовкою з питань застосування та експлуатації заходів фізичної безпеки з частотою

No: 2

Name: at_3_2_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначає персонал або ролі, які мають бути забезпечені підготовкою з питань застосування та експлуатації заходів фізичної безпеки

No: 3

Name: at_3_2_odp_02

Type: integer

Default: 30

Визначає частоту проведення підготовки з питань застосування та експлуатації заходів фізичної безпеки

2.4. НАВЧАЛЬНІ ЗАПИСИ (АТ-4)

а. Документувати та відстежувати індивідуальні навчальні заходи із забезпечення безпеки та приватності, включно з базовою підготовкою з питань безпеки та приватності, а також спеціальною підготовкою з питань безпеки та приватності визначених посадових осіб.

б. Зберігати індивідуальні записи про навчання впродовж [Призначення: визначеного організації періоду часу].

No: 1

Name: at_4_a_01

Type: string

Default: nil

Задokumentовані індивідуальні навчальні заходи із забезпечення безпеки та конфіденційності інформації, включно з базовою підготовкою з питань безпеки та конфіденційності, а також спеціальною підготовкою з безпеки та конфіденційності

No: 2
 Name: at_4_a_02
 Type: string
 Default: nil

Відстежуються індивідуальні навчальні заходи із забезпечення безпеки та конфіденційності інформації, включно з базовою підготовкою з питань безпеки та конфіденційності, а також спеціальною підготовкою з безпеки та конфіденційності

No: 3
 Name: at_4_b
 Type: integer
 Default: 30

Індивідуальні записи про навчання зберігаються протягом період часу

No: 4
 Name: at_4_odp
 Type: integer
 Default: 30

Визначено період зберігання індивідуальних записів про навчання

2.5. КОНТАКТИ З ГРУПАМИ БЕЗПЕКИ ТА АСОЦІАЦІЯМИ (АТ-5)

No: 1
 Name: at_5_01
 Type: string
 Default: nil

КОНТАКТИ З ГРУПАМИ БЕЗПЕКИ ТА АСОЦІАЦІЯМИ Вилучено: включено в РМ-15

2.6. ВІДГУКИ ПРО ПРОВЕДЕНІ НАВЧАННЯ (АТ-6)

Надати відгук про результати організаційного навчання наступному персоналу [Призначення: з визначеною організацією частотою та визначеному організації персоналу]

No: 1
 Name: at_6_01
 Type: list
 Default: ["admin", "security_officer"]

Відгуки про результати навчання надаються з визначеною частотою до персоналу

No: 2
 Name: at_6_odp_01
 Type: integer
 Default: 30

Визначено частоту надання відгуків щодо результатів навчання в організації

No: 3
 Name: at_6_odp_02
 Type: list
 Default: ["admin", "security_officer"]

Призначено персонал, якому надаватиметься відгуки щодо результатів навчання в організації

3. AU

Клас заходів захисту AU — АУДИТ ТА ПІДЗВІТНІСТЬ

Цей клас забезпечує можливість відстеження дій у системі, генерування, захист та аналіз записів аудиту для виявлення порушень політики безпеки.

Перелік заходів захисту: Політика та процедури аудиту та підзвітності (AU-1); Події аудиту (AU-2); Узагальнення записів про аудит з декількох джерел (AU-2(1)); Вибір події аудиту за компонентами (AU-2(2)); Перегляд та оновлення (AU-2(3)); Привілейовані функції (AU-2(4)); Зміст записів аудиту (AU-3); Додаткова інформація про аудит (AU-3(1)); Централізоване управління планованим змістом записів аудиту (AU-3(2)); Обмеження елементів персональних даних (AU-3(3)); Місткість сховища записів аудиту (AU-4); Передача до альтернативного сховища (AU-4(1)); Реагування на відмови обробки даних аудиту (AU-5); Місткість сховища записів аудиту (AU-5(1)); Тривожне сповіщення в реальному часі (AU-5(2)); Налаштування порогового обсягу трафіку (AU-5(3)); Вимкнення у разі відмови (AU-5(4)); Можливість альтернативного журналювання аудиту (AU-5(5)); Огляд, аналіз і звітність аудиту (AU-6); Автоматизована інтеграція процесів (AU-6(1)); Огляд, аналіз і звітність аудиту сповіщення про порушення безпеки (AU-6(2)); Зіставлення сховищ аудиту (AU-6(3)); Централізований перегляд та аналіз (AU-6(4)); Інтегрований аналіз записів аудиту (AU-6(5)); Кореляція з фізичним моніторингом (AU-6(6)); Дозволені дії (AU-6(7)); Аналіз повного тексту привілейованих команд (AU-6(8)); Регулювання рівня аудиту (AU-6(10)); Скорочення записів аудиту та формування звіту (AU-7); Автоматична обробка (AU-7(1)); Автоматичне сортування та пошук (AU-7(2)); Позначка часу (AU-8); Синхронізація з авторитетним джерелом часу (AU-8(1)); Вторинне авторитетне джерело часу (AU-8(2)); Захист інформації аудиту (AU-9); Апаратні носії інформації одноразового запису (AU-9(1)); Зберігання на окремих фізичних системах або компонентах (AU-9(2)); Криптографічний захист (AU-9(3)); Доступ, який надається через членство в підмножині привілейованих користувачів (AU-9(4)); Подвійна авторизація (AU-9(5)); Доступ тільки для читання (AU-9(6)); Зберігання на компоненті іншої операційної системи (AU-9(7)); Неспростовність (AU-10); Асоціація ідентичності (AU-10(1)); Ратифікація прив'язки інформації про ідентичність виробника (AU-10(2)); Ланцюжок збереження доказів (AU-10(3)); Валідація зв'язку ідентичності перегляда (AU-10(4)); Цифрові підписи (AU-10(5)); Збереження записів аудиту (AU-11); Довгострокова можливість отримання (AU-11(1)); Генерація даних аудиту (AU-12); Загальносистемний та синхронізований за часом журналу аудиту (AU-12(1)); Стандартизовані формати (AU-12(2)); Зміни, що вносять авторизовані особи (AU-12(3)); Аудит запитів персональних даних (AU-12(4)); Моніторинг розкриття інформації (AU-13); Використання автоматичних засобів (AU-13(1)); Огляд сайтів, що підлягають моніторингу (AU-13(2)); Авторизоване копіювання інформації (AU-13(3)); Аудит сесії (AU-14); Система запуску (AU-14(1)); Захоплення та запис інформації (AU-14(2)); Віддалений перегляд та прослуховування (AU-14(3)); Альтернативна можливість аудиту (AU-15); Міжорганізаційний аудит (AU-16); Збереження ідентичності (AU-16(1)); Обмін інформацією аудиту (AU-16(2)); Розмежування (AU-16(3)).

3.1. Політика та процедури аудиту та підзвітності (AU-1)

а. Розробити, задокументувати та поширити [Призначення: серед персоналу або ролей, що їх визначила організація]:

1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи]

політика аудиту та підзвітності, яка:

- (a) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance);
- (b) відповідає чинним законам, нормативним документам, директивам, нормам, політикам, стандартам та керівним документам.

2. Процедури, що сприяють здійсненню політики аудиту та підзвітності, а також пов'язані з ними заходи аудиту та підзвітності.

b. Призначити [Призначення: визначену організацією старшу посадову особу] для управління політикою та процедурами аудиту та підзвітності.

c. Переглядати та оновлювати поточний аудит та підзвітність:

1. політику [Призначення: частота, визначена організацією] та наступне [Призначення: події, визначені організацією];

2. процедури аудиту [Призначення: визначеною організацією частотою] та [Завдання: події, визначені організацією].

No: 1

Name: au_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику аудиту та підзвітності

No: 2

Name: au_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика аудиту та підзвітності доведена до персоналу або ролі

No: 3

Name: au_1_a_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблені та задокументовані процедури аудиту та підзвітності, що сприяють впровадженню політики аудиту та підзвітності, а також відповідні заходи контролю аудиту та підзвітності

No: 4

Name: au_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління політикою та процедурами аудиту та підзвітності AU-01(c)[01][01] переглядається та оновлюється поточна політика аудиту та підзвітності з частотою; AU-01(c)[01][02] переглядається та оновлюється поточна політика аудиту та підзвітності після подій; AU-01(c)[02][01] переглядається та оновлюється поточні процедури аудиту та підзвітності з частотою; AU-01(c)[02][02] переглядається та оновлюється поточні процедури аудиту та підзвітності після подій

No: 5

Name: au_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких має бути доведена політика аудиту та підзвітності

No: 6

Name: au_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури аудиту та підзвітності

No: 7

Name: au_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: au_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка управлятиме політикою та процедурами аудиту та підзвітності

No: 9

Name: au_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика аудиту та підзвітності

No: 10

Name: au_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, які потребують перегляду та оновлення поточної політики аудиту та підзвітності

No: 11

Name: au_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури аудиту та підзвітності

No: 12

Name: au_1_odp_08

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують перегляду та оновлення поточної процедури аудиту та підзвітності

3.2. ПОДІЇ АУДИТУ (AU-2)

- a. Визначити типи подій, які система може реєструвати для підтримки функції аудиту: [Призначення: типи подій, визначені організацією, які система здатна реєструвати];
- b. Координувати функції аудиту безпеки з іншими організаційними підрозділами, які вимагають інформації, пов'язаної з аудитом, для посилення взаємної підтримки та допомоги у виборі типів подій, що перевіряються;
- c. Визначити, які типи подій підлягають аудиту: [Призначення: визначені організацією події, що підлягають аудиту (підмножина подій, що підлягають аудиту, визначених в AU-2 а.), а також частота (або ситуація, що вимагає) проведення аудиту для кожної ідентифікованої події];
- d. Обґрунтувати, чому типи подій, що перевіряються, вважаються достатніми для підтримки розслідувань інцидентів (постфактум), пов'язаних з безпекою та приватністю;
- e. Перегляньте й оновіть типи подій, вибрані для журналювання [Призначення: частота, визначена організацією].

No: 1

Name: au_2_a

Type: string

Default: nil

Типи подій, які система здатна реєструвати, визначено для підтримки функції аудиту

No: 2

Name: au_2_b

Type: string

Default: nil

Функція аудиту безпеки координується з іншими підрозділами організації, які вимагають інформації, пов'язаної з аудитом, для посилення взаємної підтримки та допомоги у виборі типів подій, що перевіряються

No: 3

Name: au_2_c_01

Type: string

Default: nil

Типи подій (підмножина 02_ODP[01]) визначаються для реєстрації у системі; AU-

No: 4

Name: au_2_c_02

Type: string

Default: "щорічно"

Зазначені типи подій реєструються 02_ODP[03] частота або ситуація>; <AU-

No: 5

Name: au_2_d

Type: string

Default: nil

Надається обґрунтування, чому типи подій, що перевіряються, вважаються достатніми для підтримки розслідувань інцидентів (постфактум), пов'язаних з безпекою та конфіденційністю

No: 6

Name: au_2_e

Type: string

Default: "щорічно"

Переглядаються та оновлюються типи подій, вибрані для реєстрації, частота, у системі

No: 7

Name: au_2_odp_01

Type: string

Default: nil

Визначено типи подій, які система може реєструвати для підтримки функції аудиту

No: 8

Name: au_2_odp_02

Type: string

Default: nil

Визначено типи подій (підмножина AU-02_ODP[01]) що підлягають аудиту у системі

No: 9

Name: au_2_odp_03

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено частоту або ситуацію, що вимагає проведення аудиту для кожної ідентифікованої події

No: 10
 Name: au_2_odp_04
 Type: string
 Default: "щорічно"

Частота перегляду та оновлення типів подій, обраних для журналювання

3.2.1. УЗАГАЛЬНЕННЯ ЗАПИСІВ ПРО АУДИТ З ДЕКІЛЬКОХ ДЖЕРЕЛ (AU-2(1))

No: 1
 Name: au_2_1_01
 Type: list
 Default: ["login", "logout", "failed_attempt"]

ПОДІЇ АУДИТУ - УЗАГАЛЬНЕННЯ ЗАПИСІВ ПРО АУДИТ З ДЕКІЛЬКОХ ДЖЕРЕЛ [Вилучено: Включено в AU-12]. AU-02(02) ПОДІЇ АУДИТУ - ВИБІР ПОДІЇ АУДИТУ ЗА КОМПОНЕНТАМИ [Вилучено: Включено в AU-12]

3.2.2. ВИБІР ПОДІЇ АУДИТУ ЗА КОМПОНЕНТАМИ (AU-2(2))

Немає параметрів для цього контролю.

3.2.3. ПЕРЕГЛЯД ТА ОНОВЛЕННЯ (AU-2(3))

No: 1
 Name: au_2_3_01
 Type: list
 Default: ["login", "logout", "failed_attempt"]

ПОДІЇ АУДИТУ - ПЕРЕГЛЯД ТА ОНОВЛЕННЯ [Вилучено: Включено в AU-02]

3.2.4. ПРИВІЛЕЙОВАНІ ФУНКЦІЇ (AU-2(4))

No: 1
 Name: au_2_4_01
 Type: list
 Default: ["login", "logout", "failed_attempt"]

ПОДІЇ АУДИТУ - ПРИВІЛЕЙОВАНІ ФУНКЦІЇ [Вилучено: Включено в AC-06(09)]

3.3. ЗМІСТ ЗАПИСІВ АУДИТУ (AU-3)

Переконатися, що записи аудиту містять інформацію, яка встановлює наступне:

- який тип події стався;
- коли відбулася подія;
- де відбулася подія;
- джерело події;
- наслідки події;
- результат події та ідентифікатор будь-яких осіб або суб'єктів, пов'язаних з подією.

No: 1

Name: au_3_a

Type: list

Default: ["login", "logout", "failed_attempt"]

Записи аудиту містять інформацію, яка встановлює який тип події стався

No: 2

Name: au_3_b

Type: string

Default: nil

Записи аудиту містять інформацію, яка встановлює коли подія сталася

No: 3

Name: au_3_c

Type: string

Default: nil

Записи аудиту містять інформацію, яка встановлює де відбулася подія

No: 4

Name: au_3_d

Type: list

Default: ["login", "logout", "failed_attempt"]

Записи аудиту містять інформацію, яка встановлює джерело події

No: 5

Name: au_3_e

Type: list

Default: ["login", "logout", "failed_attempt"]

Записи аудиту містять інформацію, яка встановлює наслідки події

No: 6

Name: au_3_f

Type: list

Default: ["login", "logout", "failed_attempt"]

Записи аудиту містять інформацію, яка встановлює результат події та ідентифікатор будь-яких осіб або суб'єктів, пов'язаних з подією

3.3.1. ДОДАТКОВА ІНФОРМАЦІЯ ПРО АУДИТ (AU-3(1))

No: 1

Name: au_3_1_01

Type: string

Default: nil

ЗМІСТ ЗАПИСІВ АУДИТУ - ДОДАТКОВА ІНФОРМАЦІЯ ПРО АУДИТ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: au_3_1_0dp

Type: string

Default: nil

Визначено додаткову інформацію, яка має бути включена до записів аудиту

3.3.2. ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ ПЛАНОВАНИМ ЗМІСТОМ ЗАПИСІВ АУДИТУ (AU-3(2))

No: 1

Name: au_3_2_01

Type: string

Default: nil

ЗМІСТ ЗАПИСІВ АУДИТУ - ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ ПЛАНОВАНИМ ЗМІСТОМ ЗАПИСІВ АУДИТУ [Вилучено: Включено до PL-09]

3.3.3. ОБМЕЖЕННЯ ЕЛЕМЕНТІВ ПЕРСОНАЛЬНИХ ДАНИХ (AU-3(3))

Обмежити персональні дані, що міститься в записах аудиту, до таких елементів, які визначені в оцінці ризику приватності: [Призначення: визначені організацією елементи].

No: 1

Name: au_3_3_01

Type: list

Default: ["admin", "security_officer"]

Інформація, що ідентифікує особу, яка міститься в записах аудиту, обмежується елементами, визначеними в оцінці ризиків конфіденційності

No: 2

Name: au_3_3_odp

Type: string

Default: nil

Визначаються елементи, визначені конфіденційності; в оцінці ризику

3.4. МІСТКІСТЬ СХОВИЩА ЗАПИСІВ АУДИТУ (AU-4)

Розподіляти місткість сховища записів аудиту у відповідності до [Призначення: визначених організацією вимог до зберігання записів аудиту].

No: 1

Name: au_4_01

Type: string

Default: nil

Розподілено ємність для зберігання записів аудиту відповідно до вимог

No: 2

Name: au_4_odp

Type: string

Default: nil

Визначено вимоги до зберігання записів аудиту

3.4.1. ПЕРЕДАЧА ДО АЛЬТЕРНАТИВНОГО СХОВИЩА (AU-4(1))

No: 1

Name: au_4_1_01

Type: integer

Default: 30

Записи аудиту вивантажуються на іншу систему або носій інформації, з системи, що перевіряється, з частотою

No: 2

Name: au_4_1_odp

Type: integer

Default: 30

Визначено частоту завантаження записів аудиту на іншу систему чи носій інформації, з системи що перевіряється

3.5. РЕАГУВАННЯ НА ВІДМОВИ ОБРОБКИ ДАНИХ АУДИТУ (AU-5)

а. Сповіщати [Призначення: визначені організацією персонал або посади] у разі збою обробки даних аудиту в [Призначення: визначений організацією період часу].

б. Виконати наступні додаткові дії: [Призначення: визначені організацією дії, які необхідно зробити].

No: 1

Name: au_5_a

Type: list

Default: ["admin", "security_officer"]

Персонал або ролі отримують сповіщення у разі збою процесу обробки даних аудиту періоду часу

No: 2

Name: au_5_b

Type: list

Default: ["login", "logout", "failed_attempt"]

Додаткові дії виконуються у разі збою процесу обробки даних аудиту

No: 3

Name: au_5_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які отримують сповіщення про збої в процесі обробки даних аудиту

No: 4

Name: au_5_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено період часу, протягом якого персонал або ролі отримують сповіщення про збої в процесі обробки даних аудиту

No: 5

Name: au_5_odp_03

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено додаткові дії, яких слід вжити у випадку збою в процесі обробки даних аудиту

3.5.1. МІСТКІСТЬ СХОВИЩА ЗАПИСІВ АУДИТУ (AU-5(1))

No: 1

Name: au_5_1_01

Type: list

Default: ["admin", "security_officer"]

Попередження надається персоналу або ролям протягом періоду часу, коли виділений обсяг сховища журналів аудиту досягає відсотків від максимального обсягу сховища журналів аудиту

No: 2

Name: au_5_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які мають бути попереджені, коли обсяг записів аудиту, що зберігаються, досягає максимуму місткості сховища. AU-05(01)_ODP[02] визначено період часу, протягом якого визначений персонал або ролі будуть попереджені

No: 3

Name: au_5_1_odp_03

Type: string

Default: nil

Визначено відсоток максимальної ємності сховища для зберігання журналів аудиту

3.5.2. ТРИВОЖНЕ СПОВІЩЕННЯ В РЕАЛЬНОМУ ЧАСІ (AU-5(2))

Забезпечити сповіщення в [Призначення: визначений організацією період реального часу] [Призначення: визначених організацією персоналу, ролей та/або місць], коли відбуваються такі події збою аудиту: [Призначення: визначені організацією події, пов'язані зі збоями та помилками аудиту, які вимагають тривоги в реальному часі].

No: 1

Name: au_5_2_01

Type: list

Default: ["admin", "security_officer"]

Протягом періоду реального часу надається сповіщення персоналу або ролям, коли виникають події

No: 2

Name: au_5_2_odp_01

Type: integer

Default: 30

Визначено період реального часу, за який потрібно надсилати сповіщення при виникненні подій збою аудиту (визначених у AU-05(02)_ODP[03])

No: 3

Name: au_5_2_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які мають бути сповіщені при виникненні подій збоїв в аудиті (визначених в AU05(02)_ODP[03])

No: 4

Name: au_5_2_odp_03

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, пов'язані зі збоями та помилками аудиту

3.5.3. НАЛАШТУВАННЯ ПОРОГОВОГО ОБСЯГУ ТРАФІКУ (AU-5(3))

Здійснювати налаштування порогових значень обсягу трафіку комунікаційних мереж, що відображають обмеження на можливості аудиту та [Вибір: відхиляти; затримувати] мережевий трафік, якщо він перевищує цей поріг.

No: 1

Name: au_5_3_01

Type: string

Default: nil

Застосовуються налаштовані порогові значення обсягу трафіку комунікаційних мереж, що відображають обмеження на можливості аудиту

No: 2

Name: au_5_3_odp

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {відхилити; затримати}

3.5.4. ВИМКНЕННЯ У РАЗІ ВІДМОВИ (AU-5(4))

Застосовувати [Вибір: повне вимикання системи; часткове вимикання системи; знижений режим роботи з обмеженням доступної/цільової функціональності] у разі [Призначення: визначених організацією збоїв аудиту], якщо немає альтернативної можливості аудиту.

Немає параметрів для цього контролю.

3.5.5. МОЖЛИВІСТЬ АЛЬТЕРНАТИВНОГО ЖУРНАЛЮВАННЯ АУДИТУ (AU-5(5))

Надання альтернативної можливості журналювання аудиту в разі збою основної можливості журналювання аудиту, яка реалізується [Призначення: визначена організацією функція альтернативного журналювання аудиту]

No: 1

Name: au_5_5_01

Type: string

Default: nil

Альтернативна можливість ведення журналу аудиту надається на випадок відмови основної можливості ведення журналу аудиту, який реалізує визначений альтернативний функціонал ведення журналу аудиту

No: 2

Name: au_5_5_odp

Type: string

Default: nil

Визначено альтернативний функціонал ведення журналу аудиту на випадок збою в роботі основної функції ведення журналу аудиту

3.6. ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ (AU-6)

a. Переглядати та аналізувати записи системного аудиту [Призначення: з визначеною організацією частотою] для виявлення [Призначення: визначеної організацією неналежної або незвичайної діяльності].

b. Відправляти звіт про аудит [Призначення: визначеним організацією персоналу або посадам].

c. Налаштувати рівні огляду аудиту, аналізу та звітності в рамках системи, коли змінюється рівень ризику на основі інформації від правоохоронних органів, розвідувальної інформації або від інших достовірних джерел інформації.

No: 1

Name: au_6_01

Type: string

Default: nil

ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: au_6_a

Type: string

Default: "щотижня"

Записи аудиту системи переглядаються та аналізуються частота для виявлення ознак неналежної або незвичної діяльності та потенційного впливу неналежної або незвичної діяльності

No: 3

Name: au_6_b

Type: list

Default: ["admin", "security_officer"]

Звіт аудиту відправляється персоналу або ролям

No: 4

Name: au_6_c

Type: string

Default: nil

Рівень перевірки, аналізу та звітування записів аудиту в системі коригується у разі зміни ризиків на основі інформації правоохоронних органів, розвідувальної інформації або інших достовірних джерел інформації

No: 5

Name: au_6_odp_01

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та аналізуються записи аудиту системи

No: 6

Name: au_6_odp_02

Type: string

Default: nil

Визначена неналежна або незвична діяльність

No: 7
Name: au_6_odp_03
Type: list
Default: ["admin", "security_officer"]

Визначено персонал або ролі які отримують результати оглядів та аналізів системних записів

3.6.1. АВТОМАТИЗОВАНА ІНТЕГРАЦІЯ ПРОЦЕСІВ (AU-6(1))

No: 1
Name: au_6_1_01
Type: string
Default: nil

Процеси перегляду, аналізу та звітності інтегровані з використанням автоматизованих механізмів

No: 2
Name: au_6_1_odp
Type: string
Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для інтеграції процесів перегляду, аналізу та звітності записів аудиту

3.6.2. ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ СПОВІЩЕННЯ ПРО ПОРУШЕННЯ БЕЗПЕКУ (AU-6(2))

No: 1
Name: au_6_2_01
Type: string
Default: nil

ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ СПОВІЩЕННЯ ПРО ПОРУШЕННЯ БЕЗПЕКУ - АВТОМАТИЗОВАНІ [Вилучено: Включено до SI-4]

3.6.3. ЗІСТАВЛЯННЯ СХОВИЩ АУДИТУ (AU-6(3))

Аналізувати та зіставляти записи аудиту в різних сховищах задля забезпечення ситуативної обізнаності в масштабах організації.

No: 1
Name: au_6_3_01
Type: string
Default: nil

Аналізуються та зіставляються записи аудиту в різних сховищах, задля забезпечення ситуативної обізнаності в масштабах організації

3.6.4. ЦЕНТРАЛІЗОВАНИЙ ПЕРЕГЛЯД ТА АНАЛІЗ (AU-6(4))

Забезпечити та впровадити можливість централізованого перегляду та аналізу записів аудиту з декількох компонентів у системі.

No: 1
Name: au_6_4_01
Type: string

Default: nil

Забезпечено можливість централізованого перегляду та аналізу записів аудиту з декількох компонентів у системі

No: 2

Name: au_6_4_02

Type: string

Default: nil

Впроваджено можливість централізованого перегляду та аналізу записів аудиту з декількох компонентів у системі

3.6.5. ІНТЕГРОВАНІЙ АНАЛІЗ ЗАПИСІВ АУДИТУ (AU-6(5))

Інтегрувати аналіз записів аудиту з аналізом [Вибір (один або більше): інформації про сканування уразливостей; даних про продуктивність; інформації про моніторинг системи; [Призначення: визначених організацією даних/інформації, зібраних з інших джерел]] для подальшого підвищення здатності виявляти неприйнятну або незвичайну діяльність.

No: 1

Name: au_6_5_odp_01

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {інформація про сканування вразливостей; дані про продуктивність; інформація про моніторинг системи; дані/інформація, зібрана з інших джерел}

3.6.6. КОРЕЛЯЦІЯ З ФІЗИЧНИМ МОНІТОРИНГОМ (AU-6(6))

Зіставляти інформацію із записів аудиту з інформацією, отриманою від моніторингу фізичного доступу, для подальшого підвищення здатності ідентифікувати підозрілу, неприйнятну, незвичайну або зловмисну діяльність.

No: 1

Name: au_6_6_01

Type: string

Default: nil

Інформація з записів аудиту співвідноситься з інформацією, отриманою в результаті моніторингу фізичного доступу, для подальшого посилення здатності виявляти підозрілу, невідповідну, незвичну або зловмисну діяльність

3.6.7. ДОЗВОЛЕНІ ДІЇ (AU-6(7))

Визначити дозволені дії для кожного [Вибір (один або кілька): системного процесу; ролі; користувача], пов'язаного з переглядом, аналізом та поданням інформації про аудит.

No: 1

Name: au_6_7_odp

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {процес системи; роль; користувач}

3.6.8. АНАЛІЗ ПОВНОГО ТЕКСТУ ПРИВІЛЕЙОВАНИХ КОМАНД (AU-6(8))

Виконувати повний аналіз тексту привілейованих команд аудиту у фізично окремому компоненті чи підсистемі або іншій системі, яка може виконувати такий аналіз.

No: 1
Name: au_6_8_01
Type: string
Default: nil

У фізично окремому компоненті чи підсистемі або іншій системі, яка може виконувати такий аналіз. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

3.6.9. РЕГУЛЮВАННЯ РІВНЯ АУДИТУ (AU-6(10))

No: 1
Name: au_6_10_01
Type: string
Default: nil

ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ - РЕГУЛЮВАННЯ РІВНЯ АУДИТУ [Вилучено: Включено до AU-06]

3.7. СКОРОЧЕННЯ ЗАПИСІВ АУДИТУ ТА ФОРМУВАННЯ ЗВІТУ (AU-7)

Забезпечити та реалізувати можливості скорочення записів перевірок аудитом і звітів, до рівня, який:

- a. підтримує перевірку, аналіз і звітність аудиту на вимогу та розслідування (постфактум) інцидентів безпеки;
- b. не змінює оригінальний вміст або час упорядкування записів аудиту.

No: 1
Name: au_7_a_02
Type: string
Default: nil

Реалізовано можливість скорочення записів перевірок аудитом та звітів, до рівня що підтримує перевірку, аналіз і звітність аудиту на вимогу та розслідування (постфактум) інцидентів безпеки

No: 2
Name: au_7_b_01
Type: integer
Default: 30

Забезпечено можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний вміст або час упорядкування записів аудиту

No: 3
Name: au_7_b_02
Type: integer
Default: 30

Реалізовано можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний зміст або час упорядкування записів аудиту

3.7.1. АВТОМАТИЧНА ОБРОБКА (AU-7(1))

No: 1

Name: au_7_1_01

Type: string

Default: nil

Забезпечити можливість обробки записів аудиту для подій, що представляють інтерес, на основі полей в записах аудиту

No: 2

Name: au_7_1_02

Type: string

Default: nil

Реалізувати можливість обробки записів аудиту для подій, що представляють інтерес, на основі полей в записах аудиту

No: 3

Name: au_7_1_odp

Type: string

Default: nil

Визначено поля в записах аудиту, які можна обробляти, сортувати або шукати

3.7.2. АВТОМАТИЧНЕ СОРТУВАННЯ ТА ПОШУК (AU-7(2))

No: 1

Name: au_7_2_01

Type: string

Default: nil

СКОРОЧЕННЯ АУДИТУ ТА ФОРМУВАННЯ ЗВІТУ - АВТОМАТИЧНЕ СОРТУВАННЯ ТА ПОШУК
[Вилучено: Включено до AU-07(01)]

3.8. ПОЗНАЧКА ЧАСУ (AU-8)

а. Використовувати внутрішньосистемний годинник для створення позначок часу для записів аудиту.

б. Застосовувати позначки часу, які відповідають [Призначення: деталізація вимірювання часу, визначена організацією] і використовують всесвітній координований час, мають фіксоване зміщення місцевого часу відносно всесвітнього координованого часу або включають зміщення місцевого часу як частину позначки часу.

No: 1

Name: au_8_a

Type: integer

Default: 30

Внутрішній системний годинник використовується для створення позначок часу для записів аудиту

No: 2

Name: au_8_b

Type: integer

Default: 30

Позначки часу застосовуються для записів аудиту, які відповідають деталізації вимірювання часу і які використовують всесвітній координований час, мають фіксоване місцеве зміщення місцевого часу від всесвітнього координованого часу або включають зміщення місцевого часу як частину позначки часу

No: 3

Name: au_8_odp

Type: integer

Default: 30

Визначено деталізацію вимірювання часу для часових позначок записів аудиту

3.8.1. СИНХРОНІЗАЦІЯ З АВТОРИТЕТНИМ ДЖЕРЕЛОМ ЧАСУ (AU-8(1))

No: 1

Name: au_8_1_01

Type: integer

Default: 30

ПОЗНАЧКА ЧАСУ - СИНХРОНІЗАЦІЯ З АВТОРИТЕТНИМ ДЖЕРЕЛОМ ЧАСУ [Вилучено: Включено до SC-45(01)]

3.8.2. ВТОРИННЕ АВТОРИТЕТНЕ ДЖЕРЕЛО ЧАСУ (AU-8(2))

No: 1

Name: au_8_2_01

Type: integer

Default: 30

ПОЗНАЧКА ЧАСУ - ВТОРИННЕ АВТОРИТЕТНЕ ДЖЕРЕЛО ЧАСУ [Вилучено: Включено до SC-45(02)]

3.9. ЗАХИСТ ІНФОРМАЦІЇ АУДИТУ (AU-9)

- а. Захист інформації аудиту та інструментів несанкціонованого доступу, зміни та видалення; журналювання аудиту від
- б. Сповіднення [Призначення: персонал або ролі, визначені організацією] у разі виявлення несанкціонованого доступу, зміни або видалення інформації аудиту.

No: 1

Name: au_9_01

Type: string

Default: nil

ЗАХИСТ ІНФОРМАЦІЇ АУДИТУ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: au_9_a

Type: string

Default: nil

Інформація про аудит та інструменти журналювання аудиту захищені від несанкціонованого доступу, зміни та видалення

No: 3
 Name: au_9_b
 Type: list
 Default: ["admin", "security_officer"]

Персонал або ролі отримують сповіщення при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту

No: 4
 Name: au_9_odp
 Type: list
 Default: ["admin", "security_officer"]

Визначено персонал або ролі, які мають бути сповіщені при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту

3.9.1. АПАРАТНІ НОСІЇ ІНФОРМАЦІЇ ОДНОРАЗОВОГО ЗАПИСУ (AU-9(1))

No: 1
 Name: au_9_1_01
 Type: string
 Default: nil

Журнали аудиту записані на апаратні носії інформації з одноразовим записом

3.9.2. ЗБЕРІГАННЯ НА ОКРЕМИХ ФІЗИЧНИХ СИСТЕМАХ АБО КОМПОНЕНТАХ (AU-9(2))

Зберігати записи аудиту з [Призначення: визначеною організацією з частотою] у репозиторії, який є частиною фізично іншої системи або компонента системи, ніж система або компонент, який перевіряється.

No: 1
 Name: au_9_2_01
 Type: integer
 Default: 30

Зберігати записи аудиту з частотою у репозиторії, який є частиною іншої системи або компонента системи, не частиною системи або компонента системи, який перевіряється

No: 2
 Name: au_9_2_odp
 Type: integer
 Default: 30

Визначено частоту з якою необхідно зберігати записи аудиту

3.9.3. КРИПТОГРАФІЧНИЙ ЗАХИСТ (AU-9(3))

Запровадити криптографічні механізми для захисту цілісності інформації аудиту та інструментів аудиту.

No: 1
 Name: au_9_3_01
 Type: string
 Default: "AES-256-GCM"

Впроваджено криптографічні механізми для захисту цілісності інформації аудиту

3.9.4. ДОСТУП, ЯКИЙ НАДАЄТЬСЯ ЧЕРЕЗ ЧЛЕНСТВО В ПІДМНОЖИНІ ПРИВІЛЕЙОВАНИХ КОРИСТУВАЧІВ (AU-9(4))

Авторизувати доступ до управління функціональністю аудиту тільки для [Призначення: визначеної організацією підмножини привілейованих користувачів].

No: 1

Name: au_9_4_01

Type: string

Default: nil

Авторизувати доступ до управління функціональністю аудиту тільки для підмножини привілейованих користувачів

No: 2

Name: au_9_4_odp

Type: string

Default: nil

Визначено підмножину привілейованих користувачів

3.9.5. ПОДВІЙНА АВТОРИЗАЦІЯ (AU-9(5))

Здійснювати подвійну авторизацію для [Вибір (один або кілька): переміщення; видалення] [Призначення: визначеної організацією інформації аудиту].

No: 1

Name: au_9_5_odp_01

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {переміщення; видалення}

No: 2

Name: au_9_5_odp_02

Type: string

Default: nil

Визначено інформацію аудиту, для якої має бути застосована подвійна авторизація

3.9.6. ДОСТУП ТІЛЬКИ ДЛЯ ЧИТАННЯ (AU-9(6))

Авторизувати доступ лише для читання інформації аудиту для [Призначення: визначеної організацією підмножини привілейованих користувачів].

No: 1

Name: au_9_6_01

Type: string

Default: nil

Авторизувати доступ лише для читання інформації аудиту для підмножини привілейованих користувачів

No: 2

Name: au_9_6_odp

Type: string

Default: nil

Визначено підмножину привілейованих користувачів для яких доступ авторизовано тільки для читання

3.9.7. ЗБЕРІГАННЯ НА КОМПОНЕНТІ ІНШОЇ ОПЕРАЦІЙНОЇ СИСТЕМИ (AU-9(7))

Зберігати інформацію про аудит на компоненті, що працює з іншою операційною системою, ніж система або компонент, який проходить аудит.

No: 1

Name: au_9_7_01

Type: string

Default: nil

Інформація про аудит зберігається на компоненті, що працює з іншою операційною системою, ніж система або компонент, який проходить аудит

3.10. НЕСПРОСТОВНІСТЬ (AU-10)

Надавайте неспростовні докази того, що особа (або процес, який діє від імені особи) виконала [Призначення: дії, визначені організацією, на які поширюється принцип неспростовності].

No: 1

Name: au_10_01

Type: list

Default: ["admin", "security_officer"]

Надаються неспростовні докази того, що особа (або процес, що діє від імені особи) виконала дії

No: 2

Name: au_10_odp

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено дії, на які поширюється принцип неспростовності

3.10.1. АСОЦІАЦІЯ ІДЕНТИЧНОСТІ (AU-10(1))

No: 1

Name: au_10_1_a

Type: list

Default: ["admin", "security_officer"]

Особистість джерела інформації зв'язується з інформацією з сила зв'язування

No: 2

Name: au_10_1_b

Type: list

Default: ["admin", "security_officer"]

Впроваджено засоби, якими уповноважені особи можуть визначити особу виробника інформації

No: 3

Name: au_10_1_odp

Type: list

Default: ["admin", "security_officer"]

Визначено міцність зв'язку між особистістю джерела інформації та інформацією

3.10.2. РАТИФІКАЦІЯ ПРИВ'ЯЗКИ ІНФОРМАЦІЇ ПРО ІДЕНТИЧНІСТЬ ВИРОБНИКА (AU-10(2))

а) Підтвердити прив'язку інформації про ідентичність джерела до інформації з [Призначення: визначеною організацією частотою]. б) Виконати [Призначення: визначені організацією дії] у разі помилки перевірки.

No: 1

Name: au_10_2_01

Type: string

Default: nil

НЕСПРОСТОВНІСТЬ - РАТИФІКАЦІЯ ПРИВ'ЯЗКИ ІНФОРМАЦІЇ ПРО ІДЕНТИЧНІСТЬ ВИРОБНИКА
МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: au_10_2_a

Type: integer

Default: 30

Прив'язка інформації про ідентичність джерела до інформації підтверджується з частотою

No: 3

Name: au_10_2_b

Type: list

Default: ["login", "logout", "failed_attempt"]

Виконуються дії у разі помилки перевірки

No: 4

Name: au_10_2_odp_01

Type: integer

Default: 30

Визначено частоту, з якою необхідно підтверджувати прив'язку інформації про ідентичність джерела до інформації

3.10.3. ЛАНЦЮЖОК ЗБЕРЕЖЕННЯ ДОКАЗІВ (AU-10(3))

Підтримувати перегляд і випуск ідентичності та повноважень у межах встановленого ланцюжка збереження доказів для всієї переглянутої або оприлюдненої інформації.

No: 1

Name: au_10_3_01

Type: string

Default: nil

Підтримується перегляд і випуск ідентичності та повноважень у межах встановленого ланцюжка збереження доказів для всієї переглянутої або оприлюдненої інформації

3.10.4. ВАЛІДАЦІЯ ЗВ'ЯЗКУ ІДЕНТИЧНОСТІ ПЕРЕГЛЯ- (AU-10(4))

ЗВ'ЯЗКУ ІДЕНТИЧНОСТІ а) Підтвердити прив'язку особистості рецензента до інформації в точках передачі або видачі до її випуску або передачі між [Призначення: визначеними організацією домени безпеки]. б) Виконати [Призначення: визначені організацією дії] у разі помилки перевірки.

No: 1

Name: au_10_4_a

Type: list

Default: ["admin", "security_officer"]

Прив'язка особистості рецензента інформації до інформації в точках передачі або видачі до її випуску або передачі між доменами безпеки підтверджується

No: 2

Name: au_10_4_b

Type: list

Default: ["login", "logout", "failed_attempt"]

Дії виконуються у випадку помилки перевірки

No: 3

Name: au_10_4_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено домени безпеки, для яких прив'язка особи рецензента інформації до інформації повинна бути підтверджена в точках передачі або видачі

No: 4

Name: au_10_4_odp_02

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено дії, які мають бути виконані у випадку помилки перевірки

3.10.5. ЦИФРОВІ ПІДПИСИ (AU-10(5))

No: 1

Name: au_10_5_01

Type: string

Default: nil

НЕПРОСТОВНІСТЬ - ЦИФРОВІ ПІДПИСИ [Вилучено: Включено до SI-07]

3.11. ЗБЕРЕЖЕННЯ ЗАПИСІВ АУДИТУ (AU-11)

Зберігати записи аудиту впродовж [Призначення: визначеного організацією періоду часу, відповідно політиці зберігання записів], щоб забезпечити підтримку розслідувань (постфактум) інцидентів безпеки та приватності, а також для задоволення вимог нормативних і документів організації щодо збереження даних аудиту.

No: 1

Name: au_11_01

Type: integer

Default: 30

Записи аудиту зберігаються впродовж період часу, щоб забезпечити підтримку розслідування (постфактум) інцидентів безпеки та конфіденційності, а також відповідати нормативним та вимогам організації щодо збереження даних аудиту

No: 2

Name: au_11_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено період часу для зберігання записів аудиту, який узгоджується з політикою зберігання записів

3.11.1. ДОВГОСТРОКОВА МОЖЛИВІСТЬ ОТРИМАННЯ (AU-11(1))

No: 1

Name: au_11_1_01

Type: string

Default: nil

Впровадити заходи, щоб гарантувати, що довгострокові записи аудиту, можуть бути отримані

No: 2

Name: au_11_1_odp

Type: string

Default: nil

Визначено заходи, необхідні для реалізації довгострокової можливості отримання записів аудиту

3.12. ГЕНЕРАЦІЯ ДАНИХ АУДИТУ (AU-12)

а. Забезпечити генерацію даних аудиту для типів подій, що перевіряються в AU-2а в [Призначення: визначених організацією компонентах системи].

б. Дозволити [Призначення: визначеному організацією персоналу або посадам] вибирати, які типи подій, що перевіряються, повинні перевірятися окремими компонентами системи;

с. Генерувати записи аудиту для типів подій, визначених в AU-2с. з вмістом згідно з AU-3.

No: 1

Name: au_12_a

Type: string

Default: nil

Можливість генерації записів аудиту для типів подій, які система здатна перевіряти (визначених у AU-02_ODP[01]), забезпечується компонентами системи

No: 2

Name: au_12_b

Type: list

Default: ["admin", "security_officer"]

Персонал або ролі може/можуть вибирати типи подій, які будуть реєструватися певними компонентами системи; AU-12(с) згенеровано записи аудиту для типів подій, визначених у AU02_ODP[02], які включають вміст записів аудиту, визначений у AU03

No: 3

Name: au_12_odp_01

Type: string

Default: nil

Визначено компоненти системи, які забезпечують можливість генерації записів аудиту для типів подій (визначених у AU02_ODP[02])

No: 4

Name: au_12_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, яким дозволено обирати типи подій, що мають реєструватися певними компонентами системи

3.12.1. ЗАГАЛЬНОСИСТЕМНИЙ ТА СИНХРОНІЗОВАНИЙ ЗА ЧАСОМ ЖУРНАЛУ АУДИТУ (AU-12(1))

No: 1

Name: au_12_1_01

Type: integer

Default: 30

Записи аудиту з компонентів системи збираються у загальносистемний (логічний або фізичний) журнал аудиту, який синхронізується у часі в межах рівня взаємозв'язку

No: 2

Name: au_12_1_odp_01

Type: string

Default: nil

Визначено компоненти системи, з яких записи аудиту мають бути зібрані в загальносистемний (логічний або фізичний) журнал аудиту

3.12.2. СТАНДАРТИЗОВАНІ ФОРМАТИ (AU-12(2))

Створити загальносистемний (логічний або фізичний) журнал аудиту, що складається із записів аудиту в стандартизованому форматі.

No: 1

Name: au_12_2_01

Type: string

Default: nil

Створюється загальносистемний (логічний) журнал аудиту, що складається з записів аудиту в стандартизованому форматі

3.12.3. ЗМІНИ, ЩО ВНОСЯТЬ АВТОРИЗОВАНІ ОСОБИ (AU-12(3))

Забезпечити та реалізувати можливість для [Призначення: визначених організацією окремих осіб або ролей] змінити аудит, який виконуватиметься на [Призначення: визначених організацією компонентах системи] на основі [Призначення: визначених організацією критеріїв вибору подій] у межах [Призначення: визначених організацією часових порогів].

No: 1

Name: au_12_3_01

Type: list

Default: ["admin", "security_officer"]

Забезпечено можливість особам або ролям змінювати аудит на компонентах системи на основі обраних критеріїв події у межах часових порогів

No: 2

Name: au_12_3_02

Type: list

Default: ["admin", "security_officer"]

Реалізовано можливість особам або ролям змінювати аудит на компонентах системи на основі обраних критеріїв події у межах часових порогів

No: 3

Name: au_12_3_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено осіб або ролі, яким дозволено змінювати аудит компонентів системи

No: 4

Name: au_12_3_odp_02

Type: string

Default: nil

Визначено компоненти системи, на яких має виконуватися аудит

No: 5

Name: au_12_3_odp_03

Type: list

Default: []

Визначено критерії вибору подій

No: 6

Name: au_12_3_odp_04

Type: integer

Default: 30

Визначено часові пороги, в яких мають змінюватися аудит

3.12.4. АУДИТ ЗАПИТІВ ПЕРСОНАЛЬНИХ ДАНИХ (AU-12(4))

Забезпечити та реалізувати можливості аудиту параметрів подій запитів користувачів для наборів даних, що містять персональні дані.

No: 1

Name: au_12_4_01

Type: list

Default: ["admin", "security_officer"]

Забезпечена можливість аудиту параметрів подій запитів користувачів для наборів даних, що містять персональну ідентифікаційну інформацію

No: 2

Name: au_12_4_02

Type: list

Default: ["admin", "security_officer"]

Реалізована можливість аудиту параметрів подій запитів користувачів для наборів даних, що містять персональну ідентифікаційну інформацію

3.13. МОНІТОРИНГ РОЗКРИТТЯ ІНФОРМАЦІЇ (AU-13)

a. Моніторинг [Завдання: визначена організацією інформація з відкритих джерел та/або інформаційних сайтів] [Завдання: частота, визначена організацією] на наявність доказів неавторизованого розголошення конфіденційної інформації;

b. Якщо виявлено розголошення інформації:

1. Повідомити [Призначення: персонал або ролі, визначені організацією];

2. Виконайте такі додаткові дії: [Призначення: додаткові дії, визначені організацією].

No: 1

Name: au_13_a

Type: string

Default: "щорічно"

Інформація з відкритих джерел та/або інформаційні сайти відстежуються частота на наявність доказів неавторизованого розголошення конфіденційної інформації

No: 2

Name: au_13_b_01

Type: list

Default: ["admin", "security_officer"]

Персонал або ролі буде повідомлено, якщо буде виявлено розголошення інформації

No: 3

Name: au_13_b_02

Type: list

Default: ["login", "logout", "failed_attempt"]

Додаткові дії вживаються, якщо виявлено розголошення інформації

No: 4

Name: au_13_odp_01

Type: string

Default: nil

Визначено інформацію з відкритих джерел та/або інформаційні сайти, що підлягають моніторингу на наявність доказів неавторизованого розголошення конфіденційної інформації

No: 5

Name: au_13_odp_02

Type: integer

Default: 30

Визначено частоту моніторингу інформації з відкритих джерел та/або інформаційних сайтів на наявність доказів неавторизованого розголошення конфіденційної інформації

No: 6

Name: au_13_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які мають бути повідомлені в разі виявлення розголошення інформації

No: 7

Name: au_13_odp_04

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено додаткові дії, які необхідно вжити у разі виявлення розголошення інформації

3.13.1. ВИКОРИСТАННЯ АВТОМАТИЧНИХ ЗАСОБІВ (AU-13(1))

No: 1

Name: au_13_1_01

Type: string

Default: "автоматизований засіб моніторингу"

Моніторинг інформації з відкритих джерел та інформаційних сайтів здійснюється за допомогою автоматизованих механізмів

No: 2

Name: au_13_1_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми моніторингу інформації з відкритих джерел та інформаційних сайтів

3.13.2. ОГЛЯД САЙТІВ, ЩО ПІДЛЯГАЮТЬ МОНІТОРИНГУ (AU-13(2))

Проводити огляд відкритих інформаційних сайтів, що підлягають моніторингу [Призначення: з визначеною організацією частотою].

No: 1

Name: au_13_2_odp

Type: integer

Default: 30

Визначено частоту з якою проводять огляд відкритих інформаційних сайтів, що підлягають моніторингу проводиться огляд відкритих інформаційних сайтів, що підлягають моніторингу з частотою

3.13.3. АВТОРИЗОВАНЕ КОПЮВАННЯ ІНФОРМАЦІЇ (AU-13(3))

Використовуйте методи виявлення, процеси та інструменти, щоб визначити, чи зовнішні суб'єкти копіюють організаційну інформацію неавторизованим способом.

No: 1

Name: au_13_3_01

Type: string

Default: nil

Застосовуються методи, процеси та інструменти виявлення, щоб визначити, чи не копіюють зовнішні суб'єкти інформацію організації в несанкціонований спосіб

3.14. АУДИТ СЕСІЇ (AU-14)

а. Надавати та реалізувати можливість для [Призначення: користувачів або ролей, визначених організацією] для [Вибору (одного або кількох): збору/запису або перегляду/прослуховування] вмісту сесії користувача в [Призначення: обставини, визначені організацією];

б. Розробляти, інтегрувати та використовувати діяльність з аудиту сесії, консультуючись із юрисконсультантом щодо її відповідності до чинних законів, розпоряджень, директив, нормативних актів, політик, стандартів і вказівок.

No: 1

Name: au_14_b_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Діяльність з аудиту сесій розробляється після консультацій з юристом та відповідно до чинних законів, розпоряджень, директив, нормативних актів, політик, стандартів та вказівок

No: 2

Name: au_14_b_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Діяльність з аудиту сесій інтегрується після консультацій з юристом та відповідно до чинних законів, розпоряджень, директив, нормативних актів, політик, стандартів та вказівок

No: 3

Name: au_14_b_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Діяльність з аудиту сесій використовується після консультацій з юристом та відповідно до чинних законів, розпоряджень, директив, нормативних актів, політик, стандартів та вказівок

No: 4

Name: au_14_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено користувачів або ролі, які можуть перевіряти вміст сесії користувача

No: 5

Name: au_14_odp_02

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {збору/запису або перегляду/прослуховування}

No: 6

Name: au_14_odp_03

Type: string

Default: nil

Визначено обставини, за яких вміст сесії користувача може бути перевірено

3.14.1. СИСТЕМА ЗАПУСКУ (AU-14(1))

Немає параметрів для цього контролю.

3.14.2. ЗАХОПЛЕННЯ ТА ЗАПИС ІНФОРМАЦІЇ (AU-14(2))

[Вилучено: Включено до AU-14]

No: 1

Name: au_14_2_01

Type: string

Default: nil

АУДИТ СЕСІЇ - ЗАХОПЛЕННЯ ТА ЗАПИС ІНФОРМАЦІЇ [Вилучено: Включено до AU-14]

3.14.3. ВІДДАЛЕНИЙ ПЕРЕГЛЯД ТА ПРОСЛУХОВУВАННЯ (AU-14(3))

Забезпечити та реалізувати можливість авторизованих користувачів віддалено переглядати та прослуховувати вміст, пов'язаний із встановленою сесією користувача, у режимі реального часу.

No: 1

Name: au_14_3_01

Type: integer

Default: 30

Забезпечується можливість для авторизованих користувачів віддалено переглядати та прослуховувати вміст, пов'язаний із встановленою сесією користувача, в режимі реального часу

No: 2

Name: au_14_3_02

Type: integer

Default: 30

Реалізовано можливість для авторизованих користувачів віддалено переглядати та прослуховувати вміст, пов'язаний із встановленою сесією користувача, в режимі реального часу

3.15. АЛЬТЕРНАТИВНА МОЖЛИВІСТЬ АУДИТУ (AU-15)

No: 1

Name: au_15_01

Type: string

Default: nil

АЛЬТЕРНАТИВНА МОЖЛИВІСТЬ АУДИТУ [Вилучено: Включено до AU-05(05)]

3.16. МІЖОРГАНІЗАЦІЙНИЙ АУДИТ (AU-16)

Використовувати [Призначення: визначені організацією методи] для координації [Призначення: визначеної організацією інформації] серед зовнішніх організацій, коли інформація аудиту передається за межі організації.

No: 1

Name: au_16_01

Type: string

Default: nil

Організація використовує методи для координації інформації серед зовнішніх організацій, коли інформація аудиту передається через (за) межі організації (системи)

No: 2

Name: au_16_odp_01

Type: string

Default: nil

Визначено методи для координації інформації серед зовнішніх організацій, коли інформація аудиту передається через (за) межі організації (системи)

No: 3
Name: au_16_odp_02
Type: string
Default: nil

Визначено інформацію для координації інформації серед зовнішніх організацій, коли інформація аудиту передається через (за) межі організації (системи);

3.16.1. ЗБЕРЕЖЕННЯ ІДЕНТИЧНОСТІ (AU-16(1))

No: 1
Name: au_16_1_01
Type: list
Default: ["admin", "security_officer"]

Вимагається, щоб ідентичність особистості зберігалася в міжорганізаційних журналах аудиту

3.16.2. ОБМІН ІНФОРМАЦІЄЮ АУДИТУ (AU-16(2))

Надавати інформацію про міжорганізаційний аудит до [Призначення: організацій, визначених організацією] на основі [Призначення: визначеної організацією міжорганізаційної угоди про обмін].

No: 1
Name: au_16_2_01
Type: string
Default: nil

Надати інформацію про міжорганізаційний аудит до організацій організацією на основі угоди про розподіл

No: 2
Name: au_16_2_odp_01
Type: string
Default: nil

Визначено організації до яких надають інформацію про міжорганізаційний аудит

No: 3
Name: au_16_2_odp_02
Type: string
Default: nil

Визначено міжорганізаційну угоду про розподіл

3.16.3. РОЗМЕЖУВАННЯ (AU-16(3))

Запровадити [Призначення: заходи, визначені організацією], щоб розмежувати людей від інформації аудиту, що передається в межах організації.

No: 1
Name: au_16_3_01
Type: string
Default: nil

Заходи впроваджуються для того, щоб розмежування окремих осіб від інформації аудиту, що передається в межах організації

No: 2
Name: au_16_3_odp

Type: string

Default: nil

Визначено заходи для розмежування окремих осіб від інформації аудиту, що передається в межах організації

4. СА

Клас заходів захисту СА — ОЦІНЮВАННЯ,

Цей клас регламентує процеси перевірки ефективності заходів захисту, авторизації систем та їх безперервного моніторингу.

Перелік заходів захисту: Політика і процедури оцінювання, акредитація та моніторинг безпеки (СА-1); Оцінювання (СА-2); Незалежні експерти (СА-2(1)); Включаються як частина оцінювання заходів безпеки та конфіденційності; (СА-2(2)); Зовнішні організації (СА-2(3)); Взаємодія систем (СА-3); Взаємодія систем- не захищені з'єднання системи (СА-3(1)); Захищені з'єднання системи (СА-3(2)); Несекретні з'єднання системи безпеки, що не є національними (СА-3(3)); Підключення до загальнодоступних мереж (СА-3(4)); Обмеження зв'язку із зовнішніми системами (СА-3(5)); Передача дозволів (СА-3(6)); Транзитивний обмін інформацією (СА-3(7)); Сертифікація безпеки (СА-4); План усунення недоліків та контрольні показники (СА-5); Автоматизація підтримки задля точності та вживаності (СА-5(1)); Акредитація (СА-6); Спільна акредитація - одна і та сама організація (СА-6(1)); Спільна акредитація - різні організації (СА-6(2)); Безперервний моніторинг (СА-7); Незалежне оцінювання (СА-7(1)); Види оцінок (СА-7(2)); Аналіз тенденції (СА-7(3)); Моніторинг ризику (СА-7(4)); Узгоджений аналіз (СА-7(5)); Безперервний моніторингу (СА-7(6)); Тестування на проникнення (СА-8); Незалежна команда або агент на проникнення (СА-8(1)); Червона команда (СА-8(2)); Можливості перевірки на проникнення (СА-8(3)); Внутрішні з'єднання системи (СА-9).

4.1. ПОЛІТИКА І ПРОЦЕДУРИ ОЦІНЮВАННЯ, АКРЕДИТАЦІЯ ТА МОНІТОРИНГ БЕЗПЕКИ (СА-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посад]:

1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політика оцінювання, авторизації та моніторингу, яка:

(а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance);

(b) відповідає чинним законам, нормативним документам, наказам, положенням, політиці, стандартам і керівним принципам.

2. Процедури, що сприяють реалізації політики оцінювання, авторизації та моніторингу безпеки та приватності, а також пов'язаних з ними заходів оцінювання, авторизації та моніторингу безпеки та приватності.

б. Призначити [Призначення: посадова особа, визначена організацією] для управління розробкою, документуванням і розповсюдженням політики та процедур оцінювання, авторизації та моніторингу;

с. Переглядати та оновлювати поточне оцінювання, авторизацію та моніторинг:

1. Політику [Призначення: частота, визначена організацією] та наступне [Призначення: події, визначені організацією];

2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].

No: 1

Name: ca_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику оцінювання, авторизації та моніторингу

No: 2

Name: ca_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика оцінювання, авторизації та моніторингу поширюється серед персоналу або ролей

No: 3

Name: ca_1_a_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблені та задокументовані процедури оцінювання, авторизації та моніторингу, що сприяють впровадженню політики оцінювання, авторизації та моніторингу, а також пов'язані з ними засоби контролю оцінювання, авторизації та моніторингу

No: 4

Name: ca_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур оцінювання, авторизації та моніторингу; CA-01(c)[01][01] переглядається та оновлюється поточна політика оцінки, авторизації та моніторингу з частотою; CA-01(c)[01][02] переглядається та оновлюється поточна політика оцінки, авторизації та моніторингу після подій; CA-01(c)[02][01] переглядаються та оновлюються поточні процедури оцінки, авторизації та моніторингу з частотою; CA-01(c)[02][02] переглядаються та оновлюються поточні процедури оцінки, авторизації та моніторингу після подій; ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

No: 5

Name: ca_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, серед яких має бути поширена політика оцінювання, авторизації та моніторингу

No: 6

Name: ca_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, серед яких мають бути поширені процедури оцінювання, авторизації та моніторингу

No: 7

Name: ca_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: ca_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка управлятиме розробкою, документуванням і розповсюдженням політики та процедур оцінювання, авторизації та моніторингу

No: 9

Name: ca_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика оцінювання, авторизації та моніторингу

No: 10

Name: ca_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, які потребують перегляду та оновлення поточної політики оцінки, авторизації та моніторингу

No: 11

Name: ca_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядається та оновлюється поточні процедури оцінювання, авторизації та моніторингу

No: 12

Name: ca_1_odp_08

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують перегляду та оновлення поточні процедури оцінки, авторизації та моніторингу

4.2. ОЦІНЮВАННЯ (CA-2)

- a. Виберіть відповідного оцінювача або команду з оцінки для типу оцінювання, яке буде проводитися;
- b. Розробіть план контрольної оцінки, який описує обсяг оцінки, в тому числі:
 1. заходи захисту та посилені заходи, що підлягають оцінюванню;
 2. процедури оцінювання, ефективності заходів, які використовуватимуться для визначення
 3. середовище оцінювання, групу оцінювання, ролі й обов'язки з оцінювання.
- c. Забезпечити розгляд і затвердження плану оцінювання уповноваженою офіційною особою або призначеним для проведення оцінювання представником;
- d. Оцінити заходи захисту в системі та в її середовищі функціонування з [Призначення: визначеною організацією частотою] для визначення, наскільки коректно реалізовані заходи безпеки і чи працюють вони за призначенням і дають бажаний результат щодо дотримання встановлених вимог безпеки та приватності;
- e. Підготувати звіт оцінювання безпеки, який документує результати оцінювання;
- f. Надати результати оцінювання з безпеки [Призначення: особам або ролям, визначеним організацією].

No: 1

Name: ca_2_a

Type: string

Default: nil

Обрано відповідного оцінювача або команду оцінювачів для проведення оцінювання

No: 2

Name: ca_2_b_01

Type: list

Default: ["admin", "security_officer"]

Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи заходи захисту та посилені заходи, що підлягають оцінюванню. CA-02(b)[02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. CA-02(b)[03][01] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. CA-02(b)[03][02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. CA-02(b)[03][03] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи ролі й обов'язки з оцінювання

No: 3

Name: ca_2_b_02

Type: list

Default: ["admin", "security_officer"]

Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. CA-02(b)[03][01] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. CA-02(b)[03][02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. CA-02(b)[03][03] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи ролі й обов'язки з оцінювання

No: 4

Name: ca_2_c

Type: list

Default: ["admin", "security_officer"]

План оцінки заходів захисту розглядається та затверджується уповноваженою посадовою особою або призначеним представником перед проведенням оцінки

No: 5

Name: ca_2_d_01

Type: string

Default: "щорічно"

Заходи захисту оцінюються в системі та середовищі її функціонування частота оцінки, щоб визначити, наскільки коректно реалізовані заходи захисту, чи працюють вони за призначенням і чи дають бажаний результат щодо дотримання встановлених вимог до безпеки

No: 6

Name: ca_2_d_02

Type: string

Default: "щорічно"

Заходи захисту оцінюються в системі та середовищі її функціонування частота оцінки, щоб визначити, наскільки коректно реалізовані заходи захисту, чи працюють вони за призначенням і чи дають бажаний результат щодо дотримання встановлених вимог до конфіденційності; CA-02(e) готується звіт оцінювання

No: 7

Name: ca_2_f

Type: list

Default: ["admin", "security_officer"]

Результати оцінювання з безпеки надаються особам або ролям. оцінювання, який документує результати

No: 8

Name: ca_2_odp_01

Type: integer

Default: 30

Визначено частоту, з якою слід оцінювати засоби контролю в системі та середовищі її функціонування

No: 9

Name: ca_2_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначені особи або ролі, яким мають бути надані результати оцінювання з безпеки

4.2.1. НЕЗАЛЕЖНІ ЕКСПЕРТИ (CA-2(1))

No: 1

Name: ca_2_1_01

Type: string

Default: nil

Для проведення контрольних оцінок залучаються незалежні експерти або групи експертів

4.2.2. ВКЛЮЧАЮТЬСЯ ЯК ЧАСТИНА ОЦІНЮВАННЯ ЗАХОДІВ БЕЗПЕКИ ТА КОНФІДЕНЦІЙНОСТІ; (CA-2(2))

Ввести як частину оцінювання заходів безпеки та приватності, [Призначення: з визначеною організацією частотою], [Вибір: з попередженням; без попередження], [Вибір (один або кілька): поглиблений моніторинг; сканування уразливостей; тестування на шкідливих користувачів; оцінювання внутрішньої загрози; тестування продуктивності та навантаження; [Призначення: організаційно визначені інші форми оцінювання]].

No: 1

Name: ca_2_2_odp_01

Type: integer

Default: 30

Визначено частоту, з якою слід включати спеціалізовані оцінки як частину оцінювання безпеки та конфіденційності

No: 2

Name: ca_2_2_odp_02

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {з попередженням; без попередження}

No: 3

Name: ca_2_2_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {поглиблений моніторинг; сканування уразливостей; тестування на шкідливих користувачів; оцінювання внутрішньої загрози; тестування продуктивності та навантаження; }

4.2.3. ЗОВНІШНІ ОРГАНІЗАЦІЇ (CA-2(3))

Використовуйте результати контрольного оцінювання, які виконує [Призначення: зовнішня організація, визначена організацією] на [Призначення: система, визначена організацією], коли оцінювання відповідає [Завдання: вимоги, визначені організацією].

No: 1

Name: ca_2_3_01

Type: list

Default: ["admin", "security_officer"]

Визначено організацію, яка надає результати оцінок заходів захисту інформації та персональних даних визначено систему, яка приймає результати оцінок заходів захисту інформації та персональних даних визначено вимоги до результатів оцінок заходів захисту інформації та персональних даних прийняти результати оцінок заходів захисту інформації та персональних даних організаціями., що надані, на систему, коли оцінювання відповідає вимогам

4.3. ВЗАЄМОДІЯ СИСТЕМ (СА-3)

а. схвалити та керувати обміном інформацією між системою та іншими системами за допомогою [Вибір (один або кілька): угоди безпеки взаємозв'язку; договори безпеки обміну інформацією; меморандуми про взаєморозуміння; угоди про рівень обслуговування; угоди користувача; угоди про нерозголошення; [Доручення: тип договору, визначений організацією]];

б. документувати, як частину угоди про обмін, характеристики інтерфейсу, вимоги до безпеки та приватності, засоби контролю та відповідальність для кожної системи, а також характер переданої інформації;

с. здійснювати перегляд та оновлення угод з [Призначення: визначеною організацією частотою].

No: 1

Name: ca_3_b_01

Type: integer

Default: 30

Характеристики інтерфейсу задокументовані як частина кожної угоди про обмін

No: 2

Name: ca_3_b_02

Type: integer

Default: 30

Вимоги до безпеки задокументовані як частина кожної угоди про обмін

No: 3

Name: ca_3_b_03

Type: integer

Default: 30

Вимоги щодо конфіденційності задокументовані як частина кожної угоди про обмін

No: 4

Name: ca_3_b_04

Type: integer

Default: 30

Заходи захисту задокументовані як частина кожної угоди про обмін

No: 5

Name: ca_3_b_05

Type: integer

Default: 30

Відповідальність за кожну систему задокументована як частина кожної угоди про обмін

No: 6

Name: ca_3_b_06

Type: integer

Default: 30

Характер переданої інформації документується як частина кожної угоди про обмін

No: 7

Name: ca_3_c

Type: string

Default: "щорічно"

Угоди переглядаються та оновлюються частота

No: 8

Name: ca_3_odp_01

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {}: угоди безпеки взаємозв'язку; договори безпеки обміну інформацією; меморандуми про взаєморозуміння; угоди про рівень обслуговування; угоди користувача; угоди про нерозголошення; тип угоди}

No: 9

Name: ca_3_odp_02

Type: string

Default: nil

Визначено тип угоди, який використовується для схвалення та керування обміном інформацією (якщо вибрано)

No: 10

Name: ca_3_odp_03

Type: integer

Default: 30

Визначено частоту, з якою необхідно переглядати та оновлювати угоди

4.3.1. ВЗАЄМОДІЯ СИСТЕМ- НЕЗАХИЩЕНІ З'ЄДНАННЯ СИСТЕМИ (CA-3(1))

No: 1

Name: ca_3_1_01

Type: string

Default: nil

ВЗАЄМОДІЯ СИСТЕМ- НЕЗАХИЩЕНІ З'ЄДНАННЯ СИСТЕМИ [Вилучено: Включено до SC-07(25)]. CA-03(02) ВЗАЄМОДІЯ СИСТЕМ - ЗАХИЩЕНІ З'ЄДНАННЯ СИСТЕМИ [Вилучено: Включено до SC-07(26)]

4.3.2. ЗАХИЩЕНІ З'ЄДНАННЯ СИСТЕМИ (CA-3(2))

Немає параметрів для цього контролю.

4.3.3. НЕСЕКРЕТНІ З'ЄДНАННЯ СИСТЕМИ БЕЗПЕКИ, ЩО НЕ Є НАЦІОНАЛЬНИМИ (CA-3(3))

No: 1

Name: ca_3_3_01

Type: string

Default: nil

ВЗАЄМОДІЯ СИСТЕМ - НЕСЕКРЕТНІ З'ЄДНАННЯ СИСТЕМИ БЕЗПЕКИ, ЩО НЕ Є НАЦІОНАЛЬНИМИ
[Вилучено: Включено до SC-07(27)]

4.3.4. ПІДКЛЮЧЕННЯ ДО ЗАГАЛЬНОДОСТУПНИХ МЕРЕЖ (СА-3(4))

No: 1
Name: ca_3_4_01
Type: string
Default: nil

ВЗАЄМОДІЯ СИСТЕМ - ПІДКЛЮЧЕННЯ ДО ЗАГАЛЬНОДОСТУПНИХ МЕРЕЖ [Вилучено: Включено до SC-07(28)]

4.3.5. ОБМЕЖЕННЯ ЗВ'ЯЗКУ ІЗ ЗОВНІШНІМИ СИСТЕМАМИ (СА-3(5))

No: 1
Name: ca_3_5_01
Type: string
Default: nil

ВЗАЄМОДІЯ СИСТЕМ - ОБМЕЖЕННЯ ЗВ'ЯЗКУ ІЗ ЗОВНІШНІМИ СИСТЕМАМИ [Вилучено: Включено до SC-07(05)]

4.3.6. ПЕРЕДАЧА ДОЗВОЛІВ (СА-3(6))

Переконалися, що особи або системи, які передають дані між взаємопов'язаними системами, мають необхідні повноваження (тобто дозволи на запис або привілеї), до прийняття таких даних.

No: 1
Name: ca_3_6_01
Type: list
Default: ["admin", "security_officer"]

Особи або системи, які передають дані між системами, що з'єднуються, мають необхідні повноваження (тобто дозволи на запис або привілеї) перед тим, як приймати такі дані

4.3.7. ТРАНЗИТИВНИЙ ОБМІН ІНФОРМАЦІЄЮ (СА-3(7))

а) Визначити транзитивний (низхідний) обмін інформацією з іншими системами через системи, визначені в СА-3а; б) Вжити заходів для забезпечення припинення транзитивного (низхідного) обміну інформацією, коли засоби контролю ідентифікованих транзитивних (низхідних) систем не можуть бути перевірені або підтверджені.

No: 1
Name: ca_3_7_b
Type: string
Default: "автоматизований засіб моніторингу"

Вживаються заходи для забезпечення припинення транзитного обміну інформацією, коли засоби контролю над ідентифікованими транзитними системами не можуть бути перевірені або підтверджені

4.4. СЕРТИФІКАЦІЯ БЕЗПЕКИ (СА-4)

No: 1

Name: ca_4_01

Type: string

Default: nil

СЕРТИФІКАЦІЯ БЕЗПЕКИ [Вилучено: Включено до СА-02]

4.5. ПЛАН УСУНЕННЯ НЕДОЛІКІВ ТА КОНТРОЛЬНІ ПОКАЗНИКИ (СА-5)

а. Розробити для системи план усунення недоліків та контрольні показники з метою документування запланованих коригувальних дій організації для усунення недоліків і зауважень, які виявлені в ході оцінювання заходів захисту, а також для зменшення або усунення відомих вразливостей у системі.

б. Оновлювати чинний план усунення недоліків та контрольні показники з [Призначення: визначеною організацією частотою] на основі результатів оцінювання заходів, незалежних аудитів та постійного моніторингу.

No: 1

Name: ca_5_a

Type: list

Default: ["login", "logout", "failed_attempt"]

Розроблено план усунення недоліків та контрольні показники для системи, та задокументовано заплановані дії організації з коригування, спрямовані на усунення недоліків та зауважень, виявлених під час оцінки заходів захисту, а також на зменшення або усунення відомих вразливостей в системі

No: 2

Name: ca_5_b

Type: string

Default: "щорічно"

Існуючий план оновлюється частота на основі результатів оцінювання заходів, незалежних аудитів та постійного моніторингу

No: 3

Name: ca_5_odp

Type: integer

Default: 30

Визначено частоту оновлення чинного плану усунення недоліків та контрольних показників на основі результатів оцінювання заходів захисту, незалежних аудитів та постійного моніторингу

4.5.1. АВТОМАТИЗАЦІЯ ПІДТРИМКИ ЗАДЛЯ ТОЧНОСТІ ТА ВЖИВАНOSTІ (СА-5(1))

No: 1

Name: ca_5_1_01

Type: string

Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для забезпечення точності, актуальності та доступності плану усунення недоліків і основних етапів для системи

No: 2

Name: ca_5_1_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, які використовуються для забезпечення точності, актуальності та доступності плану усунення недоліків і основних етапів для системи

4.6. АКРЕДИТАЦІЯ (CA-6)

- a. Призначити старшого керівника, який відповідає за систему;
- b. Призначити старшого керівника, відповідального за систему, та будь-які загальні заходи захисту, успадковані системою.
- c. Переконаватися перед початком функціонування системи, що посадова особа:
 1. акредитує загальні заходи захисту, що успадковані системою;
 2. акредитує систему на функціонування за призначенням.
- d. Переконайтеся, що посадова особа, яка акредитує засоби захисту, дозволяє використання цих засобів захисту для успадкування організаційними системами;
- e. Оновлювати акредитацію [Призначення: з визначеною організацією частотою].

No: 1

Name: ca_6_a

Type: string

Default: nil

Призначено старшого керівника, який відповідає за систему; CA-06(b) призначено старшого керівника, відповідального за систему, та будь-які загальні заходи захисту, успадковані системою

No: 2

Name: ca_6_c_01

Type: list

Default: ["admin", "security_officer"]

Перед початком функціонування системи посадова особа, яка відповідає за систему, акредитує загальні заходи захисту, що успадковані системою

No: 3

Name: ca_6_c_02

Type: list

Default: ["admin", "security_officer"]

Перед початком функціонування системи посадова особа, яка відповідає за систему, акредитує систему на функціонування за призначенням

No: 4

Name: ca_6_d

Type: list

Default: ["admin", "security_officer"]

Посадова особа, яка акредитує заходи захисту, дозволяє використання цих заходів захисту для успадкування системами організації

No: 5

Name: ca_6_e

Type: string

Default: "щорічно"

Акредитації оновлюються частота

No: 6
 Name: ca_6_odp
 Type: integer
 Default: 30

Визначено частоту, з якою потрібно оновлювати акредитації

4.6.1. СПІЛЬНА АКРЕДИТАЦІЯ - ОДНА І ТА САМА ОРГАНІЗАЦІЯ (CA-6(1))

No: 1
 Name: ca_6_1_01
 Type: string
 Default: nil

Для системи впроваджено спільний процес акредитації

No: 2
 Name: ca_6_1_02
 Type: list
 Default: ["admin", "security_officer"]

Спільний процес акредитації, який використовується в системі, включає в себе кілька посадових осіб з однієї організації, які надають акредитацію

4.6.2. СПІЛЬНА АКРЕДИТАЦІЯ - РІЗНІ ОРГАНІЗАЦІЇ (CA-6(2))

Впровадити спільний процес акредитації для системи, що має кількох уповноважених посадових осіб з принаймні однією уповноваженою посадовою особою з організації, яка є зовнішньою організацією, що здійснює акредитацію.

No: 1
 Name: ca_6_2_01
 Type: string
 Default: nil

Для системи впроваджено спільний процес акредитації

No: 2
 Name: ca_6_2_02
 Type: list
 Default: ["admin", "security_officer"]

Спільний процес акредитації, що використовується в системі, передбачає наявність кількох посадових осіб, які надають акредитації, принаймні одна з яких є посадовою особою з організації, що не належить до організації, яка здійснює акредитацію

4.7. БЕЗПЕРЕРВНИЙ МОНІТОРИНГ (CA-7)

Розробити стратегію безперервного моніторингу безпеки та приватності й упровадити програму безперервного моніторингу безпеки та приватності, яка охоплює:

- встановлення показників безпеки та приватності, які необхідно відстежувати: [Призначення: визначені організацією метрики];
- встановлення [Призначення: визначена організацією частота] для моніторингу та [Призначення: визначена організацією частота] для безперервного оцінювання ефективності заходів захисту;
- поточні оцінювання заходів захисту відповідно до стратегії безперервного моніторингу

організації;
 d. постійний моніторинг стану безпеки та приватності відповідно до встановлених організацією метрик і відповідно до стратегії безперервного моніторингу організації;
 e. зіставлення та аналіз інформації, отриманої в результаті оцінювання та моніторингу безпеки та приватності;
 f. дії реагування за результатами аналізу інформації, пов'язаної з безпекою та приватністю;
 g. повідомлення про статус безпеки та приватності системи [Призначення: визначені організацією персонал або ролі] з [Призначення: визначеною організацією частотою].

No: 1

Name: ca_7_01

Type: string

Default: nil

Розроблено стратегію безперервного моніторингу на системному рівні; CA-07[02] безперервний моніторинг на рівні системи здійснюється відповідно до стратегії безперервного моніторингу на рівні організації

No: 2

Name: ca_7_a

Type: string

Default: nil

Безперервний моніторинг на рівні системи включає встановлення наступних метрик на рівні системи, які підлягають моніторингу: метрики системного рівня

No: 3

Name: ca_7_b_01

Type: integer

Default: 30

Безперервний моніторинг на рівні системи включає встановлені частоти для моніторингу ефективності заходів захисту

No: 4

Name: ca_7_b_02

Type: integer

Default: 30

Безперервний моніторинг на рівні системи включає встановлені частоти для оцінки ефективності заходів захисту

No: 5

Name: ca_7_c

Type: string

Default: nil

Безперервний моніторинг на рівні системи включає поточні контрольні оцінки відповідно до стратегії безперервного моніторингу

No: 6

Name: ca_7_d

Type: string

Default: nil

Безперервний моніторинг на рівні системи включає постійний моніторинг визначених системою та організацією показників відповідно до стратегії безперервного моніторингу

No: 7

Name: ca_7_e

Type: string

Default: nil

Безперервний моніторинг на рівні системи включає зіставлення та аналіз інформації, отриманої в результаті оцінювання та моніторингу

No: 8
 Name: ca_7_f
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Безперервний моніторинг на рівні системи включає в себе дії з реагування на результати аналізу інформації, пов'язаної з безпекою та приватністю

No: 9
 Name: ca_7_g_01
 Type: list
 Default: ["admin", "security_officer"]

Безперервний моніторинг на рівні системи включає повідомлення про статус безпеки системи для персоналу або ролей частота

No: 10
 Name: ca_7_g_02
 Type: list
 Default: ["admin", "security_officer"]

Безперервний моніторинг на рівні системи включає повідомлення про стан конфіденційності системи персоналу або ролям частота

No: 11
 Name: ca_7_odp_01
 Type: string
 Default: nil

Визначено метрики системного рівня, які підлягають моніторингу

No: 12
 Name: ca_7_odp_02
 Type: integer
 Default: 30

Визначено частоту, з якою слід моніторити ефективність заходів захисту

No: 13
 Name: ca_7_odp_03
 Type: integer
 Default: 30

Визначено частоту, з якою слід оцінювати ефективність заходів захисту

No: 14
 Name: ca_7_odp_04
 Type: list
 Default: ["admin", "security_officer"]

Визначено персонал або ролі, яким повідомляється про стан безпеки системи

No: 15
 Name: ca_7_odp_05
 Type: integer
 Default: 30

Визначено частоту, з якою повідомляється про стан безпеки системи

No: 16
 Name: ca_7_odp_06

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, яким повідомляється про стан конфіденційності системи

No: 17

Name: ca_7_odp_07

Type: integer

Default: 30

Визначено частоту, з якою повідомляється про стан конфіденційності системи

4.7.1. НЕЗАЛЕЖНЕ ОЦІНЮВАННЯ (CA-7(1))

No: 1

Name: ca_7_1_01

Type: string

Default: nil

Для постійного моніторингу заходів захисту в системі залучаються незалежні експертів або групи з оцінювання

4.7.2. ВИДИ ОЦІНОК (CA-7(2))

No: 1

Name: ca_7_2_01

Type: string

Default: nil

БЕЗПЕРЕРВНИЙ МОНІТОРИНГ - ВИДИ ОЦІНОК [Вилучено: Включено до CA-02]

4.7.3. АНАЛІЗ ТЕНДЕНЦІЙ (CA-7(3))

Впровадити аналіз тенденцій, щоб визначити, чи потрібно змінювати реалізацію заходу захисту, частоту постійних моніторингових заходів і види діяльності, що використовуються в процесі безперервного моніторингу, на основі емпіричних даних.

No: 1

Name: ca_7_3_01

Type: string

Default: nil

Аналіз тенденцій використовується для визначення того, чи потрібно змінювати реалізацію заходів захисту, які використовуються в процесі безперервного моніторингу, на основі емпіричних даних

No: 2

Name: ca_7_3_02

Type: integer

Default: 30

Аналіз тенденцій застосовується для того, щоб на основі емпіричних даних визначити, чи потрібно змінювати частоту постійного моніторингу

No: 3

Name: ca_7_3_03

Type: string

Default: nil

Аналіз тенденцій застосовується для того, щоб на основі емпіричних даних визначити, чи потрібно змінювати види діяльності, які використовуються в процесі безперервного моніторингу

4.7.4. МОНІТОРИНГ РИЗИКУ (CA-7(4))

Забезпечити моніторинг ризиків, що є невід'ємною частиною стратегії постійного моніторингу та включає:

- (a) моніторинг ефективності;
- (b) моніторинг відповідності;
- (c) моніторинг змін.

No: 1

Name: ca_7_4_01

Type: integer

Default: 30

Моніторинг ризиків є невід'ємною частиною стратегії безперервного моніторингу

No: 2

Name: ca_7_4_a

Type: string

Default: nil

Моніторинг ефективності включено до моніторингу ризиків

No: 3

Name: ca_7_4_b

Type: string

Default: nil

Моніторинг відповідності включено до моніторингу ризиків

No: 4

Name: ca_7_4_c

Type: string

Default: nil

Моніторинг змін включений до моніторингу ризиків

4.7.5. УЗГОДЖЕНИЙ АНАЛІЗ (CA-7(5))

Застосуйте наступні дії, щоб перевірити, що політики встановлені, а запроваджені заходи захисту працюють узгоджено: [Призначення: дії, визначені організацією].

No: 1

Name: ca_7_5_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дії використовуються для перевірки того, що політики встановлено

No: 2

Name: ca_7_5_02

Type: list

Default: ["login", "logout", "failed_attempt"]

Дії використовуються для перевірки того, що впроваджені заходи захисту працюють узгоджено

No: 3

Name: ca_7_5_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначені дії для підтвердження того, що політики встановлені

No: 4
 Name: ca_7_5_odp_02
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Визначені дії для підтвердження того, що впроваджені заходи захисту працюють узгоджено

4.7.6. БЕЗПЕРЕРВНИЙ МОНІТОРИНГУ (СА-7(6))

Забезпечити точність, актуальність і доступність результатів моніторингу для системи за допомогою [Завдання: автоматизовані механізми, визначені організацією]

No: 1
 Name: ca_7_6_01
 Type: string
 Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для забезпечення точності, актуальності та доступності результатів моніторингу системи

No: 2
 Name: ca_7_6_odp
 Type: string
 Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми забезпечення точності, актуальності та доступності результатів моніторингу системи

4.8. ТЕСТУВАННЯ НА ПРОНИКНЕННЯ (СА-8)

Проводити тестування на проникнення з [Призначення: визначеною організацією частотою] у [Призначення: визначеній організацією інформаційній системі чи системному компоненті].

No: 1
 Name: ca_8_01
 Type: integer
 Default: 30

Проводиться тестування на проникнення з частотою у системі

No: 2
 Name: ca_8_odp_01
 Type: integer
 Default: 30

Визначено частоту з якою проводить тестування на проникнення

No: 3
 Name: ca_8_odp_02
 Type: string
 Default: nil

Визначено систему у якій проводить тестування на проникнення

4.8.1. НЕЗАЛЕЖНА КОМАНДА АБО АГЕНТ НА ПРОНИКНЕННЯ (СА-8(1))

No: 1
 Name: ca_8_1_01
 Type: string
 Default: nil

Для проведення тестування на проникнення в систему або компонентів системи залучається незалежний агент або команда з тестування на проникнення

4.8.2. ЧЕРВОНА КОМАНДА (СА-8(2))

Використовувати наступні вправи червоної команди, для імітації спроб супротивників скомпрометувати системи організації відповідно до прийнятих правил ведення бойових дій: [Завдання: визначені організацією вправи червоної команди].

No: 1
 Name: ca_8_2_01
 Type: integer
 Default: 3

Залучити вправи червоної команди, щоб імітувати спроби супротивників скомпрометувати системи організації

No: 2
 Name: ca_8_2_odp
 Type: integer
 Default: 3

Визначено вправи червоної команди для імітації спроби супротивників скомпрометувати системи організації

4.8.3. МОЖЛИВОСТІ ПЕРЕВІРКИ НА ПРОНИКНЕННЯ (СА-8(3))

Впровадити процес тестування на проникнення, який охоплює [Призначення: визначену організацією частоту] [Вибір: з попередженням; без попередження] спроб обійти чи зламати заходи захисту, пов'язані з фізичними точками доступу до об'єкта.

No: 1
 Name: ca_8_3_odp_01
 Type: integer
 Default: 30

Визначено частоту спроби обійти або зламати заходи захисту, пов'язані з фізичними точками доступу до об'єкта в тестуванні на проникнення

No: 2
 Name: ca_8_3_odp_02
 Type: string
 Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {з попередженням; без попередження}

4.9. ВНУТРІШНІ З'ЄДНАННЯ СИСТЕМИ (СА-9)

- a. Авторизувати внутрішні підключення [Призначення: системні компоненти або класи компонентів, що організація визначила] до системи;
- b. Задокументувати, для кожного внутрішнього з'єднання, характеристики інтерфейсу, вимоги безпеки та приватності, а також характер переданої інформації;
- c. Розірвати внутрішні системні підключення після [Призначення: умови, визначені організацією];
- d. Переглядати [Призначення: частота, визначена організацією] постійну потребу в кожному внутрішньому з'єднанні.

No: 1

Name: ca_9_a

Type: string

Default: nil

Внутрішні підключення компонентів системи до системи є авторизовані

No: 2

Name: ca_9_b_01

Type: string

Default: nil

Для кожного внутрішнього з'єднання задокументовані характеристики інтерфейсу

No: 3

Name: ca_9_b_02

Type: string

Default: nil

Для кожного внутрішнього з'єднання задокументовані вимоги безпеки

No: 4

Name: ca_9_b_03

Type: string

Default: nil

Для кожного внутрішнього з'єднання задокументовані вимоги конфіденційності

No: 5

Name: ca_9_b_04

Type: string

Default: nil

Для кожного внутрішнього з'єднання задокументовані характер переданої інформації

No: 6

Name: ca_9_c

Type: string

Default: nil

Внутрішні з'єднання системи розриваються після виконання умов

No: 7

Name: ca_9_d

Type: string

Default: "щорічно"

Переглядається подальша потреба у кожному внутрішньому з'єднанні частота

No: 8

Name: ca_9_odp_01

Type: string

Default: nil

Визначено компоненти системи або класи компонентів, що потребують внутрішніх підключень до системи

No: 9

Name: ca_9_odp_02

Type: list

Default: []

Визначено умови, за яких необхідно розірвати внутрішні підключення

No: 10

Name: ca_9_odp_03

Type: integer

Default: 30

Визначено частоту, з якою необхідно переглядати постійну потребу в кожному внутрішньому з'єднанні

5. CM

Клас заходів захисту CM — УПРАВЛІННЯ КОНФІГУРАЦІЄЮ

Цей клас гарантує створення та підтримання базових налаштувань системи, а також строгий контроль за змінами в апаратному та програмному забезпеченні.

Перелік заходів захисту: Політика та процедури управління конфігурацією (CM-1); Базова конфігурація (CM-2); Перегляд та оновлення (CM-2(1)); Автоматизація підтримки задля точності та вживаності (CM-2(2)); Зберігання попередніх версій конфігурацій (CM-2(3)); Неавторизоване програмне забезпечення (CM-2(4)); Авторизоване програмне забезпечення (CM-2(5)); Розробка та середовище тестування (CM-2(6)); Конфігурація систем та компонентів для сфер з високим ризиком (CM-2(7)); Управління змінами конфігурації (CM-3); Автоматизоване документування, повідомлення та заборона внесення змін (CM-3(1)); Тестування, валідація та документування змін (CM-3(2)); Автоматизована реалізація змін (CM-3(3)); Представник безпеки (CM-3(4)); Автоматичне реагування безпеки (CM-3(5)); Управління засобами криптографічного захисту (CM-3(6)); Перегляд змін у системі (CM-3(7)); Запобігання чи обмеження змін конфігурації (CM-3(8)); Аналіз впливу на безпеку та приватність (CM-4); Відокремлені випробувальні середовища (CM-4(1)); Верифікація функцій безпеки та приватності (CM-4(2)); Обмеження доступу до зміни (CM-5); Аудит і здійснення автоматичного доступу (CM-5(1)); Перегляд змін у системі (CM-5(2)); Підписані компоненти (CM-5(3)); Подвійна авторизація (CM-5(4)); Обмеження повноважень для виробництва та експлуатації (CM-5(5)); Обмеження повноважень для бібліотек (CM-5(6)); Обмеження доступу до зміни вадження заходів захисту (CM-5(7)); Налаштування конфігурації (CM-6); Автоматизоване управління, застосування та верифікація (CM-6(1)); Налаштування конфігурації санкціоновані зміни (CM-6(2)); Демонстрація відповідності (CM-6(4)); Мінімально необхідна функціональність (CM-7); Періодичний перегляд (CM-7(1)); Заборона виконання програми (CM-7(2)); Відповідність реєстрації (CM-7(3)); Неавторизоване програмне забезпечення - чорний список (CM-7(4)); Авторизоване програмне забезпечення - білий список (CM-7(5)); Замкнуті середовища з обмеженими привілеями (CM-7(6)); Виконуваний код у захищеному середовищі (CM-7(7)); Бінарний або машинний виконуваний код (CM-7(8)); Заборона використання неавторизованого обладнання (CM-7(9)); Інвентаризація компонентів системи (CM-8); Оновлення під час встановлення та видалення (CM-8(1)); Автоматизована підтримка (CM-8(2)); Автоматизоване виявлення неавторизованих компонентів (CM-8(3)); Інформація про підзвітність (CM-8(4)); Інвентаризація компонентів системи дублювання компонентів обліку (CM-8(5)); Перевірені налаштування та затверджені відхилення (CM-8(6)); Централізоване сховище (CM-8(7)); Автоматизоване відстеження місця розташування (CM-8(8)); Призначення компонентів системам (CM-8(9));

План управління конфігурацією (СМ-9); Встановлення відповідальності (СМ-9(1)); Обмеження використання програмного забезпечення (СМ-10); Обмеження використання програмного забезпечення програмне забезпечення з відкритим вихідним кодом (СМ-10(1)); Встановлене користувачем програмне забезпечення (СМ-11); Встановлене користувачем програмне забезпечення попередження про несанкціоновану інсталяцію (СМ-11(1)); Встановлене користувачем програмне забезпечення встановлення програмного забезпечення з привілейованим статусом (СМ-11(2)); Встановлене користувачем програмне забезпечення автоматичне виконання і моніторинг (СМ-11(3)); Розташування інформації (СМ-12); Автоматизовані інструменти підтримки розташування інформації (СМ-12(1)); Відображення дій даних (СМ-13); Підписані компоненти (СМ-14).

5.1. Політика та процедури управління конфігурацією (СМ-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначених організацією персоналу або ролей]:

1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політики управління конфігурацією, яка:

2.

(а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance);

(b) відповідає чинним законам, нормативним документам, наказам, положенням, політикам, стандартам і керівним принципам; процедури, що сприяють реалізації політики управління конфігурацією та пов'язаних з нею заходів управління конфігурацією.

b. Призначити [Призначення: посадова особа, визначена організацією] для управління розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією.

c. Переглядати та оновлювати поточну політику управління конфігурацією:

1. Політика [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією];

2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].

No: 1

Name: cm_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику управління конфігурацією

No: 2

Name: cm_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика управління конфігурацією поширюється на персонал або ролі

No: 3

Name: cm_1_a_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблені та задокументовані процедури управління, що сприяють реалізації політики управління конфігурацією та пов'язаних з нею заходів управління конфігурацією

No: 4

Name: cm_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією; CM-01(c)[01][01] переглядається та оновлюється поточна політика управління конфігурацією частота; CM-01(c)[01][02] переглядається та оновлюється поточна політика управління конфігурацією після події; CM-01(c)[02][01] переглядаються та оновлюються поточні процедури управління конфігурацією частота; CM-01(c)[02][02] переглядаються та оновлюються поточні процедури управління конфігурацією після події; ЗНАЧЕННЯ конфігурацією

No: 5

Name: cm_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на яких поширюється політика управління конфігурацією

No: 6

Name: cm_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на яких поширюється процедури управління конфігурацією

No: 7

Name: cm_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: cm_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка управляє розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією

No: 9

Name: cm_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика управління конфігурацією

No: 10

Name: cm_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, після яких переглядається та оновлюється поточна політика управління конфігурацією

No: 11

Name: cm_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури управління конфігурацією

No: 12

Name: cm_1_odp_08

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, після яких переглядаються та оновлюються поточні процедури управління конфігурацією

5.2. БАЗОВА КОНФІГУРАЦІЯ (СМ-2)

a. Розробити, задокументувати та підтримувати за допомогою заходів конфігурації поточні базові налаштування системи.

b. Переглядати та оновлювати базові налаштування системи:

1. з [Призначення: визначеною організацією частотою];
2. за потреби внаслідок [Призначення: визначених організацією обставин];
3. коли встановлені нові або оновлені компоненти системи.

No: 1

Name: cm_2_a_01

Type: string

Default: nil

Розроблено та задокументовано поточні базові налаштування системи

No: 2

Name: cm_2_a_02

Type: string

Default: nil

Поточні базові налаштування системи підтримуються за допомогою заходів конфігурації

No: 3

Name: cm_2_b_01

Type: string

Default: "щорічно"

Переглядаються та оновлюються базові налаштування системи частота

No: 4

Name: cm_2_b_02

Type: string

Default: nil

Переглядаються та оновлюються базові налаштування системи після подій

No: 5

Name: cm_2_b_03

Type: string

Default: nil

Переглядаються та оновлюються базові налаштування системи коли встановлюються або модернізуються компоненти системи

No: 6

Name: cm_2_odp_01

Type: integer

Default: 30

Визначено частоту налаштувань; перегляду та оновлення базових

No: 7

Name: cm_2_odp_02

Type: string

Default: nil

Визначено обставини, що вимагають перегляду та оновлення базових налаштувань

5.2.1. ПЕРЕГЛЯД ТА ОНОВЛЕННЯ (СМ-2(1))

No: 1
Name: cm_2_1_01
Type: string
Default: nil

БАЗОВА КОНФІГУРАЦІЯ - ПЕРЕГЛЯД ТА ОНОВЛЕННЯ [Вилучено: Включено до СМ-02]

5.2.2. АВТОМАТИЗАЦІЯ ПІДТРИМКИ ЗАДЛЯ ТОЧНОСТІ ТА ВЖИВАНOSTІ (СМ-2(2))

Підтримувати актуальність, повноту, точність і доступність базової конфігурації системи за допомогою [Призначення: автоматизовані механізми, визначені організацією].

No: 1
Name: cm_2_2_02
Type: string
Default: "автоматизований засіб моніторингу"

Повнота базової конфігурації системи підтримується за допомогою автоматизовані механізми

No: 2
Name: cm_2_2_03
Type: string
Default: "автоматизований засіб моніторингу"

Точність базової конфігурації системи підтримується за допомогою автоматизовані механізми

No: 3
Name: cm_2_2_04
Type: string
Default: "автоматизований засіб моніторингу"

Доступність базової конфігурації системи підтримується за допомогою автоматизовані механізми

No: 4
Name: cm_2_2_odp
Type: string
Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми підтримки базової конфігурації системи; СМ-02(02)[01] актуальність базової конфігурації системи підтримується за допомогою автоматизовані механізми

5.2.3. ЗБЕРІГАННЯ ПОПЕРЕДНІХ ВЕРСІЙ КОНФІГУРАЦІЙ (СМ-2(3))

Зберігати [Призначення: кількість, визначена організацією] попередніх версій базових конфігурацій системи для підтримки відкату.

No: 1
Name: cm_2_3_01
Type: string
Default: nil

Визначено попередні версії базових конфігурацій системи необхідні для підтримки відкату зберігати попередні версії для підтримки відкату

5.2.4. НЕАВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ (СМ-2(4))

Немає параметрів для цього контролю.

5.2.5. АВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ (СМ-2(5))

No: 1

Name: cm_2_5_01

Type: string

Default: nil

БАЗОВА КОНФІГУРАЦІЯ - АВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ [Вилучено: Включено до СМ-07(05)]

5.2.6. РОЗРОБКА ТА СЕРЕДОВИЩЕ ТЕСТУВАННЯ (СМ-2(6))

Підтримувати базову конфігурацію для розробки системи та тестових середовищ, які керуються окремо від робочої базової конфігурації.

No: 1

Name: cm_2_6_01

Type: string

Default: nil

Підтримується базова конфігурація для розробки системи, які керуються окремо від робочої базової конфігурації

No: 2

Name: cm_2_6_02

Type: string

Default: nil

Підтримується базова конфігурація для розробки тестових середовищ, які керуються окремо від робочої базової конфігурації

5.2.7. КОНФІГУРАЦІЯ СИСТЕМ ТА КОМПОНЕНТІВ ДЛЯ СФЕР З ВИСОКИМ РИЗИКОМ (СМ-2(7))

(a) Видавати [Призначення: визначених організацією систем або компонентів систем] з [Призначенням: визначеними організацією конфігураціями] особам, що перебувають у місцях, які організація вважає місцями зі значним ризиком;

(b) Застосувати [Призначення: визначені організацією запобіжні заходи безпеки] до компонентів, коли особи повертаються з поїздки.

No: 1

Name: cm_2_7_a

Type: list

Default: ["admin", "security_officer"]

Системи або компоненти системи з конфігураціями видаються особам, що перебувають у місцях, які організація вважає, становлять значний ризик

No: 2

Name: cm_2_7_b

Type: list

Default: ["admin", "security_officer"]

Заходи безпеки застосовуються до систем або компонентів системи, коли особи повертаються з поїздки

No: 3

Name: cm_2_7_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено системи або компоненти систем, які мають видаватися особам, що перебувають у місцях зі значним ризиком

5.3. УПРАВЛІННЯ ЗМІНАМИ КОНФІГУРАЦІЇ (СМ-3)

- a. Визначити типи змін у системі, які контролюються конфігурацією.
- b. Переглядати запропоновані зміни в конфігурації, контрольовані системою, і схвалити або відхилити ці зміни з явним урахуванням аналізу наслідків безпеки.
- c. Документувати рішення зі зміни конфігурації системи.
- d. Впровадити схвалені зміни конфігурації в систему.
- e. Зберігати записи змін конфігурації системі впродовж [Призначення: певного періоду часу, визначеного організацією].
- f. Здійснювати моніторинг і аналіз дій, пов'язаних зі змінами конфігурації системи.
- g. Координувати та впроваджувати нагляд за діяльністю з управління змінами конфігурації за допомогою [Призначення: елементу управління змінами конфігурації, визначеного організацією], який викликається [Вибір (один або кілька): [Призначення: з визначеною організацією частотою]; [Призначення: визначені організацією умови зміни конфігурації]].

No: 1

Name: cm_3_b_01

Type: string

Default: nil

Розглядаються запропоновані зміни в конфігурації, що контролюються системою

No: 2

Name: cm_3_b_02

Type: string

Default: nil

Запропоновані зміни в конфігурації, що контролюються системою, схвалюються або відхиляються з урахуванням аналізу наслідків безпеки

No: 3

Name: cm_3_c

Type: string

Default: nil

Рішення про зміну конфігурації системи документуються

No: 4

Name: cm_3_d

Type: string

Default: nil

Впроваджуються схвалені зміни до конфігурації в систему

No: 5

Name: cm_3_e

Type: integer

Default: 30

Записи про зміни конфігурації у системі зберігаються протягом <період часу CM-03_ODP[01]>

No: 6

Name: cm_3_f_01

Type: string

Default: nil

Здійснюється моніторинг конфігурації системи

No: 7

Name: cm_3_f_02

Type: string

Default: nil

Здійснюється аналіз дій, пов'язаних зі змінами конфігурації системи

No: 8

Name: cm_3_g_01

Type: string

Default: nil

Діяльність з управління змінами конфігурації координується та контролюється елемент управління

No: 9

Name: cm_3_odp_01

Type: integer

Default: 30

Визначено період часу, протягом якого зберігатимуться записи про зміни конфігурації

No: 10

Name: cm_3_odp_02

Type: string

Default: nil

Визначено елементи управління змінами конфігурації, відповідальні за координацію та нагляд за діяльністю з управління змінами

No: 11

Name: cm_3_odp_03

Type: list

Default: []

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {частота; коли умови}

No: 12

Name: cm_3_odp_04

Type: integer

Default: 30

Визначено частоту, з якою викликаються елементи управління змінами конфігурації (якщо вибрано)

No: 13

Name: cm_3_odp_05

Type: list

Default: []

Визначено умови, за яких викликаються елементи управління змінами конфігурації (якщо вибрано); CM-03(a) визначено та задокументовано типи змін до системи, які контролюються конфігурацією

5.3.1. АВТОМАТИЗОВАНЕ ДОКУМЕНТУВАННЯ, ПОВІДОМЛЕННЯ ТА ЗАБОРОНА ВНЕСЕННЯ ЗМІН (CM-3(1))

No: 1

Name: cm_3_1_a

Type: string

Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для документування запропонованих змін до системи

No: 2

Name: cm_3_1_b

Type: string

Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для повідомлення уповноважені органи про запропоновані зміни в системі та запиту на затвердження змін

No: 3

Name: cm_3_1_c

Type: integer

Default: 30

Автоматизовані механізми використовуються для виділення запропонованих змін до системи, які не були схвалені або відхилені протягом період часу

No: 4

Name: cm_3_1_d

Type: string

Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для заборони внесення змін до системи до отримання відповідних погоджень

No: 5

Name: cm_3_1_e

Type: string

Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для документування всіх змін в системі

No: 6

Name: cm_3_1_f

Type: list

Default: ["admin", "security_officer"]

Автоматизовані механізми використовуються для повідомлення персоналу про завершення погоджених змін у системі

No: 7

Name: cm_3_1_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено механізми, що використовуються для автоматизації управління змінами конфігурації

No: 8

Name: cm_3_1_odp_02

Type: string

Default: nil

Визначені уповноважені органи, про які необхідно повідомляти та узгоджувати пропоновані зміни в системі

No: 9

Name: cm_3_1_odp_03

Type: integer

Default: 30

Визначено період часу, після якого слід виділяти зміни, які не були схвалені або відхилені

No: 10

Name: cm_3_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено персонал, який буде повідомлений про завершення затверджених змін

5.3.2. ТЕСТУВАННЯ, ВАЛІДАЦІЯ ТА ДОКУМЕНТУВАННЯ ЗМІН (СМ-3(2))

Тестувати, перевіряти та документувати зміни в системі до повної їх реалізації.

No: 1

Name: cm_3_2_01

Type: string

Default: nil

Зміни в системі тестуються перед повним впровадженням змін

No: 2

Name: cm_3_2_02

Type: string

Default: nil

Зміни в системі перевіряються перед повним впровадженням змін

No: 3

Name: cm_3_2_03

Type: string

Default: nil

Зміни в системі документуються перед повним впровадженням змін

5.3.3. АВТОМАТИЗОВАНА РЕАЛІЗАЦІЯ ЗМІН (СМ-3(3))

Внести зміни в поточний базову план системи та розгорнути оновлений базовий план на встановленій базі за допомогою [Призначення: автоматизовані механізми, визначені організацією].

No: 1

Name: cm_3_3_01

Type: string

Default: "автоматизований засіб моніторингу"

Зміни до поточного базового плану системи реалізуються за допомогою автоматизовані механізми

No: 2

Name: cm_3_3_02

Type: string

Default: "автоматизований засіб моніторингу"

Оновлений базовий план розгортається по всій встановленій базі за допомогою автоматизовані механізми

No: 3

Name: cm_3_3_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми для внесення змін та розгортання оновленого базового плану по всій встановленій базі

5.3.4. ПРЕДСТАВНИК БЕЗПЕКИ (СМ-3(4))

Вимагати від [Призначення: визначеного організацією представника з інформаційної безпеки] бути членом [Призначення: визначеного організацією елементу керування зміною конфігурацій].

No: 1

Name: cm_3_4_01

Type: string

Default: nil

Представники безпеки повинні бути членами елемента керування змінами конфігурації

No: 2

Name: cm_3_4_02

Type: string

Default: nil

Представники конфіденційності повинні бути членами елемента керування змінами конфігурації

No: 3

Name: cm_3_4_odp_01

Type: string

Default: nil

Визначено представника з безпеки, який має бути членом елементу керування змінами конфігурації

No: 4

Name: cm_3_4_odp_02

Type: string

Default: nil

Визначено представника з конфіденційності, який має бути членом елементу керування змінами конфігурації

No: 5

Name: cm_3_4_odp_03

Type: string

Default: nil

Визначено елемент керування змінами конфігурації, членами якого мають бути представники безпеки та конфіденційності

5.3.5. АВТОМАТИЧНЕ РЕАГУВАННЯ БЕЗПЕКИ (СМ-3(5))

Реалізувати автоматичне [Призначення: визначене організацією реагування безпеки], якщо базова конфігурація системи змінюється несанкціонованим чином.

No: 1
 Name: cm_3_5_01
 Type: string
 Default: nil

Реагування безпеки автоматично застосовуються, якщо базова конфігурація системи змінюється несанкціонованим чином

No: 2
 Name: cm_3_5_odp
 Type: string
 Default: nil

Визначено реагування безпеки, які мають бути застосовані автоматично

5.3.6. УПРАВЛІННЯ ЗАСОБАМИ КРИПТОГРАФІЧНОГО ЗАХИСТУ (СМ-3(6))

Забезпечити, щоб криптографічні механізми, які використовуються для забезпечення відповідних заходів захисту перебували під управлінням конфігурацією [Призначення: визначених організацією заходів безпеки].

No: 1
 Name: cm_3_6_01
 Type: string
 Default: "AES-256-GCM"

Криптографічні механізми, які використовуються для забезпечення відповідних заходів захисту перебувають під управлінням конфігурацією заходи захисту

No: 2
 Name: cm_3_6_odp
 Type: string
 Default: nil

Визначено заходи захисту

5.3.7. ПЕРЕГЛЯД ЗМІН У СИСТЕМІ (СМ-3(7))

Перегляньте зміни в системі [Призначення: частота, визначена організацією] або коли [Призначення: обставини, визначені організацією], щоб визначити, чи відбулися неавторизовані зміни.

No: 1
 Name: cm_3_7_01
 Type: string
 Default: "щорічно"

Зміни в системі переглядаються частота або за обставин, щоб визначити, чи відбулися неавторизовані зміни

No: 2
 Name: cm_3_7_odp_01
 Type: integer
 Default: 30

Визначено частоту, з якою необхідно переглядати зміни

No: 3
 Name: cm_3_7_odp_02

Type: string

Default: nil

Визначено обставини, за яких зміни мають бути переглянуті

5.3.8. ЗАПОБІГАННЯ ЧИ ОБМЕЖЕННЯ ЗМІН КОНФІГУРАЦІЇ (СМ-3(8))

Запобігати або обмежити зміни конфігурації системи за таких обставин: [Призначення: обставини, визначені організацією].

No: 1

Name: cm_3_8_01

Type: string

Default: nil

Зміни конфігурації системи запобігають або обмежують за обставин

No: 2

Name: cm_3_8_odp

Type: string

Default: nil

Визначено обставини, за яких зміни мають бути запобіжені або обмежені

5.4. АНАЛІЗ ВПЛИВУ НА БЕЗПЕКУ ТА ПРИВАТНІСТЬ (СМ-4)

Аналізувати зміни в системі, щоб визначити потенційну загрозу безпеці та приватності перед реалізацією змін.

No: 1

Name: cm_4_01

Type: string

Default: nil

Аналізуються зміни в системі, щоб визначити потенційну загрозу безпеці перед реалізацією змін

No: 2

Name: cm_4_02

Type: string

Default: nil

Аналізуються зміни в системі, щоб визначити потенційну загрозу конфіденційності перед реалізацією змін

5.4.1. ВІДОКРЕМЛЕНІ ВИПРОБУВАЛЬНІ СЕРЕДОВИЩА (СМ-4(1))

No: 1

Name: cm_4_1_01

Type: string

Default: nil

Зміни в системі аналізуються в окремому тестовому середовищі перед впровадженням в операційному середовищі

No: 2

Name: cm_4_1_02

Type: string

Default: nil

Зміни в системі аналізуються на предмет впливу на безпеку через недоліки

No: 3

Name: cm_4_1_03

Type: string

Default: nil

Зміни в системі аналізуються на предмет впливу на конфіденційність через недоліки

No: 4

Name: cm_4_1_04

Type: string

Default: nil

Зміни в системі аналізуються на предмет впливу на безпеку через слабкості

No: 5

Name: cm_4_1_05

Type: string

Default: nil

Зміни в системі аналізуються на предмет впливу на конфіденційність через слабкості

No: 6

Name: cm_4_1_06

Type: string

Default: nil

Зміни в системі аналізуються на предмет впливу на безпеку через несумісність

No: 7

Name: cm_4_1_07

Type: string

Default: nil

Зміни в системі аналізуються на предмет впливу на конфіденційність через несумісність

No: 8

Name: cm_4_1_08

Type: string

Default: nil

Зміни в системі аналізуються на предмет впливу на безпеку через навмисне спричинення шкоди

No: 9

Name: cm_4_1_09

Type: string

Default: nil

Зміни в системі аналізуються на предмет впливу на конфіденційність через навмисне спричинення шкоди

5.4.2. ВЕРИФІКАЦІЯ ФУНКЦІЙ БЕЗПЕКИ ТА ПРИВАТНОСТІ (СМ-4(2))

Після змін у системі переконайтеся, що відповідні заходи захисту реалізовано правильно і вони функціонують належним чином та дають бажаний результат щодо дотримання вимог безпеки та приватності для системи.

No: 1

Name: cm_4_2_01

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, реалізовані правильно з точки зору відповідності вимогам безпеки системи після внесення змін до системи

No: 2

Name: cm_4_2_02

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, реалізовані правильно з точки зору відповідності вимогам конфіденційності системи після внесення змін до системи

No: 3

Name: cm_4_2_03

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, функціонують належним чином з точки зору відповідності вимогам безпеки системи після внесення змін до системи

No: 4

Name: cm_4_2_04

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, функціонують належним чином з точки зору відповідності вимогам конфіденційності системи після внесення змін до системи

No: 5

Name: cm_4_2_05

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, дають бажаний результат з точки зору відповідності вимогам безпеки системи після внесення змін до системи

No: 6

Name: cm_4_2_06

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, дають бажаний результат з точки зору відповідності вимогам конфіденційності системи після внесення змін до системи; ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

5.5. ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ (СМ-5)

Визначити, задокументувати, затвердити та забезпечити застосування фізичних і логічних обмежень доступу, пов'язаних зі змінами в системі.

No: 1

Name: cm_5_01

Type: string

Default: nil

Визначені та задокументовані фізичні обмеження доступу, пов'язані зі змінами в системі

No: 2

Name: cm_5_02

Type: string

Default: nil

Затверджені фізичні обмеження доступу, пов'язані зі змінами в системі

No: 3

Name: cm_5_03

Type: string

Default: nil

Застосовуються фізичні обмеження доступу, пов'язані зі змінами в системі

No: 4

Name: cm_5_04

Type: string

Default: nil

Визначені та задокументовані логічні обмеження доступу, пов'язані зі змінами в системі

No: 5

Name: cm_5_05

Type: string

Default: nil

Затверджені логічні обмеження доступу, пов'язані зі змінами в системі

No: 6

Name: cm_5_06

Type: string

Default: nil

Застосовуються логічні обмеження доступу, пов'язані зі змінами в системі

5.5.1. АУДИТ І ЗДІЙСНЕННЯ АВТОМАТИЧНОГО ДОСТУПУ (СМ-5(1))

No: 1

Name: cm_5_1_a

Type: string

Default: nil

Обмеження доступу до змін застосовуються за допомогою автоматизованих механізмів

No: 2

Name: cm_5_1_b

Type: string

Default: nil

Автоматично формуються записи аудиту для виконаних дій

No: 3

Name: cm_5_1_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначено механізми, що використовуються для автоматизації застосування обмежень доступу

5.5.2. ПЕРЕГЛЯД ЗМІН У СИСТЕМІ (СМ-5(2))

No: 1
Name: cm_5_2_01
Type: string
Default: nil

ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ - ПЕРЕГЛЯД ЗМІН У СИСТЕМІ [Вилучено: перенесено до СМ-03(07)]

5.5.3. ПІДПИСАНІ КОМПОНЕНТИ (СМ-5(3))

No: 1
Name: cm_5_3_01
Type: string
Default: nil

ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ - ПІДПИСАНІ КОМПОНЕНТИ [Вилучено: перенесено до СМ-14]

5.5.4. ПОДВІЙНА АВТОРИЗАЦІЯ (СМ-5(4))

Здійснювати подвійну авторизацію для внесення змін до [Призначення: компонентів системи та інформації на рівні системи, визначених організацією].

No: 1
Name: cm_5_4_01
Type: string
Default: nil

Запроваджено подвійну авторизацію для внесення змін до компонентів системи

No: 2
Name: cm_5_4_02
Type: string
Default: nil

Запроваджено подвійну авторизацію для внесення змін до інформації

No: 3
Name: cm_5_4_odp_01
Type: string
Default: nil

Визначено компоненти системи, що потребують подвійної авторизації для внесення змін

No: 4
Name: cm_5_4_odp_02
Type: string
Default: nil

Визначено інформацію на рівні системи, що потребують подвійної авторизації для внесення змін

5.5.5. ОБМЕЖЕННЯ ПОВНОВАЖЕНЬ ДЛЯ ВИРОБНИЦТВА ТА ЕКСПЛУАТАЦІЇ (СМ-5(5))

- (a) обмежити повноваження для зміни компонентів системи та інформації, пов'язаної із системою, у виробничому або операційному середовищі;
- (b) переглядати та переоцінювати повноваження [Призначення: визначеною організацією з частотою].

No: 1

Name: cm_5_5_a_01

Type: string

Default: nil

Повноваження для зміни компонентів системи у виробничому або операційному середовищі обмежені

No: 2

Name: cm_5_5_a_02

Type: string

Default: nil

Повноваження для зміни інформації, пов'язаної із системою у виробничому або операційному середовищі обмежені

No: 3

Name: cm_5_5_b_01

Type: string

Default: "щорічно"

Переглядаються частота>

No: 4

Name: cm_5_5_b_02

Type: string

Default: "щорічно"

Переоцінюються повноваження частота; повноваження <CM-05(05)_ODP[01]

No: 5

Name: cm_5_5_odp_01

Type: integer

Default: 30

Визначено частоту перегляду повноважень

No: 6

Name: cm_5_5_odp_02

Type: integer

Default: 30

Визначено частоту переоцінення повноважень

5.5.6. ОБМЕЖЕННЯ ПОВНОВАЖЕНЬ ДЛЯ БІБЛІОТЕК (CM-5(6))

Обмежити повноваження для зміни програмного забезпечення, яке перебуває в бібліотеках програмного забезпечення.

No: 1

Name: cm_5_6_01

Type: string

Default: nil

Обмежено повноваження для зміни програмного забезпечення, яке перебуває в бібліотеках програмного забезпечення

5.5.7. ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ ВАДЖЕННЯ ЗАХОДІВ ЗАХИСТУ (СМ-5(7))

No: 1

Name: cm_5_7_01

Type: string

Default: nil

ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ ВАДЖЕННЯ ЗАХОДІВ ЗАХИСТУ - АВТОМАТИЧНЕ ВПРО-
[Вилучено: включено до SI-07]

5.6. НАЛАШТУВАННЯ КОНФІГУРАЦІЇ (СМ-6)

a. Встановити та задокументувати параметри конфігурації компонентів, які застосовуються в системі, які відображають найбільш обмежений режим, що відповідає експлуатаційним вимогам, використовуючи [Призначення: визначені організацією загальні безпечні конфігурації].

b. Реалізувати конфігураційні установки.

c. Визначити, задокументувати та затвердити будь-які відхилення від встановлених конфігураційних параметрів конфігурації для [Призначення: визначених організацією компонентів системи] на основі [Призначення: визначених організацією експлуатаційних вимог].

d. Відстежувати та керувати змінами конфігураційних параметрів відповідно до організаційної політики та процедур.

No: 1

Name: cm_6_a

Type: string

Default: nil

Налаштування конфігурації, які відображають найбільш обмежувальний режим, що відповідає експлуатаційним вимогам, встановлені та задокументовані для компонентів, що застосовуються в системі з використанням безпечні конфігурації

No: 2

Name: cm_6_b

Type: string

Default: nil

Реалізовано установки конфігурації, задокументовані в СМ-06a

No: 3

Name: cm_6_c_01

Type: string

Default: nil

Будь-які відхилення від встановлених параметрів конфігурації для компонентів системи визначаються та документуються на основі експлуатаційних вимог

No: 4

Name: cm_6_c_02

Type: string

Default: nil

Будь-які відхилення від встановлених налаштувань конфігурації для компонентів системи затверджуються

No: 5

Name: cm_6_d_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Зміни в налаштуваннях конфігурації відстежуються відповідно до політики та процедур організації

No: 6

Name: cm_6_d_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Зміни налаштувань конфігурації керуються відповідно до політики та процедур організації

No: 7

Name: cm_6_odp_01

Type: string

Default: nil

Визначено загальні безпечні конфігурації для встановлення та документування параметрів конфігурації компонентів, які застосовуються в системі; CM-06_ODP[02] визначено компоненти системи, для яких необхідно затвердити відхилення

No: 8

Name: cm_6_odp_03

Type: string

Default: nil

Визначені експлуатаційні вимоги, що вимагають затвердження відхилень

5.6.1. АВТОМАТИЗОВАНЕ УПРАВЛІННЯ, ЗАСТОСУВАННЯ ТА ВЕРИФІКАЦІЯ (CM-6(1))

No: 1

Name: cm_6_1_01

Type: string

Default: nil

Налаштування конфігурації для компонентів системи керуються за допомогою автоматизованих механізмів

No: 2

Name: cm_6_1_02

Type: string

Default: nil

Налаштування конфігурації для компонентів системи застосовуються за допомогою автоматизованих механізмів

No: 3

Name: cm_6_1_03

Type: string

Default: "автоматизований засіб моніторингу"

Налаштування конфігурації для компонентів системи перевіряються за допомогою автоматизованих механізмів; механізми керування перевірки

No: 4

Name: cm_6_1_odp_02

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми налаштуваннями конфігурації

No: 5

Name: cm_6_1_odp_03

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми застосування налаштувань конфігурації

No: 6

Name: cm_6_1_odp_04

Type: string

Default: nil

Визначено автоматизовані налаштувань конфігурації

5.6.2. НАЛАШТУВАННЯ КОНФІГУРАЦІЇ САНКЦІОНОВАНІ ЗМІНИ (СМ-6(2))

Виконайте такі дії у відповідь на неавторизовані зміни в [Призначення: параметри конфігурації, визначені організацією]: [Призначення: дії, визначені організацією].

Немає параметрів для цього контролю.

5.6.3. ДЕМОНСТРАЦІЯ ВІДПОВІДНОСТІ (СМ-6(4))

No: 1

Name: cm_6_4_01

Type: string

Default: nil

НАЛАШТУВАННЯ КОНФІГУРАЦІЇ - ДЕМОНСТРАЦІЯ ВІДПОВІДНОСТІ [Вилучено: Включено до СМ-04]

5.7. МІНІМАЛЬНО НЕОБХІДНА ФУНКЦІОНАЛЬНІСТЬ (СМ-7)

а. Налаштуйте систему для забезпечення лише [Призначення: основні функції, визначені організацією для місії];

б. Заборонити або обмежити використання таких функцій, портів, протоколів, програмного забезпечення та/або служб: [Призначення: визначені організацією заборонені або обмежені функції, системні порти, протоколи, програмне забезпечення та/або служби].

No: 1

Name: cm_7_a

Type: string

Default: nil

Система налаштована на забезпечення лише основні функції системи

No: 2

Name: cm_7_b_01

Type: string

Default: nil

Використання функцій заборонено або обмежено

No: 3

Name: cm_7_b_02

Type: string

Default: nil

Використання порти заборонено або обмежено

No: 4

Name: cm_7_b_03

Type: string

Default: "TLS 1.3"

Використання протоколи заборонено або обмежено

No: 5

Name: cm_7_b_04

Type: string

Default: nil

Використання програмне забезпечення заборонено або обмежено

No: 6

Name: cm_7_b_05

Type: string

Default: nil

Використання служби заборонено або обмежено

No: 7

Name: cm_7_odp_01

Type: string

Default: nil

Визначено основні функції системи, необхідні для виконання місії

No: 8

Name: cm_7_odp_02

Type: string

Default: nil

Визначено функції, які необхідно заборонити або обмежити

No: 9

Name: cm_7_odp_03

Type: string

Default: nil

Визначено системні порти, які необхідно заборонити або обмежити

No: 10

Name: cm_7_odp_04

Type: string

Default: "TLS 1.3"

Визначено протоколи, які необхідно заборонити або обмежити; CM-07_ODP[05] визначено програмне забезпечення, яке необхідно заборонити або обмежити

No: 11

Name: cm_7_odp_06

Type: string

Default: nil

Визначено служби, які необхідно заборонити або обмежити

5.7.1. ПЕРІОДИЧНИЙ ПЕРЕГЛЯД (СМ-7(1))

No: 1

Name: cm_7_1_a

Type: string

Default: "TLS 1.3"

Система переглядається частота для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг

No: 2

Name: cm_7_1_b_01

Type: string

Default: nil

Функції, які вважаються непотрібними та/або незахищеними, вимкнено

No: 3

Name: cm_7_1_b_02

Type: string

Default: nil

Порти, які вважаються непотрібними та/або незахищеними, вимкнено

No: 4

Name: cm_7_1_b_03

Type: string

Default: "TLS 1.3"

Протоколи, які вважаються непотрібними та/або незахищеними, вимкнено

No: 5

Name: cm_7_1_b_04

Type: string

Default: nil

Послуги, які вважаються непотрібними та/або незахищеними, вимкнено

No: 6

Name: cm_7_1_odp_01

Type: string

Default: "TLS 1.3"

Визначено частоту, з якою слід переглядати систему для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг

No: 7

Name: cm_7_1_odp_02

Type: string

Default: nil

Визначено функції, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними; CM-07(01)_ODP[03] визначено порти, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними

No: 8

Name: cm_7_1_odp_04

Type: string

Default: "TLS 1.3"

Визначено протоколи, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними

No: 9

Name: cm_7_1_odp_05

Type: string

Default: nil

Визначено послуги, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними

5.7.2. ЗАБОРОНА ВИКОНАННЯ ПРОГРАМИ (СМ-7(2))

Заборонити виконання програми відповідно до [Вибір (один або кілька): [Призначення: визначеної організацією політики, правил поведінки та/або угод про доступ щодо використання програмного забезпечення та обмежень]; правил, що встановлюють терміни та умови використання програмного забезпечення].

No: 1

Name: cm_7_2_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {політики, правил поведінки та/або угод про доступ щодо використання програмного забезпечення та обмежень; правила, що встановлюють терміни та умови використання програмного забезпечення}

No: 2

Name: cm_7_2_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначені політики, правил поведінки та/або угод про доступ щодо використання програмного забезпечення та обмежень (якщо вибрано)

5.7.3. ВІДПОВІДНІСТЬ РЕЄСТРАЦІЇ (СМ-7(3))

Забезпечити відповідність [Призначення: визначеним організацією вимогам до реєстрації для функцій, портів, протоколів і послуг].

No: 1

Name: cm_7_3_01

Type: string

Default: nil

Вимоги до реєстрації дотримано

No: 2

Name: cm_7_3_odp

Type: string

Default: "TLS 1.3"

Визначено вимоги до реєстрації функцій, портів, протоколів та сервісів

5.7.4. НЕАВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ - ЧОРНИЙ СПИСОК (СМ-7(4))

(а) Визначити [Призначення: визначені організацією програмне забезпечення, що не має дозволу виконуватися в системі].

(б) Впровадити політику «дозволу всього, за винятком деяких» для заборони виконання неавторизованих програм у системі

(с) Переглядати та оновлювати список неавторизованих програм [Призначення: з визначеною організацією частотою].

No: 1

Name: cm_7_4_a

Type: string

Default: nil

Визначено програмне забезпечення

No: 2

Name: cm_7_4_b

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Політика "дозволу всього, за винятком деяких" застосовується для заборони виконання неавторизованих програм у системі

No: 3

Name: cm_7_4_c

Type: list

Default: []

Переглядається та оновлюється список неавторизованих програм частота

No: 4

Name: cm_7_4_odp_01

Type: string

Default: nil

Визначено програмне забезпечення, яке не має дозволу на виконання в системі

No: 5

Name: cm_7_4_odp_02

Type: list

Default: []

Визначено частоту, з якою слід переглядати та оновлювати список неавторизованих програм

5.7.5. АВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ – БІЛИЙ СПИСОК (СМ-7(5))

(а) Визначити [Призначення: визначені організацією програмне забезпечення, яке авторизовано виконується в системі]

(b) Впровадити політику «заборони всього, за винятком деяких», щоб дозволити виконання авторизованих програм у системі.

(c) Переглядати та оновлювати список авторизованих програм [Призначення: з визначеною організацією частотою].

No: 1

Name: cm_7_5_a

Type: string

Default: nil

Визначено програмне забезпечення

No: 2

Name: cm_7_5_b

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Політика "заборонити все, дозволити за винятком" застосовується, щоб дозволити виконання авторизованих програм у системі

No: 3

Name: cm_7_5_c

Type: list

Default: []

Переглядається та оновлюється список авторизованих програм частота

No: 4

Name: cm_7_5_odp_01

Type: string

Default: nil

Визначено програмне забезпечення, яке авторизовано для виконання в системі

No: 5

Name: cm_7_5_odp_02

Type: integer

Default: 30

Визначено частоту перегляду та оновлення списку авторизованих програм

5.7.6. ЗАМКНУТІ СЕРЕДОВИЩА З ОБМЕЖЕНИМИ ПРИВІЛЕЯМИ (СМ-7(6))

Вимагайте, щоб визначене програмне забезпечення, встановлене користувачем, виконувалося в обмеженому середовищі фізичної або віртуальної машини з обмеженими привілеями: [Призначення: програмне забезпечення, встановлене користувачем, визначене організацією]

No: 1

Name: cm_7_6_01

Type: string

Default: nil

Програмне забезпечення, встановлене користувачем має виконуватися в обмеженому середовищі фізичної або віртуальної машини з обмеженими привілеями

No: 2

Name: cm_7_6_odp

Type: string

Default: nil

Визначено встановлене користувачем програмне забезпечення, яке потрібно виконувати в обмеженому середовищі

5.7.7. ВИКОНУВАНИЙ КОД У ЗАХИЩЕНОМУ СЕРЕДОВИЩІ (СМ-7(7))

Дозволити виконання двійкового або машинно-виконуваного коду лише в обмеженому фізичному або віртуальному машинному середовищі та за явного дозволу [Призначення: персонал або ролі, визначені організацією], якщо такий код: а) Отримано з джерел з обмеженою гарантією або без неї; та/або б) Без надання вихідного коду.

No: 1

Name: cm_7_7_01

Type: string

Default: nil

Виконання двійкового або машинного коду дозволено лише в обмеженому середовищі фізичної або віртуальної машини

No: 2

Name: cm_7_7_a

Type: list

Default: ["admin", "security_officer"]

Виконання двійкового або машинного коду, отриманого з джерел з обмеженою гарантією або без неї, дозволяється лише з явного дозволу персоналу або ролі

No: 3

Name: cm_7_7_b

Type: list

Default: ["admin", "security_officer"]

Виконання двійкового або машинного коду без надання вихідного коду дозволяється лише з явного дозволу персоналу або ролі

No: 4

Name: cm_7_7_odp

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі для явного дозволу на виконання двійкового або машинно-виконуваного коду

5.7.8. БІНАРНИЙ АБО МАШИННИЙ ВИКОНУВАНИЙ КОД (СМ-7(8))

а) Заборонити використання двійкового або машинно-виконуваного коду з джерел з обмеженою гарантією або без неї або без надання вихідного коду; і б) Дозволяти винятки лише для обов'язкових місій або оперативних вимог і за погодженням з уповноваженою посадовою особою.

No: 1

Name: cm_7_8_a

Type: string

Default: nil

Використання двійкового або машинного коду заборонено, якщо він походить з джерел з обмеженою гарантією або без неї, або без надання вихідного коду

No: 2

Name: cm_7_8_b_01

Type: string

Default: nil

Винятки із заборони на використання двійкового або машинного коду з джерел з обмеженою гарантією або без неї, або без надання вихідного коду допускаються лише для обов'язкових місій або оперативних вимог

No: 3

Name: cm_7_8_b_02

Type: list

Default: ["admin", "security_officer"]

Винятки із заборони на використання двійкового або машинного коду з джерел з обмеженою гарантією або без неї, або без надання вихідного коду допускаються лише у разі погодження з уповноваженою посадовою особою

5.7.9. ЗАБОРОНА ВИКОРИСТАННЯ НЕАВТОРИЗОВАНОГО ОБЛАДНАННЯ (СМ-7(9))

а.

б. с. ЗАБОРОНА Визначити [Призначення: апаратні компоненти, визначені організацією, авторизовані для використання в системі]; Заборонити використання або підключення неавторизованих апаратних компонентів; Перегляд та оновлення списку авторизованих апаратних компонентів [Призначення: частота, визначена організацією].

No: 1

Name: cm_7_9_a

Type: string

Default: nil

Ідентифіковано апаратні компоненти

No: 2

Name: cm_7_9_b

Type: string

Default: nil

Використання або підключення несанкціонованих апаратних компонентів заборонено

No: 3

Name: cm_7_9_c

Type: list

Default: []

Список дозволених апаратних компонентів переглядається та оновлюється з частотою;

No: 4

Name: cm_7_9_odp_01

Type: list

Default: []

Визначено апаратні компоненти, дозволені для використання в системі; CM-07(09)_ODP[02 визначено періодичність перегляду та оновлення переліку дозволених апаратних компонентів

5.8. ІНВЕНТАРИЗАЦІЯ КОМПОНЕНТІВ СИСТЕМИ (CM-8)

a.

b. Розробити та задокументувати процес інвентаризації компонентів системи, який:

1. точно описує поточну систему;
2. охоплює всі компоненти в межах акредитації системи;
3. не включає повторний облік компонентів або компонентів, будь-якої іншої системи;
4. визначає рівень деталізації, який є необхідним для відстеження та звітування;
5. включає інформацію для досягнення підзвітності компонентів системи: [Призначення: визначена організацією інформація, необхідна для досягнення ефективної підзвітності компонентів системи]. Переглядати та оновлювати опис компонентів системи з [Призначення: визначеною організацією частотою].

No: 1

Name: cm_8_a_01

Type: string

Default: nil

Розроблено та задокументовано процес інвентаризації компонентів системи, який точно описує поточну систему

No: 2

Name: cm_8_a_02

Type: string

Default: nil

Розроблено та задокументовано процес інвентаризації компонентів системи, який охоплює всі компоненти в межах акредитації системи

No: 3

Name: cm_8_a_03

Type: string

Default: nil

Розроблено та задокументовано процес інвентаризації компонентів системи, який не включає повторний облік компонентів або компонентів, будь-якої іншої системи

No: 4

Name: cm_8_a_04

Type: string

Default: nil

Розроблено та задокументовано процес інвентаризації компонентів системи, який визначає рівень деталізації, який є необхідним для відстеження та звітування

No: 5

Name: cm_8_a_05

Type: string

Default: nil

Розроблено та задокументовано процес інвентаризації компонентів системи, який включає інформацію

No: 6

Name: cm_8_b

Type: string

Default: "щорічно"

Переглядається та оновлюється опис компонентів системи частота

No: 7

Name: cm_8_odp_01

Type: string

Default: nil

Визначено інформацію, яка вважається необхідною для досягнення ефективної підзвітності компонентів системи

No: 8

Name: cm_8_odp_02

Type: integer

Default: 30

Визначено частоту перегляду та оновлення опису компонентів системи

5.8.1. ОНОВЛЕННЯ ПІД ЧАС ВСТАНОВЛЕННЯ ТА ВИДАЛЕННЯ (CM-8(1))

No: 1

Name: cm_8_1_01

Type: string

Default: nil

Інвентаризація компонентів системи оновлюється в рамках інсталяцій компонентів системи

No: 2

Name: cm_8_1_02

Type: string

Default: nil

Інвентаризація компонентів системи оновлюється в рамках видалення компонентів системи

No: 3
Name: cm_8_1_03
Type: string
Default: nil

Інвентаризація компонентів системи оновлюється в рамках оновлення компонентів системи

5.8.2. АВТОМАТИЗОВАНА ПІДТРИМКА (СМ-8(2))

No: 1
Name: cm_8_2_01
Type: string
Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для підтримки актуальності інвентаризації компонентів системи

No: 2
Name: cm_8_2_02
Type: string
Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для підтримки повноти інвентаризації компонентів системи

No: 3
Name: cm_8_2_03
Type: string
Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для підтримки точності інвентаризації компонентів системи

No: 4
Name: cm_8_2_04
Type: string
Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для підтримки доступності інвентаризації компонентів системи

No: 5
Name: cm_8_2_odp_01
Type: string
Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми підтримки актуальності інвентаризації компонентів системи

No: 6
Name: cm_8_2_odp_02
Type: string
Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми підтримки повноти інвентаризації компонентів системи

No: 7
Name: cm_8_2_odp_03
Type: string
Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми підтримки точності інвентаризації компонентів системи

No: 8
Name: cm_8_2_odp_04
Type: string
Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми підтримки доступності інвентаризації компонентів системи

5.8.3. АВТОМАТИЗОВАНЕ ВИЯВЛЕННЯ НЕАВТОРИЗОВАНИХ КОМПОНЕНТІВ (СМ-8(3))

No: 1

Name: cm_8_3_a_01

Type: string

Default: "щорічно"

Наявність несанкціонованого обладнання в системі виявляється за допомогою автоматизованих механізмів частота

No: 2

Name: cm_8_3_a_02

Type: string

Default: "щорічно"

Наявність несанкціонованого програмного забезпечення в системі виявляється за допомогою автоматизованих механізмів частота

No: 3

Name: cm_8_3_a_03

Type: string

Default: "щорічно"

Наявність несанкціонованих мікропрограмних компонентів в системі виявляється за допомогою автоматизованих механізмів частота

No: 4

Name: cm_8_3_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для виявлення наявності несанкціонованого обладнання в системі

No: 5

Name: cm_8_3_odp_02

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для виявлення наявності несанкціонованого програмного забезпечення в системі

No: 6

Name: cm_8_3_odp_03

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для виявлення наявності несанкціонованих мікропрограмних компонентів в системі

No: 7

Name: cm_8_3_odp_04

Type: integer

Default: 30

Визначено частоту, з якою використовуються автоматизовані механізми для виявлення присутності несанкціонованих компонентів системи в системі

No: 8

Name: cm_8_3_odp_05

Type: list

Default: ["admin", "security_officer"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {відключення доступу до мережі такими компонентами; ізолювати компоненти; повідомити персонал або ролі}

No: 9

Name: cm_8_3_odp_06

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які мають бути повідомлені при виявленні несанкціонованих компонентів (якщо вибрано)

5.8.4. ІНФОРМАЦІЯ ПРО ПІДЗВІТНІСТЬ (СМ-8(4))

No: 1

Name: cm_8_4_odp

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {ім'я; позиція; роль}

5.8.5. ІНВЕНТАРИЗАЦІЯ КОМПОНЕНТІВ СИСТЕМИ ДУБЛЮВАННЯ КОМПОНЕНТІВ ОБЛІКУ (СМ-8(5))

Немає параметрів для цього контролю.

5.8.6. ПЕРЕВІРЕНІ НАЛАШТУВАННЯ ТА ЗАТВЕРДЖЕНІ ВІДХИЛЕННЯ (СМ-8(6))

No: 1

Name: cm_8_6_01

Type: string

Default: nil

Включено перевірені налаштування компонентів до поточних розгорнутих конфігурацій в інвентаризаційний облік компонентів системи

No: 2

Name: cm_8_6_02

Type: string

Default: nil

Включено будь-які затверджені відхилення до поточних розгорнутих конфігурацій в інвентаризаційний облік компонентів системи

5.8.7. ЦЕНТРАЛІЗОВАНЕ СХОВИЩЕ (СМ-8(7))

Впровадити централізоване компонентів системи. сховище СИСТЕМИ для ЦЕНТРАЛІЗОВА-
НЕ інвентаризаційного обліку

No: 1
 Name: cm_8_7_01
 Type: string
 Default: nil

Впроваджено централізоване сховище для інвентаризаційного обліку компонентів системи

5.8.8. АВТОМАТИЗОВАНЕ ВІДСТЕЖЕННЯ МІСЦЯ РОЗТАШУВАННЯ (СМ-8(8))

No: 1
 Name: cm_8_8_01
 Type: string
 Default: "автоматизований засіб моніторингу"

Використовуються автоматизовані механізми для підтримки відстеження компонентів системи за географічним розташуванням

No: 2
 Name: cm_8_8_odp
 Type: string
 Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми відстеження компонентів

5.8.9. ПРИЗНАЧЕННЯ КОМПОНЕНТІВ СИСТЕМАМ (СМ-8(9))

No: 1
 Name: cm_8_9_a
 Type: string
 Default: nil

Компоненти системи призначаються системі

No: 2
 Name: cm_8_9_b
 Type: list
 Default: ["admin", "security_officer"]

Отримано підтвердження призначення компонента від персонал або ролі

No: 3
 Name: cm_8_9_odp
 Type: list
 Default: ["admin", "security_officer"]

Визначено персонал або ролі, від яких слід отримувати підтвердження

5.9. ПЛАН УПРАВЛІННЯ КОНФІГУРАЦІЄЮ (СМ-9)

Унікально ідентифікувати та автентифікувати користувачів або процеси, що діють від імені користувачів.

No: 1
 Name: cm_9_01
 Type: string
 Default: nil

Розроблено та задокументовано план управління конфігурацією системи

No: 2

Name: cm_9_a_01

Type: list

Default: ["admin", "security_officer"]

План управління конфігурацією описує ролі

No: 3

Name: cm_9_a_02

Type: string

Default: nil

План управління конфігурацією описує відповідальність

No: 4

Name: cm_9_a_03

Type: string

Default: nil

План управління конфігурацією описує процеси та процедури управління конфігурацією

No: 5

Name: cm_9_b_01

Type: string

Default: nil

План управління конфігурацією встановлює процес ідентифікації елементів конфігурації протягом всього життєвого циклу розробки системи

No: 6

Name: cm_9_b_02

Type: string

Default: nil

План управління конфігурацією встановлює процес управління конфігурацією елементів

No: 7

Name: cm_9_c_01

Type: string

Default: nil

План управління конфігурацією визначає елементи конфігурації системи

No: 8

Name: cm_9_c_02

Type: string

Default: nil

План управління конфігурацією розміщує елементи конфігурації під управлінням конфігурацією

No: 9

Name: cm_9_d

Type: list

Default: ["admin", "security_officer"]

План управління конфігурацією розглянуто та затверджено персонал або ролі; CM-09(e)[01] план управління конфігурацією захищений від несанкціонованого розкриття

No: 10

Name: cm_9_e_02

Type: string

Default: nil

План управління конфігурацією захищений від несанкціонованої модифікації

No: 11

Name: cm_9_odp

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі для розгляду та затвердження плану управління конфігурацією

5.9.1. ВСТАНОВЛЕННЯ ВІДПОВІДАЛЬНОСТІ (СМ-9(1))

No: 1

Name: cm_9_1_01

Type: list

Default: ["admin", "security_officer"]

Встановлено відповідальність за реалізацію процесу управління конфігурацією персоналу, який безпосередньо не бере участь у розробці системи

5.10. ОБМЕЖЕННЯ ВИКОРИСТАННЯ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ (СМ-10)

No: 1

Name: cm_10_b

Type: string

Default: nil

Використання програмного забезпечення та пов'язаної з ним документації, захищеної ліцензіями, відстежується для контролю за копіюванням та розповсюдженням

No: 2

Name: cm_10_c

Type: string

Default: nil

Використання технології однорангового обміну файлами контролюється та документується, щоб гарантувати, що одноранговий обмін файлами не використовується для несанкціонованого розповсюдження, відображення, виконання або відтворення програмного забезпечення, захищеного авторським правом

5.10.1. ОБМЕЖЕННЯ ВИКОРИСТАННЯ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ З ВІДКРИТИМ ВИХІДНИМ КОДОМ (СМ-10(1))

No: 1

Name: cm_10_1_01

Type: string

Default: nil

Встановлено обмеження на використання програмного забезпечення з відкритим вихідним кодом

No: 2

Name: cm_10_1_odp

Type: string

Default: nil

Визначено обмеження на використання програмного забезпечення з відкритим вихідним кодом

5.11. ВСТАНОВЛЕНЕ КОРИСТУВАЧЕМ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ (СМ-11)

No: 1

Name: cm_11_a

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Встановлено правила (політики), що регулюють встановлення програмного забезпечення користувачами

No: 2

Name: cm_11_b

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Правила (політики) встановлення програмного забезпечення застосовуються за допомогою методів

No: 3

Name: cm_11_c

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дотримання політик контролюється частота

No: 4

Name: cm_11_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено правила (політики), що регулюють встановлення програмного забезпечення користувачами

No: 5

Name: cm_11_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено методи, що використовуються для забезпечення дотримання правил (політик) встановлення програмного забезпечення

No: 6

Name: cm_11_odp_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою слід контролювати відповідність правил (політик)

5.11.1. ВСТАНОВЛЕНЕ КОРИСТУВАЧЕМ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ ПОПЕРЕДЖЕННЯ ПРО НЕСАНКЦІОНОВАНУ ІНСТАЛЯЦІЮ (СМ-11(1))

Немає параметрів для цього контролю.

5.11.2. ВСТАНОВЛЕНЕ КОРИСТУВАЧЕМ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ ВСТАНОВЛЕННЯ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ З ПРИВІЛЕЙОВАНИМ СТАТУСОМ (СМ-11(2))

No: 1

Name: cm_11_2_01

Type: string

Default: nil

Встановлювати програмне забезпечення дозволено користувачеві лише при наявності привілейованого статусу

5.11.3. ВСТАНОВЛЕНЕ КОРИСТУВАЧЕМ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ АВТОМАТИЧНЕ ВИКОНАННЯ І МОНІТОРИНГ (СМ-11(3))

No: 1

Name: cm_11_3_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дотримання політик виконання програмного забезпечення забезпечується за допомогою автоматизованих механізмів; дотримання політик контролю програмного забезпечення контролюється за допомогою автоматизованих механізмів

No: 2

Name: cm_11_3_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено автоматизовані механізми для забезпечення дотримання політик виконання програмного забезпечення

No: 3

Name: cm_11_3_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено автоматизовані механізми для забезпечення дотримання політик контролю програмного забезпечення

5.12. РОЗТАШУВАННЯ ІНФОРМАЦІЇ (СМ-12)

No: 1

Name: cm_12_a_01

Type: string

Default: nil

Місцезнаходження інформація визначено та задокументовано

No: 2

Name: cm_12_a_02

Type: string

Default: nil

Визначено та задокументовано конкретні компоненти системи, на яких обробляється інформація

No: 3
Name: cm_12_a_03
Type: string
Default: nil

Визначено та задокументовано конкретні компоненти системи, на яких зберігається інформація

No: 4
Name: cm_12_b_01
Type: string
Default: nil

Визначено та задокументовано користувачів, які мають доступ до системи та компонентів системи, де обробляється інформація

No: 5
Name: cm_12_b_02
Type: string
Default: nil

Визначено та задокументовано користувачів, які мають доступ до системи та компонентів системи, де зберігається інформація; CM-12(c)[01] задокументовано зміни розташування (наприклад, системи або компонентів системи), де обробляється інформація

No: 6
Name: cm_12_c_02
Type: string
Default: nil

Задокументовано зміни розташування (наприклад, системи або компонентів системи), де зберігається інформація

No: 7
Name: cm_12_odp
Type: string
Default: nil

Визначено інформацію, місцезнаходження якої має бути визначено та задокументовано

5.12.1. АВТОМАТИЗОВАНІ ІНСТРУМЕНТИ ПІДТРИМКИ РОЗТАШУВАННЯ ІНФОРМАЦІЇ (CM-12(1))

No: 1
Name: cm_12_1_01
Type: list
Default: ["admin", "security_officer"]

Автоматизовані інструменти використовуються для ідентифікації інформації за типом на компонентах системи, щоб забезпечити впровадження належних заходів захисту щодо інформації про організацію і персональних даних

No: 2
Name: cm_12_1_odp_01
Type: string
Default: nil

Інформація визначена за типом

No: 3
Name: cm_12_1_odp_02

Type: string

Default: nil

Визначено компоненти системи, де знаходиться інформація

5.13. ВІДОБРАЖЕННЯ ДІЙ ДАНИХ (СМ-13)

No: 1

Name: cm_13_01

Type: string

Default: nil

Розроблено та задокументовано карту дій з даними системи

5.14. ПІДПИСАНІ КОМПОНЕНТИ (СМ-14)

No: 1

Name: cm_14_01

Type: string

Default: nil

Інсталяція програмне забезпечення попередньо запобігається, якщо не буде перевірено, що програмне забезпечення було підписано цифровим підписом за допомогою сертифіката, визнаного та затвердженого організацією

No: 2

Name: cm_14_02

Type: string

Default: nil

Інсталяція мікропрограмні компоненти попередньо запобігається, якщо не буде перевірено, що мікропрограмні компоненти були підписані цифровим підписом за допомогою сертифіката, визнаного та затвердженого організацією

No: 3

Name: cm_14_odp_01

Type: string

Default: nil

Визначено програмне забезпечення, яке потребує перевірки сертифікату з цифровим підписом перед встановленням

No: 4

Name: cm_14_odp_02

Type: string

Default: nil

Визначено мікропрограмні компоненти, які потребує перевірки сертифікату з цифровим підписом перед встановленням

6. СР

Клас заходів захисту СР — ПЛАНУВАННЯ БЕЗПЕРЕРВНОЇ РОБОТИ

Цей клас описує заходи для відновлення функціонування інформаційної системи та забезпечення її безперебійної роботи у разі надзвичайних ситуацій.

Перелік заходів захисту: Політика та процедури планування безперервної роботи (CP-1); План забезпечення безперервної роботи та відновлення функціонування (CP-2); Координація з пов'язаними планами (CP-2(1)); Навчання із забезпечення безперервної роботи (CP-3); Тестування плану забезпечення безперервної роботи та відновлення функціонування (CP-4); Альтернативна платформа тестування (CP-4(2)); Автоматичне тестування (CP-4(3)); Повне відновлення (CP-4(4)); Застосовуються для порушення та негативного впливу на (CP-4(5)); Оновлення плану забезпечення безперервної роботи та відновлення функціонування (CP-5); Альтернативне місце зберігання (CP-6); Відділення від первинного сховища (CP-6(1)); Час відновлення та встановлення цілей відновлення (CP-6(2)); Доступність (CP-6(3)); Альтернативний майданчик роботи (CP-7); Відділення від основного майданчика (CP-7(1)); Доступність (CP-7(2)); Пріоритет обслуговування (CP-7(3)); Підготовка для використання (CP-7(4)); Нездатність повернутися на основний майданчик (CP-7(6)); Комунікаційні послуги (CP-8); Пріоритет постачання послуг (CP-8(1)); Єдині точки відмови (CP-8(2)); Відділення основних та альтернативних провайдерів (CP-8(3)); План забезпечення безперервної роботи постачальника комунікаційних послуг (CP-8(4)); Тестування альтернативних комунікаційних послуг (CP-8(5)); Резервне копіювання (CP-9); Випробування на надійність та цілісність (CP-9(1)); Тестування відновлення з використанням зразків (CP-9(2)); Відокремлене сховище критичної інформації (CP-9(3)); Передача на альтернативне сховище зберігання (CP-9(5)); Надлишкова вторинна система (CP-9(6)); Подвійна авторизація (CP-9(7)); Криптографічний захист (CP-9(8)); Відновлення та відтворення системи (CP-10); Відновлення транзакцій (CP-10(2)); Відновлення в межах часового періоду (CP-10(4)); Здатність відмовостійкості (CP-10(5)); Альтернативні протоколи зв'язку (CP-11); Безпечний режим (CP-12); Альтернативні механізми безпеки (CP-13).

6.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ПЛАНУВАННЯ БЕЗПЕРЕРВНОЇ РОБОТИ (CP-1)

No: 1

Name: cp_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику планування безперервної роботи на випадок надзвичайних ситуацій

No: 2

Name: cp_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика планування безперервної роботи на випадок надзвичайних ситуацій поширюється на персонал або посади

No: 3

Name: cp_1_a_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблені та задокументовані процедури планування безперервної роботи на випадок надзвичайних ситуацій, що сприяють впровадженню політики планування безперервної роботи на випадок надзвичайних ситуацій та пов'язаних з нею заходів захисту на випадок надзвичайних ситуацій

No: 4

Name: cp_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління , документуванням та розповсюдженням політики та процедур планування безперервної роботи на випадок надзвичайних ситуацій; CP-01(c)[01][01] переглядається та оновлюється поточна політика планування безперервної роботи на випадок надзвичайних ситуацій частота; CP-01(c)[01][02] переглядається та оновлюється поточна політика планування безперервної роботи на випадок надзвичайних ситуацій після подій; CP-01(c)[02][01] переглядаються та оновлюються поточні процедури планування безперервної роботи на випадок надзвичайних ситуацій частота; CP-01(c)[02][02] переглядаються та оновлюються поточні процедури планування безперервної роботи на випадок надзвичайних ситуацій після подій

No: 5

Name: cp_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або посади, на які поширюється політика планування безперервної роботи на випадок надзвичайних ситуацій

No: 6

Name: cp_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або посади, на які поширюється процедури планування безперервної роботи на випадок надзвичайних ситуацій

No: 7

Name: cp_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: cp_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами планування безперервної роботи на випадок надзвичайних ситуацій

No: 9

Name: cp_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика

No: 10

Name: cp_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, після яких переглядається та оновлюється поточна політика

No: 11

Name: cp_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури

No: 12

Name: cp_1_odp_08

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, після яких переглядаються та оновлюються поточні процедури

6.2. ПЛАН ЗАБЕЗПЕЧЕННЯ БЕЗПЕРЕРВНОЇ РОБОТИ ТА ВІДНОВЛЕННЯ ФУНКЦІОНУВАННЯ (CP-2)

No: 1

Name: cp_2_a_01

Type: list

Default: ["admin", "security_officer"]

Розроблено план забезпечення безперервної роботи у надзвичайних ситуаціях для системи, який визначає основні завдання, функції та пов'язані з ними вимоги щодо безперервної роботи; CP-02(a)[02][01] розроблено план забезпечення безперервної роботи у надзвичайних ситуаціях для системи, який забезпечує цілі; CP-02(a)[02][02] розроблено план забезпечення безперервної роботи у надзвичайних ситуаціях для системи, який забезпечує пріоритети; CP-02(a)[02][03] розроблено план забезпечення безперервної роботи у надзвичайних ситуаціях для системи, який забезпечує відповідні показники; CP-02(a)[03][01] розроблено план забезпечення безперервної роботи на випадок надзвичайних ситуацій для системи, в якому визначено ролі; CP-02(a)[03][02] розроблено план забезпечення безперервної роботи на випадок надзвичайних ситуацій для системи, в якому визначено обов'язки; CP-02(a)[03][03] розроблено план забезпечення безперервної роботи на випадок надзвичайних ситуацій для системи, в якому визначено відповідальних осіб з контактною інформацією

No: 2

Name: cp_2_a_04

Type: string

Default: nil

Розроблено план забезпечення безперервної роботи на випадок непередбачених обставин для системи, який спрямований на підтримку основних завдань і функцій, попри системні збої, компрометації або помилки

No: 3

Name: cp_2_a_05

Type: list

Default: ["admin", "security_officer"]

Розроблено план забезпечення безперервної роботи у надзвичайних ситуаціях для системи, який спрямований на повне відновлення функціонування системи без погіршення запланованих і реалізованих заходів захисту інформації та персональних даних

No: 4

Name: cp_2_a_06

Type: list

Default: ["admin", "security_officer"]

Розроблено план забезпечення безперервної роботи на випадок надзвичайних ситуацій для системи, який вирішує питання обміну інформацією про надзвичайні ситуації; CP-02(a)[07][01] розроблено план забезпечення безперервної роботи у надзвичайних ситуаціях для системи, який переглядається персоналом або ролями; CP-02(a)[07][02] розроблено план забезпечення безперервної роботи у надзвичайних ситуаціях для системи, який затверджено персоналом або ролями

No: 5

Name: cp_2_b_01

Type: list

Default: ["admin", "security_officer"]

Копії плану забезпечення безперервної роботи на випадок надзвичайних ситуацій розповсюджуються серед персоналу

No: 6

Name: cp_2_b_02

Type: string

Default: nil

Копії плану забезпечення безперервної роботи на випадок надзвичайних ситуацій розповсюджуються серед елементів

No: 7

Name: cp_2_c

Type: string

Default: "щорічно"

Діяльність з планування безперервної роботи координується з діяльністю із заходами по усуненню інцидентів; CP-02(d) переглядається план забезпечення безперервної роботи у надзвичайних ситуаціях для системи частота

No: 8

Name: cp_2_e_01

Type: string

Default: nil

План забезпечення безперервної роботи на випадок надзвичайних ситуацій оновлюється з урахуванням змін в організації, системі або середовищі функціонування

No: 9

Name: cp_2_e_02

Type: integer

Default: 30

План забезпечення безперервної роботи на випадок надзвичайних ситуацій оновлюється для вирішення проблем, що виникають під час впровадження, виконання або тестування плану дій на випадок надзвичайних ситуацій

No: 10

Name: cp_2_f_01

Type: list

Default: ["admin", "security_officer"]

Зміни в плані забезпечення безперервної роботи на випадок надзвичайних ситуацій повідомляються персоналу

No: 11

Name: cp_2_f_02

Type: string

Default: nil

Зміни в плані забезпечення безперервної роботи на випадок надзвичайних ситуацій повідомляються елементам

No: 12

Name: cp_2_g_01

Type: integer

Default: 30

Уроки, отримані під час тестування планів забезпечення безперервної роботи у надзвичайних ситуаціях або фактичних дій у надзвичайних ситуаціях, включаються в навчання

No: 13

Name: cp_2_g_02

Type: integer

Default: 30

Уроки, отримані під час тестування планів забезпечення безперервної роботи у надзвичайних ситуаціях або фактичних дій у надзвичайних ситуаціях, включаються в тестування

No: 14

Name: cp_2_h_01

Type: string

Default: nil

План забезпечення безперервної роботи у надзвичайних ситуаціях захищений від несанкціонованого доступу

No: 15

Name: cp_2_h_02

Type: string

Default: nil

План забезпечення безперервної роботи у надзвичайних ситуаціях захищений від несанкціонованих змін

No: 16

Name: cp_2_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі для перегляду плану забезпечення безперервної роботи у надзвичайних ситуаціях

No: 17

Name: cp_2_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі для затвердження плану забезпечення безперервної роботи у надзвичайних ситуаціях

No: 18

Name: cp_2_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначено ключовий резервний персонал (ідентифікований за іменами та/або за ролями), якому поширюються копії плану забезпечення безперервної роботи на випадок надзвичайних ситуацій

No: 19

Name: cp_2_odp_04

Type: string

Default: nil

Визначено ключові елементи, на які поширюються копії плану забезпечення безперервної роботи на випадок надзвичайних ситуацій

No: 20

Name: cp_2_odp_05

Type: string

Default: "щорічно"

Визначено періодичність перегляду плану забезпечення безперервної роботи у надзвичайних ситуаціях

No: 21

Name: cp_2_odp_06

Type: list

Default: ["admin", "security_officer"]

Визначено ключовий резервний персонал (ідентифікований за іменами та/або ролями), якому необхідно повідомити про зміни

No: 22
 Name: cp_2_odp_07
 Type: string
 Default: nil

Визначено ключові елементи організації, і які необхідно повідомити про зміни

6.2.1. КООРДИНАЦІЯ З ПОВ'ЯЗАНИМИ ПЛАНАМИ (CP-2(1))

No: 1
 Name: cp_2_1_01
 Type: string
 Default: nil

Розробка плану забезпечення безперервної роботи у надзвичайних ситуаціях координується зі структурними підрозділами, які відповідають за розробку та реалізацію пов'язаних планів

6.3. НАВЧАННЯ ІЗ ЗАБЕЗПЕЧЕННЯ БЕЗПЕРЕРВНОЇ РОБОТИ (CP-3)

No: 1
 Name: cp_3_a_01
 Type: list
 Default: ["admin", "security_officer"]

Підготовка на випадок надзвичайних ситуацій надається користувачам системи відповідно до призначених ролей та обов'язків протягом періоду часу з моменту прийняття на себе надзвичайної ролі або обов'язку

No: 2
 Name: cp_3_a_02
 Type: string
 Default: nil

Навчання на випадок надзвичайних ситуацій проводиться для користувачів системи відповідно до призначених ролей та обов'язків, якщо цього вимагають зміни в системі

No: 3
 Name: cp_3_a_03
 Type: string
 Default: "щорічно"

Користувачам системи надається навчання на випадок надзвичайних ситуацій відповідно до призначених ролей та обов'язків частота

No: 4
 Name: cp_3_b_01
 Type: string
 Default: "щорічно"

Переглядається та оновлюється зміст тренувань за планом реагування на надзвичайні ситуації частота

No: 5
 Name: cp_3_b_02
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Зміст тренувань за планом реагування на надзвичайні ситуації переглядається та оновлюється після наступних подій

No: 6

Name: cp_3_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено період часу, протягом якого необхідно провести тренінг з підготовки до дій в умовах надзвичайних ситуацій після прийняття на себе ролі або відповідальності в умовах надзвичайних ситуацій

No: 7

Name: cp_3_odp_02

Type: integer

Default: 30

Визначено частоту проведення тренінгів для користувачів системи, які виконують непередбачувану роль або несуть відповідальність

No: 8

Name: cp_3_odp_03

Type: integer

Default: 30

Визначено частоту, з якою необхідно переглядати та оновлювати зміст тренувань на випадок надзвичайних ситуацій

No: 9

Name: cp_3_odp_04

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують перегляду та оновлення тренувань на випадок надзвичайних ситуацій

6.4. ТЕСТУВАННЯ ПЛАНУ ЗАБЕЗПЕЧЕННЯ БЕЗПЕРЕРВНОЇ РОБОТИ ТА ВІДНОВЛЕННЯ ФУНКЦІОНУВАННЯ (CP-4)

No: 1

Name: cp_4_a_01

Type: string

Default: "щорічно"

Тестується план забезпечення безперервної роботи у надзвичайних ситуаціях для системи частота

No: 2

Name: cp_4_a_02

Type: string

Default: nil

Тести використовуються для визначення ефективності плану

No: 3

Name: cp_4_a_03

Type: string

Default: nil

Тести використовуються для визначення готовності до виконання плану

No: 4
 Name: cp_4_b
 Type: string
 Default: nil

Переглядаються результати тестування плану забезпечення безперервної роботи у надзвичайних ситуаціях

No: 5
 Name: cp_4_c
 Type: list
 Default: ["login", "logout", "failed_attempt"]

За необхідності ініціюються коригувальні дії

No: 6
 Name: cp_4_odp_01
 Type: integer
 Default: 30

Визначено частоту тестування плану забезпечення безперервної роботи у надзвичайних ситуаціях для системи

No: 7
 Name: cp_4_odp_02
 Type: string
 Default: nil

Визначено тести для визначення ефективності плану забезпечення безперервної роботи у надзвичайних ситуаціях

No: 8
 Name: cp_4_odp_03
 Type: string
 Default: nil

Визначені тести для визначення готовності до виконання плану забезпечення безперервної роботи у надзвичайних ситуаціях

6.4.1. АЛЬТЕРНАТИВНА ПЛАТФОРМА ТЕСТУВАННЯ (CP-4(2))

No: 1
 Name: cp_4_2_a
 Type: list
 Default: ["admin", "security_officer"]

План забезпечення безперервної роботи у надзвичайних ситуаціях тестується на альтернативній платформі для ознайомлення персоналу з об'єктом та наявними ресурсами

No: 2
 Name: cp_4_2_b
 Type: string
 Default: nil

План забезпечення безперервної роботи у надзвичайних ситуаціях тестується на альтернативній платформі для оцінки можливостей альтернативної платформи

6.4.2. АВТОМАТИЧНЕ ТЕСТУВАННЯ (CP-4(3))

No: 1
 Name: cp_4_3_01

Type: string

Default: nil

ТЕСТУВАННЯ ПЛАНУ ЗАБЕЗПЕЧЕННЯ БЕЗПЕРЕРВНОЇ РОБОТИ ТА ВІДНОВЛЕННЯ ФУНКЦІОНУВАННЯ - АВТОМАТИЧНЕ ТЕСТУВАННЯ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: cp_4_3_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми тестування планів забезпечення безперервної роботи у надзвичайних ситуаціях

6.4.3. ПОВНЕ ВІДНОВЛЕННЯ (CP-4(4))

No: 1

Name: cp_4_4_01

Type: integer

Default: 30

Включено повне відновлення системи до відомого стану як частину тестування плану забезпечення безперервної роботи та відновлення функціонування

No: 2

Name: cp_4_4_02

Type: integer

Default: 30

Включено повне повернення системи до відомого стану як частину тестування плану забезпечення безперервної роботи та відновлення функціонування

6.4.4. ЗАСТОСОВУЮТЬСЯ ДЛЯ ПОРУШЕННЯ ТА НЕГАТИВНОГО ВПЛИВУ НА (CP-4(5))

No: 1

Name: cp_4_5_01

Type: string

Default: "автоматизований засіб моніторингу"

Механізми застосовуються для порушення та негативного впливу на систему або компонент системи

No: 2

Name: cp_4_5_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено механізми, що застосовуються для порушення та негативного впливу на систему або на компонент системи

No: 3

Name: cp_4_5_odp_02

Type: string

Default: "автоматизований засіб моніторингу"

Визначено систему або компонент системи, до яких застосовуються механізми порушення та негативного впливу

6.5. ОНОВЛЕННЯ ПЛАНУ ЗАБЕЗПЕЧЕННЯ БЕЗПЕРЕРВНОЇ РОБОТИ ТА ВІДНОВЛЕННЯ ФУНКЦІОНУВАННЯ (СР-5)

No: 1

Name: cp_5_01

Type: string

Default: nil

ОНОВЛЕННЯ ПЛАНУ ЗАБЕЗПЕЧЕННЯ БЕЗПЕРЕРВНОЇ РОБОТИ ТА ВІДНОВЛЕННЯ ФУНКЦІОНУВАННЯ [Вилучено: Включено до СР-02]

6.6. АЛЬТЕРНАТИВНЕ МІСЦЕ ЗБЕРІГАННЯ (СР-6)

No: 1

Name: cp_6_01

Type: string

Default: nil

АЛЬТЕРНАТИВНЕ МІСЦЕ ЗБЕРІГАННЯ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: cp_6_a_01

Type: string

Default: nil

Створено альтернативне місце зберігання

No: 3

Name: cp_6_a_02

Type: string

Default: nil

Створення альтернативного місця зберігання включає в себе необхідні угоди, що дозволяють зберігати та видавати інформацію резервного копіювання системи

No: 4

Name: cp_6_b

Type: string

Default: nil

В альтернативному місці зберігання впроваджені заходи захисту, аналогічні заходам захисту основної локації

6.6.1. ВІДДІЛЕННЯ ВІД ПЕРВИННОГО СХОВИЩА (СР-6(1))

No: 1

Name: cp_6_1_01

Type: string

Default: nil

Визначено альтернативне місце зберігання, яке відокремлено від основного місця зберігання, щоб зменшити сприйнятливість до тих самих загроз

6.6.2. ЧАС ВІДНОВЛЕННЯ ТА ВСТАНОВЛЕННЯ ЦІЛЕЙ ВІДНОВЛЕННЯ (CP-6(2))

No: 1

Name: cp_6_2_01

Type: integer

Default: 30

Налаштувати альтернативне місце зберігання для полегшення операцій відновлення відповідно до часу відновлення

No: 2

Name: cp_6_2_02

Type: string

Default: nil

Налаштувати альтернативне місце зберігання для полегшення операцій відновлення відповідно до встановлених цілей відновлення

6.6.3. ДОСТУПНІСТЬ (CP-6(3))

No: 1

Name: cp_6_3_01

Type: string

Default: nil

Визначено потенційні проблеми доступності для альтернативного місця зберігання в разі збоїв або стихійних лих по всьому регіоні

No: 2

Name: cp_6_3_02

Type: list

Default: ["login", "logout", "failed_attempt"]

В загальних рисах окреслено дії щодо пом'якшення наслідків

6.7. АЛЬТЕРНАТИВНИЙ МАЙДАНЧИК РОБОТИ (CP-7)

No: 1

Name: cp_7_a

Type: integer

Default: 30

Альтернативний майданчик для роботи, включно з необхідними угодами, які дозволяють передачу та відновлення операцій системи для виконання основних завдань та функцій, створюється протягом періоду часу, коли можливості основного майданчика недоступні

No: 2

Name: cp_7_b_01

Type: integer

Default: 30

Обладнання та прилади, необхідні для передачі, доступні на альтернативному місці роботи або якщо укладені контракти на підтримку доставки на це місце протягом періоду часу для передачі

No: 3
 Name: cp_7_b_02
 Type: integer
 Default: 30

Обладнання та прилади, необхідні для відновлення, доступні на альтернативному місці роботи або якщо укладені контракти на підтримку доставки на це місце протягом періоду часу для передачі

No: 4
 Name: cp_7_c
 Type: string
 Default: nil

Впроваджено на альтернативному майданчику роботи заходи захисту, еквівалентні тим, що впровадженні на основному майданчику

No: 5
 Name: cp_7_odp_01
 Type: string
 Default: nil

Визначені операції системи для основних завдань і функцій

No: 6
 Name: cp_7_odp_02
 Type: integer
 Default: 30

Визначено період часу, відповідно термінам відновлення та встановленим цілям відновлення

6.7.1. ВІДДІЛЕННЯ ВІД ОСНОВНОГО МАЙДАНЧИКА (CP-7(1))

No: 1
 Name: cp_7_1_01
 Type: string
 Default: nil

АЛЬТЕРНАТИВНИЙ МАЙДАНЧИК ДЛЯ РОБОТИ - ВІДДІЛЕННЯ ВІД ОСНОВНОГО МАЙДАНЧИКА
 МЕТА ОЦІНКИ: Визначити, чи: визначено альтернативний майданчик для роботи, який відокремлений від основного майданчика, з метою зменшення сприйнятливості до тих самих загроз

6.7.2. ДОСТУПНІСТЬ (CP-7(2))

No: 1
 Name: cp_7_2_01
 Type: string
 Default: nil

Визначено потенційні проблеми доступності для альтернативного майданчика для роботи в разі збоїв або катастрофи по всьому регіону

No: 2
 Name: cp_7_2_02
 Type: string
 Default: nil

Окреслено чіткі заходи щодо пом'якшення наслідків

6.7.3. ПРІОРИТЕТ ОБСЛУГОВУВАННЯ (CP-7(3))

No: 1
 Name: cp_7_3_01
 Type: integer
 Default: 30

Розроблено угоди про альтернативний майданчик для роботи, які містять положення щодо пріоритету обслуговування відповідно до вимог стосовно доступності (включно з вимогами щодо часу відновлення)

6.7.4. ПІДГОТОВКА ДЛЯ ВИКОРИСТАННЯ (CP-7(4))

No: 1
 Name: cp_7_4_01
 Type: string
 Default: nil

Підготовлено альтернативний майданчик для роботи таким чином, щоб майданчик був готовий до використання як оперативний майданчик, що підтримує виконання основних завдань та функцій

6.7.5. НЕЗДАТНІСТЬ ПОВЕРНУТИСЯ НА ОСНОВНИЙ МАЙДАНЧИК (CP-7(6))

No: 1
 Name: cp_7_6_02
 Type: string
 Default: nil

Підготувалися до обставин, які виключають повернення на основне місце роботи

6.8. КОМУНІКАЦІЙНІ ПОСЛУГИ (CP-8)

No: 1
 Name: cp_8_01
 Type: integer
 Default: 30

Альтернативні комунікаційні послуги, включно з необхідними угодами, що дозволяють відновити операції системи, створюються для основних завдань та функцій протягом періоду часу, коли основні комунікаційні можливості недоступні на основному або альтернативному місцях роботи або зберігання

No: 2
 Name: cp_8_odp_01
 Type: string
 Default: nil

Визначено операції системи, які необхідно відновити для виконання основних завдань та функцій

No: 3
 Name: cp_8_odp_02
 Type: integer
 Default: 30

Визначено період часу, протягом якого необхідно відновити основні завдання та функції, коли основні комунікаційні можливості недоступні

6.8.1. ПРІОРИТЕТ ПОСТАЧАННЯ ПОСЛУГ (CP-8(1))

No: 1
 Name: cp_8_1_01
 Type: string
 Default: nil

КОМУНІКАЦІЙНІ ПОСЛУГИ - ПРІОРИТЕТ ПОСТАЧАННЯ ПОСЛУГ МЕТА ОЦІНКИ: Визначити, чи:

No: 2
 Name: cp_8_1_a_01
 Type: integer
 Default: 30

Розроблено угоди про надання основних комунікаційних послуг, які містять пріоритетні положення про надання послуг відповідно до вимог щодо доступності (включно з вимогами щодо часу відновлення)

No: 3
 Name: cp_8_1_a_02
 Type: integer
 Default: 30

Розроблено альтернативні угоди про надання комунікаційних послуг, які містять положення про пріоритетність надання послуг відповідно до вимог доступності (включно з вимогами щодо часу відновлення)

No: 4
 Name: cp_8_1_b
 Type: string
 Default: nil

Надсилається запит про пріоритети комунікаційних послуг для всіх комунікаційних послуг, що використовуються для забезпечення безперервності роботи, якщо основні та/або альтернативні комунікаційні послуги надаються загальним оператором

6.8.2. ЄДИНІ ТОЧКИ ВІДМОВИ (CP-8(2))

No: 1
 Name: cp_8_2_01
 Type: string
 Default: nil

Отримано альтернативні комунікаційні послуги з метою зменшення ймовірності спільного використання єдиної точки відмови з основними комунікаційними послугами

6.8.3. ВІДДІЛЕННЯ ОСНОВНИХ ТА АЛЬТЕРНАТИВНИХ ПРОВАЙДЕРІВ (CP-8(3))

No: 1
 Name: cp_8_3_01
 Type: string
 Default: nil

Отримуються альтернативні комунікаційні послуги від постачальників, які відокремлені від основних постачальників послуг, щоб зменшити сприйнятливості до тих самих загроз

6.8.4. ПЛАН ЗАБЕЗПЕЧЕННЯ БЕЗПЕРЕРВНОЇ РОБОТИ ПОСТАЧАЛЬНИКА КОМУНІКАЦІЙНИХ ПОСЛУГ (CP-8(4))

No: 1

Name: cp_8_4_a_01

Type: string

Default: nil

Постачальники основних комунікаційних послуг зобов'язані мати плани забезпечення безперервної роботи

No: 2

Name: cp_8_4_a_02

Type: string

Default: nil

Постачальники альтернативних комунікаційних послуг зобов'язані мати плани забезпечення безперервної роботи

No: 3

Name: cp_8_4_b

Type: string

Default: nil

Переглядаються плани забезпечення безперервної роботи постачальників комунікаційних послуг для забезпечення відповідності планам забезпечення безперервної роботи організації

No: 4

Name: cp_8_4_c_01

Type: string

Default: "щорічно"

Отримано свідчення про тестування планів забезпечення безперервної роботи частота

No: 5

Name: cp_8_4_c_02

Type: string

Default: "щорічно"

Отримано свідчення про тренування з планів забезпечення безперервної роботи частота

No: 6

Name: cp_8_4_odp_01

Type: integer

Default: 30

Визначено частоту, з якою постачальники послуг повинні надавати свідчення про тестування планів забезпечення безперервної роботи

No: 7

Name: cp_8_4_odp_02

Type: integer

Default: 30

Визначено частоту, з якою постачальники послуг повинні надавати свідчення про тренування з планів забезпечення безперервної роботи

6.8.5. ТЕСТУВАННЯ АЛЬТЕРНАТИВНИХ КОМУНІКАЦІЙНИХ ПОСЛУГ (CP-8(5))

No: 1

Name: cp_8_5_01

Type: integer

Default: 30

Тестування надання альтернативних комунікаційних послуг з частотою

No: 2

Name: cp_8_5_odp

Type: integer

Default: 30

Визначено частоту з якою необхідно тестувати надання альтернативних комунікаційних послуг

6.9. РЕЗЕРВНЕ КОПЮВАННЯ (CP-9)

No: 1

Name: cp_9_01

Type: string

Default: nil

РЕЗЕРВНЕ КОПЮВАННЯ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: cp_9_a

Type: string

Default: "щорічно"

Резервне копіювання інформації користувача, що міститься в компонентах системи, здійснюється частота

No: 3

Name: cp_9_b

Type: string

Default: "щорічно"

Виконується резервне копіювання інформації системи, що міститься в системі частота; CP-09(c) створюються резервні копії документації системи, включаючи документацію, пов'язану з безпекою та конфіденційністю частота

No: 4

Name: cp_9_d_01

Type: string

Default: nil

Конфіденційність резервних копій інформації захищена

No: 5

Name: cp_9_d_02

Type: string

Default: nil

Цілісність резервних копій інформації захищена

No: 6

Name: cp_9_d_03

Type: string

Default: nil

Доступність резервних копій інформації захищена

No: 7

Name: cp_9_odp_01

Type: string

Default: nil

Визначено компоненти системи, для яких необхідно проводити резервне копіювання інформації користувачів

No: 8

Name: cp_9_odp_02

Type: integer

Default: 30

Визначено частоту, з якою слід проводити резервне копіювання інформації користувача відповідно до часу відновлення та цілей відновлення

No: 9

Name: cp_9_odp_03

Type: integer

Default: 30

Визначено частоту проведення резервного копіювання інформації системи, що відповідає завдань відновлення і встановлених цілей відновлення

No: 10

Name: cp_9_odp_04

Type: integer

Default: 30

Визначено частоту, з якою слід проводити резервне копіювання документації системи відповідно до часу відновлення та цілей точки відновлення

6.9.1. ВИПРОБУВАННЯ НА НАДІЙНІСТЬ ТА ЦІЛІСНІСТЬ (CP-9(1))

No: 1

Name: cp_9_1_01

Type: string

Default: "щорічно"

Носії резервних копій інформації тестується 09(01)_ODP[01] частота> для перевірки надійності; <CP-

No: 2

Name: cp_9_1_02

Type: string

Default: "щорічно"

Носії резервних копій інформації тестується 09(01)_ODP[02] частота> для перевірки цілісності; <CP-

No: 3

Name: cp_9_1_odp_01

Type: integer

Default: 30

Визначено частоту тестування на надійність носіїв резервних копій інформації

No: 4

Name: cp_9_1_odp_02

Type: integer

Default: 30

Визначено частоту тестування на цілісність носіїв резервних копій інформації

6.9.2. ТЕСТУВАННЯ ВІДНОВЛЕННЯ З ВИКОРИСТАННЯМ ЗРАЗКІВ (СР-9(2))

No: 1

Name: cp_9_2_01

Type: integer

Default: 30

Використовується зразок резервної копії інформації при відновленні вибраних функцій системи як частину тестування плану забезпечення безперервної роботи та відновлення функціонування

6.9.3. ВІДОКРЕМЛЕНЕ СХОВИЩЕ КРИТИЧНОЇ ІНФОРМАЦІЇ (СР-9(3))

No: 1

Name: cp_9_3_01

Type: string

Default: nil

Резервні копії критичного системного програмного забезпечення та іншої інформації, пов'язаної з безпекою зберігаються в окремому сховищі або у вогнетривкому контейнері, не пов'язаному з системою

No: 2

Name: cp_9_3_odp

Type: string

Default: nil

Визначено критичного системного програмного забезпечення та іншої інформації, пов'язаної з безпекою яке має зберігатися в окремому сховищі або у вогнетривкому контейнері

6.9.4. ПЕРЕДАЧА НА АЛЬТЕРНАТИВНЕ СХОВИЩЕ ЗБЕРІГАННЯ (СР-9(5))

No: 1

Name: cp_9_5_01

Type: integer

Default: 30

Інформація резервної копії системи передається до альтернативного сховища протягом періоду часу; СР-09(05)[02] інформація резервної копії системи передається до альтернативного сховища з швидкістю передачі

No: 2

Name: cp_9_5_odp_01

Type: integer

Default: 30

Визначено період часу, що відповідає часу відновлення та цілям відновлення

No: 3

Name: cp_9_5_odp_02

Type: integer

Default: 30

Визначено швидкість передачі даних, що відповідає часу відновлення та цілям відновлення

6.9.5. НАДЛИШКОВА ВТОРИННА СИСТЕМА (СР-9(6))

No: 1

Name: cp_9_6_01

Type: string

Default: nil

Резервне копіювання системи здійснюється шляхом підтримки надлишкової вторинної системи, яка не пов'язана з первинною системою

No: 2

Name: cp_9_6_02

Type: string

Default: nil

Резервне копіювання системи здійснюється шляхом підтримки резервної вторинної системи, яка може бути активована без втрати інформації або порушення роботи

6.9.6. ПОДВІЙНА АВТОРИЗАЦІЯ (СР-9(7))

No: 1

Name: cp_9_7_01

Type: string

Default: nil

Застосовано подвійну авторизацію для видалення або знищення резервної інформації

No: 2

Name: cp_9_7_odp

Type: string

Default: nil

Визначено резервну інформацію, для якої необхідно застосувати подвійну авторизацію з метою видалення або знищення

6.9.7. КРИПТОГРАФІЧНИЙ ЗАХИСТ (СР-9(8))

No: 1

Name: cp_9_8_01

Type: string

Default: "AES-256-GCM"

Реалізовано криптографічні механізми для запобігання несанкціонованому розкриттю та зміні резервної інформації

No: 2

Name: cp_9_8_odp

Type: string

Default: nil

Визначено резервні копії інформації для захисту від несанкціонованого розкриття та змін

6.10. ВІДНОВЛЕННЯ ТА ВІДТВОРЕННЯ СИСТЕМИ (CP-10)

No: 1

Name: cp_10_01

Type: integer

Default: 30

Відновлення системи до відомого стану забезпечується протягом часу після збою, компрометації або помилки

No: 2

Name: cp_10_02

Type: integer

Default: 30

Відтворення системи до відомого стану забезпечується протягом часу після збою, компрометації або помилки

No: 3

Name: cp_10_odp_02

Type: integer

Default: 30

Визначено період часу для відновлення, часу та цілям відновлення системи; визначено період часу для відтворення, часу та цілям відновлення системи

6.10.1. ВІДНОВЛЕННЯ ТРАНЗАКЦІЙ (CP-10(2))

No: 1

Name: cp_10_2_01

Type: string

Default: nil

Реалізовано відновлення транзакцій для систем, що базуються на транзакціях

6.10.2. ВІДНОВЛЕННЯ В МЕЖАХ ЧАСОВОГО ПЕРІОДУ (CP-10(4))

No: 1

Name: cp_10_4_01

Type: integer

Default: 30

Забезпечено можливість відновлення компонентів системи протягом періоду часу відновлення з інформації управління конфігурацією та захищеною цілісністю, яка описує відомий робочий стан компонентів

No: 2

Name: cp_10_4_odp

Type: integer

Default: 30

Визначено період часу відновлення, протягом якого компоненти системи відновлюються до відомого, робочого стану

6.10.3. ЗДАТНІСТЬ ВІДМОВОСТІЙКОСТІ (CP-10(5))

No: 1

Name: cp_10_5_01
 Type: string
 Default: nil

ВІДНОВЛЕННЯ ТА ВІДТВОРЕННЯ СИСТЕМИ - ЗДАТНІСТЬ ВІДМОВОСТІЙКОСТІ [Вилучено: Включено до SI-13]. CP10(06) ВІДНОВЛЕННЯ ТА ВІДТВОРЕННЯ СИСТЕМИ - ЗАХИСТ КОМПОНЕНТУ

6.11. АЛЬТЕРНАТИВНІ ПРОТОКОЛИ ЗВ'ЯЗКУ (CP-11)

No: 1
 Name: cp_11_01
 Type: string
 Default: "TLS 1.3"

Організація забезпечує можливість застосування альтернативних протоколів зв'язку для підтримки збереження безперервності функціонування

6.12. БЕЗПЕЧНИЙ РЕЖИМ (CP-12)

No: 1
 Name: cp_12_01
 Type: list
 Default: []

При виявленні умови, вводиться безпечний режим роботи з обмеженням

No: 2
 Name: cp_12_odp_01
 Type: list
 Default: []

Визначено умови, за яких організація вводить безпечний режим роботи

No: 3
 Name: cp_12_odp_02
 Type: string
 Default: nil

Визначено обмеження в безпечному режимі роботи

6.13. АЛЬТЕРНАТИВНІ МЕХАНІЗМИ БЕЗПЕКИ (CP-13)

No: 1
 Name: cp_13_01
 Type: string
 Default: "автоматизований засіб моніторингу"

Альтернативні або додаткові механізми безпеки використовуються для реалізації функцій безпеки, коли основні засоби реалізації функцій безпеки недоступні або скомпрометовані

No: 2

Name: cp_13_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначені альтернативні або додаткові механізми безпеки

No: 3

Name: cp_13_odp_02

Type: string

Default: nil

Визначені функції безпеки

7. ІА

Клас заходів захисту ІА — ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ

Цей клас відповідає за однозначне розпізнавання користувачів або пристроїв та підтвердження їхньої справжності перед наданням доступу до системи.

Перелік заходів захисту: Політика та процедури ідентифікації та автентифікації (ІА-1); Ідентифікація та автентифікація користувачів (ІА-2); Багатофакторна автентифікація привілейованих облікових записів (ІА-2(1)); Багатофакторна автентифікація непривілейованих (ІА-2(2)); Локальний доступ до привілейованих облікових записів (ІА-2(3)); Локальний доступ до непривілейованих облікових записів (ІА-2(4)); Індивідуальна автентифікація з груповою автентифікацією (ІА-2(5)); Мережевий доступ до непривілейованих облікових записів – окремий пристрій (ІА-2(7)); Доступ до облікових записів — стійкість до відтворення (ІА-2(8)); Доступ до непривілейованих облікових записів – стійкість до відтворення (ІА-2(9)); Єдина точка входу (ІА-2(10)); Віддалений доступ - окремий пристрій (ІА-2(11)); ПРИЙНЯТТЯ ПОВНОВАЖЕНЬ ДЛЯ ВЕРИФІКАЦІЇ ОСОБИСТОЇ ІНФОРМАЦІЇ (PIV CREDENTIALS) (ІА-2(12)); Автентифікація по зовнішньому каналу (ІА-2(13)); Ідентифікація та автентифікація пристроїв (ІА-3); Криптографічна двобічна автентифікація (ІА-3(1)); Криптографічний двобічна мережа автентифікація [виключено: включено до іа-03(01)]. (ІА-3(2)); Динамічний розподіл адреси (ІА-3(3)); Ідентифікація та автентифікація пристрою виконується на основі атестації за допомогою (ІА-3(4)); Управління ідентифікацією (ІА-4); Заборона використання ідентифікаторів облікових записів таки самих, як й публічні ідентифікатори (ІА-4(1)); Авторизація супервайзера [виключено: включено до іа-12(01)]. (ІА-4(2)); Множинні форми сертифікації (ІА-4(3)); Ідентифікація статусу користувача (ІА-4(4)); Динамічне управління (ІА-4(5)); Крос-організаційне управління (ІА-4(6)); Особиста реєстрація [виключено: включено до іа-12(04)]. (ІА-4(7)); Попарні псевдонімні ідентифікатори (ІА-4(8)); Попарні псевдонімні ідентифікатори (ІА-4(9)); АВТЕНТИФІКАТОР УПРАВЛІННЯ; Автентифікація на основі пароля (ІА-5(1)); Автентифікація на основі відкритого ключа (ІА-5(2)); Особиста або довірча автентифікація зовнішньої сторони [виключено: включено до іа-12(04)]. (ІА-5(3)); Автоматизована підтримка для визначення міцності пароля [виключено: включено до іа-05(01)]. (ІА-5(4)); Зміна автентифікаторів до доставки (ІА-5(5)); Захист автентифікаторів (ІА-5(6)); Відсутність вбудованих незашифрованих статичних автентифікаторів (ІА-5(7)); Багатовимірні облікові записи (ІА-5(8)); Управління об'єднанням автентифікаторів (ІА-5(9)); Динамічне зв'язування мандатів (ІА-5(10)); Автентифікація на основі апаратних токенів (ІА-5(11)); Ефективність біометричної автентифікації (ІА-5(12)); Закінчення терміну шування автентифікаторів (ІА-5(13)); Управління змістом довірчих сховищ інфраструктури відкритих ключів (ІА-5(14)); Продукти та послуги, затверджені уповноваженим органом (ІА-5(15)); Передача особистої або довірчої автентифікації зовнішньої сторони (ІА-5(16)); Автоматизовані засоби виявлення атак із використанням біометричних автентифікаторів (ІА-5(17)); Менеджер паролів (ІА-5(18)); ПРИХОВУВАННЯ ЗВОРОТНОГО ЗВ'ЯЗКУ АВТЕНТИФІКАТОРА; Автентифікація крипто-

графічного модуля (IA-7); ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІ, ЩО НЕ НАЛЕЖАТЬ ДО ОРГАНІЗАЦІЇ) (IA-8); Використання затверджених продуктів (IA-8(3)); ВИЗНАННЯ ПОСВІДЧЕНЬ ОСОБИ (PIV-I) (IA-8(5)); Розмежування (IA-8(6)); Послуги ідентифікації та автентифікації (IA-9); Обмін інфо- (IA-9(1)); Передача рішень [виключено: перенесено до ia-09] (IA-9(2)); Адаптивна автентифікація (IA-10); Повторна автентифікація (IA-11); ПЕРЕВІРКА СПРАВЖНОСТІ (ІДЕНТИЧНОСТІ) (IA-12); Авторизація супервайзера (IA-12(1)); Посвідчення особи (IA-12(2)); Очна перевірка та верифікація (IA-12(4)); Підтвердження адреси (IA-12(5)); Прийняття ідентифікацій схвалених третьою стороною (IA-12(6)).

7.1. Політика та процедури ідентифікації та автентифікації (IA-1)

No: 1

Name: ia_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику ідентифікації та автентифікації

No: 2

Name: ia_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика ідентифікації та автентифікації поширюється на персонал або ролі

No: 3

Name: ia_1_a_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблені та задокументовані процедури ідентифікації та автентифікації, що сприяють впровадженню політики ідентифікації та автентифікації, а також відповідні заходи ідентифікації та перевірки автентичності

No: 4

Name: ia_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління політикою та процедурами ідентифікації та автентифікації; IA-01(c)[01][01] переглядається та оновлюється поточна політика ідентифікації та автентифікації частота; IA-01(c)[01][02] переглядається та оновлюється поточна політика ідентифікації та автентифікації після подій; IA-01(c)[02][01] переглядаються та оновлюються поточні процедури ідентифікації та автентифікації частота; IA-01(c)[02][02] переглядаються та оновлюються поточні процедури ідентифікації та автентифікації після подій

No: 5

Name: ia_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюється політика ідентифікації та автентифікації

No: 6

Name: ia_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури ідентифікації та автентифікації

No: 7

Name: ia_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесів; рівень системи}

No: 8

Name: ia_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка управляє політикою та процедурами ідентифікації та автентифікації

No: 9

Name: ia_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика ідентифікації та автентифікації

No: 10

Name: ia_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, які потребують перегляду та оновлення поточної політики ідентифікації та автентифікації

No: 11

Name: ia_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури ідентифікації та автентифікації

No: 12

Name: ia_1_odp_08

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують перегляду та оновлення процедур ідентифікації та автентифікації

7.2. ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ КОРИСТУВАЧІВ (IA-2)

No: 1

Name: ia_2_01

Type: string

Default: nil

ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: ia_2_02

Type: string

Default: nil

Процеси що діють від імені користувачів унікально ідентифіковані та автентифіковані

7.2.1. БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ ПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ (ІА-2(1))

No: 1
Name: ia_2_1_01
Type: string
Default: nil

Реалізовано багатофакторну автентифікацію для доступу до привілейованих облікових записів

7.2.2. БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ НЕПРИВІЛЕЙОВАНИХ (ІА-2(2))

No: 1
Name: ia_2_2_01
Type: string
Default: nil

Реалізовано багатофакторну автентифікацію для доступу до непривілейованих облікових записів

7.2.3. ЛОКАЛЬНИЙ ДОСТУП ДО ПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ (ІА-2(3))

No: 1
Name: ia_2_3_01
Type: string
Default: nil

ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - ЛОКАЛЬНИЙ ДОСТУП
ДО ПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ [Вилучено: Включено до ІА-02(01)]

7.2.4. ЛОКАЛЬНИЙ ДОСТУП ДО НЕПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ (ІА-2(4))

No: 1
Name: ia_2_4_01
Type: string
Default: nil

ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - ЛОКАЛЬНИЙ ДОСТУП
ДО НЕПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ [Вилучено: Включено до ІА-02(02)]

7.2.5. ІНДИВІДУАЛЬНА АВТЕНТИФІКАЦІЯ З ГРУПОВОЮ АВТЕНТИФІКАЦІЄЮ (ІА-2(5))

No: 1
Name: ia_2_5_01
Type: string
Default: nil

Користувачі повинні пройти індивідуальну автентифікацію перед наданням доступу до спільних облікових записів або ресурсів, якщо використовуються спільні облікові записи або автентифікатори

7.2.6. МЕРЕЖЕВИЙ ДОСТУП ДО НЕПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ – ОКРЕМИЙ ПРИСТРІЙ (IA-2(7))

No: 1
Name: ia_2_7_01
Type: string
Default: nil

ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - МЕРЕЖЕВИЙ ДОСТУП ДО НЕПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ – ОКРЕМИЙ ПРИСТРІЙ [Вилучено: Включено до IA-02(01)]

7.2.7. Доступ до облікових записів — стійкість до відтворення (IA-2(8))

No: 1
Name: ia_2_8_odp
Type: string
Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {привілейовані облікові записи; непривілейовані облікові записи}

7.2.8. ДОСТУП ДО НЕПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ – СТІЙКІСТЬ ДО ВІДТВОРЕННЯ (IA-2(9))

No: 1
Name: ia_2_9_01
Type: string
Default: nil

ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - ДОСТУП ДО НЕПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ – СТІЙКІСТЬ ДО ВІДТВОРЕННЯ [Вилучено: Включено до IA-02(08)]. IA-02(10) ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - ЄДИНА ТОЧКА ВХОДУ

7.2.9. ЄДИНА ТОЧКА ВХОДУ (IA-2(10))

No: 1
Name: ia_2_10_odp
Type: string
Default: nil

Визначено облікові записи та послуги системи, для яких має бути забезпечена можливість єдиного входу; забезпечено можливість єдиного входу для облікових записів і послуг системи

7.2.10. ВІДДАЛЕНИЙ ДОСТУП - ОКРЕМИЙ ПРИСТРІЙ (IA-2(11))

No: 1
Name: ia_2_11_01
Type: string

Default: nil

ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - ВІДДАЛЕНИЙ ДОСТУП -
ОКРЕМИЙ ПРИСТРІЙ [Вилучено: Включено до IA-02(06)]

7.2.11. ПРИЙНЯТТЯ ПОВНОВАЖЕНЬ ДЛЯ ВЕРИФІКАЦІЇ ОСОБИСТОЇ ІНФОРМАЦІЇ (PIV CREDENTIALS) (IA-2(12))

No: 1

Name: ia_2_12_01

Type: list

Default: ["admin", "security_officer"]

Приймаються та електронним шляхом підтверджуються повноваження облікових даних особистої ідентифікації

7.2.12. АВТЕНТИФІКАЦІЯ ПО ЗОВНІШНЬОМУ КАНАЛУ (IA-2(13))

No: 1

Name: ia_2_13_01

Type: string

Default: "автоматизований засіб моніторингу"

Механізми зовнішньої автентифікації застосовано за умов

No: 2

Name: ia_2_13_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено механізми зовнішньої автентифікації

No: 3

Name: ia_2_13_odp_02

Type: list

Default: []

Визначено умови, за яких має бути реалізована зовнішня автентифікація

7.3. ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ ПРИСТРОЇВ (IA-3)

No: 1

Name: ia_3_odp_01

Type: string

Default: nil

Визначені пристрої та/або типи пристроїв, які повинні бути унікально ідентифіковані та автентифіковані перед установкою підключення

No: 2

Name: ia_3_odp_02

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {локальний; віддалений; мережевий}

7.3.1. КРИПТОГРАФІЧНА ДВОБІЧНА АВТЕНТИФІКАЦІЯ (IA-3(1))

No: 1

Name: ia_3_1_odp_01

Type: string

Default: "AES-256-GCM"

Визначено пристрої та/або типи пристроїв, які потребують використання двобічної автентифікації яка заснована на криптографічних механізмах для автентифікації перед встановленням підключення

No: 2

Name: ia_3_1_odp_02

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {локальний; віддалений; мережевий}

7.3.2. КРИПТОГРАФІЧНИЙ ДВОБІЧНА МЕРЕЖА АВТЕНТИФІКАЦІЯ [Виключено: включено до IA-03(01)]. (IA-3(2))

Немає параметрів для цього контролю.

7.3.3. ДИНАМІЧНИЙ РОЗПОДІЛ АДРЕСИ (IA-3(3))

No: 1

Name: ia_3_3_a_01

Type: string

Default: nil

Інформація про оренду динамічного розподілу адрес, що призначається пристроєм з динамічним розподілом адрес, стандартизована відповідно до інформація про оренду

No: 2

Name: ia_3_3_a_02

Type: string

Default: nil

Тривалість оренди динамічного виділення адреси, що призначається пристроєм з динамічним виділенням адреси, стандартизовано відповідно до тривалість оренди

No: 3

Name: ia_3_3_b

Type: string

Default: nil

Інформація про оренду перевіряється, коли її призначено пристрою

No: 4

Name: ia_3_3_odp_01

Type: string

Default: nil

Визначено інформацію про оренду, яку буде використано для стандартизації динамічного розподілу адрес для пристроїв

No: 5

Name: ia_3_3_odp_02

Type: string

Default: nil

Визначено тривалість оренди, яка буде використовуватися для стандартизації динамічного виділення адрес для пристроїв

7.3.4. ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ ПРИСТРОЮ ВИКОНУЄТЬСЯ НА ОСНОВІ АТЕСТАЦІЇ ЗА ДОПОМОГОЮ (IA-3(4))

No: 1

Name: ia_3_4_01

Type: string

Default: nil

Ідентифікація та автентифікація пристрою виконується на основі атестації за допомогою процес управління конфігурацією

No: 2

Name: ia_3_4_odp

Type: string

Default: nil

Визначено процес управління конфігурацією, який буде використовуватися для ідентифікації та автентифікації пристроїв на основі атестації

7.4. УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ (IA-4)

No: 1

Name: ia_4_a

Type: list

Default: ["admin", "security_officer"]

Управління ідентифікаторами здійснюється шляхом отримання дозволу від персоналу або ролей на призначення ідентифікатора особі, групі, ролі або пристрою

No: 2

Name: ia_4_b

Type: list

Default: ["admin", "security_officer"]

Управління ідентифікаторами здійснюється шляхом вибору ідентифікатора, який ідентифікує окрему особу, групу, ролі або пристрій

No: 3

Name: ia_4_c

Type: list

Default: ["admin", "security_officer"]

Управління ідентифікаторами здійснюється шляхом призначення ідентифікатора особі, групі, ролі або пристрою; IA-04(d) ідентифікатори управляються шляхом запобігання повторному використанню ідентифікаторів впродовж період часу

No: 4
 Name: ia_4_odp_01
 Type: list
 Default: ["admin", "security_officer"]

Визначено персонал або ролі, від яких необхідно отримати дозвіл на призначення ідентифікатора

No: 5
 Name: ia_4_odp_02
 Type: integer
 Default: 30

Визначено період часу для запобігання повторному використанню ідентифікаторів

7.4.1. ЗАБОРОНА ВИКОРИСТАННЯ ІДЕНТИФІКАТОРІВ ОБЛІКОВИХ ЗАПИСІВ ТАКИ САМИХ, ЯК Й ПУБЛІЧНІ ІДЕНТИФІКАТОРИ (IA-4(1))

No: 1
 Name: ia_4_1_01
 Type: string
 Default: nil

Заборонено використання ідентифікаторів облікових записів системи, які збігаються із загальнодоступними ідентифікаторами для індивідуальних облікових записів

7.4.2. АВТОРИЗАЦІЯ СУПЕРВАЙЗЕРА [Виключено: Включено до IA-12(01)]. (IA-4(2))

No: 1
 Name: ia_4_2_01
 Type: string
 Default: nil

УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ - АВТОРИЗАЦІЯ СУПЕРВАЙЗЕРА [Виключено: Включено до IA-12(01)]

7.4.3. МНОЖИННІ ФОРМИ СЕРТИФІКАЦІЇ (IA-4(3))

No: 1
 Name: ia_4_3_01
 Type: string
 Default: nil

УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ - МНОЖИННІ ФОРМИ СЕРТИФІКАЦІЇ [Виключено: Включено до IA-12(02)]

7.4.4. ІДЕНТИФІКАЦІЯ СТАТУСУ КОРИСТУВАЧА (IA-4(4))

No: 1
 Name: ia_4_4_01
 Type: string
 Default: nil

Управління індивідуальними ідентифікаторами, однозначно ідентифікуючи кожного індивідуума ознака, що ідентифікує індивідуальний статус

No: 2
 Name: ia_4_4_odp
 Type: string
 Default: nil

Визначено ознаку, що ідентифікує індивідуальний статус

7.4.5. ДИНАМІЧНЕ УПРАВЛІННЯ (IA-4(5))

No: 1
 Name: ia_4_5_01
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Індивідуальні ідентифікатори динамічно управляються відповідно до політика динамічних ідентифікаторів

No: 2
 Name: ia_4_5_odp
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Визначено політику динамічних ідентифікаторів управління індивідуальними ідентифікаторами

7.4.6. КРОС-ОРГАНІЗАЦІЙНЕ УПРАВЛІННЯ (IA-4(6))

No: 1
 Name: ia_4_6_odp
 Type: string
 Default: nil

Визначено зовнішні організації з якими необхідно здійснювати координацію для крос-організаційного управління ідентифікаторами; здійснюється координація з зовнішні організації для крос-організаційного управління ідентифікаторами

7.4.7. ОСОБИСТА РЕЄСТРАЦІЯ [Виключено: Включено до IA-12(04)]. (IA-4(7))

No: 1
 Name: ia_4_7_01
 Type: list
 Default: ["admin", "security_officer"]

УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ - ОСОБИСТА РЕЄСТРАЦІЯ [Виключено: Включено до IA-12(04)]

7.4.8. ПОПАРНІ ПСЕВДОНІМНІ ІДЕНТИФІКАТОРИ (IA-4(8))

No: 1
 Name: ia_4_8_01
 Type: string
 Default: nil

Створено попарні псевдонімні ідентифікатори

7.4.9. ПОПАРНІ ПСЕВДОНІМНІ ІДЕНТИФІКАТОРИ (IA-4(9))

No: 1

Name: ia_4_9_odp

Type: list

Default: ["admin", "security_officer"]

Визначено захищене центральне сховище, яке використовується для зберігання атрибутів для кожної унікально ідентифікованої особи, пристрою або служби; атрибути для кожної унікально ідентифікованої особи, пристрою або служби зберігаються у захищеному центральному сховищі

7.5. АВТЕНТИФІКАТОР УПРАВЛІННЯ

No: 1

Name: ia_5_a

Type: list

Default: ["admin", "security_officer"]

Управління системними автентифікаторами здійснюється шляхом перевірки, як частини початкового розподілу автентифікатора, особи, групи, ролі або пристрою, який отримує автентифікатор

No: 2

Name: ia_5_b

Type: string

Default: nil

Управління системними автентифікаторами здійснюється шляхом створення вихідного вмісту автентифікатора для будь-яких автентифікаторів, виданих організацією

No: 3

Name: ia_5_c

Type: string

Default: nil

Управління системними автентифікаторами здійснюється шляхом забезпечення того, щоб автентифікатори мали достатню стійкість механізму для їх використання за призначенням; IA-05(d) управління системними автентифікаторами здійснюється шляхом створення та реалізація адміністративних процедур для первинного розповсюдження автентифікаторів, для втрачених/скомпрометованих або пошкоджених автентифікаторів, а також для відкликання автентифікаторів

No: 4

Name: ia_5_e

Type: string

Default: nil

Управління системними автентифікаторами здійснюється шляхом зміни типових автентифікаторів перед першим використанням

No: 5

Name: ia_5_f

Type: list

Default: ["login", "logout", "failed_attempt"]

Управління системними автентифікаторами здійснюється шляхом зміни/оновлення автентифікаторів у встановлений період часу або коли відбуваються події

No: 6

Name: ia_5_g

Type: string

Default: nil

Управління системними автентифікаторами здійснюється шляхом захисту вмісту автентифікатора від несанкціонованого розкриття та модифікацій

No: 7

Name: ia_5_h

Type: string

Default: nil

Управління системними автентифікаторами здійснюється шляхом вимоги до осіб, які використовують пристрої, використовувати спеціальні заходи безпеки для захисту автентифікаторів

No: 8

Name: ia_5_i

Type: string

Default: nil

Управління системними автентифікаторами здійснюється шляхом вимоги змінювати автентифікатори для облікових записів груп/ролей при зміні членства в цих облікових записах

No: 9

Name: ia_5_odp_01

Type: integer

Default: 30

Визначено період часу для зміни або оновлення автентифікаторів за типом автентифікатора

7.5.1. АВТЕНТИФІКАЦІЯ НА ОСНОВІ ПАРОЛЯ (ІА-5(1))

No: 1

Name: ia_5_1_a

Type: list

Default: ["admin", "security_officer"]

Для автентифікації на основі паролів підтримується та оновлюється список часто використовуваних, очікуваних або скомпрометованих паролів частота, а також коли є підозра, що паролі організації були скомпрометовані прямо чи опосередковано

No: 2

Name: ia_5_1_b

Type: list

Default: ["admin", "security_officer"]

Для автентифікації на основі паролів, коли паролі створюються або оновлюються користувачами, паролі перевіряються на відсутність у списку загальновживаних, очікуваних або скомпрометованих паролів в ІА-05(01)(a)

No: 3

Name: ia_5_1_c

Type: list

Default: ["admin", "security_officer"]

Для автентифікації на основі паролів, паролі передаються лише криптографічно захищеними каналами

No: 4

Name: ia_5_1_d

Type: list

Default: ["admin", "security_officer"]

Для автентифікації на основі паролів паролі зберігаються за допомогою затвердженого алгоритму гешування, переважно використовуючи ключову геш-функцію

No: 5
 Name: ia_5_1_e
 Type: string
 Default: nil

Для автентифікації на основі пароля після відновлення облікового запису потрібно негайно вибрати новий пароль

No: 6
 Name: ia_5_1_f
 Type: list
 Default: ["admin", "security_officer"]

Для автентифікації на основі пароля дозволяється вибір користувачем довгих паролів і фраз, що включають пробіли та всі друковані символи

No: 7
 Name: ia_5_1_g
 Type: list
 Default: ["admin", "security_officer"]

Для автентифікації на основі пароля використовуються автоматизовані інструменти, які допомагають користувачеві у виборі надійних автентифікаторів паролів

No: 8
 Name: ia_5_1_h
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Для автентифікації на основі пароля застосовуються склад та правила складності

No: 9
 Name: ia_5_1_odp_01
 Type: list
 Default: ["admin", "security_officer"]

Визначено частоту оновлення списку часто використовуваних, очікуваних або скомпрометованих паролів

No: 10
 Name: ia_5_1_odp_02
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Визначено склад та правила складності автентифікатора

7.5.2. АВТЕНТИФІКАЦІЯ НА ОСНОВІ ВІДКРИТОГО КЛЮЧА (IA-5(2))

Немає параметрів для цього контролю.

7.5.3. ОСОБИСТА АБО ДОВІРЧА АВТЕНТИФІКАЦІЯ ЗОВНІШНЬОЇ СТОРОНИ [Виключено: Включено до IA-12(04)]. (IA-5(3))

No: 1

Name: ia_5_3_01

Type: list

Default: ["admin", "security_officer"]

УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - ОСОБИСТА АБО ДОВІРЧА АВТЕНТИФІКАЦІЯ ЗОВНІШНЬОЇ
СТОРОНИ [Виключено: Включено до IA-12(04)]

7.5.4. АВТОМАТИЗОВАНА ПІДТРИМКА ДЛЯ ВИЗНАЧЕННЯ МІЦНОСТІ ПАРОЛЯ [Виключено: Включено до IA-05(01)]. (IA-5(4))

No: 1

Name: ia_5_4_01

Type: string

Default: nil

УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - АВТОМАТИЗОВАНА ПІДТРИМКА ДЛЯ ВИЗНАЧЕННЯ МІ-
ЦНОСТІ ПАРОЛЯ [Виключено: Включено до IA-05(01)]

7.5.5. ЗМІНА АВТЕНТИФІКАТОРІВ ДО ДОСТАВКИ (IA-5(5))

No: 1

Name: ia_5_5_01

Type: string

Default: nil

Розробники та інсталятори компонентів системи зобов'язані надавати унікальні автентифікатори або змінювати
автентифікатори за замовчуванням до доставки та встановлення

7.5.6. ЗАХИСТ АВТЕНТИФІКАТОРІВ (IA-5(6))

No: 1

Name: ia_5_6_01

Type: string

Default: nil

Автентифікатори захищені відповідно до категорії безпеки інформації, до якої дозволяє доступ використання
автентифікатора

7.5.7. ВІДСУТНІСТЬ ВБУДОВАНИХ НЕЗАШИФРОВАНИХ СТАТИЧНИХ АВТЕНТИФІКАТОРІВ (IA-5(7))

No: 1

Name: ia_5_7_01

Type: string

Default: nil

Незашифровані статичні автентифікатори не вбудовуються в застосунки або сценарії доступу та не збережені на функціональній клавіші

7.5.8. БАГАТОСИСТЕМНІ ОБЛІКОВІ ЗАПИСИ (IA-5(8))

No: 1

Name: ia_5_8_01

Type: string

Default: nil

Заходи захисту впроваджені для управління ризиком компрометації через наявність облікових записів у декількох системах

No: 2

Name: ia_5_8_odp

Type: string

Default: nil

Визначено заходи захисту, впроваджені для управління ризиком компрометації через те, що користувачі мають облікові записи в декількох системах

7.5.9. УПРАВЛІННЯ ОБ'ЄДНАННЯМ АВТЕНТИФІКАТОРІВ (IA-5(9))

No: 1

Name: ia_5_9_01

Type: string

Default: nil

Зовнішні організації використовуються для об'єднання автентифікаторів

No: 2

Name: ia_5_9_odp

Type: string

Default: nil

Визначено зовнішні організації, які будуть використовуватися для об'єднання автентифікаторів

7.5.10. ДИНАМІЧНЕ ЗВ'ЯЗУВАННЯ МАНДАТІВ (IA-5(10))

No: 1

Name: ia_5_10_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Ідентифікатори та автентифікатори динамічно зв'язуються за допомогою правила для динамічного зв'язування

No: 2

Name: ia_5_10_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено правила для динамічного зв'язування ідентифікаторів та автентифікаторів

7.5.11. АВТЕНТИФІКАЦІЯ НА ОСНОВІ АПАРАТНИХ ТОКЕНІВ (ІА-5(11))

No: 1
Name: ia_5_11_01
Type: string
Default: nil

УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - АВТЕНТИФІКАЦІЯ НА ОСНОВІ АПАРАТНИХ ТОКЕНІВ [Вилучено: Включено до ІА-02(01), ІА-02(02)]

7.5.12. ЕФЕКТИВНІСТЬ БІОМЕТРИЧНОЇ АВТЕНТИФІКАЦІЇ (ІА-5(12))

No: 1
Name: ia_5_12_odp
Type: string
Default: "автоматизований засіб моніторингу"

Визначено вимоги до якості біометрії; для біометричної автентифікації використовувати механізми, які задовольняють вимоги

7.5.13. ЗАКІНЧЕННЯ ТЕРМІНУ ШУВАННЯ АВТЕНТИФІКАТОРІВ (ІА-5(13))

No: 1
Name: ia_5_13_odp
Type: integer
Default: 30

Визначено періоду часу після якого необхідно заборонити використання кешованих автентифікаторів забороняється використання кешованих автентифікаторів після періоду часу

7.5.14. УПРАВЛІННЯ ЗМІСТОМ ДОВІРЧИХ СХОВИЩ ІНФРАСТРУКТУРИ ВІДКРИТИХ КЛЮЧІВ (ІА-5(14))

No: 1
Name: ia_5_14_01
Type: string
Default: nil

Для автентифікації на основі інфраструктури з відкритим ключем використовується загальноорганізаційна методологія управління змістом довірених сховищ інфраструктури відкритого ключа, встановлених на всіх платформах, включно з мережами, операційними системами, браузерами та застосунками

7.5.15. ПРОДУКТИ ТА ПОСЛУГИ, ЗАТВЕРДЖЕНІ УПОВНОВАЖЕНИМ ОРГАНОМ (ІА-5(15))

No: 1
Name: ia_5_15_01
Type: string
Default: nil

Використовуються лише схвалені та затверджені уповноваженим органом продукти та послуги

7.5.16. ПЕРЕДАЧА ОСОБИСТОЇ АБО ДОВІРЧОЇ АВТЕНТИФІКАЦІЇ ЗОВНІШНЬОЇ СТОРОНИ (IA-5(16))

No: 1

Name: ia_5_16_01

Type: list

Default: ["admin", "security_officer"]

УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - ПЕРЕДАЧА ОСОБИСТОЇ АБО ДОВІРЧОЇ АВТЕНТИФІКАЦІЇ
ЗОВНІШНЬОЇ СТОРОНИ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: ia_5_16_odp_01

Type: string

Default: nil

Визначено типи та/або конкретні автентифікатори, які будуть передаватися

No: 3

Name: ia_5_16_odp_02

Type: list

Default: ["admin", "security_officer"]

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {особисто; довіреною зовнішньою стороною}

No: 4

Name: ia_5_16_odp_03

Type: string

Default: nil

Визначено зареєстрований орган, який приймає автентифікатори

No: 5

Name: ia_5_16_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які уповноважують передачу автентифікаторів

7.5.17. АВТОМАТИЗОВАНІ ЗАСОБИ ВИЯВЛЕННЯ АТАК ІЗ ВИКОРИСТАННЯМ БІОМЕТРИЧНИХ АВТЕНТИФІКАТОРІВ (IA-5(17))

No: 1

Name: ia_5_17_01

Type: string

Default: "автоматизований засіб моніторингу"

Використовуються механізми виявлення атак із використанням штучно виготовлених артефактів для біометричних автентифікаторів

7.5.18. МЕНЕДЖЕР ПАРОЛІВ (IA-5(18))

No: 1

Name: ia_5_18_a

Type: list

Default: ["admin", "security_officer"]

Менеджери паролів використовуються для створення та керування паролями

No: 2

Name: ia_5_18_b

Type: list

Default: ["admin", "security_officer"]

Паролі захищені за допомогою елементи керування

No: 3

Name: ia_5_18_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено менеджери паролів, які використовуються для створення та керування паролями

No: 4

Name: ia_5_18_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено елементи керування для захисту паролів

7.6. ПРИХОВУВАННЯ ЗВОРОТНОГО ЗВ'ЯЗКУ АВТЕНТИФІКАТОРА

No: 1

Name: ia_6_01

Type: list

Default: ["admin", "security_officer"]

Забезпечено приховану зворотну передачу інформації автентифікації в процесі автентифікації для забезпечення захисту інформації від можливої експлуатації та використання неавторизованими особами

7.7. АВТЕНТИФІКАЦІЯ КРИПТОГРАФІЧНОГО МОДУЛЯ (IA-7)

No: 1

Name: ia_7_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Впроваджено механізми автентифікації в криптографічний модуль, який відповідає вимогам чинних законів, виконавчих розпоряджень, директив, політик, правил, стандартів та рекомендацій для такої автентифікації

7.8. ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІ, ЩО НЕ НАЛЕЖАТЬ ДО ОРГАНІЗАЦІЇ) (IA-8)

No: 1
Name: ia_8_01
Type: string
Default: nil

Унікально ідентифікуються та автентифікуються користувачі, що не належать до організації або процеси (що не належать організації), які діють від імені користувачів

7.8.1. ВИКОРИСТАННЯ ЗАТВЕРДЖЕНИХ ПРОДУКТІВ (IA-8(3))

No: 1
Name: ia_8_3_01
Type: string
Default: nil

ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІ, ЩО НЕ НАЛЕЖАТЬ ДО ОРГАНІЗАЦІЇ) -
ВИКОРИСТАННЯ ЗАТВЕРДЖЕНИХ ПРОДУКТІВ [Вилучено: Включено до IA-08(02)]

7.8.2. ВИЗНАННЯ ПОСВІДЧЕНЬ ОСОБИ (PIV-I) (IA-8(5))

No: 1
Name: ia_8_5_01
Type: list
Default: ["default_deny_rule", "abac_rule_1"]

Приймаються облікові дані або дані РКІ, які відповідають політика

No: 2
Name: ia_8_5_02
Type: list
Default: ["default_deny_rule", "abac_rule_1"]

Підтверджуються облікові дані або дані РКІ, які відповідають політика

No: 3
Name: ia_8_5_odp
Type: list
Default: ["default_deny_rule", "abac_rule_1"]

Визначено політику використання ативних облікових даних або облікових даних РКІ

7.8.3. РОЗМЕЖУВАННЯ (IA-8(6))

No: 1
Name: ia_8_6_odp
Type: list
Default: ["admin", "security_officer"]

Визначено заходи, щоб розмежувати атрибути користувача або зв'язки підтвердження ідентифікатора між окремими особами, постачальниками облікових даних і довіреними сторонами; впроваджено заходи щоб

розмежувати атрибути користувача або зв'язки підтвердження ідентифікатора між окремими особами, постачальниками облікових даних і довіреними сторонами

7.9. ПОСЛУГИ ІДЕНТИФІКАЦІЇ ТА АВТЕНТИФІКАЦІЇ (IA-9)

No: 1
Name: ia_9_01
Type: string
Default: nil

Системні служби та застосунки унікально ідентифікуються та автентифікуються перед встановленням зв'язку з пристроями, користувачами або іншими службами чи застосунками

No: 2
Name: ia_9_odp
Type: string
Default: nil

Визначено системні служби та застосунки, які мають бути унікально ідентифіковані та автентифіковані

7.9.1. ОБМІН ІНФО- (IA-9(1))

No: 1
Name: ia_9_1_01
Type: string
Default: nil

ПОСЛУГИ ІДЕНТИФІКАЦІЇ ТА АВТЕНТИФІКАЦІЇ - ОБМІН ІНФО- РМАЦІЄЮ [Виключено: перенесено до IA-09]

7.9.2. ПЕРЕДАЧА РІШЕНЬ [Виключено: перенесено до IA-09] (IA-9(2))

No: 1
Name: ia_9_2_01
Type: string
Default: nil

ПОСЛУГИ ІДЕНТИФІКАЦІЇ ТА АВТЕНТИФІКАЦІЇ - ПЕРЕДАЧА РІШЕНЬ [Виключено: перенесено до IA-09]

7.10. АДАПТИВНА АВТЕНТИФІКАЦІЯ (IA-10)

No: 1
Name: ia_10_01
Type: list
Default: ["admin", "security_officer"]

Особи, які отримують доступ до системи, повинні використовувати додаткові методи або механізми автентифікації за певних обставин або ситуацій

No: 2
 Name: ia_10_odp_01
 Type: string
 Default: nil

Визначені обставини або ситуації, які вимагають від осіб, що отримують доступ до системи, використання додаткових методів або механізмів автентифікації

7.11. ПОВТОРНА АВТЕНТИФІКАЦІЯ (IA-11)

No: 1
 Name: ia_11_01
 Type: string
 Default: nil

Користувачі повинні повторно автентифікуватися, коли обставини або ситуації

No: 2
 Name: ia_11_odp
 Type: string
 Default: nil

Визначено обставини або ситуації, що вимагають повторної автентифікації

7.12. ПЕРЕВІРКА СПРАВЖНОСТІ (ІДЕНТИЧНОСТІ) (IA-12)

No: 1
 Name: ia_12_a
 Type: string
 Default: nil

Користувачі, яким потрібні облікові записи для логічного доступу до систем на основі вимог гарантій відповідного рівня, як це зазначено у відповідних стандартах і рекомендаціях, мають підтверджену ідентичність

No: 2
 Name: ia_12_b
 Type: list
 Default: ["admin", "security_officer"]

Встановлені ідентифікатори користувачів унікальні для особи

No: 3
 Name: ia_12_c_01
 Type: list
 Default: ["admin", "security_officer"]

Збираються докази ідентичності особи

No: 4
 Name: ia_12_c_02
 Type: list
 Default: ["admin", "security_officer"]

Затверджуються докази ідентичності особи

No: 5
Name: ia_12_c_03
Type: list
Default: ["admin", "security_officer"]

Перевіряються докази ідентичності особи

7.12.1. АВТОРИЗАЦІЯ СУПЕРВАЙЗЕРА (IA-12(1))

No: 1
Name: ia_12_1_01
Type: string
Default: nil

Процес реєстрації для отримання облікового запису для логічного доступу включає авторизацію супервайзера

7.12.2. ПОСВІДЧЕННЯ ОСОБИ (IA-12(2))

No: 1
Name: ia_12_2_01
Type: list
Default: ["admin", "security_officer"]

Документи, що посвідчують особу пред'являються до реєстраційного органу

7.12.3. ОЧНА ПЕРЕВІРКА ТА ВЕРИФІКАЦІЯ (IA-12(4))

No: 1
Name: ia_12_4_01
Type: list
Default: ["admin", "security_officer"]

Підтвердження та перевірка посвідчення особи проводиться особисто в призначеному органі реєстрації

7.12.4. ПІДТВЕРДЖЕННЯ АДРЕСИ (IA-12(5))

No: 1
Name: ia_12_5_01
Type: string
Default: nil

ПЕРЕВІРКА СПРАВЖНОСТІ (ІДЕНТИЧНОСТІ) - ПІДТВЕРДЖЕННЯ АДРЕСИ МЕТА ОЦІНКИ: Визначити, чи:

No: 2
Name: ia_12_5_odp
Type: string
Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {реєстраційний код; повідомлення про перевірку}

7.12.5. ПРИЙНЯТТЯ ІДЕНТИФІКАЦІЙ СХВАЛЕНИХ ТРЕТЬОЮ СТОРОНОЮ (IA-12(6))

No: 1
Name: ia_12_6_01

Type: string

Default: nil

Приймаються зовнішньо підтверджені ідентифікатори рівень гарантії ідентичності

No: 2

Name: ia_12_6_odp

Type: string

Default: nil

Визначено рівень гарантії ідентичності для прийняття зовнішньо підтверджених ідентифікаторів

8. IR

Клас заходів захисту IR — РЕАГУВАННЯ НА ІНЦИДЕНТИ

Цей клас визначає процедури виявлення, аналізу, локалізації та усунення наслідків інцидентів інформаційної безпеки.

Перелік заходів захисту: Політика та процедури реагування на інциденти (IR-1); Навчання з реагування на інциденти (IR-2); Моделювання подій (IR-2(1)); Злам (IR-2(3)); Перевірка реагувань на інциденти (IR-3); Координація з пов'язаними планами (IR-3(2)); Постійне покращення (IR-3(3)); Обробка інциденту (IR-4); Динамічна реконфігурація (IR-4(2)); Безперервність операцій (IR-4(3)); Інформаційна кореляція (IR-4(4)); Внутрішні загрози - особливі можливості (IR-4(6)); Координація з зовнішніми організаціями (IR-4(8)); Здатність динамічного реагування (IR-4(9)); Координація ланцюга постачання (IR-4(10)); Інтегрована група реагування на інциденти (IR-4(11)); Зловмисний код та криміналістичний аналіз (IR-4(12)); Аналіз поведінки (IR-4(13)); Центр безпеки (IR-4(14)); Зв'язки з громадкістю та відновлення репутації (IR-4(15)); Моніторинг інциденту (IR-5); Автоматизоване відстеження, збір даних і аналіз (IR-5(1)); Звітність про інциденти (IR-6); Автоматичне звітування (IR-6(1)); Координація ланцюжка постачання (IR-6(3)); Підтримка реагування на інциденти (IR-7); Автоматизація підтримки для забезпечення доступності інформації та підтримки (IR-7(1)); Координація з зовнішніми постачальниками (IR-7(2)); План реагування на інциденти (IR-8); Обробка персональних даних (IR-8(1)); Реагування на витік інформації (IR-9); Відповідальний персонал (IR-9(1)); Тренування (IR-9(2)); Робота після витоку (IR-9(3)); Викриття неавторизованого персоналу (IR-9(4)); Інтегрована команда аналізу інформаційної безпеки (IR-10).

8.1. Політика та процедури реагування на інциденти (IR-1)

No: 1

Name: ir_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику реагування на інциденти

No: 2

Name: ir_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика реагування на інциденти поширюється серед персоналу або ролей

No: 3

Name: ir_1_a_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблені та задокументовані процедури реагування на інциденти, що сприяють впровадженню політики реагування на інциденти та пов'язаних з нею заходів захисту з реагування на інциденти

No: 4

Name: ir_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур реагування на інциденти; IR-01(с)[01][01] переглядається та оновлюється поточна політика реагування на інциденти частота; IR-01(с)[01][02] поточна політика реагування на інциденти переглядається та оновлюється після подій; IR-01(с)[02][01] переглядаються та оновлюються поточні процедури реагування на інциденти частота; IR-01(с)[02][02] поточні процедури реагування на інциденти переглядаються та оновлюються після подій

No: 5

Name: ir_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких має бути доведена політика реагування на інциденти

No: 6

Name: ir_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких мають бути доведені процедури реагування на інциденти

No: 7

Name: ir_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: ir_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами реагування на інциденти

No: 9

Name: ir_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика реагування на інциденти

No: 10

Name: ir_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначаються події, які потребують перегляду та оновлення поточної політики реагування на інциденти

No: 11
 Name: ir_1_odp_07
 Type: integer
 Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури реагування на інциденти

No: 12
 Name: ir_1_odp_08
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують перегляду та оновлення процедур реагування на інциденти

8.2. НАВЧАННЯ З РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-2)

No: 1
 Name: ir_2_a_01
 Type: list
 Default: ["admin", "security_officer"]

Навчання з реагування на інциденти надається користувачам системи відповідно до призначених ролей та обов'язків протягом періоду часу з моменту прийняття на себе ролі або обов'язків з реагування на інциденти або отримання доступу до системи

No: 2
 Name: ir_2_a_02
 Type: string
 Default: nil

Навчання з реагування на інциденти надається користувачам системи відповідно до призначених ролей та обов'язків, коли цього вимагають зміни в системі

No: 3
 Name: ir_2_a_03
 Type: string
 Default: "щорічно"

Користувачам системи надається навчання з реагування на інциденти відповідно до призначених ролей та обов'язків частота

No: 4
 Name: ir_2_b_01
 Type: string
 Default: "щорічно"

Зміст навчання з реагування на інциденти переглядається та оновлюється частота

No: 5
 Name: ir_2_b_02
 Type: string
 Default: nil

Зміст навчання з реагування на інциденти переглядається та оновлюється після подій

No: 6
 Name: ir_2_odp_02

Type: integer

Default: 30

Визначено частоту, з якою користувачі повинні проходити навчання з реагування на інциденти

No: 7

Name: ir_2_odp_03

Type: integer

Default: 30

Визначено частоту перегляду та оновлення змісту навчання з реагування на інциденти

No: 8

Name: ir_2_odp_04

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які ініціюють перегляд змісту навчання з реагування на інциденти

8.2.1. МОДЕЛЮВАННЯ ПОДІЙ (IR-2(1))

Немає параметрів для цього контролю.

8.2.2. ЗЛАМ (IR-2(3))

No: 1

Name: ir_2_3_01

Type: string

Default: nil

Проводиться навчання з реагування на інциденти щодо виявлення та реагу IR-02(03)[02] проводиться навчання з реагування на інциденти щодо процесу повідомлення п

8.3. ПЕРЕВІРКА РЕАГУВАНЬ НА ІНЦИДЕНТИ (IR-3)

No: 1

Name: ir_3_01

Type: string

Default: "щорічно"

Ефективність реагування системи на інциденти перевіряється частота за допомогою тестів

No: 2

Name: ir_3_odp_01

Type: integer

Default: 30

Визначено частоту, з якою необхідно перевіряти ефективність реагування системи на інциденти

No: 3

Name: ir_3_odp_02

Type: string

Default: nil

Визначено тести, що використовуються для перевірки ефективності реагування на інциденти в системі

8.3.1. КООРДИНАЦІЯ З ПОВ'ЯЗАНИМИ ПЛАНАМИ (IR-3(2))

No: 1
 Name: ir_3_2_01
 Type: string
 Default: nil

Тестування реагування на інциденти координується з елементами організації, відповідальними за пов'язані плани

8.3.2. ПОСТІЙНЕ ПОКРАЩЕННЯ (IR-3(3))

No: 1
 Name: ir_3_3_a_01
 Type: string
 Default: nil

Якісні дані тестування використовуються для визначення ефективності процесів реагування на інциденти; IR-03(03)(a)[02] кількісні дані тестування використовуються для визначення ефективності процесів реагування на інциденти

No: 2
 Name: ir_3_3_b_01
 Type: string
 Default: nil

Якісні дані тестування використовуються для постійного вдосконалення процесів реагування на інциденти

No: 3
 Name: ir_3_3_b_02
 Type: string
 Default: nil

Кількісні дані тестування використовуються для постійного вдосконалення процесів реагування на інциденти

No: 4
 Name: ir_3_3_c_01
 Type: string
 Default: nil

Якісні дані, отримані за результатами тестування , використовуються для забезпечення точних показників та метрик реагування на інциденти

No: 5
 Name: ir_3_3_c_02
 Type: string
 Default: nil

Кількісні дані, отримані за результатами тестування , використовуються для забезпечення точних показників та метрик реагування на інциденти

No: 6
 Name: ir_3_3_c_03
 Type: string
 Default: nil

Якісні дані, отримані за результатами тестування , використовуються для забезпечення послідовності показників та метрик реагування на інциденти

No: 7
 Name: ir_3_3_c_04

Type: string

Default: nil

Кількісні дані, отримані за результатами тестування , використовуються для забезпечення послідовності показників та метрик реагування на інциденти

No: 8

Name: ir_3_3_c_05

Type: string

Default: nil

Якісні дані, отримані за результатами тестування , використовуються для забезпечення відтворюваності показників та метрик реагування на інциденти

No: 9

Name: ir_3_3_c_06

Type: string

Default: nil

Кількісні дані, отримані за результатами тестування , використовуються для забезпечення відтворюваності показників та метрик реагування на інциденти

8.4. Обробка інциденту (IR-4)

No: 1

Name: ir_4_a_02

Type: string

Default: nil

Впроваджено можливість обробки інцидентів безпеки включно з виявленням

No: 2

Name: ir_4_a_03

Type: string

Default: nil

Впроваджено можливість обробки інцидентів безпеки включно з аналізом

No: 3

Name: ir_4_a_04

Type: string

Default: nil

Впроваджено можливість обробки інцидентів безпеки включно з локалізацією

No: 4

Name: ir_4_a_05

Type: string

Default: nil

Впроваджено можливість обробки інцидентів безпеки включно з ліквідацією

No: 5

Name: ir_4_a_06

Type: string

Default: nil

Впроваджено можливість обробки інцидентів безпеки включно з відновленням

No: 6

Name: ir_4_b

Type: string

Default: nil

Діяльність з обробки інцидентів координується із заходами із забезпечення безперервності функціонування

No: 7

Name: ir_4_c_01

Type: string

Default: nil

Уроки, отримані з поточних дій з обробки інцидентів, включаються в процедури реагування на інциденти, навчання та тестування

No: 8

Name: ir_4_c_02

Type: string

Default: nil

Зміни, що впливають відповідним чином

No: 9

Name: ir_4_d_01

Type: string

Default: nil

Строгість заходів з обробки інцидентів передбачуваною в межах всієї організації

No: 10

Name: ir_4_d_02

Type: string

Default: nil

Інтенсивність заходів з обробки інцидентів є порівнянною та передбачуваною в межах всієї організації

No: 11

Name: ir_4_d_03

Type: string

Default: nil

Обсяг заходів з обробки інцидентів є порівнянною та передбачуваною в межах всієї організації

No: 12

Name: ir_4_d_04

Type: string

Default: nil

Результати діяльності заходів з обробки інцидентів є порівнянною та передбачуваною в межах всієї організації; з отриманих уроків, є впроваджуються порівнянною

8.4.1. ДИНАМІЧНА РЕКОНФІГУРАЦІЯ (IR-4(2))

No: 1

Name: ir_4_2_01

Type: integer

Default: 30

Типи динамічної реконфігурації для компонентів системи включені як частина здатності реагування на інциденти

No: 2

Name: ir_4_2_odp_01

Type: string

Default: nil

Визначено типи динамічної реконфігурації для компонентів системи

No: 3
Name: ir_4_2_odp_02
Type: string
Default: nil

Визначено компоненти системи, які потребують динамічної реконфігурації

8.4.2. БЕЗПЕРЕПРВНІСТЬ ОПЕРАЦІЙ (IR-4(3))

No: 1
Name: ir_4_3_01
Type: string
Default: nil

Ідентифіковано класи інцидентів

No: 2
Name: ir_4_3_02
Type: list
Default: ["login", "logout", "failed_attempt"]

Дії вживаються у відповідь на ці інциденти (визначені в IR-04(03)_ODP[01]) для забезпечення продовження виконання завдань та функцій організації

No: 3
Name: ir_4_3_odp_01
Type: string
Default: nil

Визначено класи інцидентів, що вимагають вживання дій, визначених організацією (визначених в IR04(03)_ODP[02])

No: 4
Name: ir_4_3_odp_02
Type: list
Default: ["login", "logout", "failed_attempt"]

Визначено дії, які необхідно вжити у відповідь на визначені організацією класи інцидентів

8.4.3. ІНФОРМАЦІЙНА КОРЕЛЯЦІЯ (IR-4(4))

No: 1
Name: ir_4_4_01
Type: string
Default: nil

Інформація про інциденти та індивідуальне реагування на інциденти зіставляється з метою досягнення загальноорганізаційного бачення на обізнаність про інциденти та реагування на них

8.4.4. ВНУТРІШНІ ЗАГРОЗИ - ОСОБЛИВІ МОЖЛИВОСТІ (IR-4(6))

No: 1
Name: ir_4_6_01
Type: string
Default: nil

Реалізовано можливість обробки інцидентів, пов'язаних з внутрішніми загрозами

8.4.5. КООРДИНАЦІЯ З ЗОВНІШНІМИ ОРГАНІЗАЦІЯМИ (IR-4(8))

No: 1

Name: ir_4_8_01

Type: string

Default: nil

Здійснюється координація з зовнішніми організаціями для кореляції та обміну інформацією про інциденти для досягнення міжорганізаційного бачення щодо обізнаності про інциденти та більш ефективного реагування на інциденти

No: 2

Name: ir_4_8_odp_01

Type: string

Default: nil

Визначено зовнішні організації, з якими необхідно координувати та обмінюватися інформацією про інциденти в організації

No: 3

Name: ir_4_8_odp_02

Type: string

Default: nil

Визначено інформацію про інциденти, яку необхідно зіставляти та поширювати із зовнішніми організаціями

8.4.6. ЗДАТНІСТЬ ДИНАМІЧНОГО РЕАГУВАННЯ (IR-4(9))

No: 1

Name: ir_4_9_odp

Type: string

Default: nil

Визначено можливості динамічного реагування для ефективного реагування на інциденти безпеки. використовуються можливості динамічного реагування для ефективного реагування на інциденти безпеки

8.4.7. КООРДИНАЦІЯ ЛАНЦЮГА ПОСТАЧАННЯ (IR-4(10))

No: 1

Name: ir_4_10_01

Type: integer

Default: 30

Координується діяльність з обробки інцидентів, пов'язана з подіями ланцюжка постачання, з іншими організаціями, що беруть участь у ланцюжку постачання

8.4.8. ІНТЕГРОВАНА ГРУПА РЕАГУВАННЯ НА ІНЦЕДЕНТИ (IR-4(11))

No: 1

Name: ir_4_11_01

Type: string

Default: nil

Створена та підтримується інтегрована група реагування на інциденти

No: 2

Name: ir_4_11_02

Type: integer

Default: 30

Інтегрована група реагування на інциденти може бути розгорнута в будь-якому місці, визначеному організацією протягом часового періоду

No: 3

Name: ir_4_11_odp

Type: integer

Default: 30

Визначено період часу, протягом якого може бути розгорнута інтегрована група реагування на інцидент

8.4.9. ЗЛОВМИСНИЙ КОД ТА КРИМІНАЛІСТИЧНИЙ АНАЛІЗ (IR-4(12))

No: 1

Name: ir_4_12_01

Type: string

Default: nil

Шкідливий код, що залишився в системі, аналізується після інциденту

No: 2

Name: ir_4_12_02

Type: string

Default: nil

Інші залишкові артефакти, що залишилися в системі (якщо такі є), аналізуються після інциденту. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

8.4.10. АНАЛІЗ ПОВЕДІНКИ (IR-4(13))

No: 1

Name: ir_4_13_01

Type: string

Default: nil

Аналізується аномальна або підозрювана ворожа поведінка в середовищах або ресурсах або пов'язана з ними

No: 2

Name: ir_4_13_odp

Type: string

Default: nil

Визначаються середовища або ресурси, які можуть містити або можуть бути пов'язані з аномальною або підозрілою ворожою поведінкою

8.4.11. ЦЕНТР БЕЗПЕКИ (IR-4(14))

No: 1

Name: ir_4_14_01

Type: string

Default: nil

Створено оперативний центр безпеки

No: 2

Name: ir_4_14_02

Type: string

Default: nil

Підтримується оперативний центр безпеки

8.4.12. ЗВ'ЯЗКИ З ГРОМАДКІСТЮ ТА ВІДНОВЛЕННЯ РЕПУТАЦІЇ (IR-4(15))

Немає параметрів для цього контролю.

8.5. Моніторинг інциденту (IR-5)

No: 1

Name: ir_5_01

Type: string

Default: nil

Відстежуються інциденти безпеки та приватності

No: 2

Name: ir_5_02

Type: string

Default: nil

Документуються інциденти безпеки та приватності. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

8.5.1. АВТОМАТИЗОВАНЕ ВІДСТЕЖЕННЯ, ЗБІР ДАНИХ І АНАЛІЗ (IR-5(1))

No: 1

Name: ir_5_1_01

Type: string

Default: nil

Інциденти відстежуються за допомогою 05(01)_ODP[01] автоматизованих механізмів>

No: 2

Name: ir_5_1_02

Type: string

Default: nil

Інформація про інциденти збирається за допомогою автоматизованих механізмів

No: 3

Name: ir_5_1_03

Type: string

Default: nil

Інформація про інциденти аналізується за допомогою автоматизованих механізмів. <IR-

No: 4

Name: ir_5_1_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми відстеження інцидентів

No: 5

Name: ir_5_1_odp_02

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми збору інформації про інциденти

No: 6

Name: ir_5_1_odp_03

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми аналізу інформації про інциденти

8.6. ЗВІТНІСТЬ ПРО ІНЦИДЕНТИ (IR-6)

No: 1

Name: ir_6_a

Type: list

Default: ["admin", "security_officer"]

Персонал зобов'язаний повідомляти про підозрілі інциденти протягом періоду часу

No: 2

Name: ir_6_b

Type: string

Default: nil

Інформацію про інцидент повідомляється органам

No: 3

Name: ir_6_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено період часу, протягом якого персонал повинен повідомляти про підозрілі інциденти до уповноваженого органу

No: 4

Name: ir_6_odp_02

Type: string

Default: nil

Визначені органи, до яких слід повідомляти інформацію про інцидент

8.6.1. АВТОМАТИЧНЕ ЗВІТУВАННЯ (IR-6(1))

No: 1

Name: ir_6_1_01

Type: string

Default: "автоматизований засіб моніторингу"

Використовуються автоматичні механізми звітування про інциденти

No: 2
Name: ir_6_1_odp
Type: string
Default: "автоматизований засіб моніторингу"

Визначені автоматичні механізми звітування про інциденти

8.6.2. КООРДИНАЦІЯ ЛАНЦЮЖКА ПОСТАЧАННЯ (IR-6(3))

No: 1
Name: ir_6_3_01
Type: integer
Default: 30

Інформація про інцидент надається постачальнику продукту або послуги та іншим організаціям, які беруть участь у ланцюжку постачання систем або компонентів системи, пов'язаних з інцидентом

8.7. ПІДТРИМКА РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-7)

No: 1
Name: ir_7_01
Type: string
Default: nil

Ресурс підтримки реагування на інциденти містить поради та допомогу користувачам системи для обробки та формування звітності про інциденти

8.7.1. АВТОМАТИЗАЦІЯ ПІДТРИМКИ ДЛЯ ЗАБЕЗПЕЧЕННЯ ДОСТУПНОСТІ ІНФОРМАЦІЇ ТА ПІДТРИМКИ (IR-7(1))

No: 1
Name: ir_7_1_01
Type: string
Default: nil

Підвищено доступність інформації та підтримки реагування на інциденти з використанням автоматизованих механізмів

No: 2
Name: ir_7_1_odp
Type: string
Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для збільшення доступності інформації та підтримки при реагуванні на інциденти

8.7.2. КООРДИНАЦІЯ З ЗОВНІШНІМИ ПОСТАЧАЛЬНИКАМИ (IR-7(2))

No: 1
Name: ir_7_2_a
Type: string

Default: nil

Встановлено прямі відносини кооперації між здатністю реагування на інциденти та зовнішніми постачальниками можливостей захисту системи

No: 2

Name: ir_7_2_b

Type: string

Default: nil

Визначено членів команди реагування на інциденти в організації для зовнішніх постачальників послуг

8.8. План реагування на інциденти (IR-8)

No: 1

Name: ir_8_a_01

Type: string

Default: nil

Розроблено план реагування на інциденти, який надає організації дорожню карту для впровадження її можливостей реагування на інциденти

No: 2

Name: ir_8_a_02

Type: string

Default: nil

Розроблено план реагування на інциденти, який описує структуру та організацію спроможності реагування на інциденти

No: 3

Name: ir_8_a_03

Type: string

Default: nil

Розроблено план реагування на інциденти, який надає високорівневий підхід до того, як здатність реагування на інциденти вписується в загальну практику організації

No: 4

Name: ir_8_a_04

Type: string

Default: nil

Розроблено план реагування на інциденти, який відповідає унікальним вимогам організації, які пов'язані із завданнями, розміром, структурою і функціями

No: 5

Name: ir_8_a_05

Type: string

Default: nil

Розроблено план реагування на інциденти, який визначає підзвітні інциденти

No: 6

Name: ir_8_a_06

Type: string

Default: nil

Розроблено план реагування на інциденти, який надає показники для вимірювання можливостей реагування на інциденти всередині організації

No: 7

Name: ir_8_a_07

Type: string

Default: nil

Розроблено план реагування на інциденти, який визначає ресурси та управлінську підтримку, необхідну для ефективної підтримки та розвитку можливостей реагування на інциденти

No: 8

Name: ir_8_a_08

Type: string

Default: nil

Розроблено план реагування на інциденти, який вирішує питання обміну інформацією про інциденти

No: 9

Name: ir_8_a_09

Type: list

Default: ["admin", "security_officer"]

Розроблено план реагування на інцидент, який розглядається та затверджується персоналом або ролями частота

No: 10

Name: ir_8_a_10

Type: list

Default: ["admin", "security_officer"]

Розроблено план реагування на інциденти, в якому чітко визначено відповідальність за реагування на інциденти для організацій, персоналу або ролей

No: 11

Name: ir_8_b_01

Type: list

Default: ["admin", "security_officer"]

Копії плану реагування на інцидент розповсюджуються серед <IR- 08_ODP[04] персоналу з реагування на інциденти>

No: 12

Name: ir_8_b_02

Type: string

Default: nil

Копії плану реагування на інцидент розповсюджуються серед елементів організації

No: 13

Name: ir_8_c

Type: integer

Default: 30

План реагування на інциденти оновлюється з урахуванням змін у системі та організації або проблем, що виникають під час впровадження, виконання або тестування плану

No: 14

Name: ir_8_d_01

Type: list

Default: ["admin", "security_officer"]

Зміни в плані реагування на інцидент повідомляються персоналу з реагування на інциденти

No: 15

Name: ir_8_d_02

Type: string

Default: nil

Зміни в плані реагування на інциденти надсилаються до елементів організації

No: 16

Name: ir_8_e_01

Type: string

Default: nil

План реагування на інциденти захищений від несанкціонованого розкриття

No: 17

Name: ir_8_e_02

Type: string

Default: nil

План реагування на інциденти захищений від несанкціонованої модифікації

No: 18

Name: ir_8_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які переглядають та затверджують план реагування на інциденти

No: 19

Name: ir_8_odp_02

Type: string

Default: "щорічно"

Визначено періодичність перегляду та затвердження плану реагування на інциденти

No: 20

Name: ir_8_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначені організації, персонал або ролі, які несуть відповідальність за реагування на інциденти; IR-08_ODP[04] визначено персонал з реагування на інцидент (ідентифікований за іменами та/або за ролями), якому мають бути роздані копії плану реагування на інцидент

No: 21

Name: ir_8_odp_05

Type: string

Default: nil

Визначено елементи організації, серед яких мають розповсюджені копії плану реагування на інцидент; бути

No: 22

Name: ir_8_odp_06

Type: list

Default: ["admin", "security_officer"]

Визначено персонал з реагування на інцидент (ідентифікований за іменами та/або ролями), якому повідомляються зміни до плану реагування на інцидент

No: 23

Name: ir_8_odp_07

Type: string

Default: nil

Визначено елементи організації, яким повідомляється про зміни в плані реагування на інцидент

8.8.1. ОБРОБКА ПЕРСОНАЛЬНИХ ДАНИХ (IR-8(1))

No: 1

Name: ir_8_1_a

Type: list

Default: ["admin", "security_officer"]

План реагування на інциденти для інцидентів, пов'язаних з персональними даними, включає процес визначення доцільності повідомлення наглядових організацій і надання такого повідомлення, якщо це доречно

No: 2

Name: ir_8_1_b

Type: list

Default: ["admin", "security_officer"]

План реагування на інциденти для інцидентів, пов'язаних з персональними даними, включає процес оцінювання для визначення ступеня шкоди, труднощів, незручностей або несправедливості щодо постраждалих осіб та будь-які механізми пом'якшення такої шкоди

No: 3

Name: ir_8_1_c

Type: list

Default: ["admin", "security_officer"]

План реагування на інциденти для інцидентів, пов'язаних з персональними даними, включає ідентифікацію застосовних вимог щодо конфіденційності. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

8.9. РЕАГУВАННЯ НА ВИТІК ІНФОРМАЦІЇ (IR-9)

No: 1

Name: ir_9_a

Type: list

Default: ["admin", "security_officer"]

Персонал або ролі призначено відповідальним за реагування на витоки інформації

No: 2

Name: ir_9_b

Type: string

Default: nil

У відповідь на витік інформації визначається конкретна інформація, пов'язана з джерелом витоку в системі

No: 3

Name: ir_9_c

Type: list

Default: ["admin", "security_officer"]

Персонал або ролі попереджається про витік інформації за допомогою методу зв'язку, не пов'язаного з витоком

No: 4

Name: ir_9_d

Type: string

Default: nil

Ізолюється система або компонент системи де відбувся витік інформації

No: 5

Name: ir_9_e

Type: string

Default: nil

Інформація видаляється із зараженої системи або компонента у відповідь на витік інформації

No: 6

Name: ir_9_f

Type: string

Default: nil

У відповідь на витік інформації визначаються інші системи або компоненти системи, які могли бути згодом джерелом витіку інформації

No: 7

Name: ir_9_g

Type: list

Default: ["login", "logout", "failed_attempt"]

Дії виконуються у відповідь на витік інформації

No: 8

Name: ir_9_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які покладено відповідальність за реагування на витіки інформації

No: 9

Name: ir_9_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які мають бути сповіщені про витік інформації за допомогою методу зв'язку, не пов'язаного з витіком

No: 10

Name: ir_9_odp_03

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначені дії, які необхідно виконати

8.9.1. ВІДПОВІДАЛЬНИЙ ПЕРСОНАЛ (IR-9(1))

No: 1

Name: ir_9_1_01

Type: list

Default: ["admin", "security_officer"]

РЕАГУВАННЯ НА ВИТІК ІНФОРМАЦІЇ - ВІДПОВІДАЛЬНИЙ ПЕРСОНАЛ [Вилучено: включено до IR-09]

8.9.2. ТРЕНУВАННЯ (IR-9(2))

No: 1

Name: ir_9_2_01

Type: string

Default: "щорічно"

Забезпечено навчання з реагування на витік інформації частота

No: 2

Name: ir_9_2_odp

Type: integer

Default: 30

Визначено частоту навчання з реагування на витік інформації

8.9.3. РОБОТА ПІСЛЯ ВИТОКУ (IR-9(3))

No: 1

Name: ir_9_3_01

Type: list

Default: ["admin", "security_officer"]

Реалізовано процедури, з метою забезпечення спроможності для персоналу організації, на який впливає витік інформації, продовжувати виконувати поставлені завдання, у той час, як постраждалі системи зазнають коригувальних дій

No: 2

Name: ir_9_3_odp

Type: list

Default: ["admin", "security_officer"]

Визначено процедури з метою забезпечення спроможності персоналу організації, на який впливає витік інформації, продовжувати виконувати поставлені завдання, у той час, як постраждалі системи зазнають коригувальних дій

8.9.4. ВИКРИТТЯ НЕАВТОРИЗОВАНОГО ПЕРСОНАЛУ (IR-9(4))

No: 1

Name: ir_9_4_01

Type: list

Default: ["admin", "security_officer"]

Застосовуються механізми захисту для персоналу, що має доступ до інформації, яка не відповідає призначеним правам доступу

No: 2

Name: ir_9_4_odp

Type: list

Default: ["admin", "security_officer"]

Визначено механізми захисту для персоналу, що має доступ до інформації, яка не відповідає призначеним правам доступу

8.10. ІНТЕГРОВАНА КОМАНДА АНАЛІЗУ ІНФОРМАЦІЙНОЇ БЕЗПЕКИ (IR-10)

No: 1

Name: ir_10_01

Type: string

Default: nil

ІНТЕГРОВАНА КОМАНДА АНАЛІЗУ ІНФОРМАЦІЙНОЇ БЕЗПЕКИ [Вилучено: перенесено до IR-04(11)]

IX. КЛАС ЗАХОДІВ ЗАХИСТУ МА – ТЕХНІЧНЕ ОБСЛУГОВУВАННЯ

9. МА

Клас заходів захисту МА — ТЕХНІЧНЕ ОБСЛУГОВУВАННЯ

Цей клас регулює процеси планового та позапланового технічного обслуговування компонентів системи для запобігання збоям.

Перелік заходів захисту: Політика та процедури технічного обслуговування (МА-1); Зміст запису (МА-2(1)); Автоматизована технічна діяльність (МА-2(2)); Інструменти для обслуговування (МА-3); Перевірка інструментів (МА-3(1)); Перевірка носіїв інформації (МА-3(2)); Запобігання несанкціонованому переміщенню (МА-3(3)); Обмеження використання інструмента (МА-3(4)); Привілейоване виконання (МА-3(5)); Оновлення програм- (МА-3(6)); Віддалене обслуговування (МА-4); Аудит та огляд (МА-4(1)); Документування віддаленого обслуговування (МА-4(2)); Порівняльна безпека і очищення (МА-4(3)); Схвалення та повідомлення (МА-4(5)); Віддалене обслуговування роз'єднання (МА-4(7)); Технічний персонал (МА-5); Особи без належного доступу (МА-5(1)); Оформлення допуску для систем, що обробляють інформацію з обмеженим доступом (МА-5(2)); Вимоги до громадянства (МА-5(3)); Іноземні громадяни (МА-5(4)); Несистемне обслуговування (МА-5(5)); Своєчасне обслуговування (МА-6); Профілактичне обслуговування (МА-6(1)); Планове технічне обслуговування (МА-6(2)); Автоматизована підтримка планового технічного обслуговування (МА-6(3)); Технічне обслуговування в польових умовах (МА-7).

9.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ТЕХНІЧНОГО ОБСЛУГОВУВАННЯ (МА-1)

- a. Планувати, документувати та переглядати записи з технічного обслуговування, ремонту або заміни компонентів системи відповідно до вимог виробника та постачальників та/або вимог організації.
- b. Затвердити та здійснювати моніторинг усіх заходів з технічного обслуговування, незалежно від того, виконуються вони на місці або віддалено, а також чи обслуговуються системи або системні компоненти на місці, чи переміщуються в інше місце.
- c. Вимагати, щоб [Призначення: визначені організацією персонал чи ролі] явно схвалили видалення системи або компоненту системи з організаційного обладнання для технічного обслуговування, ремонту чи заміни поза об'єктами експлуатації.
- d. Очищати обладнання з погляду видалення всієї інформації з носіїв до вилучення обладнання організації для технічного обслуговування, ремонту чи заміни поза об'єктами експлуатації.
- e. Перевірити всі потенційно порушені заходи захисту, щоб переконатися, що вони, як і раніше, працюють належним чином після дій з обслуговування, ремонту або заміни.
- f. Вносити [Призначення: визначену організацією інформацію, пов'язану з технічним обслуговуванням] до записів з технічного обслуговування.

No: 1

Name: ma_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику технічного обслуговування

No: 2

Name: ma_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика технічного обслуговування поширюється на персонал або ролі

No: 3

Name: ma_1_a_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблені та задокументовані процедури технічного обслуговування, що сприяють впровадженню політики технічного обслуговування та пов'язаних з нею заходів технічного обслуговування

No: 4

Name: ma_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур технічного обслуговування; МА-01(с)[01][01] переглядається та оновлюється поточна політика обслуговування частота; МА-01(с)[01][02] переглядається та оновлюється поточна політика обслуговування після подій; МА-01(с)[02][01] переглядаються та оновлюються поточні процедури технічного обслуговування частота; МА-01(с)[02][02] переглядаються та оновлюються поточні процедури технічного обслуговування після подій

No: 5

Name: ma_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюється політика технічного обслуговування

No: 6

Name: ma_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури технічного обслуговування

No: 7

Name: ma_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: ma_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами технічного обслуговування

No: 9

Name: ma_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика технічного обслуговування

No: 10

Name: ma_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, які потребують перегляду та оновлення поточної політики технічного обслуговування

No: 11
Name: ma_1_odp_07
Type: integer
Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури технічного обслуговування

No: 12
Name: ma_1_odp_08
Type: list
Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують перегляду та оновлення процедур технічного обслуговування

9.1.1. ЗМІСТ ЗАПИСУ (МА-2(1))

No: 1
Name: ma_2_1_01
Type: string
Default: nil

КОНТРОЛЬОВАНЕ ОБСЛУГОВУВАННЯ - ЗМІСТ ЗАПИСУ [Вилучено: Включено до МА-02]

9.1.2. АВТОМАТИЗОВАНА ТЕХНІЧНА ДІЯЛЬНІСТЬ (МА-2(2))

No: 1
Name: ma_2_2_a_01
Type: string
Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для планування дій з технічного обслуговування, ремонту та заміни системи

No: 2
Name: ma_2_2_a_02
Type: string
Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для проведення дій з технічного обслуговування, ремонту та заміни системи; МА-02(02)(a)[03] автоматизовані механізми використовуються для документування дій з технічного обслуговування, ремонту та заміни системи

No: 3
Name: ma_2_2_b_01
Type: list
Default: ["login", "logout", "failed_attempt"]

Надаються актуальні, точні та повні записи про всі замовлені, заплановані, виконувані та завершені дії з технічного обслуговування

No: 4
Name: ma_2_2_b_02
Type: list
Default: ["login", "logout", "failed_attempt"]

Надаються актуальні, точні та повні записи про всі замовлені, заплановані, виконувані та завершені дії ремонту

No: 5
Name: ma_2_2_b_03
Type: list
Default: ["login", "logout", "failed_attempt"]

Надаються актуальні, точні та повні записи про всі замовлені, заплановані, виконувані та завершені дії з заміни

No: 6

Name: ma_2_2_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для планування дій з технічного обслуговування, ремонту та заміни системи

No: 7

Name: ma_2_2_odp_02

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для проведення дій з технічного обслуговування, ремонту та заміни системи

No: 8

Name: ma_2_2_odp_03

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для документування дій з технічного обслуговування, ремонту та заміни системи

9.2. ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ (МА-3)

a. Затвердити, контролювати та відстежувати використання засобів технічного обслуговування.

b. Переглядати раніше затверджені інструменти технічного [Призначення: з частотою, визначеною організацією]. обслуговування

No: 1

Name: ma_3_a_01

Type: string

Default: nil

Використання засобів технічного обслуговування затверджено

No: 2

Name: ma_3_a_02

Type: string

Default: nil

Використання засобів технічного обслуговування контролюється

No: 3

Name: ma_3_a_03

Type: string

Default: nil

Використання засобів технічного обслуговування відстажуються

No: 4

Name: ma_3_b

Type: string
Default: "щорічно"

Переглядаються раніше затверджені інструменти технічного обслуговування частота

No: 5
Name: ma_3_odp
Type: integer
Default: 30

Визначено частоту, з якою слід переглядати раніше затверджені інструменти технічного обслуговування

9.2.1. ПЕРЕВІРКА ІНСТРУМЕНТІВ (МА-3(1))

No: 1
Name: ma_3_1_01
Type: list
Default: ["admin", "security_officer"]

Оглядаються інструменти для технічного обслуговування, які доставлені на об'єкт обслуговуючим персоналом, на предмет неправильних або несанкціонованих модифікацій

9.2.2. ПЕРЕВІРКА НОСІЇВ ІНФОРМАЦІЇ (МА-3(2))

Перед використанням носіїв у системі перевірити носії, що містять діагностичні та тестові програми на наявність шкідливого коду.

No: 1
Name: ma_3_2_01
Type: string
Default: nil

Перед використанням носіїв у системі перевіряються носії, що містять діагностичні та тестові програми на наявність шкідливого коду

9.2.3. ЗАПОБІГАННЯ НЕСАНКЦІОНОВАНОМУ ПЕРЕМІЩЕННЮ (МА-3(3))

Запобігти переміщенню обладнання для технічного обслуговування, що містить організаційну інформацію, шляхом:

- (a) перевірки відсутності організаційної інформації, розміщеної на обладнанні;
- (b) очищення або знищення обладнання;
- (c) утримання обладнання на об'єкті;
- (d) отримання дозволу від [Призначення: визначених організацією персоналу чи ролей], які явно дозволяють переміщення обладнання з об'єкта.

No: 1
Name: ma_3_3_a
Type: string
Default: nil

Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом перевірки того, що на обладнанні не міститься ніякої інформації організації; або

No: 2
Name: ma_3_3_b
Type: string
Default: nil

Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом очищення або знищення обладнання; або

No: 3
Name: ma_3_3_c
Type: string
Default: nil

Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом утримання обладнання на об'єкті; або

No: 4
Name: ma_3_3_d
Type: list
Default: ["admin", "security_officer"]

Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом отримання дозволу від персоналу або ролі

No: 5
Name: ma_3_3_odp
Type: list
Default: ["admin", "security_officer"]

Визначено персонал або ролі, які можуть надавати дозвіл на переміщення обладнання з об'єкту

9.2.4. ОБМЕЖЕННЯ ВИКОРИСТАННЯ ІНСТРУМЕНТА (МА-3(4))

Обмежити використання інструментів авторизованим персоналом. технічного ОБМЕЖЕННЯ обслуговування лише

No: 1
Name: ma_3_4_01
Type: list
Default: ["admin", "security_officer"]

Обмежено використання інструментів технічного обслуговування лише авторизованим персоналом

9.2.5. ПРИВІЛЕЙОВАНЕ ВИКОНАННЯ (МА-3(5))

- (a) вимагати схвалення кожного віддаленого сеансу технічного обслуговування [Призначення: персоналом або роллю, що визначила організація];
- (b) повідомити [Призначення: персонал або ролі, що визначила організація] про дату та час запланованого віддаленого обслуговування.

No: 1
Name: ma_3_5_01
Type: string
Default: nil

Відстежується використання інструментів обслуговування, які виконуються з підвищеними привілеями

9.2.6. ОНОВЛЕННЯ ПРОГРАМ- (МА-3(6))

Запровадити криптографічні механізми для захисту цілісності та конфіденційності віддаленого обслуговування та діагностичних комунікацій.

No: 1
 Name: ma_3_6_01
 Type: string
 Default: nil

Інструменти технічного обслуговування перевіряються, щоб переконатися, що встановлені найновіші оновлення програмного забезпечення та патчі

9.3. ВІДДАЛЕНЕ ОБСЛУГОВУВАННЯ (МА-4)

No: 1
 Name: ma_4_a_01
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Впроваджено віддалені дії з обслуговування та діагностики

No: 2
 Name: ma_4_a_02
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Відстежуються віддалені дії з обслуговування та діагностики

No: 3
 Name: ma_4_b_01
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Використання віддалених засобів технічного обслуговування та діагностики дозволено лише відповідно до політики організації

No: 4
 Name: ma_4_b_02
 Type: string
 Default: nil

Використання віддалених засобів технічного обслуговування та діагностики задокументовано в плані захисту інформації

No: 5
 Name: ma_4_c
 Type: string
 Default: nil

Надійна автентифікація використовується при встановленні віддалених технічних та діагностичних сеансів

No: 6
 Name: ma_4_d
 Type: string
 Default: nil

Ведеться облік віддалених дій з обслуговування та діагностики

No: 7
 Name: ma_4_e_01
 Type: string
 Default: nil

Сесія припиняється, коли завершено віддалене обслуговування

No: 8
 Name: ma_4_e_02
 Type: string
 Default: nil

Мережеве з'єднання припиняється, коли завершено віддалене обслуговування

9.3.1. АУДИТ ТА ОГЛЯД (МА-4(1))

No: 1
 Name: ma_4_1_a_01
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Події аудиту журналюються для віддалених сеансів обслуговування

No: 2
 Name: ma_4_1_a_02
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Події аудиту журналюються для віддалених сеансів діагностики

No: 3
 Name: ma_4_1_b_01
 Type: string
 Default: nil

Здійснюється огляд записів про сеанси віддаленого обслуговування

No: 4
 Name: ma_4_1_b_02
 Type: string
 Default: nil

Здійснюється огляд записів про сеанси віддаленої діагностики

No: 5
 Name: ma_4_1_odp_01
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Визначено події аудиту, які слід журналювати для віддалених сеансів обслуговування

No: 6
 Name: ma_4_1_odp_02
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Визначено події аудиту, які слід журналювати для віддалених сеансів діагностики

9.3.2. ДОКУМЕНТУВАННЯ ВІДДАЛЕНОГО ОБСЛУГОВУВАННЯ (МА-4(2))

No: 1
 Name: ma_4_2_01
 Type: string
 Default: nil

ВІДДАЛЕНЕ ОБСЛУГОВУВАННЯ - ДОКУМЕНТУВАННЯ ВІДДАЛЕНОГО ОБСЛУГОВУВАННЯ [Вилучено: включено до МА-01 та МА-04]

9.3.3. ПОРІВНЯЛЬНА БЕЗПЕКА І ОЧИЩЕННЯ (МА-4(3))

No: 1

Name: ma_4_3_a_01

Type: string

Default: nil

Віддалені послуги з технічного обслуговування повинні виконуватися з системи, яка реалізує заходи захисту, співставні з заходами захисту, реалізованими в системі, що обслуговується

No: 2

Name: ma_4_3_a_02

Type: string

Default: nil

Віддалені послуги з діагностики повинні виконуватися з системи, яка реалізує заходи захисту, співставні з заходами захисту, реалізованими в системі, що обслуговується

No: 3

Name: ma_4_3_b_01

Type: string

Default: nil

Компонент, що підлягає обслуговуванню, видаляється з системи перед проведенням віддаленого технічного обслуговування або діагностики

No: 4

Name: ma_4_3_b_02

Type: string

Default: nil

Компонент, що підлягає обслуговуванню, пройшов процедуру очищення (від інформації організації)

No: 5

Name: ma_4_3_b_03

Type: string

Default: nil

Компонент перевіряється та очищується (на наявність потенційно шкідливого програмного забезпечення) після виконання послуги та перед повторним підключенням компонента до системи

9.3.4. СХВАЛЕННЯ ТА ПОВІДОМЛЕННЯ (МА-4(5))

No: 1

Name: ma_4_5_a

Type: list

Default: ["admin", "security_officer"]

Схвалення кожного віддаленого сеансу обслуговування від персоналу або ролі

No: 2

Name: ma_4_5_b

Type: list

Default: ["admin", "security_officer"]

Персонал і ролі повідомлено про дату і час запланованого віддаленого технічного обслуговування

No: 3

Name: ma_4_5_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, необхідні для затвердження кожного віддаленого сеансу технічного обслуговування; MA-04(05)_ODP[02] визначено персонал та ролі, які мають бути повідомлені про дату та час запланованого віддаленого технічного обслуговування

9.3.5. ВІДДАЛЕНЕ ОБСЛУГОВУВАННЯ РОЗ'ЄДНАННЯ (МА-4(7))

No: 1

Name: ma_4_7_01

Type: string

Default: nil

Реалізовано перевірку роз'єднання у разі припинення віддалених сеансів обслуговування

No: 2

Name: ma_4_7_02

Type: string

Default: nil

Реалізовано перевірку роз'єднання у разі припинення віддалених сеансів діагностики

9.4. ТЕХНІЧНИЙ ПЕРСОНАЛ (МА-5)

a. Встановити процедуру авторизації технічного персоналу та вести перелік авторизованих організацій технічного обслуговування або персоналу.

b. Перевіряти, що персонал, який не супроводжується та виконує технічне обслуговування в системі, має необхідні дозволи на доступ.

c. Визначити персонал організації з необхідними повноваженнями щодо доступу та технічною компетенцією для нагляду за персоналом з технічного обслуговування, який не має необхідних дозволів на доступ.

No: 1

Name: ma_5_a_01

Type: list

Default: ["admin", "security_officer"]

Запроваджено процес авторизації технічного персоналу

No: 2

Name: ma_5_a_02

Type: list

Default: ["admin", "security_officer"]

Ведеться перелік авторизованих організацій або персоналу з технічного обслуговування

No: 3

Name: ma_5_b

Type: list

Default: ["admin", "security_officer"]

Персонал без супроводу, який виконує технічне обслуговування системи, має необхідні дозволи на доступ

No: 4

Name: ma_5_c

Type: list

Default: ["admin", "security_officer"]

Персонал організації з необхідними повноваженнями доступу та технічною компетентністю призначений/призначені для нагляду за діяльністю з технічного обслуговування персоналу, який не має необхідних дозволів на доступ

9.4.1. ОСОБИ БЕЗ НАЛЕЖНОГО ДОСТУПУ (МА-5(1))

No: 1

Name: ma_5_1_a_01

Type: list

Default: ["admin", "security_officer"]

Впроваджені процедури залучення персоналу з технічного обслуговування, який не має відповідних дозволів (допуску) або не є громадянами України, містять вимогу: обслуговуючий персонал, що не має необхідних прав доступу, рівня допуску, або офіційного затвердженого доступу, повинен супроводжуватися та бути під наглядом уповноваженого організацією персоналу, з необхідним рівнем допуску, а також мати відповідну технічну кваліфікацію для виконання технічного обслуговування та діагностичних заходів у системі

No: 2

Name: ma_5_1_a_02

Type: list

Default: ["admin", "security_officer"]

Впроваджені процедури залучення персоналу з технічного обслуговування, який не має відповідних дозволів (допуску) або не є громадянами України, містять вимогу: перед тим, як розпочати технічне обслуговування або діагностику персоналом, який не має необхідних прав допуску, рівня допуску або офіційного затвердженого доступу, упевнитися, що всі компоненти енергонезалежного зберігання інформації в системі очищуються, а всі енергонезалежні носії видаляються або фізично відключаються від системи та надійно захищаються

No: 3

Name: ma_5_1_b

Type: string

Default: nil

Альтернативні заходи захисту розробляються і впроваджуються у випадку, якщо систему неможливо очистити, вилучити або відключити від системи

No: 4

Name: ma_5_1_odp

Type: string

Default: nil

Визначені альтернативні заходи захисту, які мають бути розроблені та впроваджені на випадок, якщо компонент системи не може бути очищений, вилучений або відключений від системи

9.4.2. ОФОРМЛЕННЯ ДОПУСКУ ДЛЯ СИСТЕМ, ЩО ОБРОБЛЯЮТЬ ІНФОРМАЦІЮ З ОБМЕЖЕНИМ ДОСТУПОМ (МА-5(2))

Переконатися, що персонал, який виконує технічне обслуговування та діагностику в системі, що обробляє, зберігає або передає інформацію з обмеженим доступом, має рівень допуску та офіційне схвалення на доступ для найвищого рівня секретності та для всієї інформації в системі.

No: 1

Name: ma_5_2_01

Type: list

Default: ["admin", "security_officer"]

Персонал, який виконує роботи з технічного обслуговування та діагностики в системі, що обробляє, зберігає або передає інформацію з обмеженим доступом, має відповідний рівень допуску

No: 2

Name: ma_5_2_02

Type: list

Default: ["admin", "security_officer"]

Персонал, який виконує роботи з технічного обслуговування та діагностики в системі, що обробляє, зберігає або передає інформацію з обмеженим доступом, має офіційне схвалення на допуск

9.4.3. ВИМОГИ ДО ГРОМАДЯНСТВА (МА-5(3))

Переконайтеся, що працівники, які виконують технічне обслуговування та діагностичні заходи з обробки, зберігання або передачі таємної інформації, є громадянами України.

No: 1

Name: ma_5_3_01

Type: string

Default: nil

Працівники, які виконують технічне обслуговування та діагностичні заходи з обробки, зберігання або передачі інформації з обмеженим доступом, є громадянами України

9.4.4. ІНОЗЕМНІ ГРОМАДЯНИ (МА-5(4))

Переконайтеся, що:

(а) іноземні громадяни з відповідним рівнем допуску залучаються для проведення технічного обслуговування та діагностичних робіт у системах, що обробляють інформацію з обмеженим доступом тільки тоді, коли ці системи спільно належать і експлуатуються урядами України та закордонних союзників, або належать та експлуатуються виключно іноземними союзними урядами;

(б) схвалення, згоди та додаткові умови експлуатації, що стосуються залучення іноземних громадян для проведення робіт з технічного обслуговування та діагностики систем, що обробляють інформацію з обмеженим доступом, повністю задокументовані в Меморандумі про угоду.

No: 1

Name: ma_5_4_a

Type: string

Default: nil

Іноземні громадяни з відповідним рівнем допуску залучаються для проведення технічного обслуговування та діагностичних робіт у системах, що обробляють інформацію з обмеженим доступом тільки тоді, коли ці системи спільно належать і експлуатуються урядами України та закордонних союзників, або належать та експлуатуються виключно іноземними союзними урядами

No: 2

Name: ma_5_4_b_01

Type: string

Default: nil

Схвалення, що стосуються залучення іноземних громадян для проведення робіт з технічного обслуговування та діагностики систем, що обробляють інформацію з обмеженим доступом, повністю задокументовані в Меморандумі про угоду

No: 3

Name: ma_5_4_b_02

Type: string

Default: nil

Згоди, що стосуються залучення іноземних громадян для проведення робіт з технічного обслуговування та діагностики систем, що обробляють інформацію з обмеженим доступом, повністю задокументовані в Меморандумі про угоду

No: 4

Name: ma_5_4_b_03

Type: list

Default: []

Додаткові умови експлуатації, що стосуються залучення іноземних громадян для проведення робіт з технічного обслуговування та діагностики систем, що обробляють інформацію з обмеженим доступом, повністю задокументовані в Меморандумі про угоду

9.4.5. НЕСИСТЕМНЕ ОБСЛУГОВУВАННЯ (МА-5(5))

Переконалися, що персонал, який не супроводжується та здійснює ремонтні роботи, не пов'язаний безпосередньо із системою, але перебуває фізично близько від системи, має необхідні дозволи на доступ.

No: 1

Name: ma_5_5_01

Type: list

Default: ["admin", "security_officer"]

Персонал, який не супроводжується, що здійснює ремонтні роботи, не пов'язаний безпосередньо з системою, але знаходиться фізично близько від системи, має необхідні дозволи на доступ

9.5. СВОЄЧАСНЕ ОБСЛУГОВУВАННЯ (МА-6)

Отримати технічну підтримку та/або запасні частини для [Призначення: визначених організацією компонентів системи] в межах [Призначення: визначеного організацією періоду часу] у разі відмови.

No: 1

Name: ma_6_01

Type: integer

Default: 30

Технічна підтримка та/або запасні частини отримуються для компонентів системи протягом періоду часу після відмови. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

No: 2

Name: ma_6_odp_01

Type: integer

Default: 30

Визначено компоненти системи, для яких отримується технічна підтримка та/або запасні частини

No: 3

Name: ma_6_odp_02

Type: integer

Default: 30

Визначено період часу, протягом якого можна отримати технічну підтримку та/або запасні частини у разі відмови

9.5.1. ПРОФІЛАКТИЧНЕ ОБСЛУГОВУВАННЯ (МА-6(1))

No: 1

Name: ma_6_1_01

Type: integer

Default: 30

Здійснюється профілактичне обслуговування 06(01)_ODP[01] компонентів системи> у 06(01)_ODP[02] часові інтервали>. <МА<МА-

No: 2

Name: ma_6_1_odp_01

Type: string

Default: nil

Визначено компоненти системи яким необхідно здійснювати профілактичне обслуговування

No: 3

Name: ma_6_1_odp_02

Type: integer

Default: 30

Визначено часові інтервали з якими необхідно здійснювати профілактичне обслуговування визначеним компонентами системи

9.5.2. ПЛАНОВЕ ТЕХНІЧНЕ ОБСЛУГОВУВАННЯ (МА-6(2))

Здійснювати планове технічне обслуговування [Призначення: визначених організацією компонентів системи] у [Призначення: визначені організацією часові інтервали].

No: 1

Name: ma_6_2_01

Type: integer

Default: 30

Здійснюється планове технічне обслуговування компонентів системи у часові інтервали

No: 2

Name: ma_6_2_odp_02

Type: integer

Default: 30

Визначено часові інтервали з якими необхідно здійснювати планове технічне обслуговування

9.5.3. АВТОМАТИЗОВАНА ПІДТРИМКА ПЛАНОВОГО ТЕХНІЧНОГО ОБСЛУГОВУВАННЯ (МА-6(3))

Використовувати автоматизовані механізми для передачі даних планового технічного обслуговування до комп'ютеризованої системи управління обслуговуванням [Призначення: автоматизовані засоби визначені організацією].

No: 1

Name: ma_6_3_01

Type: string

Default: "автоматизований засіб моніторингу"

Використовуються автоматизовані механізми для передачі даних планового технічного обслуговування до комп'ютеризованої системи управління обслуговуванням

No: 2
 Name: ma_6_3_odp
 Type: string
 Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми для передачі даних планового технічного обслуговування до комп'ютеризованої системи управління обслуговуванням

9.6. ТЕХНІЧНЕ ОБСЛУГОВУВАННЯ В ПОЛЬОВИХ УМОВАХ (МА-7)

No: 1
 Name: ma_7_01
 Type: string
 Default: nil

Технічне обслуговування в польових умовах систем або компонентів системи обмежене або заборонене для довірених засобів технічного обслуговування

No: 2
 Name: ma_7_odp_01
 Type: string
 Default: nil

Визначені системи або компоненти системи, на яких технічне обслуговування в польових умовах обмежене або заборонене

No: 3
 Name: ma_7_odp_02
 Type: string
 Default: "автоматизований засіб моніторингу"

Визначено довірени засоби технічного обслуговування технічного обслуговування

10. МР

Клас заходів захисту МР — ЗАХИСТ НОСІЇВ ІНФОРМАЦІЇ

Цей клас спрямований на безпечне зберігання, транспортування, використання та знищення як цифрових, так і паперових носіїв інформації.

Перелік заходів захисту: Політика та процедури щодо захисту носіїв інформації (МР-1); Доступ до носіїв інформації (МР-2); Автоматизований обмежений доступ (МР-2(1)); Криптографічний захист (МР-2(2)); Маркування носіїв інформації (МР-3); Зберігання носіїв інформації (МР-4); Криптографічний захист (МР-4(1)); Автоматизований обмежений доступ (МР-4(2)); Транспортування носіїв інформації (МР-5); Захист поза контрольованими зонами (МР-5(1)); Документування дій (МР-5(2)); Зберігачі (МР-5(3)); Криптографічний захист (МР-5(4)); Знищення інформації на носіях інформації (МР-6); Переглядати, затвердження, відстеження, документування та перевірка (МР-6(1)); Перевірка обладнання (МР-6(2)); Неруйнівні методи (МР-6(3)); Керована несекретна інформація (МР-6(4)); Секретна інформація (МР-6(5)); Знищення носіїв інформації (МР-6(6)); Подвійна авторизація (МР-6(7)); Віддалене очищення або стирання інформації (МР-6(8)); Використання носіїв інформації (МР-7); Заборона використання без визначеного власника (МР-7(1)); Заборона використання (МР-7(2)); Зниження

категорії безпеки носіїв інформації (МР-8); Документування процесу (МР-8(1)); Перевірка обладнання (МР-8(2)); Критична інформація (МР-8(3)); Таємна інформація (МР-8(4)).

10.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ЩОДО ЗАХИСТУ НОСІІВ ІНФОРМАЦІЇ (МР-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посад]:

1. 2. політику захисту носіїв інформації, яка:

(а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance);

(b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам та керівним принципам; процедури, які сприяють здійсненню політики та заходів захисту носіїв інформації.

b. Призначити [Призначення: визначену організацією посадову особу] для управління розробкою, документування, та розповсюдження політики та процедурами захисту носіїв інформації.

c. Переглядати та оновлювати чинну систему захисту носіїв інформації:

1. поточну політику захисту носіїв інформації [Призначення: з визначеною організацією частотою];

2. поточні процедури захисту носіїв інформації [Призначення: з визначеною організацією частотою].

No: 1

Name: mp_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику захисту носіїв інформації

No: 2

Name: mp_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика захисту носіїв інформації поширюється на персонал або ролі

No: 3

Name: mp_1_a_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано процедури захисту носіїв інформації, що сприятимуть реалізації політики захисту носіїв інформації та заходів захисту носіїв інформації

No: 4

Name: mp_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур захисту носіїв інформації. МР-01(с)[01][01] переглядається та оновлюється поточна політика захисту носіїв інформації частота; МР-01(с)[01][02] переглядається та оновлюється поточна політика захисту носіїв інформації після подій; МР-01(с)[02][01] переглядаються та оновлюються поточні процедури захисту носіїв інформації частота; МР-01(с)[02][02] переглядаються та оновлюються поточні процедури захисту носіїв інформації після подій

No: 5

Name: mp_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, серед яких має бути поширена політика захисту носіїв інформації

No: 6

Name: mp_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, серед яких мають бути поширені процедури захисту носіїв інформації

No: 7

Name: mp_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: mp_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами захисту носіїв інформації

No: 9

Name: mp_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика захисту носіїв інформації

No: 10

Name: mp_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, які потребують перегляду та оновлення чинної політики захисту носіїв інформації

No: 11

Name: mp_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються чинні процедури захисту носіїв інформації

No: 12

Name: mp_1_odp_08

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують перегляду та оновлення процедур захисту носіїв інформації

10.2. ДОСТУП ДО НОСІІВ ІНФОРМАЦІЇ (МР-2)

Обмежити доступ до [Призначення: визначених організацією типів цифрових та/або нецифрових носіїв інформації] [Призначення: визначеним організацією персоналом або ролями].

No: 1

Name: mp_2_01

Type: list

Default: ["admin", "security_officer"]

Доступ до типів цифрових носіїв інформації обмежено для персоналу або ролей

No: 2

Name: mp_2_02

Type: list

Default: ["admin", "security_officer"]

Доступ до типів нецифрових носіїв інформації обмежено для персоналу або ролей

No: 3

Name: mp_2_odp_01

Type: string

Default: nil

Визначено типи цифрових носіїв інформації, доступ до яких обмежено

No: 4

Name: mp_2_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, уповноважені на доступ до цифрових носіїв інформації

No: 5

Name: mp_2_odp_03

Type: string

Default: nil

Визначено типи нецифрових носіїв інформації, доступ до яких обмежено

No: 6

Name: mp_2_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, уповноважені на доступ до нецифрових носіїв інформації

10.2.1. АВТОМАТИЗОВАНИЙ ОБМЕЖЕННИЙ ДОСТУП (MP-2(1))

No: 1

Name: mp_2_1_01

Type: string

Default: nil

ДОСТУП ДО НОСІЇВ ІНФОРМАЦІЇ - АВТОМАТИЗОВАНИЙ ОБМЕЖЕННИЙ ДОСТУП [Вилучено:
Включено до MP-04(02)]

10.2.2. КРИПТОГРАФІЧНИЙ ЗАХИСТ (MP-2(2))

No: 1

Name: mp_2_2_01

Type: string

Default: "AES-256-GCM"

ДОСТУП ДО НОСІЇВ ІНФОРМАЦІЇ - КРИПТОГРАФІЧНИЙ ЗАХИСТ [Вилучено: Включено до SC-28(01)]

10.3. МАРКУВАННЯ НОСІЇВ ІНФОРМАЦІЇ (МР-3)

- а. Наносити на носії інформації маркування, що вказують на обмеження поширення, обробки, а також застереження та відповідні мітки безпеки (якщо такі є) інформації.
- б. Звільнити [Призначення: визначені організацією типи носіїв системи] від маркування, якщо носії залишаються в межах [Призначення: визначених організацією контрольованих зон].

No: 1
 Name: mp_3_01
 Type: string
 Default: nil

МАРКУВАННЯ НОСІЇВ ІНФОРМАЦІЇ МЕТА ОЦІНКИ: Визначити, чи:

No: 2
 Name: mp_3_a
 Type: string
 Default: nil

Носії інформації маркуються, щоб вказати на обмеження поширення, обробки, а також застереження та відповідні мітки безпеки (якщо такі є) інформації

No: 3
 Name: mp_3_b
 Type: string
 Default: nil

Типи носіїв інформації залишаються в межах контрольованих зон

No: 4
 Name: mp_3_odp_01
 Type: integer
 Default: 30

Визначено типи носіїв інформації, які звільняються від маркування під час перебування на контрольованих зонах

No: 5
 Name: mp_3_odp_02
 Type: string
 Default: nil

Визначено контрольовані зони, де носії інформації звільняються від маркування

10.4. ЗБЕРІГАННЯ НОСІЇВ ІНФОРМАЦІЇ (МР-4)

- а. Фізично контролювати та безпечно зберігати [Призначення: визначені організацією типи цифрових та/або нецифрових носіїв інформації] в межах [Призначення: визначених організацією контрольованих зон].
- б. Захищати системні носії, які визначені в МР-4 до того часу, як носії знищуються або очищаються, з використанням затвердженого обладнання, методів та процедур.

No: 1
 Name: mp_4_a_01
 Type: string
 Default: nil

Типи цифрових носіїв контролюються фізично

No: 2

Name: mp_4_a_02

Type: string

Default: nil

Типи нецифрових носіїв контролюються фізично

No: 3

Name: mp_4_a_03

Type: string

Default: nil

Типи цифрових носіїв безпечно зберігаються в контрольованих зонах

No: 4

Name: mp_4_a_04

Type: string

Default: nil

Типи нецифрових носіїв безпечно зберігаються в контрольованих зонах

No: 5

Name: mp_4_b

Type: string

Default: nil

Типи носіїв інформації (визначені в MP-04_ODP[01], MP04_ODP[02], MP-04_ODP[03], MP-04_ODP[04]) захищені доти, доки носії інформації не будуть знищені або очищені за допомогою визначеного обладнання, методик та процедур

No: 6

Name: mp_4_odp_01

Type: string

Default: nil

Визначено типи цифрових носіїв інформації, які підлягають фізичному контролю (якщо вибрано)

No: 7

Name: mp_4_odp_02

Type: string

Default: nil

Визначено типи нецифрових носіїв інформації, які підлягають фізичному контролю (якщо вибрано)

No: 8

Name: mp_4_odp_03

Type: string

Default: nil

Визначено типи цифрових носіїв інформації для безпечного зберігання (якщо вибрано)

No: 9

Name: mp_4_odp_04

Type: string

Default: nil

Визначено типи нецифрових носіїв інформації для безпечного зберігання (якщо вибрано)

No: 10

Name: mp_4_odp_05

Type: string

Default: nil

Визначено контрольовані зони, в яких можна безпечно зберігати цифрові носії інформації; MP-04_ODP[06]
визначено контрольовані зони, в яких можна безпечно зберігати нецифрові носії інформації

10.4.1. КРИПТОГРАФІЧНИЙ ЗАХИСТ (MP-4(1))

No: 1
Name: mp_4_1_01
Type: string
Default: "AES-256-GCM"

ЗБЕРІГАННЯ НОСІЇВ ІНФОРМАЦІЇ - КРИПТОГРАФІЧНИЙ ЗАХИСТ [Вилучено: Включено до SC-28(01)]

10.4.2. АВТОМАТИЗОВАНИЙ ОБМЕЖЕНИЙ ДОСТУП (MP-4(2))

No: 1
Name: mp_4_2_01
Type: string
Default: nil

Доступ до зон зберігання носіїв інформації обмежено за допомогою автоматизованих механізмів

No: 2
Name: mp_4_2_02
Type: integer
Default: 3

Спроби доступу до зон зберігання носіїв інформації реєструються за допомогою автоматизованих механізмів

No: 3
Name: mp_4_2_03
Type: string
Default: nil

Доступ, наданий до зон зберігання носіїв, реєструється за допомогою автоматизованих механізмів

No: 4
Name: mp_4_2_odp_01
Type: string
Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми обмеження доступу до зон зберігання носіїв інформації

No: 5
Name: mp_4_2_odp_02
Type: integer
Default: 3

Визначено автоматизовані механізми реєстрації спроб доступу до зон зберігання носіїв інформації; MP-04(02)_ODP[03] визначено автоматизовані механізми реєстрації доступу, наданого до зон зберігання носіїв інформації

10.5. Транспортування носіїв інформації (MP-5)

- a. Захищати та контролювати [Призначення: визначені організацією типи носіїв системи] під час транспортування за межами контрольованих зон, використовуючи [Призначення: визначені організацією заходи безпеки].
- b. Вести облік носіїв системи інформації під час транспортування за межами контрольованих зон.

- c. Документувати дії, пов'язані з транспортуванням носіїв системи.
 d. Обмежити діяльність уповноваженого персоналу, пов'язану з транспортуванням носіїв системи.

No: 1

Name: mp_5_a_01

Type: integer

Default: 30

Типи носіїв інформації системи захищаються під час транспортування за межі контрольованих зон за допомогою заходів безпеки

No: 2

Name: mp_5_a_02

Type: integer

Default: 30

Типи носіїв інформації системи контролюються під час транспортування за межі контрольованих зон за допомогою заходів безпеки

No: 3

Name: mp_5_b

Type: integer

Default: 30

Під час транспортування за межі контрольованих зон ведеться облік носіїв інформації системи

No: 4

Name: mp_5_c

Type: string

Default: nil

Діяльність, пов'язана з транспортуванням носіїв інформації системи, задокументована

No: 5

Name: mp_5_d_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал, уповноважений здійснювати діяльність з транспортування носіїв інформації

No: 6

Name: mp_5_d_02

Type: list

Default: ["admin", "security_officer"]

Діяльність, пов'язана з транспортуванням носіїв інформації системи, обмежується визначеним уповноваженим персоналом

No: 7

Name: mp_5_odp_01

Type: integer

Default: 30

Визначено типи носіїв інформації системи для захисту та контролю під час транспортування за межі контрольованих зон

No: 8

Name: mp_5_odp_02

Type: string

Default: nil

Визначено заходи безпеки, що використовуються для захисту носіїв інформації системи поза контрольованими зонами

No: 9

Name: mp_5_odp_03

Type: string

Default: nil

Визначено заходи безпеки, що використовуються для контролю носіїв інформації системи за межами контрольованих зон

10.5.1. ЗАХИСТ ПОЗА КОНТРОЛЬОВАНИМИ ЗОНАМИ (MP-5(1))

No: 1

Name: mp_5_1_01

Type: string

Default: nil

ТРАНСПОРТУВАННЯ НОСІЇВ ІНФОРМАЦІЇ - ЗАХИСТ ПОЗА КОНТРОЛЬОВАНИМИ ЗОНАМИ [Вилучено: Включено до MP-05]

10.5.2. ДОКУМЕНТУВАННЯ ДІЙ (MP-5(2))

No: 1

Name: mp_5_2_01

Type: string

Default: nil

ТРАНСПОРТУВАННЯ НОСІЇВ ІНФОРМАЦІЇ - ДОКУМЕНТУВАННЯ ДІЙ [Вилучено: Включено до MP-05]

10.5.3. ЗБЕРІГАЧІ (MP-5(3))

No: 1

Name: mp_5_3_01

Type: integer

Default: 30

Визначено зберігачів інформації під час транспортування носіїв інформації системи за межі контрольованих зон

No: 2

Name: mp_5_3_02

Type: integer

Default: 30

Залучено визначених зберігачів інформації під час транспортування носіїв інформації системи за межі контрольованих зон

10.5.4. КРИПТОГРАФІЧНИЙ ЗАХИСТ (MP-5(4))

No: 1

Name: mp_5_4_01

Type: string

Default: "AES-256-GCM"

ТРАНСПОРТУВАННЯ НОСІВ ІНФОРМАЦІЇ - КРИПТОГРАФІЧНИЙ ЗАХИСТ [Вилучено: Включено до SC-28(01)]

10.6. ЗНИЩЕННЯ ІНФОРМАЦІЇ НА НОСІЯХ ІНФОРМАЦІЇ (MP-6)

a. Очищувати [Призначення: визначені організацією системні носії] перед утилізацією, випуском за межі організаційного контролю, або перед повторним використанням [Призначення: методами та процедурами очищення, визначеними організацією].

b. Використовувати механізми очищення зі стійкістю та цілісністю, що відповідає категорії безпеки або рівню секретності інформації.

No: 1

Name: mp_6_a_01

Type: string

Default: nil

Носії інформації системи перед утилізацією піддаються очищенню за допомогою методів та процедур очищення

No: 2

Name: mp_6_a_02

Type: string

Default: nil

Носії інформації системи очищаються за допомогою методів та процедур очищення перед випуском за межі контрольованої зони

No: 3

Name: mp_6_a_03

Type: string

Default: nil

Носії інформації системи очищуються за допомогою методів і процедур очищення перед повторним використанням

No: 4

Name: mp_6_b

Type: string

Default: "автоматизований засіб моніторингу"

Застосовуються механізми очищення, надійність і цілісність яких відповідає категорії безпеки або рівню секретності інформації

No: 5

Name: mp_6_odp_01

Type: string

Default: nil

Визначено носії інформації системи, які підлягають очищенню перед утилізацією

No: 6

Name: mp_6_odp_02

Type: string

Default: nil

Визначено носії інформації системи, які підлягають очищенню перед випуском за межі контрольованої зони

No: 7

Name: mp_6_odp_03

Type: string

Default: nil

Визначені носії інформації системи, що підлягають очищенню перед повторним використанням

No: 8

Name: mp_6_odp_04

Type: string

Default: nil

Визначено методи та процедури очищення, які слід використовувати для очищення перед утилізацією

No: 9

Name: mp_6_odp_05

Type: string

Default: nil

Визначено методи та процедури очищення, які слід використовувати для очищення перед випуском за межі контрольованої зони

No: 10

Name: mp_6_odp_06

Type: string

Default: nil

Визначено методи та процедури очищення, які слід використовувати для очищення перед повторним використанням

10.6.1. ПЕРЕГЛЯДАТИ, ЗАТВЕРДЖЕННЯ, ВІДСТЕЖЕННЯ, ДОКУМЕНТУВАННЯ ТА ПЕРЕВІРКА (МР-6(1))

No: 1

Name: mp_6_1_01

Type: string

Default: nil

Переглядаються заходи з очищення та утилізації носіїв інформації

No: 2

Name: mp_6_1_02

Type: string

Default: nil

Затверджуються заходи з очищення та утилізації носіїв інформації

No: 3

Name: mp_6_1_03

Type: string

Default: nil

Відстежуються заходи з очищення та утилізації носіїв інформації

No: 4

Name: mp_6_1_04

Type: string

Default: nil

Документуються заходи з очищення та утилізації носіїв інформації

No: 5

Name: mp_6_1_05

Type: string

Default: nil

Перевіряються заходи з очищення та утилізації носіїв інформації

10.6.2. ПЕРЕВІРКА ОБЛАДНАННЯ (МР-6(2))

No: 1

Name: mp_6_2_01

Type: string

Default: "щорічно"

Обладнання для очищення тестується частота, щоб переконатися в досягненні запланованого очищення

No: 2

Name: mp_6_2_02

Type: string

Default: "щорічно"

Процедури санітарної обробки тестуються частота, щоб переконатися в досягненні запланованого очищення

No: 3

Name: mp_6_2_odp_01

Type: string

Default: "щорічно"

Визначена частота, з якою проводиться перевірка обладнання для очищення

No: 4

Name: mp_6_2_odp_02

Type: integer

Default: 30

Визначено частоту, з якою потрібно перевіряти процедури очищення

10.6.3. НЕРУЙНІВНІ МЕТОДИ (МР-6(3))

No: 1

Name: mp_6_3_01

Type: string

Default: nil

Застосовуються методи неруйнівного очищення до зовнішніх носіїв інформації перед підключенням таких пристроїв до системи при умовах, що вимагають очищення зовнішніх носіїв інформації

No: 2

Name: mp_6_3_odp

Type: list

Default: []

Визначено умови, які вимагають очищення зовнішніх носіїв інформації

10.6.4. КЕРОВАНА НЕСЕКРЕТНА ІНФОРМАЦІЯ (МР-6(4))

No: 1

Name: mp_6_4_01

Type: string

Default: nil

ЗНИЩЕННЯ ІНФОРМАЦІЇ НА НОСІЯХ ІНФОРМАЦІЇ - КЕРОВАНА НЕСЕКРЕТНА ІНФОРМАЦІЯ
[Вилучено: Включено до МР-06]

10.6.5. СЕКРЕТНА ІНФОРМАЦІЯ (МР-6(5))

No: 1
Name: mp_6_5_01
Type: string
Default: nil

ЗНИЩЕННЯ ІНФОРМАЦІЇ НА НОСІЯХ ІНФОРМАЦІЇ - СЕКРЕТНА ІНФОРМАЦІЯ [Вилучено: Включено до МР-06]

10.6.6. ЗНИЩЕННЯ НОСІЇВ ІНФОРМАЦІЇ (МР-6(6))

No: 1
Name: mp_6_6_01
Type: string
Default: nil

ЗНИЩЕННЯ ІНФОРМАЦІЇ НА НОСІЯХ ІНФОРМАЦІЇ - ЗНИЩЕННЯ НОСІЇВ ІНФОРМАЦІЇ [Вилучено: Включено до МР-06]

10.6.7. ПОДВІЙНА АВТОРИЗАЦІЯ (МР-6(7))

No: 1
Name: mp_6_7_01
Type: string
Default: nil

Здійснюється подвійна авторизація для очищення носії інформації

No: 2
Name: mp_6_7_odp
Type: string
Default: nil

Визначено носії інформації для яких необхідно здійснювати подвійну авторизацію для очищення

10.6.8. ВІДДАЛЕНЕ ОЧИЩЕННЯ АБО СТИРАННЯ ІНФОРМАЦІЇ (МР-6(8))

No: 1
Name: mp_6_8_odp_01
Type: string
Default: nil

Визначено системи або компоненти системи для очищення або стирання інформації віддалено або за певних умов

No: 2
Name: mp_6_8_odp_02
Type: string
Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {віддалено; за умов }

No: 3

Name: mp_6_8_odp_03

Type: list

Default: []

Визначаються умови, за яких інформація підлягає очищенню або стиранню (якщо вибрано)

10.7. ВИКОРИСТАННЯ НОСІЇВ ІНФОРМАЦІЇ (МР-7)

а. [Вибір: обмежити; заборонити] використання [Призначення: визначених організацією типів носіїв системи] на [Призначення: визначені організацією системи або компоненти системи], використовуючи [Призначення: визначені організацією заходи безпеки].

б. Заборонити використання портативних пристроїв зберігання даних в системах організації, якщо такі пристрої не мають визначеного власника.

No: 1

Name: mp_7_01

Type: string

Default: nil

ВИКОРИСТАННЯ НОСІЇВ ІНФОРМАЦІЇ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: mp_7_b

Type: string

Default: nil

Використання зовнішніх носіїв інформації в системах організації заборонено, якщо такі пристрої не мають власника, якого можна ідентифікувати

No: 3

Name: mp_7_odp_01

Type: string

Default: nil

Визначено типи носіїв інформації, які мають бути обмежені або заборонені до використання в системі або компонентах системи

No: 4

Name: mp_7_odp_02

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРА: {обмежити; заборонити}

No: 5

Name: mp_7_odp_03

Type: string

Default: nil

Системи або компоненти системи, для яких визначено використання певних типів носіїв інформації, що підлягають обмеженню або забороні

No: 6

Name: mp_7_odp_04

Type: string

Default: nil

Визначено заходи безпеки для обмеження або заборони використання певних типів носіїв інформації в системах або компонентах системи

10.7.1. ЗАБОРОНА ВИКОРИСТАННЯ БЕЗ ВИЗНАЧЕНОГО ВЛАСНИКА (МР-7(1))

No: 1
Name: mp_7_1_01
Type: string
Default: nil

ВИКОРИСТАННЯ НОСІЇВ ІНФОРМАЦІЇ - ЗАБОРОНА ВИКОРИСТАННЯ БЕЗ ВИЗНАЧЕНОГО ВЛАСНИКА [Вилучено: Включено до МР-07]

10.7.2. ЗАБОРОНА ВИКОРИСТАННЯ (МР-7(2))

No: 1
Name: mp_7_2_01
Type: string
Default: nil

Ідентифіковано стійкі до очищення носії інформації

No: 2
Name: mp_7_2_02
Type: string
Default: nil

Використання стійких до очищення носіїв інформації в системах організації заборонено

10.8. ЗНИЖЕННЯ КАТЕГОРІЇ БЕЗПЕКИ НОСІЇВ ІНФОРМАЦІЇ (МР-8)

- а. сплануйте розташування або ділянку об'єкта, де знаходиться система, враховуючи фізичні та екологічні ризики;
- б. для існуючих об'єктів врахуйте фізичні та екологічні ризики в організаційній стратегії управління ризиками.

No: 1
Name: mp_8_a_01
Type: string
Default: nil

Встановлено безпеки носіїв інформації; процес зниження категорії

No: 2
Name: mp_8_a_02
Type: string
Default: nil

Процес зниження категорії безпеки носіїв інформації охоплює використання механізмів зниження грифа секретності носіїв інформації за стійкістю та цілісністю, що відповідає категорії безпеки або рівню секретності інформації

No: 3
Name: mp_8_b_01
Type: string
Default: nil

Здійснюється перевірка того, що процес зниження категорії безпеки носіїв інформації відповідає категорії безпеки та/або рівню секретності інформації, що підлягає видаленню

No: 4
Name: mp_8_b_02
Type: string
Default: nil

Здійснюється перевірка того, що процес зниження категорії безпеки носіїв інформації співмірний з правами доступу потенційних одержувачів пониженої інформації; МР-08(с) визначено носії інформації системи, що потребують пониження статусу

No: 5
Name: mp_8_d
Type: string
Default: nil

Визначений носій інформації понижено у категорії безпеки за допомогою процес зниження категорії безпеки носіїв інформації

No: 6
Name: mp_8_odp_01
Type: string
Default: nil

Визначено процес зниження категорії безпеки носіїв інформації

No: 7
Name: mp_8_odp_02
Type: string
Default: nil

Визначено носії інформації системи, що вимагають зниження категорії безпеки

10.8.1. ДОКУМЕНТУВАННЯ ПРОЦЕСУ (МР-8(1))

No: 1
Name: mp_8_1_01
Type: list
Default: ["login", "logout", "failed_attempt"]

Документуються дії зі зниження категорії безпеки носіїв інформації

10.8.2. ПЕРЕВІРКА ОБЛАДНАННЯ (МР-8(2))

No: 1
Name: mp_8_2_01
Type: string
Default: "щорічно"

Обладнання для заниження категорії безпеки перевіряється частота, щоб переконатися в досягненні запланованих заходів щодо зниження

No: 2
Name: mp_8_2_02
Type: string
Default: "щорічно"

Процедури для заниження категорії безпеки перевіряється частота, щоб переконатися в досягненні запланованих заходів щодо зниження

No: 3
 Name: mp_8_2_odp_02
 Type: integer
 Default: 30

Визначено частоту, з якою потрібно перевіряти процедури для зниження категорії безпеки

10.8.3. КРИТИЧНА ІНФОРМАЦІЯ (MP-8(3))

No: 1
 Name: mp_8_3_01
 Type: string
 Default: nil

Визначено критичну інформацію за наявності якої на носії інформації, знижують категорію безпеки до рівня публічного доступу

No: 2
 Name: mp_8_3_02
 Type: string
 Default: nil

Знижується категорія безпеки носіїв інформації, що містять визначену критичну інформацію до рівня публічного доступу

10.8.4. ТАЄМНА ІНФОРМАЦІЯ (MP-8(4))

No: 1
 Name: mp_8_4_01
 Type: string
 Default: nil

Ідентифіковано носії інформації, що містять інформацію з обмеженим доступом

No: 2
 Name: mp_8_4_02
 Type: list
 Default: ["admin", "security_officer"]

Носії інформації, що містять інформацію з обмеженим доступом, знижуються в класі перед передачею особам, які не мають необхідних дозволів на доступ

11. РЕ

Клас заходів захисту РЕ — ФІЗИЧНИЙ ЗАХИСТ І ЗАХИСТ РОБОЧОГО

Цей клас охоплює заходи контролю фізичного доступу до об'єктів організації та захисту обладнання від загроз навколишнього середовища.

Перелік заходів захисту: РЕ-1 фізичного захисту та захисту робочого середовища авторизація фізичного (РЕ-1); РЕ-2 доступу (РЕ-2); ФІЗИЧНИЙ ДОСТУП ДО СИСТЕМИ; Керування фізичним доступом — захист від злому (РЕ-3(5)); РЕ-4 ліній електроживлення (РЕ-4); КОНТРОЛЬ ДОСТУПУ В ПРИМІЩЕННЯ ДЛЯ ВІДОВБРАЖЕННЯ ІНФОРМАЦІЇ; МОНІТОРИНГ ФІЗИЧНОГО ДОСТУПУ; Моніторинг фізичного доступу — автоматичні розпізнавання вторгнень і відповідна реакція (РЕ-6(2)); Реєстри доступу відвідувачів — обмеження інформації, що

ідентифікує особу (PE-8(3)); Аварійне освітлення (PE-12); Альтернативне робоче місце (PE-17); Розташування компонентів системи (PE-18); Моніторинг і відстеження активів (PE-20); Захист від електромагнітного імпульсу (PE-21); Маркування компонентів (PE-22).

11.1. PE-1 фізичного захисту та захисту робочого середовища Авторизація фізичного (PE-1)

No: 1

Name: pe_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику фізичного захисту та захисту робочого середовища

No: 2

Name: pe_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика фізичного захисту та захисту робочого середовища розповсюджується серед персоналу або ролей

No: 3

Name: pe_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур фізичного захисту та захисту робочого середовища; PE-01(c)[01][01] переглядається та оновлюється поточна політика фізичного захисту та захисту робочого середовища частота; PE-01(c)[01][02] поточна політика фізичного захисту та захисту робочого середовища переглядається та оновлюється після подій; PE-01(c)[02][01] переглядаються та оновлюються поточні процедури фізичного захисту та захисту робочого середовища частота; поточні процедури фізичного та екологічного захисту переглядаються та оновлюються після подій. PE-01(c)[02][02]

No: 4

Name: pe_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких має бути доведена політика фізичного захисту та захисту робочого середовища

No: 5

Name: pe_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури фізичного захисту та захисту робочого середовища

No: 6

Name: pe_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 7

Name: pe_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами фізичного захисту та захисту робочого середовища

No: 8

Name: pe_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика фізичного захисту та захисту робочого середовища

No: 9

Name: pe_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, які потребують перегляду та оновлення поточної політики фізичного захисту та захисту робочого середовища

No: 10

Name: pe_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури фізичного захисту та захисту робочого середовища

No: 11

Name: pe_1_odp_08

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують перегляду та оновлення процедур фізичного захисту та захисту робочого середовища

11.2. PE-2 доступу (PE-2)

No: 1

Name: pe_2_a_01

Type: list

Default: []

Розроблено перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система

No: 2

Name: pe_2_a_02

Type: list

Default: []

Затверджено перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система

No: 3

Name: pe_2_a_03

Type: list

Default: []

Ведеться перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система

No: 4
 Name: pe_2_b
 Type: string
 Default: nil

Для доступу до об'єкта надаються повноваження

No: 5
 Name: pe_2_c
 Type: list
 Default: ["admin", "security_officer"]

Переглядається список доступу, , у якому закріплений перелік персоналу або ролей, яким дозволений санкціонований доступ до об'єкта частота

No: 6
 Name: pe_2_d
 Type: list
 Default: ["admin", "security_officer"]

Особи видаляються зі списку доступу до об'єкта, коли доступ більше не потрібен

No: 7
 Name: pe_2_odp
 Type: list
 Default: ["admin", "security_officer"]

Визначено періодичність перегляду списку доступу, у якому закріплений перелік персоналу або ролей, яким дозволений санкціонований доступ до об'єкта

11.3. ФІЗИЧНИЙ ДОСТУП ДО СИСТЕМИ

No: 1
 Name: pe_3_a_01
 Type: string
 Default: nil

Авторизація фізичного доступу забезпечується в пунктах входу і виходу шляхом перевірки індивідуальних дозволів доступу

No: 2
 Name: pe_3_b
 Type: string
 Default: nil

Журнали контролю фізичного доступу ведуться для 03_ODP[04] точок входу або виходу>

No: 3
 Name: pe_3_c
 Type: string
 Default: nil

Доступ в зони всередині об'єкту, визначені як загальнодоступні, підтримується шляхом впровадження заходів захисту

No: 4
 Name: pe_3_d_01
 Type: string
 Default: nil

Відвідувачів супроводжують

No: 5

Name: pe_3_d_02

Type: list

Default: []

Активність відвідувачів контролюється умови

No: 6

Name: pe_3_e_01

Type: string

Default: nil

Ключі захищені

No: 7

Name: pe_3_e_02

Type: string

Default: nil

Коди доступу захищені

No: 8

Name: pe_3_e_03

Type: string

Default: nil

Інші пристрої фізичного доступу захищені

No: 9

Name: pe_3_f

Type: string

Default: "щорічно"

Пристрої фізичного доступу інвентаризуються частота

No: 10

Name: pe_3_g_01

Type: list

Default: ["admin", "security_officer"]

Коди доступу змінюється частота, коли код скомпрометовано, або коли особи, які володіють кодом, переводяться або звільняються; <PE- PE-03(g)[02] ключі змінюються частота, коли ключі втрачено, або коли особи, що володіють ключами, переводяться або звільняються

No: 11

Name: pe_3_odp_01

Type: string

Default: nil

Визначено точки входу та виходу в об'єкт, в якому знаходиться система

No: 12

Name: pe_3_odp_02

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {системи або пристрої; охоронці}

No: 13

Name: pe_3_odp_03

Type: string

Default: nil

Визначено фізичні системи або пристрої контролю доступу, що використовуються для контролю входу та виходу на об'єкт (якщо вибрано); PE-03_ODP[04] визначено точки входу або виходу, для яких ведуться журнали контролю фізичного доступу

No: 14
Name: pe_3_odp_05
Type: string
Default: nil

Визначено заходи захисту для контролю доступу в зони всередині об'єкту, позначені як загальнодоступні

No: 15
Name: pe_3_odp_06
Type: list
Default: []

Визначено умови, що вимагають супроводу відвідувачів та моніторингу активності відвідувачів

No: 16
Name: pe_3_odp_07
Type: string
Default: nil

Визначені пристрої фізичного доступу, що підлягають інвентаризації

No: 17
Name: pe_3_odp_08
Type: integer
Default: 30

Визначено частоту проведення інвентаризації пристроїв фізичного доступу

No: 18
Name: pe_3_odp_09
Type: integer
Default: 30

Визначено частоту, з якою потрібно змінювати коди доступу

No: 19
Name: pe_3_odp_10
Type: integer
Default: 30

Визначено частоту, з якою потрібно змінювати ключі

11.3.1. Керування фізичним доступом — Захист від злому (PE-3(5))

No: 1
Name: pe_3_5_odp_01
Type: string
Default: nil

Визначено заходи захисту від фізичної підробки або підміни

No: 2
Name: pe_3_5_odp_02
Type: string
Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {виявлення; запобігання}

No: 3

Name: pe_3_5_odp_03

Type: string

Default: nil

Визначено апаратні компоненти, які мають захищені від фізичної підробки або підміни

11.4. РЕ-4 ліній електроживлення (РЕ-4)

No: 1

Name: pe_4_01

Type: string

Default: nil

Фізичний доступ до систем розподілу та постачання живлення в межах об'єктів організації контролюється за допомогою заходів захисту

No: 2

Name: pe_4_odp_01

Type: string

Default: nil

Визначені системи розподілу та постачання живлення, які потребують фізичного контролю доступу

No: 3

Name: pe_4_odp_02

Type: string

Default: nil

Визначено заходи захисту, які необхідно впровадити для контролю фізичного доступу до систем розподілу та постачання живлення в межах об'єкту організації

11.5. КОНТРОЛЬ ДОСТУПУ В ПРИМІЩЕННЯ ДЛЯ ВІДОБРАЖЕННЯ ІНФОРМАЦІЇ

No: 1

Name: pe_5_odp

Type: string

Default: nil

Визначено пристрої для виведення інформації над якими необхідний контроль над фізичним доступом до вихідних даних

11.6. МОНІТОРИНГ ФІЗИЧНОГО ДОСТУПУ

No: 1

Name: pe_6_a

Type: string

Default: nil

Фізичний доступ до об'єкту, де знаходиться система, моніториться з метою виявлення та реагування на інциденти фізичної безпеки

No: 2
 Name: pe_6_b_01
 Type: string
 Default: "щорічно"

Переглядаються журнали фізичного доступу частота

No: 3
 Name: pe_6_b_02
 Type: string
 Default: nil

Журнали фізичного доступу переглядаються при виникненні подій

No: 4
 Name: pe_6_c_01
 Type: string
 Default: nil

Результати переглядів узгоджуються з можливостями організації щодо реагування на інциденти

No: 5
 Name: pe_6_c_02
 Type: string
 Default: nil

Результати розслідувань узгоджуються з можливостями організації щодо реагування на інциденти

No: 6
 Name: pe_6_odp_01
 Type: integer
 Default: 30

Визначено частоту перегляду журналів фізичного доступу

No: 7
 Name: pe_6_odp_02
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Визначено події або потенційні ознаки подій, що вимагають перегляду журналів фізичного доступу

11.6.1. Моніторинг фізичного доступу — Автоматичні розпізнавання вторгнень і відповідна реакція (PE-6(2))

No: 1
 Name: pe_6_2_01
 Type: string
 Default: nil

Розпізнаються класи або типи вторгнень

No: 2
 Name: pe_6_2_02
 Type: string
 Default: nil

Реакції ініціюються за допомогою автоматизованих механізмів

No: 3
 Name: pe_6_2_odp_01

Type: string

Default: nil

Визначено класи або типи вторгнень, які мають розпізнаватися автоматизованими механізмами

No: 4

Name: pe_6_2_odp_02

Type: string

Default: nil

Визначено реакції, які мають ініціюватися автоматизованими механізмами при розпізнаванні визначених організацією класів або типів вторгнень

No: 5

Name: pe_6_2_odp_03

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для розпізнавання класів або типів вторгнень та ініціювання дій реагування (визначені в PE06(02)_ODP)

11.6.2. РЕЄСТРИ ДОСТУПУ ВІДВІДУВАЧІВ — ОБМЕЖЕННЯ ІНФОРМАЦІЇ, ЩО ІДЕНТИФІКУЄ ОСОБУ (PE-8(3))

No: 1

Name: pe_8_3_01

Type: list

Default: ["admin", "security_officer"]

Інформація, що ідентифікує особу, яка міститься в реєстрах доступу відвідувачів, обмежується елементами, визначеними в оцінці ризиків для конфіденційності

No: 2

Name: pe_8_3_odp

Type: string

Default: nil

В оцінці ризиків для конфіденційності визначено елементи, що обмежуються в реєстрі відвідувачів

11.7. АВАРІЙНЕ ОСВІТЛЕННЯ (PE-12)

No: 1

Name: pe_12_01

Type: string

Default: nil

Автоматичне аварійне освітлення, яке вмикається в разі відключення або збою в електропостачанні

No: 2

Name: pe_12_02

Type: string

Default: nil

Підтримується автоматичне аварійне освітлення, яке вмикається в разі відключення або збою в електропостачанні

No: 3

Name: pe_12_03

Type: string

Default: nil

Автоматичне аварійне освітлення системи освітлює евакуаційні виходи в межах об'єкта

No: 4

Name: pe_12_04

Type: string

Default: nil

Автоматичне аварійне освітлення системи освітлює шляхи евакуації в межах об'єкта

11.8. АЛЬТЕРНАТИВНЕ РОБОЧЕ МІСЦЕ (PE-17)

No: 1

Name: pe_17_odp_01

Type: string

Default: nil

Визначені альтернативні робочі місця, дозволені для використання працівниками

No: 2

Name: pe_17_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначаються заходи захисту, які будуть застосовуватися на альтернативних робочих місцях; PE-17(a) альтернативні робочі місця визначені та задокументовані; PE-17(b) заходи захисту впроваджені на альтернативних робочих місцях; PE-17(c) оцінюється ефективність заходів захисту на альтернативних робочих місцях; PE-17(d) працівникам надаються засоби комунікації з персоналом служби інформаційної безпеки на випадок інцидентів

11.9. РОЗТАШУВАННЯ КОМПОНЕНТІВ СИСТЕМИ (PE-18)

No: 1

Name: pe_18_01

Type: string

Default: nil

Компоненти системи розміщені в межах об'єкта так, щоб мінімізувати потенційну шкоду від фізичні та екологічні небезпеки і звести до мінімуму можливість несанкціонованого доступу

No: 2

Name: pe_18_odp

Type: string

Default: nil

Визначено фізичні та екологічні небезпеки, які можуть призвести до потенційного пошкодження компонентів системи на об'єкті

11.10. МОНІТОРИНГ І ВІДСТЕЖЕННЯ АКТИВІВ (РЕ-20)

No: 1

Name: pe_20_01

Type: string

Default: nil

Технології використовуються для відстеження та моніторингу місцезнаходження і переміщення <РЕ- 20_ ODP[02] активів> в межах контрольованої зони

No: 2

Name: pe_20_odp_01

Type: string

Default: nil

Визначено технології, які будуть використовуватися для відстеження та моніторингу місцезнаходження та переміщення активів

No: 3

Name: pe_20_odp_02

Type: string

Default: nil

Визначено активи, місцезнаходження та переміщення яких необхідно відстежувати та моніторити

No: 4

Name: pe_20_odp_03

Type: string

Default: nil

Визначено контрольовані зони, в межах яких місцезнаходження та переміщення активів підлягають відстеженню та моніторингу

11.11. ЗАХИСТ ВІД ЕЛЕКТРОМАГНІТНОГО ІМПУЛЬСУ (РЕ-21)

No: 1

Name: pe_21_01

Type: string

Default: nil

Заходи захисту застосовуються проти пошкодження електромагнітними імпульсами для системи та компонентів системи

No: 2

Name: pe_21_odp_01

Type: string

Default: nil

Визначено заходи захисту від пошкодження електромагнітними імпульсами

No: 3

Name: pe_21_odp_02

Type: string

Default: nil

Визначено систему та компоненти системи, що потребують захисту від пошкодження електромагнітними імпульсами

11.12. МАРКУВАННЯ КОМПОНЕНТІВ (PE-22)

No: 1

Name: pe_22_01

Type: string

Default: nil

Апаратні компоненти системи позначаються із зазначенням рівня впливу або класифікації інформації, яку дозволено обробляти, зберігати або передавати за допомогою апаратного компонента

No: 2

Name: pe_22_odp

Type: string

Default: nil

Визначено апаратні компоненти системи, які підлягають маркуванню із зазначенням рівня впливу або класифікації інформації, яку дозволено обробляти, зберігати або передавати за допомогою апаратного компонента

12. PL

Клас заходів захисту PL — ПЛАНУВАННЯ БЕЗПЕКИ

Цей клас регламентує розробку, документування та регулярне оновлення планів захисту інформації, архітектури безпеки та приватності.

Перелік заходів захисту: Політики та процедури планування безпеки (PL-1); Плани захисту інформації та персональних даних (PL-2); Керування ризиками ланцюга диверсифікація постачальників (PL-2(1)); Плани захисту інформації функціональна архітектура (PL-2(2)); Оновлення планів захисту інформації та персональних даних (PL-3); Правила поведінки (PL-4); Обмеження на соціальні медіа та мережу (PL-4(1)); Оцінка впливу на приватність (PL-5); Планування діяльності, пов'язаної з безпекою (PL-6); Концепція експлуатації (PL-7); Архітектура безпеки та приватності (PL-8); «глибока оборона» (PL-8(1)); Різноманітність постачальників (PL-8(2)); Централізоване управління (PL-9); Вибір базового профілю безпеки (PL-10); Налаштування базового профілю безпеки (PL-11).

12.1. ПОЛІТИКИ ТА ПРОЦЕДУРИ ПЛАНУВАННЯ БЕЗПЕКИ (PL-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або ролей]:

1. 2. [вибір (один або декілька): рівень організації; рівень місії/бізнес процесу; рівень системи] політику планування, яка:

(а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та системою контролю (compliance);

(b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам та керівним принципам; процедури, що полегшують здійснення планування політики безпеки та приватності й пов'язані з ними заходи.

б. Призначити [Призначення: визначену організацією посадову особу] для управління політи-

кою та процедурами планування політики безпеки та приватності.

с. Переглядати та оновлювати поточне планування:

1. політики планування безпеки та приватності [Призначення: з визначеною організацією частотою] та наступні [Призначення: визначені організацією події];
2. поточні процедури планування політики [Призначення: з визначеною організацією [Призначення: визначені організацією події]. безпеки та приватності частотою] та наступні

No: 1

Name: pl_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких має бути доведена політика планування безпеки

No: 2

Name: pl_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюватимуться процедури планування безпеки

No: 3

Name: pl_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: pl_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами планування безпеки

No: 5

Name: pl_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено періодичність перегляду та оновлення поточної політики планування безпеки

No: 6

Name: pl_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Є події, які потребують перегляду та оновлення поточної політики планування безпеки

No: 7

Name: pl_1_odp_07

Type: string

Default: "щорічно"

Визначена частота, з якою переглядаються та оновлюються поточні процедури планування безпеки

12.2. ПЛАНИ ЗАХИСТУ ІНФОРМАЦІЇ ТА ПЕРСОНАЛЬНИХ ДАНИХ (PL-2)

а. Розробити план захисту інформації та персональних даних для інформаційної системи, який:

1. узгоджується з архітектурою підприємства організації;
 2. чітко визначає складові компоненти системи;
 3. описує оперативний контекст інформаційної системи з точки зору завдань та процесів;
 4. визначає осіб, які виконують системні ролі та обов'язки;
 5. визначає тип інформації, яка обробляється, зберігається та передається системою;
 6. надає огляд вимог безпеки та приватності інформаційної системи;
 7. описує будь які конкретні загрози системи, які викликають стурбованість організації;
 8. надає результати оцінки ризику конфіденційності для систем, в яких обробляються персональні дані;
 9. описує робоче середовище інформаційної системи та будь які залежності від систем або компонентів систем або підключень до таких систем та їх компонентів;
 10. надає огляд вимог безпеки та конфіденційності системи;
 11. визначає будь які відповідні контрольні базові рівні або накладання, якщо вони застосовуються;
 12. описує чинні або заплановані заходи щодо забезпечення безпеки та приватності, включно з обґрунтуванням рішень щодо налаштування
 13. включає виявлення ризиків для архітектури безпеки і приватності, а також проєктних рішень;
 14. включає дії, пов'язані з безпекою та конфіденційністю, які впливають на систему, виконання яких вимагає планування та координацію з [Призначення: визначені організацією окремі особи або групи];
 15. розглядається та затверджується уповноваженою посадовою особою або призначеним представником до початку реалізації плану.
- b. Поширити копії планів захисту інформації та персональних даних і повідомляти про подальші зміни планів серед [Призначення: визначеного організацією персоналу або ролей].
- c. Переглядати плани захисту інформації та персональних даних [Призначення: з визначеною організацією частотою].
- d. Оновлювати плани захисту інформації та персональних даних для врахування змін в інформаційній системі й робочому середовищі або проблем, виявлених у ході реалізації або оцінювання заходів безпеки та приватності.
- e. забезпечити захист планів захисту інформації та персональних даних від несанкціонованого розголошення та змін.

No: 1

Name: pl_2_odp_01

Type: list

Default: ["admin", "security_officer"]

Призначені особи або групи, з якими пов'язана діяльність з безпекою та конфіденційністю, що впливає на систему, яка потребує планування та координації

No: 2

Name: pl_2_odp_02

Type: list

Default: ["admin", "security_officer"]

Призначено персонал або ролі для отримання розповсюджуваних копій планів захисту інформації та конфіденційності системи

No: 3

Name: pl_2_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначено періодичність перегляду інформації та конфіденційності системи; планів захисту PL-02a.01[01] розроблено план захисту інформації, архітектурі підприємства організації; який відповідає PL-02a.01[02] розроблено план конфіденційності для системи, відповідає архітектурі підприємства організації; який PL-02a.02[01] розроблено план захисту інформації, який чітко визначає складові компоненти системи; PL-02a.02[02] розроблено для системи план забезпечення конфіденційності, який чітко визначає складові компоненти системи; PL-02a.03[01] розроблено план захисту інформації системи, який описує операційний контекст системи з точки зору місії та бізнеспроцесів; PL-02a.03[02] розроблено для системи план забезпечення конфіденційності, який описує операційний контекст системи з точки зору місії та бізнес-процесів; PL-02a.04[01] розроблено план захисту інформації, який визначає осіб, що виконують системні ролі та обов'язки; PL-02a.04[02] розроблено для системи план забезпечення конфіденційності, який визначає осіб, що виконують ролі та обов'язки в системі; PL-02a.05[01] розроблено план захисту інформації, який визначає типи інформації, що обробляється, зберігається та передається системою; PL-02a.05[02] розроблено план конфіденційності для системи, який визначає типи інформації, що обробляється, зберігається та передається системою; PL-02a.06[01] розроблено план захисту інформації, який передбачає категоризацію безпеки системи, включаючи відповідне обґрунтування; PL-02a.06[02] розроблено для системи план забезпечення конфіденційності, який передбачає категоризацію системи за рівнем безпеки, включаючи обґрунтування; PL-02a.07[01] розроблено план захисту інформації, який описує будь-які конкретні загрози для системи, що викликають потенційні ризики для організації; PL-02a.07[02] розроблено план конфіденційності для системи, який описує будь-які конкретні загрози для системи, що викликають потенційні ризики для організації; PL-02a.08[01] розроблено план захисту інформації, який містить результати оцінки ризиків конфіденційності для систем, що обробляють інформацію, яка ідентифікує особу; PL-02a.08[02] розроблено для системи план забезпечення конфіденційності, який містить результати оцінки ризиків конфіденційності для систем, що обробляють інформацію, яка ідентифікує особу; PL-02a.09[01] розроблено план захисту інформації, який описує операційне середовище системи та будь-які залежності або зв'язки з іншими системами чи компонентами системи; PL-02a.09[02] розроблено для системи план забезпечення конфіденційності, який описує робоче середовище системи та будь-які залежності або зв'язки з іншими системами чи компонентами системи; PL-02a.10[01] розроблено план захисту інформації, який містить огляд вимог до безпеки системи; PL-02a.10[02] розроблено для системи план забезпечення конфіденційності, який містить огляд вимог до конфіденційності системи; PL-02a.11[01] розроблено план захисту інформації, який визначає будь-які відповідні базові рівні контролю або обмеження, якщо такі є; PL-02a.11[02] розроблено для системи план забезпечення конфіденційності, який визначає будь-які відповідні базові рівні контролю або обмеження, якщо такі є; PL-02a.12[01] розроблено план захисту інформації, який описує наявні або заплановані засоби контролю для виконання вимог безпеки, включаючи обґрунтування будь-яких рішень щодо адаптації; PL-02a.12[02] розроблено для системи план забезпечення конфіденційності, який описує наявні або заплановані засоби контролю для виконання вимог щодо конфіденційності, включаючи обґрунтування будь-яких рішень, пов'язаних з адаптацією; PL-02a.13[01] розроблено план захисту інформації, який включає визначення ризиків для архітектури безпеки та проектних рішень; PL-02a.13[02] розроблено план забезпечення конфіденційності для системи, який включає визначення ризиків для архітектури конфіденційності та проектних рішень; PL-02a.14[01] розроблено захисту інформації, який включає діяльність, пов'язану з безпекою, що впливає на систему і потребує планування та координації з окремими особами або групами; PL-02a.14[02] розроблено для системи план забезпечення конфіденційності, який включає діяльність, пов'язану з конфіденційністю, що впливає на систему і потребує планування та координації з окремими особами або групами; PL-02a.15[01] розроблено план захисту інформації, який розглядається та затверджується уповноваженою посадовою особою або призначеним представником до початку реалізації плану; PL-02a.15[02] розроблено план забезпечення конфіденційності для системи, який перевіряється та затверджується уповноваженою посадовою особою або призначеним представником перед впровадженням плану. PL-02b.[01] розповсюджуються копії персонал або ролі>; PL-02b.[02] повідомляються наступні зміни до планів персонал або ролі; PL-02c. переглядаються плани частота; планів серед <PL-02_ODP[02] PL-02d.[01] оновлюються плани відповідно до змін у системі та середовищі діяльності; PL-02d.[02] оновлюються плани для вирішення проблем, виявлених під час реалізації плану; PL-02d.[03] оновлюються плани для вирішення проблем, виявлених під час контрольних оцінок; PL-02e.[01] захищені плани від несанкціонованого розголошення; PL-02e.[02] захищені плани від несанкціонованої модифікації

12.2.1. КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ДИВЕРСИФІКАЦІЯ ПОСТАЧАЛЬНИКІВ (PL-2(1))

No: 1
Name: pl_2_1_01
Type: string
Default: nil

КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ДИВЕРСИФІКАЦІЯ ПОСТАЧАЛЬНИКІВ [Вилучено: включено до PL-7]

12.2.2. ПЛАНИ ЗАХИСТУ ІНФОРМАЦІЇ ФУНКЦІОНАЛЬНА АРХІТЕКТУРА (PL-2(2))

No: 1
Name: pl_2_2_01
Type: string
Default: nil

ПЛАНИ ЗАХИСТУ ІНФОРМАЦІЇ ФУНКЦІОНАЛЬНА АРХІТЕКТУРА [Вилучено: включено до PL-8]

12.3. ОНОВЛЕННЯ ПЛАНІВ ЗАХИСТУ ІНФОРМАЦІЇ ТА ПЕРСОНАЛЬНИХ ДАНИХ (PL-3)

No: 1
Name: pl_3_01
Type: list
Default: ["admin", "security_officer"]

ОНОВЛЕННЯ ПЛАНІВ ЗАХИСТУ ІНФОРМАЦІЇ ТА ПЕРСОНАЛЬНИХ ДАНИХ [Вилучено: включено до PL-2]

12.4. ПРАВИЛА ПОВЕДІНКИ (PL-4)

- a. Створити та надати особам, що потребують доступу до інформаційної системи, правила, які описують їхні обов'язки й очікувану поведінку щодо інформації та використання інформаційної системи, безпеки та приватності.
- b. Отримати документальне підтвердження від таких осіб про те, що вони прочитали, зрозуміли та погодилися дотримуватися правил поведінки, перш ніж дозволяти доступ до інформації та інформаційної системи.
- c. Переглядати й оновлювати правила поведінки [Призначення: з визначеною організацією частотою].
- d. Вимагати від осіб, які підписали попередню версію правил поведінки, перечитати та повторно підписати правила [Вибір (один або декілька): [Призначення: з визначеною організацією частотою]; коли правила переглядаються чи оновлюються].

No: 1
Name: pl_4_odp_01
Type: string
Default: "щорічно"

Визначено періодичність перегляду та оновлення правил поведінки

No: 2

Name: pl_4_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРА: {частота; коли правила переглядаються або оновлюються}

No: 3

Name: pl_4_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначена періодичність перегляду та повторного підтвердження правил поведінки (якщо вибрано); PL-04a.[01] встановлені правила, які описують обов'язки та очікувану поведінку щодо використання інформації та системи, безпеки та конфіденційності для осіб, яким потрібен доступ до системи; PL-04a.[02] надаються правила, які описують обов'язки та очікувану поведінку щодо використання інформації та системи, безпеки та конфіденційності, особам, які отримують доступ до системи; PL-04b. отримано перед наданням доступу до інформації та системи задокументоване підтвердження від таких осіб про те, що вони прочитали, зрозуміли та згодні дотримуватися правил поведінки; PL-04c. переглядаються та оновлюються правила поведінки частота; PL-04d. потрібно особам, які визнали попередню версію правил поведінки, прочитати та повторно визнати ЗНАЧЕННЯ ВИБРАНОВОГО ПАРАМЕТРА(ів)

12.4.1. ОБМЕЖЕННЯ НА СОЦІАЛЬНІ МЕДІА ТА МЕРЕЖУ (PL-4(1))

No: 1

Name: pl_4_1_a

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Включають правила поведінки обмеження на використання соціальних медіа, соціальних мереж та зовнішніх сайтів/додатків

No: 2

Name: pl_4_1_b

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Включають правила поведінки обмеження на розміщення інформації про організацію на публічних веб-сайтах

No: 3

Name: pl_4_1_c

Type: list

Default: ["admin", "security_officer"]

Включають правила поведінки обмеження на використання наданих організацією ідентифікаторів (наприклад, адрес електронної пошти) та секретів автентифікації (наприклад, паролів) для створення облікових записів на зовнішніх сайтах/додатках. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

12.5. ОЦІНКА ВПЛИВУ НА ПРИВАТНІСТЬ (PL-5)

No: 1

Name: pl_5_01

Type: string

Default: nil

ОЦІНКА ВПЛИВУ НА ПРИВАТНІСТЬ [Вилучено: включено до RA-8]

12.6. ПЛАНУВАННЯ ДІЯЛЬНОСТІ, ПОВ'ЯЗАНОЇ З БЕЗПЕКОЮ (PL-6)

No: 1

Name: pl_6_01

Type: string

Default: nil

ПЛАНУВАННЯ ДІЯЛЬНОСТІ, ПОВ'ЯЗАНОЇ З БЕЗПЕКОЮ [Вилучено: включено до PL-2]

12.7. КОНЦЕПЦІЯ ЕКСПЛУАТАЦІЇ (PL-7)

- a. Розробити концепцію експлуатації інформаційної системи, яка описує, як організація має намір керувати системою з погляду забезпечення безпеки та приватності інформації.
- b. Переглядати й оновлювати концепцію експлуатації [Призначення: з визначеною організацією частотою].

No: 1

Name: pl_7_odp

Type: string

Default: "щорічно"

Визначена періодичність перегляду концепцію експлуатації системи; та оновлення PL-07a. розроблено концепцію експлуатації системи, що описує, як організація має намір експлуатувати систему з точки зору інформаційної безпеки та конфіденційності; PL-07b. переглядається та оновлюється концепція експлуатації системи частота

12.8. АРХІТЕКТУРА БЕЗПЕКИ ТА ПРИВАТНОСТІ (PL-8)

- a.
- b. Розробити архітектуру безпеки та приватності для інформаційної системи, яка:
 - 1. характеризує методологію, вимоги та підходи, які слід вживати для забезпечення конфіденційності, цілісності та доступності інформації, що циркулює в системі;
 - 2. характеризує методологію, вимоги та підхід до обробки персональних даних для мінімізації ризику їх втрати;
 - 3. характеризує, як архітектури безпеки та приватності інтегруються в архітектуру підприємства;
 - 4. характеризує будь-які припущення, що пов'язані з безпекою та приватністю, щодо зовнішніх служб і залежності від них. Переглядати й оновлювати архітектуру безпеки та приватності [Призначення: з визначеною організацією частотою], щоб відображати оновлення в архітектурі підприємства.
- c. Відображати заплановані зміни архітектури плану безпеки та приватності, концепції експлуатації інформаційної системи, аналізу критичності, організаційних заходах, постачань та закупівель.

No: 1
 Name: pl_8_01
 Type: string
 Default: nil

АРХІТЕКТУРА БЕЗПЕКИ ТА ПРИВАТНОСТІ МЕТА ОЦІНКИ: Визначити, чи:

No: 2
 Name: pl_8_odp
 Type: list
 Default: ["admin", "security_officer"]

Потрібно переглядати та оновлювати частоту, відображати зміни в архітектурі підприємства; PL-08a.01 описує архітектура безпеки системи вимоги та підходи до захисту конфіденційності, цілісності та доступності організаційної інформації; PL-08a.02 описує архітектура конфіденційності вимоги та підходи до обробки персональних даних з метою мінімізації ризиків для приватного життя людей; PL-08a.03[01] описує архітектура безпеки системи те, як вона інтегрована в архітектуру підприємства та підтримує її; PL-08a.03[02] описує архітектура конфіденційності системи те, як вона інтегрована в архітектуру підприємства та підтримує її; PL-08a.04[01] описує архітектура безпеки системи будь-які припущення та залежності від зовнішніх систем та сервісів; PL-08a.04[02] описує архітектура конфіденційності системи будь-які припущення та залежності від зовнішніх систем і сервісів; PL-08b. переглядаються та оновлюються зміни в архітектурі підприємства частота для відображення змін в архітектурі підприємства; PL-08c.[01] заплановані зміни в архітектурі відображені в плані безпеки; PL-08c.[02] відображені заплановані конфіденційності; PL-08c.[03] заплановані зміни архітектури відображені діяльності концепції експлуатації системи; PL-08c.[04] заплановані зміни критичності; PL-08c.[05] відображені заплановані зміни архітектури в організаційних процедурах; PL-08c.[06] заплановані зміни в архітектурі відображаються на закупівлях та придбанні. в зміни архітектури в архітектурі в щоб плані в Концепції відображені в аналізі

12.8.1. «ГЛИБОКА ОБОРОНА» (PL-8(1))

No: 1
 Name: pl_8_1_a_01
 Type: string
 Default: nil

Архітектура безпеки системи розроблена з використанням підходу «глибокої оборони», який розподіляє елементи керування за місцями та архітектурними рівнями

No: 2
 Name: pl_8_1_a_02
 Type: string
 Default: nil

Архітектура конфіденційності системи розроблена з використанням підходу глибокого захисту, який розподіляє елементи керування за місцями та архітектурними рівнями

No: 3
 Name: pl_8_1_b_01
 Type: string
 Default: "автоматизований засіб моніторингу"

Архітектура безпеки системи розроблена з використанням підходу «глибокої оборони», який гарантує, що виділені засоби контролю працюють скоординовано і взаємно підсилюють один одного

No: 4
 Name: pl_8_1_b_02
 Type: string
 Default: "автоматизований засіб моніторингу"

Архітектура конфіденційності системи розроблена з використанням підходу «глибокої оборони», який гарантує, що виділені засоби контролю працюють скоординовано і взаємно підкріплюють один одного

12.8.2. РІЗНОМАНІТНІСТЬ ПОСТАЧАЛЬНИКІВ (PL-8(2))

No: 1

Name: pl_8_2_01

Type: string

Default: nil

Потрібно отримувати елементи керування, призначені для локацій та архітектурних рівнів, від різних постачальників

12.9. ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ (PL-9)

Централізовано управляти [Призначення: визначеними організацією організаційними заходами захисту та пов'язаними з ними процесами].

No: 1

Name: pl_9_01

Type: string

Default: nil

Здійснюється централізоване управління контролюями та пов'язаними з ними процесами

No: 2

Name: pl_9_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначені засоби контролю безпеки та конфіденційності і пов'язані з ними процеси, якими слід централізовано керувати

12.10. ВИБІР БАЗОВОГО ПРОФІЛЮ БЕЗПЕКИ (PL-10)

Вибрати базовий профіль безпеки для інформаційної системи.

No: 1

Name: pl_10_01

Type: string

Default: nil

Вибрано базовий профіль безпеки для системи

12.11. НАЛАШТУВАННЯ БАЗОВОГО ПРОФІЛЮ БЕЗПЕКИ (PL-11)

а. Розробити та поширити на організаційному рівні план програми (концепцію) з інформаційної безпеки, яка:

1. містить огляд вимог до програми (концепції) безпеки й описує заходи управління програмою

інформаційної безпеки та загальних заходів безпеки, які використовуються або плануються для виконання цих вимог;

2. містить визначення та розподіл ролей, обов'язків, відповідальності керівництва, заходи з координації діяльності організації і забезпечення відповідності вимогам законодавства та іншим нормативним документам;

3. відображає координацію між організаційними елементами, що відповідають за інформаційну безпеку;

4. затверджена вищою посадовою особою, що відповідає та підзвітна за управління ризиками, пов'язаними з організаційними операціями (включно з завданнями (місією), функціями, іміджем і репутацією організації), організаційні активи, фізичних осіб, інші організації та державу.

b. Переглядати та оновлювати загальноорганізаційний план програми (концепцію) інформаційної безпеки [Призначення: з визначеною організацією частотою] та у випадку [Призначення: визначені організацією випадки].

c. Забезпечити захист плану програми (концепції) інформаційної безпеки від несанкціонованого розкриття та зміни.

No: 1

Name: pl_11_01

Type: list

Default: ["login", "logout", "failed_attempt"]

Налаштовуватиметься вибраний базовий профіль застосовуючи вказані дії для налаштування. безпеки,

13. PS

Клас заходів захисту PS — КАДРОВА БЕЗПЕКА

Цей клас встановлює вимоги до перевірки, надання повноважень та звільнення персоналу з метою мінімізації ризиків інсайдерських загроз.

Перелік заходів захисту: Політика та процедури кадрової безпеки (PS-1); Визначення посадового ризику (PS-2); Перевірка персоналу (PS-3); Звільнення персоналу (PS-4); Переведення персоналу (PS-5); Угоди про доступ (PS-6); Інформація, що вимагає спеціального захисту (PS-6(1)); Безпека зовнішнього персоналу (PS-7); Кадрові санкції (PS-8); Опис позицій (PS-9).

13.1. Політика та процедури кадрової безпеки (PS-1)

No: 1

Name: ps_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюється політика кадрової безпеки

No: 2

Name: ps_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури кадрової безпеки

No: 3

Name: ps_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: ps_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами кадрової безпеки

No: 5

Name: ps_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначена періодичність перегляду та оновлення поточної політики кадрової безпеки

No: 6

Name: ps_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Є події, які вимагають перегляду та оновлення поточної політики кадрової безпеки

No: 7

Name: ps_1_odp_07

Type: string

Default: "щорічно"

Визначено періодичність перегляду та оновлення поточних процедур кадрової безпеки

13.2. Визначення посадового ризику (PS-2)

No: 1

Name: ps_2_odp

Type: list

Default: ["admin", "security_officer"]

Визначено періодичність перегляду ідентифікаторів посадових ризиків; та оновлення PS-02a. всім посадам в організації присвоєно ідентифікатор ризику; PS-02b. вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}; PS-02c. встановлені критерії відбору для осіб, які обіймають посади в організації

13.3. Перевірка персоналу (PS-3)

No: 1

Name: ps_3_odp_01

Type: list

Default: []

Визначені умови, що вимагають повторної перевірки осіб

No: 2

Name: ps_3_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначена частота повторної перевірки осіб, для яких це показано; PS-03a. проходять особи перевірку перед тим, як надати їм доступ до системи; PS-03b.[01] проходять особи повторну перевірку відповідно до умови, що вимагають повторної перевірки; PS-03b.[02] проводиться повторна перевірка у випадках, коли це зазначено, частота

13.4. Звільнення персоналу (PS-4)

No: 1

Name: ps_4_odp_01

Type: integer

Default: 30

Визначено період часу, протягом якого забороняється доступ до системи

No: 2

Name: ps_4_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначені теми інформаційної безпеки для обговорення під час проведення співбесід; PS-04a. при звільненні працівника доступ до системи вимикається протягом часового періоду; PS-04b. припиняють дію або анулюють будь-які автентифікатори та облікові дані після припинення трудових відносин з окремими особами; PS-04c. проводяться при звільненні окремих працівників співбесіди, які включають обговорення питань інформаційної безпеки; PS-04d. отримується після звільнення особи все майно, пов'язане з безпекою організаційної системи; PS-04e. зберігається доступ до організаційної інформації та систем, які раніше перебували під контролем особи, що звільняється, після припинення нею трудових відносин

13.5. Переведення персоналу (PS-5)

No: 1

Name: ps_5_odp_01

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначені дії, які мають бути ініційовані після переведення або перепризначення

No: 2

Name: ps_5_odp_02

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено період часу, протягом якого мають бути здійснені дії з переведення або перепризначення після переведення або перепризначення

No: 3

Name: ps_5_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, про які необхідно повідомляти, коли осіб призначають на інші посади або переводять на інші посади в організації

No: 4

Name: ps_5_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено період часу, протягом якого необхідно повідомляти визначений організацією персонал або ролі, коли осіб перепризначають або переводять на інші посади в межах організації; PS-05a. переглядаються та підтверджуються поточні потреби в логічних та фізичних дозволах на доступ до систем та об'єктів при перепризначенні або переведенні осіб на інші посади в організації; PS-05b. були ініційовані дії з переведення або перепризначення протягом періоду часу після формальної дії з переведення; PS-05c. змінюється авторизація доступу за необхідності, щоб відповідати будь-яким змінам в оперативних потребах у зв'язку з перепризначенням або переведенням; PS-05d. було повідомлено персонал або ролі протягом часового періоду

13.6. Угоди про доступ (PS-6)

No: 1

Name: ps_6_odp_01

Type: string

Default: "щорічно"

Визначено періодичність перегляду та оновлення угод про доступ

No: 2

Name: ps_6_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначена періодичність перепідписання угод про доступ для збереження доступу до інформації організації; PS-06a. розроблені та задокументовані угоди про доступ до систем організації; PS-06b. переглядаються та оновлюються угоди про доступ частота; PS-06c.01 підписують особи, яким потрібен доступ до інформації та систем організації, відповідні угоди про доступ до того, як їм буде надано доступ; PS-06c.02 перепідписують особи, яким потрібен доступ до інформації та систем організації, угоди про доступ для збереження доступу до систем організації, коли угоди про доступ були оновлені чи як частота

13.6.1. ІНФОРМАЦІЯ, ЩО ВИМАГАЄ СПЕЦІАЛЬНОГО ЗАХИСТУ (PS-6(1))

No: 1

Name: ps_6_1_01

Type: string

Default: nil

УГОДИ ПРО ДОСТУП - ІНФОРМАЦІЯ, ЩО ВИМАГАЄ СПЕЦІАЛЬНОГО ЗАХИСТУ [Вилучено: включено до PS-3] PS-6(2) УГОДИ ПРО ДОСТУП - ІНФОРМАЦІЯ З ОБМЕЖЕНИМ ДОСТУПОМ, ЩО ВИМАГАЄ СПЕЦІАЛЬНОГО ЗАХИСТУ

13.7. Безпека зовнішнього персоналу (PS-7)

No: 1

Name: ps_7_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які мають бути повідомлені про будь-які кадрові переведення або звільнення зовнішнього персоналу, який володіє організаційними повноваженнями та/або бейджами, або має системні привілеї

No: 2

Name: ps_7_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено період часу, протягом якого сторонні провайдери повинні повідомляти визначений організацією персонал або ролі про будь-які кадрові переведення або звільнення зовнішнього персоналу, який володіє організаційними повноваженнями та/або бейджами або має системні привілеї; PS-07a. встановлені вимоги до безпеки персоналу, включаючи ролі та обов'язки зовнішніх постачальників послуг у сфері безпеки; PS-07b. зобов'язані зовнішні провайдери дотримуватися політики та процедур кадрової безпеки, встановлених організацією; PS-07c. задокументовані вимоги до безпеки персоналу; PS-07d. зобов'язані зовнішні провайдери повідомляти персонал або ролі про будь-які кадрові переведення або звільнення зовнішнього персоналу, який володіє організаційними повноваженнями та/або бейджами або має системні привілеї протягом часового періоду; PS-07e. контролюється дотримання провайдером вимог щодо безпеки персоналу

13.8. Кадрові санкції (PS-8)

No: 1

Name: ps_8_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, про які необхідно повідомляти, коли ініціюється офіційний процес санкцій щодо працівників

13.9. ОПИС ПОЗИЦІЙ (PS-9)

No: 1

Name: ps_9_02

Type: list

Default: ["admin", "security_officer"]

Включені функції та обов'язки з безпеки в описи посадових осіб в організації; включені ролі та обов'язки щодо конфіденційності в описи посадових осіб в організації

14. RA

Клас заходів захисту RA — ОЦІНЮВАННЯ РИЗИКУ

Цей клас забезпечує систематичний підхід до виявлення, аналізу та реагування на ризики, пов'язані з обробкою інформації та функціонуванням системи.

Перелік заходів захисту: Політика та процедури оцінювання ризику (RA-1); Категоріювання безпеки (RA-2); Категоріювання другого рівня (RA-2(1)); Оцінювання ризику (RA-3); Оцінювання постачання (RA-3(1)); Використання інформації з усіх доступних джерел (RA-3(2)); Усвідомлення динамічних загроз (RA-3(3)); Прогностична кібераналітика (RA-3(4)); Оновлення оцінювання ризику (RA-4); Сканування вразливостей (RA-5); Сканування вразливостей інструментів (RA-5(1)); Оновлення за частотою, перед новим скануванням або при ідентифікації (RA-5(2)); Широта та глибина покриття (RA-5(3)); Виявна інформація (RA-5(4)); Привілейований доступ (RA-5(5)); Сканування тенденцій (RA-5(6)); Автоматизоване виявлення та сповіщення про неавторизовані компоненти (RA-5(7)); Огляд журналів аудиту за

минулі періоди (RA-5(8)); Сканування вразливостей проникнення (RA-5(9)); Заходи протидії технічній розвідці (RA-6); Реагування на ризик (RA-7); Оцінка впливу на приватність (RA-8); Аналіз критичності (RA-9); Активний пошук загроз (RA-10).

14.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ОЦІНЮВАННЯ РИЗИКУ (RA-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посадових осіб]:

1. 2. Політику оцінювання ризику, яка:

(а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance);

(b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам і керівним принципам. Процедури, що сприяють здійсненню політики оцінювання ризику та пов'язаних з ними заходів оцінювання ризику.

b. Призначити [Призначення: визначена організацією посадову особу] для управління політикою та процедурами оцінювання ризику.

с. Переглядати й оновлювати:

1. Поточну політику оцінювання організацією частотою]. ризику [Призначення: з визначеною

2. Поточні процедури оцінювання ризику [Призначення: з визначеною організацією частотою].

No: 1

Name: ra_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюється політика оцінювання ризику

No: 2

Name: ra_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури, що сприяють здійсненню політики оцінювання ризику

No: 3

Name: ra_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: ra_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначена посадова особа, відповідальна за управління політикою та процедурами оцінювання ризику

No: 5

Name: ra_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначена періодичність перегляду та оновлення поточної політики оцінювання ризику

No: 6

Name: ra_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Є події, які вимагають перегляду та оновлення поточної політики оцінювання ризику

No: 7

Name: ra_1_odp_07

Type: string

Default: "щорічно"

Визначено періодичність перегляду поточних процедур оцінювання ризику

14.2. КАТЕГОРІЮВАННЯ БЕЗПЕКИ (RA-2)

a.

b. Проводити оцінювання ризику, включно з вірогідністю й величиною шкоди від:

1. несанкціонованого доступу, використання, розголошення, руйнування, модифікації або знищення інформаційної системи, інформації, яку вона обробляє, зберігає та передає; а також будь-якої пов'язаної інформації;

2. проблем, пов'язаних з приватністю фізичних осіб, що виникають у результаті обробки персональних даних. Інтегрувати результати оцінювання ризику та рішення з управління ризиками на рівні організації та завдань/процесів з оцінюванням ризиків на рівні інформаційної системи.

c. Задокументувати результати оцінювання ризику до [Вибір: планів безпеки та приватності; звіту про оцінювання ризику; [Призначення: визначеного організацією документа]].

d. Переглядати результати оцінювання ризиків [Призначення: з визначеною організацією частотою].

e. Поширити результати оцінювання ризику серед [Призначення: визначеного організацією персоналу або посадових осіб].

f. Оновлювати оцінювання ризику [Призначення: з визначеною організацією частотою] або коли є суттєві зміни в інформаційній системі, її робочому середовищі чи інших умовах, які можуть вплинути на стан безпеки або приватність інформаційної системи.

Немає параметрів для цього контролю.

14.2.1. КАТЕГОРІЮВАННЯ ДРУГОГО РІВНЯ (RA-2(1))

No: 1

Name: ra_2_1_01

Type: string

Default: nil

Проводиться категоріювання другого рівня для інформаційних систем організації з метою отримання додаткової деталізації рівнів критичності системи

14.3. ОЦІНЮВАННЯ РИЗИКУ (RA-3)

No: 1

Name: ra_3_odp_01

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {плани безпеки та приватності; звіт про оцінювання ризику; документ}

No: 2

Name: ra_3_odp_02

Type: string

Default: nil

Визначено документ, в якому мають бути задокументовані результати оцінювання ризику (якщо вони не задокументовані в планах безпеки та приватності або в звіті про оцінювання ризику) (якщо вибрано)

No: 3

Name: ra_3_odp_03

Type: string

Default: "щорічно"

Визначено періодичність оцінювання ризику

No: 4

Name: ra_3_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких мають бути доведені результати оцінювання ризику

No: 5

Name: ra_3_odp_05

Type: list

Default: ["admin", "security_officer"]

Визначена періодичність оновлення оцінювання ризику; перегляду результатів RA-03a.01 проводиться оцінювання ризику для виявлення загроз і вразливостей у системі; RA-03a.02 проводиться оцінювання ризику для визначення ймовірності та розміру шкоди від несанкціонованого доступу, використання, розкриття, порушення, модифікації або знищення системи; інформації, яку вона обробляє, зберігає або передає; а також будь-якої пов'язаної з нею інформації; RA-03a.03 проводиться оцінювання ризику для визначення ймовірності та впливу несприятливих наслідків для фізичних осіб, що виникають у зв'язку з обробкою інформації, яка ідентифікує особу; RA-03b. інтегровані результати оцінювання ризику та рішення з управління ризиками з точки зору організації та місії або бізнес-процесів з оцінкою ризиків на системному рівні; RA-03c. результати оцінювання ризику задокументовані в ЗНАЧЕННЯ ВИБРАНОГО ПАРАМЕТРА; RA-03d. переглядаються результати 03_ODP[03] частота>; RA-03e. поширюються результати оцінювання ризику серед персоналу або ролей; RA-03f. оновлюється оцінювання ризику частота або коли відбуваються значні зміни в системі, середовищі її функціонування або інших умовах, які можуть вплинути на стан безпеки або приватності системи оцінювання ризику <RA-

14.3.1. ОЦІНЮВАННЯ ПОСТАЧАВАННЯ (RA-3(1))

No: 1

Name: ra_3_1_a

Type: string

Default: nil

Оцінювання ризику ланцюга постачання, пов'язані з системами, системними компонентами та системними послугами

No: 2

Name: ra_3_1_b

Type: string

Default: nil

Потрібно оновлювати оцінювання ризику ланцюга постачання, коли відбуваються значні зміни у відповідному ланцюгу постачання, або коли зміни в системі, середовищі функціонування чи інших умовах можуть вимагати

змін у ланцюгу постачання

14.3.2. ВИКОРИСТАННЯ ІНФОРМАЦІЇ З УСІХ ДОСТУПНИХ ДЖЕРЕЛ (RA-3(2))

No: 1

Name: ra_3_2_01

Type: string

Default: nil

Використовується інформація з усіх доступних джерел для аналізу ризиків

14.3.3. УСВІДОМЛЕННЯ ДИНАМІЧНИХ ЗАГРОЗ (RA-3(3))

No: 1

Name: ra_3_3_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначається поточне середовище кіберзагроз на постійній основі за допомогою засоби

No: 2

Name: ra_3_3_odp

Type: string

Default: "автоматизований засіб моніторингу"

Є засоби для постійного визначення поточного стану кіберзагроз

14.3.4. ПРОГНОСТИЧНА КІБЕРАНАЛІТИКА (RA-3(4))

No: 1

Name: ra_3_4_01

Type: string

Default: nil

Використовуються розширені можливості автоматизації для прогнозування та виявлення ризику для систем або компонентів системи

No: 2

Name: ra_3_4_02

Type: string

Default: nil

Застосовуються розширені аналітичні можливості для прогнозування та виявлення ризику для систем або компонентів системи. аналітики

14.4. ОНОВЛЕННЯ ОЦІНЮВАННЯ РИЗИКУ (RA-4)

No: 1

Name: ra_4_01

Type: string

Default: nil

ОНОВЛЕННЯ ОЦІНЮВАННЯ РИЗИКУ [Вилучено: включено до RA-3]

14.5. СКАНУВАННЯ ВРАЗЛИВОСТЕЙ (RA-5)

Використовувати заходи ПДТР за [Призначення: визначені організацією місця] [Вибір (один або кілька): [Призначення: з визначеною організацією частотою]; [Призначення: за визначеними організацією подіями або показниками]].

No: 1

Name: ra_5_odp_01

Type: string

Default: nil

Визначена необхідність моніторингу систем та розміщених застосунків на наявність вразливостей

No: 2

Name: ra_5_odp_02

Type: string

Default: "щорічно"

Визначена періодичність перевірки систем та розміщених на них застосунків на наявність вразливостей

No: 3

Name: ra_5_odp_03

Type: integer

Default: 30

Визначено час реагування на усунення законних вразливостей відповідно до організаційної оцінки ризику

No: 4

Name: ra_5_odp_04

Type: list

Default: ["admin", "security_officer"]

Потрібно ділитися інформацією, отриманою в процесі сканування вразливостей та оцінок контролю, з персоналом або ролями, з якими потрібно ділитися; RA-05a.[01] здійснюється моніторинг систем та розміщених застосунків на наявність вразливостей частота та/або випадковість відповідно до визначеного організацією процесу, а також коли виявляються та повідомляються нові вразливості, що потенційно можуть вплинути на систему; RA-05a.[02] перевіряються системи та розміщені застосунки на наявність вразливостей частота та/або випадковим чином відповідно до визначеного організацією процесу, а також коли виявляються та повідомляються нові вразливості, що потенційно можуть вплинути на систему; RA-05b. застосовуються інструменти та методи моніторингу вразливостей для забезпечення сумісності між інструментами; RA-05b.01 застосовуються інструменти та методи моніторингу вразливостей для автоматизації частини процесу управління вразливостями, використовуючи стандарти для переліку платформ, недоліків програмного забезпечення та неправильних конфігурацій; RA-05b.02 застосовуються інструменти та методи моніторингу вразливостей для полегшення взаємодії між інструментами та автоматизації частини процесу управління вразливостями шляхом використання стандартів для формування контрольних списків та процедур тестування; RA-05b.03 застосовуються інструменти та методи моніторингу вразливостей для полегшення взаємодії між інструментами та автоматизації частин процесу управління вразливостями шляхом використання стандартів для вимірювання впливу вразливостей; RA-05c. аналізуються звіти про сканування вразливостей та результати моніторингу вразливостей; RA-05d. усуваються легітимні вразливості час реагування відповідно до організаційної оцінки ризиків; RA-05e. надається інформація, отримана в процесі моніторингу вразливостей та оцінки контролю, персонал або ролі, щоб допомогти усунути подібні вразливості в інших системах; RA-05f. використовуються інструменти моніторингу вразливостей, які передбачають можливість швидкого оновлення вразливостей, що підлягають скануванню

14.5.1. СКАНУВАННЯ ВРАЗЛИВОСТЕЙ ІНСТРУМЕНТІВ (RA-5(1))

No: 1
Name: ra_5_1_01
Type: string
Default: nil

СКАНУВАННЯ ВРАЗЛИВОСТЕЙ ІНСТРУМЕНТІВ [Вилучено: включено до RA-5]

14.5.2. ОНОВЛЕННЯ ЗА ЧАСТОТОЮ, ПЕРЕД НОВИМ СКАНУВАННЯМ АБО ПРИ ІДЕНТИФІКАЦІЇ (RA-5(2))

No: 1
Name: ra_5_2_01
Type: integer
Default: 30

Визначено час реагування на усунення законних вразливостей відповідно до організаційної оцінки ризику

14.5.3. ШИРОТА ТА ГЛИБИНА ПОКРИТТЯ (RA-5(3))

No: 1
Name: ra_5_3_01
Type: string
Default: nil

Визначено ширину вразливостей, та глибину охоплення сканування

14.5.4. ВИЯВНА ІНФОРМАЦІЯ (RA-5(4))

No: 1
Name: ra_5_4_01
Type: list
Default: ["login", "logout", "failed_attempt"]

Є інформація про систему відкритою; RA-05(04)[02] вживаються коригувальні дії, коли інформація про систему підтверджується як така, що може бути виявлена

No: 2
Name: ra_5_4_odp
Type: list
Default: ["login", "logout", "failed_attempt"]

Визначені коригувальні дії, які необхідно вжити, якщо інформація про систему буде виявлена

14.5.5. ПРИВІЛЕЙОВАНИЙ ДОСТУП (RA-5(5))

No: 1
Name: ra_5_5_01
Type: string
Default: nil

Реалізовано авторизацію привілейованого доступу до компоненти системи для діяльності зі сканування вразливостей

14.5.6. СКАНУВАННЯ ТЕНДЕНЦІЙ (RA-5(6))

No: 1

Name: ra_5_6_01

Type: string

Default: "автоматизований засіб моніторингу"

Порівнюються результати багаторазового сканування вразливостей за допомогою автоматизовані механізми

No: 2

Name: ra_5_6_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначені автоматизовані механізми для порівняння результатів багаторазового сканування вразливостей

14.5.7. АВТОМАТИЗОВАНЕ ВИЯВЛЕННЯ ТА СПОВІЩЕННЯ ПРО НЕАВТОРИЗОВАНІ КОМПОНЕНТИ (RA-5(7))

No: 1

Name: ra_5_7_01

Type: string

Default: nil

СКАНУВАННЯ ВРАЗЛИВОСТЕЙ - АВТОМАТИЗОВАНЕ ВИЯВЛЕННЯ ТА СПОВІЩЕННЯ ПРО НЕАВТОРИЗОВАНІ КОМПОНЕНТИ [Вилучено: включено до СМ-8]

14.5.8. ОГЛЯД ЖУРНАЛІВ АУДИТУ ЗА МИНУЛІ ПЕРІОДИ (RA-5(8))

Немає параметрів для цього контролю.

14.5.9. СКАНУВАННЯ ВРАЗЛИВОСТЕЙ ПРОНИКНЕННЯ (RA-5(9))

No: 1

Name: ra_5_9_01

Type: string

Default: nil

СКАНУВАННЯ ВРАЗЛИВОСТЕЙ ПРОНИКНЕННЯ [Вилучено: включено до СА-8] RA5(10) СКАНУВАННЯ ВРАЗЛИВОСТЕЙ - ЗІСТАВЛЕННЯ ІНФОРМАЦІЇ ПРО СКАНУВАННЯ - ТЕСТУВАННЯ ТА АНАЛІЗ

14.6. ЗАХОДИ ПРОТИДІЇ ТЕХНІЧНІЙ РОЗВІДЦІ (RA-6)

No: 1

Name: ra_6_odp_01

Type: string

Default: nil

Визначені місця для використання заходів ПДТР

No: 2

Name: ra_6_odp_02

Type: list

Default: ["login", "logout", "failed_attempt"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {частота; коли події або показники}

No: 3

Name: ra_6_odp_03

Type: integer

Default: 30

Визначено частоту, з якою слід проводити заходи ПДТР (якщо обрано)

No: 4

Name: ra_6_odp_04

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначені події або показники, які, у разі їх виникнення, спричиняють проведення заходів ПДТР (якщо вони були обрані)

14.7. РЕАГУВАННЯ НА РИЗИК (RA-7)

Реагувати на результати оцінювання, моніторингу й аудиту безпеки та приватності.

No: 1

Name: ra_7_01

Type: string

Default: nil

Вживаються заходи реагування на результати оцінок безпеки відповідно до організаційної толерантності до ризиків

No: 2

Name: ra_7_02

Type: string

Default: nil

Вживаються заходи реагування на результати оцінювання приватності відповідно до організаційної толерантності до ризиків

No: 3

Name: ra_7_03

Type: string

Default: nil

Вживаються заходи реагування на результати моніторингу відповідно до організаційної толерантності до ризиків

No: 4

Name: ra_7_04

Type: string

Default: nil

Вживаються заходи реагування на висновки аудиту відповідно до організаційної толерантності до ризиків

14.8. ОЦІНКА ВПЛИВУ НА ПРИВАТНІСТЬ (RA-8)

Проводити оцінювання впливу на приватність інформаційних систем, програм або інших заходів, які становлять ризик приватності перед тим, як:

- a. розробити або закупити інформаційні технології, які збирають, підтримують чи поширюють критичну інформацію;
- b. ініціювати створення нових архівів інформації, яка:
 1. буде зібрана, збережена чи розповсюджена за допомогою інформаційних технологій;
 2. містить персональні дані, які дозволяють встановити фізичне або онлайн-з'єднання з конкретною особою.

Немає параметрів для цього контролю.

14.9. АНАЛІЗ КРИТИЧНОСТІ (RA-9)

Визначити критичні компоненти інформаційної системи та функції, виконавши аналіз критичності для [Призначення: визначених організацією систем, компонентів системи або послуг для системи] в [Призначення: визначенні організацією точки ухвалення рішень у життєвому циклі розробки системи].

No: 1

Name: ra_9_01

Type: string

Default: nil

Визначені критичні компоненти та функції системи шляхом проведення аналізу критичності для систем, системних компонентів або системних служб в точках прийняття рішень в життєвому циклі розробки системи

No: 2

Name: ra_9_odp_01

Type: string

Default: nil

Визначені системи, компоненти системи або системні сервіси, що підлягають аналізу на предмет критичності

No: 3

Name: ra_9_odp_02

Type: string

Default: nil

Визначені точки прийняття рішень в життєвому циклі розробки системи, коли необхідно проводити аналіз критичності

14.10. АКТИВНИЙ ПОШУК ЗАГРОЗ (RA-10)

a. Створити та підтримувати можливості активного пошуку кіберзагроз:

1. пошук індикаторів компрометації в системах організації;
 2. виявлення, відстеження та знищення загроз, які можуть обходити існуючі засоби контролю безпеки.
- b. використовуйте можливості активного пошуку загроз [Призначення: частота, визначена організацією].

No: 1

Name: ra_10_odp

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначена частота, з якою можливість виявлення загроз; слід використовувати RA-10a.01 створена та підтримується спроможність протидії кіберзагрозам для пошуку індикаторів компрометації в організаційних системах; RA-10a.02 створена та підтримується спроможність виявляти, відслідковувати та знешкоджувати кіберзагрози, які не піддаються існуючому контролю; RA-10b. використовується функція відстеження загроз частота

15. SA

Клас заходів захисту SA — ПРИДБАННЯ СИСТЕМИ ТА ПОСЛУГ

Цей клас зосереджується на інтеграції вимог безпеки на всіх етапах життєвого циклу розробки та закупівлі ІТ-продуктів чи послуг.

Перелік заходів захисту: Політики та процедури придбання систем та послуг (SA-1); Розподіл ресурсів (SA-2); Життєвий цикл розробки системи (SA-3); Життєвий цикл розробки середовищем розробки (SA-3(1)); Життєвий цикл реальних даних (SA-3(2)); Життєвий цикл технологій (SA-3(3)); Процес закупівель (SA-4); Функціональні властивості заходів (SA-4(1)); Розробка та впровадження інформації для заходів (SA-4(2)); Процес закупівель розробки (SA-4(3)); Віднесення компонентів до систем (SA-4(4)); Конфігурації системи, компонента та системної служби (SA-4(5)); Процес закупівель інформації (SA-4(6)); Затверджені профілі захищеності (SA-4(7)); План безперервного моніторингу заходів безпеки (SA-4(8)); Функції, послуги, що використовуються (SA-4(9)); Системна документація (SA-5); Функціональні властивості заходів безпеки (SA-5(1)); Зовнішні системні інтерфейси, (SA-5(2)); АРХІТЕКТУРА (ПРОЄКТ) ВИСОКОГО РІВНЯ (SA-5(3)); АРХІТЕКТУРА (ПРОЄКТ) НИЗЬКОГО РІВНЯ (SA-5(4)); Вихідний код (SA-5(5)); Обмеження щодо використання забезпечення (SA-6); Встановлене користувачем програмне забезпечення (SA-7); Безпека та приватність принципів інжинірингу (SA-8); Чітка абстракція (SA-8(1)); Безпека та приватність принципів найменш поширений механізм (SA-8(2)); Безпека та приватність принципів модульність і багаторівневості (SA-8(3)); Безпека та приватність принципів частково впорядковані залежності (SA-8(4)); Безпека та приватність принципів ефективний опосередкований доступ (SA-8(5)); Безпека та приватність мінімізований обмін (SA-8(6)); Знижена складність (SA-8(7)); Безпека та приватність принципів еволюція безпеки в системі (SA-8(8)); Довірені компоненти системи (SA-8(9)); Реалізують принцип ієрархічної довіри в дизайні безпеки (SA-8(10)); Реалізують принцип проектування безпеки зворотного порогу модифікації (SA-8(11)); Реалізують принцип побудови ієрархічного захисту (SA-8(12)); Реалізують принцип проектування безпеки з мінімізацією елементів безпеки (SA-8(13)); Реалізують принцип побудови безпеки за принципом найменших привілеїв (SA-8(14)); Реалізують принцип проектування безпеки попереднього дозволу (SA-8(15)); Реалізують принцип проектування безпеки самодостатньої надійності (SA-8(16)); Реалізують принцип проектування безпеки захищеного розподіленого вмісту (SA-8(17)); Реалізують принцип побудови безпеки довірених каналів зв'язку (SA-8(18)); Реалізують принцип проектування безпеки довготривалого (SA-8(19)); Реалізують принцип безпечного управління метаданими (SA-8(20)); Реалізують принцип проектування безпеки на основі самоаналізу (SA-8(21)); Реалізують принцип проектування безпечних налаштувань за замовчуванням (SA-8(23)); <sa-08(25)_odp системи або компоненти реалізують принцип безпеки економіки. (SA-8(25)); <sa-08(26)_odp системи або компоненти реалізують принцип безпеки продуктивності. (SA-8(26)); Реалізують принцип безпеки з урахуванням людського фактору (SA-8(27)); <sa-08(28)_odp системи або компоненти реалізують принцип прийняттого рівня безпеки. (SA-8(28)); Реалізують принцип безпечної модифікації систем (SA-8(31)); Реалізують принцип достатньої допускної документації (SA-8(32)); <sa-08(33)_odp системи або компоненти реалі-

зують принцип мінімізації конфіденційності. (SA-8(33)); Зовнішні послуги для системи (SA-9); Зовнішні послуги для системи- оцінювання ризиків та організаційні погодження (SA-9(1)); Зовнішні послуги для системи- визначення функцій, портів, протоколів та служб (SA-9(2)); Створення та підтримка довірчих відносин з постачальниками (SA-9(3)); Зовнішні системні служби споживачів і постачальників (SA-9(4)); Зовнішні послуги для системи- місце обробки, зберігання та обслуговування (SA-9(5)); Зовнішні послуги для системи- криптографічні ключі, керовані організацією (SA-9(6)); Зовнішні послуги для системи- перевірка цілісності, що контролюється організацією (SA-9(7)); Зовнішні послуги для системи- зберігання – юрисдикція України (SA-9(8)); Управління конфігурацією розробника (SA-10); Управління конфігурацією розробника — перевірка цілісності програмного забезпечення та мікропрограм (SA-10(1)); Управління конфігурацією розробника — довірене постачання (SA-10(6)); Представники безпеки та приватності (SA-11); Тестування та оцінювання розробника — моделювання загроз і аналіз вразливостей (SA-11(2)); Ate_ind.2 eal2 незалежне тестування eal3 незалежне тестування — eal4 eal5 eal6 зразок (SA-11(3)); Тестування та оцінювання розробника — тестування на проникнення (SA-11(5)); Покриття аналіз покриття (SA-11(7)); Динамічний аналіз коду (SA-11(8)); Керування ризиками ланцюга постачання (SA-12); Довірчість (SA-13); Аналіз критичності (SA-14); Процеси, стандарти та інструменти розробки (SA-15); Зменшення поверхні атаки (SA-15(5)); Постійне вдосконалення (SA-15(6)); Співбесіда: [вибір: персонал організації, який відповідає за придбання систем та послуг; персонал організації, який відповідає за інформаційну процес, стандарти та інструменти розробки безпеки; розробник системи]. аналіз вразливостей автоматизований (SA-15(7)); Повторне використання інформації про загрози та вразливості (SA-15(8)); Процес, стандарти та інструменти використання реальних даних (SA-15(9)); Навчання, що надається розробниками (SA-16); Проєкт та архітектура розробника (SA-17); Проєкт і архітектура безпеки розробника — формальна модель політики (SA-17(1)); Проєкт і архітектура безпеки розробника — компоненти, що необхідні для забезпечення безпеки (SA-17(2)); Проєкт і архітектура безпеки розробника — формальна відповідність (SA-17(3)); Проєкт і архітектура безпеки розробника — неформальна відповідність (SA-17(4)); Захист та виявлення підробки (SA-18); Справжність компонента (SA-19); Індивідуальна розробка критичних компонентів (SA-20); Перевірка розробника (SA-21); Компоненти системи, що не підтримуються (SA-22); Спеціалізація (SA-23).

15.1. ПОЛІТИКИ ТА ПРОЦЕДУРИ ПРИДБАННЯ СИСТЕМ ТА ПОСЛУГ (SA-1)

a. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або ролей]:

1. 2.

b. [Вибір (один або декілька): рівень організації; рівень місії/бізнес-процесу; рівень системи] політики придбання систем і послуг, яка:

(a) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю (compliance);

(b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам і рекомендаціям. Процедури, що полегшують впровадження політики та заходів придбання систем і послуг. Призначити [Призначення: визначену організацією посадову особу] для управління політикою та процедурами придбання системи та послуг.

c. Переглядати й оновлювати поточні політику та процедури придбання систем та послуг:

1. Поточну політику придбання системи та послуг [Призначення: з визначеною організацією частотою].

2. Поточні процедури придбання системи та послуг [Призначення: з визначеною організацією частотою] та наступні [Призначення: події, визначені організацією].

No: 1

Name: sa_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюватиметься політика придбання систем і послуг

No: 2

Name: sa_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури придбання систем і послуг

No: 3

Name: sa_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: sa_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами придбання систем і послуг

No: 5

Name: sa_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено періодичність перегляду та оновлення поточної політики придбання систем і послуг

No: 6

Name: sa_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Є події, які вимагають перегляду та оновлення поточної політики придбання систем і послуг

No: 7

Name: sa_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури придбання систем і послуг

15.2. РОЗПОДІЛ РЕСУРСІВ (SA-2)

- a. Визначити вимоги щодо інформаційної безпеки та приватності для систем або послуг для системи при плануванні завдань та процесів.
- b. Визначити, задокументувати та розподілити ресурси, які необхідні для захисту систем або послуг для системи у рамках процесу фінансового планування в організації та управління інвестиціями.
- c. Створити окрему позицію бюджету для фінансування заходів із забезпечення інформаційної безпеки та приватності.

Немає параметрів для цього контролю.

15.3. ЖИТТЄВИЙ ЦИКЛ РОЗРОБКИ СИСТЕМИ (SA-3)

- a. Придбати, розробити та керувати системою, використовуючи [Призначення: визначений організацією життєвий цикл розробки], який охоплює питання захисту інформації та приватності.
- b. Визначити та задокументувати роль і обов'язки із забезпечення безпеки та приватності інформації протягом усього життєвого циклу розробки системи.
- c. Визначити осіб, які мають повноваження та обов'язки в області інформаційної безпеки та приватності.
- d. Інтегрувати процес управління інформаційною безпекою та приватністю в процеси життєвого циклу розробки системи.

No: 1

Name: sa_3_odp

Type: list

Default: ["admin", "security_officer"]

Визначено життєвий цикл розробки системи; SA-03a.[01] система придбана, розроблена та керується з використанням життєвого циклу життєвий цикл розробки системи, який охоплює інформаційну безпеку; SA-03a.[02] система придбана, розроблена та керується з використанням життєвий цикл розробки системи, який охоплює приватність; SA-03b.[01] визначені та задокументовані ролі та обов'язки з інформаційної безпеки протягом усього життєвого циклу розробки системи; SA-03b.[02] визначені та задокументовані ролі та обов'язки щодо приватності протягом усього життєвого циклу розробки системи; SA-03c.[01] визначені особи, які виконують функції та обов'язки з інформаційної безпеки; SA-03c.[02] визначені особи з функціями та обов'язками, пов'язаними з приватністю; SA-03d.[01] інтегровані процеси управління інформаційною безпекою організації в діяльність життєвого циклу розробки системи; SA-03d.[02] інтегровані процеси управління приватністю в життєвого циклу розробки системи

15.3.1. ЖИТТЄВИЙ ЦИКЛ РОЗРОБКИ СЕРЕДОВИЩЕМ РОЗРОБКИ (SA-3(1))

No: 1

Name: sa_3_1_01

Type: string

Default: nil

Захищене середовище розробки системи, відповідно до ризиків протягом усього життєвого циклу розробки системи для системи, компонентів системи або служб.

15.3.2. ЖИТТЄВИЙ ЦИКЛ РЕАЛЬНИХ ДАНИХ (SA-3(2))

Немає параметрів для цього контролю.

15.3.3. ЖИТТЄВИЙ ЦИКЛ ТЕХНОЛОГІЙ (SA-3(3))

No: 1

Name: sa_3_3_01

Type: string

Default: nil

Планується оновлення технологій для підтримки системи протягом усього життєвого циклу розробки системи

No: 2

Name: sa_3_3_02

Type: string

Default: nil

Впроваджено графік оновлення технологій для підтримки системи протягом усього життєвого циклу розробки системи

15.4. ПРОЦЕС ЗАКУПІВЕЛЬ (SA-4)

Включіть такі вимоги, описи та критерії, явно або за допомогою посилання, використовуючи [Вибір (один або більше): стандартні пункти контракту; [Призначення: пункти контракту, визначені організацією]] в контракті про придбання системи, системного компонента або системної послуги:

- a. функціональні вимоги безпеки та приватності;
- b. вимоги до стійкості механізму;
- c. вимоги до забезпечення безпеки та приватності;
- d. заходи захисту для забезпечення вимог безпеки та приватності;
- e. вимоги до захисту документації з безпеки та приватності;
- f. опис середовища розробки системи та середовища, у якому система призначена для роботи;
- g. розподіл відповідальності або визначення сторін, відповідальних за управління інформаційною безпекою, приватністю та управлінням ланцюгами постачання;
- h. критерії прийнятності.

No: 1

Name: sa_4_odp_01

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРА: { стандартні пункти контракту; пункт контракту }

15.4.1. ФУНКЦІОНАЛЬНІ ВЛАСТИВОСТІ ЗАХОДІВ (SA-4(1))

No: 1

Name: sa_4_1_01

Type: string

Default: nil

Планується оновлення технологій для системи протягом життєвого циклу розробки системи

15.4.2. РОЗРОБКА ТА ВПРОВАДЖЕННЯ ІНФОРМАЦІЇ ДЛЯ ЗАХОДІВ (SA-4(2))

Немає параметрів для цього контролю.

15.4.3. ПРОЦЕС ЗАКУПІВЕЛЬ РОЗРОБКИ (SA-4(3))

No: 1

Name: sa_4_3_a

Type: string

Default: nil

Повинен розробник системи, системного компонента або системної послуги демонструвати використання процесу життєвого циклу розробки системи, який включає методи системної інженерії

15.4.4. ВІДНЕСЕННЯ КОМПОНЕНТІВ ДО СИСТЕМ (SA-4(4))

No: 1

Name: sa_4_4_01

Type: string

Default: nil

ПРОЦЕС ЗАКУПІВЕЛЬ - ВІДНЕСЕННЯ КОМПОНЕНТІВ ДО СИСТЕМ [Вилучено: включено до CM-8(9)]

15.4.5. КОНФІГУРАЦІЇ СИСТЕМИ, КОМПОНЕНТА ТА СИСТЕМНОЇ СЛУЖБИ (SA-4(5))

No: 1

Name: sa_4_5_a

Type: string

Default: nil

Повинен розробник системи, компонента системи або системної служби постачати систему, компонент або службу із впровадженими конфігураціями безпеки

No: 2

Name: sa_4_5_b

Type: string

Default: nil

Будуть конфігурації використовуватися за замовчуванням для будь-якої наступної переінсталяції або оновлення системи, компонента чи служби

No: 3

Name: sa_4_5_odp

Type: string

Default: nil

Визначено конфігурації безпеки для системи, компонента або служби

15.4.6. ПРОЦЕС ЗАКУПІВЕЛЬ ІНФОРМАЦІЇ (SA-4(6))

No: 1

Name: sa_4_6_a

Type: string

Default: "AES-256-GCM"

Використовуються лише засоби захисту інформації, які пройшли державну експертизу або сертифікацію, створені для технічного та криптографічного захисту інформації

No: 2

Name: sa_4_6_b

Type: string

Default: "автоматизований засіб моніторингу"

Були ці засоби захисту мають позитивний експертний висновок або сертифікат відповідності, а також відповідні дозволи для використання для захисту критичної інформації

15.4.7. ЗАТВЕРДЖЕНІ ПРОФІЛІ ЗАХИЩЕНОСТІ (SA-4(7))

No: 1

Name: sa_4_7_a

Type: string

Default: nil

Обмежується використання комерційної готової до використання технічної продукції, створеної для захисту інформації та з функцією підтримки забезпечення безпеки інформації, до тих продуктів, які були успішно оцінені відповідно до профілю захищеності для конкретного типу технології, затвердженого уповноваженим державним органом, якщо такий профіль наявний

No: 2

Name: sa_4_7_b

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Якщо немає профілю захищеності для певного типу технологій, затвердженого уповноваженим органом, але забезпечення політики безпеки продукту, що надається на комерційній основі, залежить від криптографічних функцій, — вимагати, щоб криптографічний модуль пройшов державну експертизу, мав позитивний експертний висновок і був рекомендований до використання уповноваженим органом

15.4.8. ПЛАН БЕЗПЕРЕРВНОГО МОНІТОРИНГУ ЗАХОДІВ БЕЗПЕКИ (SA-4(8))

No: 1

Name: sa_4_8_01

Type: string

Default: nil

Розробник системи, системного компонента або системної служби створив план безперервного моніторингу ефективності заходів безпеки та приватності, який узгоджується з відповідним планом постійного моніторингу організації

15.4.9. ФУНКЦІЇ, ПОСЛУГИ, ЩО ВИКОРИСТОВУЮТЬСЯ (SA-4(9))

No: 1

Name: sa_4_9_01

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системного сервісу визначити функції, призначені для використання в організації

No: 2

Name: sa_4_9_02

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної служби визначити порти, призначені для використання в організації

No: 3

Name: sa_4_9_03

Type: string

Default: "TLS 1.3"

Зобов'язаний розробник системи, системного компонента або системної служби визначити протоколи, призначені для використання в організації

No: 4

Name: sa_4_9_04

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної послуги визначити послуги, призначені для використання в організації

15.5. СИСТЕМНА ДОКУМЕНТАЦІЯ (SA-5)

a.

b. Отримати або розробити документацію адміністратора для системи, системного компонента або системної служби, яка описує:

1. безпечне налаштування, установку та роботу системи, компонента або служби;
2. ефективне використання, підтримку функцій та механізмів безпеки та приватності;
3. відомі вразливості щодо конфігурації та використання адміністративних або привілейованих функцій. Отримати або розробити документацію користувача для системи, системного компонента або системної служби, яка описує:

1. функції та механізми безпеки та приватності та способи ефективного використання цих функцій і механізмів;
2. методи взаємодії з користувачем, що дозволяють окремим особам використовувати систему, компонент або службу безпечнішим чином та захищати індивідуальну приватність;
3. обов'язки користувача щодо забезпечення безпеки системи, компонента або служби та приватності окремих осіб.

c. Документувати спроби отримати доступ до документації системи, системного компонента чи системної служби, коли така документація недоступна або ж відсутня, і вжити [Призначення: визначені організацією заходи] у відповідь.

d. Поширити документацію серед [Призначення: визначеного організацією персоналу або посадових осіб].

No: 1

Name: sa_5_odp_01

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначені дії, яких слід вжити, коли документація на систему, системний компонент або системне обслуговування недоступна або відсутня

No: 2

Name: sa_5_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або системної документації; SA-05a.01[01] отримана або розроблена документація для адміністратора системи, системного компонента або системної служби, яка описує безпечну конфігурацію системи, компонента або служби; SA-05a.01[02] була отримана або розроблена документація для адміністратора системи, системного компонента або системної служби, яка описує безпечне встановлення системи, компонента або служби; SA-05a.01[03] отримана або розроблена ролі для розповсюдження документація адміністратора системи, системного компонента або системної служби, яка описує безпечну роботу системи, компонента або служби; SA-05a.02[01] отримана або розроблена адміністраторська документація системи, системного компонента або системної служби, яка описує ефективне використання функцій та механізмів безпеки; SA-05a.02[02] була отримана або розроблена документація адміністратора системи, системного компонента або системної служби, яка описує безпечне встановлення системи, компонента або служби; SA-05a.02[03] отримана або розроблена документація для адміністратора системи, системного компонента або системної служби, яка описує ефективне

використання функцій і механізмів забезпечення конфіденційності; SA-05a.02[04] отримана або розроблена документація для адміністратора системи, системного компонента або системної служби, яка описує ефективну підтримку функцій і механізмів забезпечення конфіденційності; SA-05a.03[01] була отримана або розроблена документація адміністратора системи, системного компонента або системної служби, яка описує відомі вразливості, що стосуються конфігурації адміністративних або привілейованих функцій; SA-05a.03[02] була отримана або розроблена документація адміністратора системи, системного компонента або системної служби, яка описує відомі вразливості, пов'язані з використанням адміністративних або привілейованих функцій; SA-05b.01[01] отримана або розроблена користувацька документація системи, системного компонента або системної служби, яка описує доступні користувачеві функції та механізми безпеки; SA-05b.01[02] отримана або розроблена користувацька документація системи, системного компонента або системної служби, яка описує, як ефективно використовувати ці (доступні користувачеві) функції та механізми безпеки; SA-05b.01[03] отримана або розроблена користувацька документація системи, системного компонента або системної служби, яка описує доступні користувачеві функції та механізми забезпечення конфіденційності; SA-05b.01[04] отримана або розроблена користувацька документація системи, системного компонента або системної служби, яка описує, як ефективно використовувати ці (доступні користувачеві) функції та механізми захисту приватності; SA-05b.02[01] отримана або розроблена користувацька документація системи, системного компонента або системної послуги, яка описує методи взаємодії з користувачем, що дозволяють особам використовувати систему, компонент або послугу в більш безпечний спосіб; SA-05b.02[02] отримана або розроблена користувацька документація системи, системного компонента або системної служби, яка описує методи взаємодії з користувачем, що дозволяють особам використовувати систему, компонент або службу для захисту особистої приватності; SA-05b.03[01] отримана або розроблена користувацька документація системи, системного компонента або системного сервісу, яка описує обов'язки користувача щодо підтримання безпеки системи, компоненту або сервісу; SA-05b.03[02] отримана або розроблена користувацька документація системи, системного компонента або системної служби, яка описує обов'язки користувачів щодо збереження приватності приватних осіб; SA-05c.[01] були задокументовані спроби отримати документацію на систему, системний компонент або системне обслуговування, коли така документація або недоступна, або взагалі не існує; SA-05c.[02] після спроб отримати документацію системи, системного компонента або системної служби, коли така документація недоступна або не існує, у відповідь виконуються дії; SA-05d. розповсюджується документація персоналу або ролей>. серед <SA-05_ODP[02]

15.5.1. ФУНКЦІОНАЛЬНІ ВЛАСТИВОСТІ ЗАХОДІВ БЕЗПЕКИ (SA-5(1))

No: 1
Name: sa_5_1_01
Type: string
Default: nil

СИСТЕМНА ДОКУМЕНТАЦІЯ - ФУНКЦІОНАЛЬНІ ВЛАСТИВОСТІ ЗАХОДІВ БЕЗПЕКИ [Вилучено: включено до SA-4(1)]

15.5.2. ЗОВНІШНІ СИСТЕМНІ ІНТЕРФЕЙСИ, (SA-5(2))

No: 1
Name: sa_5_2_01
Type: string
Default: nil

СИСТЕМНА ДОКУМЕНТАЦІЯ - ЗОВНІШНІ СИСТЕМНІ ІНТЕРФЕЙСИ, ЩО СТОСУЮТЬСЯ БЕЗПЕКИ [Вилучено: включено до SA-4(2)]

15.5.3. АРХІТЕКТУРА (ПРОЄКТ) ВИСОКОГО РІВНЯ (SA-5(3))

No: 1
Name: sa_5_3_01

Type: string

Default: nil

СИСТЕМНА ДОКУМЕНТАЦІЯ - АРХІТЕКТУРА (ПРОЄКТ) ВИСОКОГО РІВНЯ [Вилучено: включено до SA-4(2)]

15.5.4. АРХІТЕКТУРА (ПРОЄКТ) НИЗЬКОГО РІВНЯ (SA-5(4))

No: 1

Name: sa_5_4_01

Type: string

Default: nil

СИСТЕМНА ДОКУМЕНТАЦІЯ - АРХІТЕКТУРА (ПРОЄКТ) НИЗЬКОГО РІВНЯ [Вилучено: включено до SA-4(2)]

15.5.5. ВИХІДНИЙ КОД (SA-5(5))

No: 1

Name: sa_5_5_01

Type: string

Default: nil

СИСТЕМНА ДОКУМЕНТАЦІЯ - ВИХІДНИЙ КОД [Вилучено: включено до SA-4(2)]

15.6. ОБМЕЖЕННЯ ЩОДО ВИКОРИСТАННЯ ЗАБЕЗПЕЧЕННЯ (SA-6)

No: 1

Name: sa_6_01

Type: string

Default: nil

ОБМЕЖЕННЯ ЩОДО ВИКОРИСТАННЯ ЗАБЕЗПЕЧЕННЯ [Вилучено: включено до CM-10 та SI-7]

15.7. ВСТАНОВЛЕНЕ КОРИСТУВАЧЕМ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ (SA-7)

No: 1

Name: sa_7_01

Type: string

Default: nil

ВСТАНОВЛЕНЕ КОРИСТУВАЧЕМ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ [Вилучено: включено до CM-11 та SI-7]

15.8. БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ІНЖИНІРИНГУ (SA-8)

Застосовувати [Призначення: визначені організацією принципи інжинірингу безпеки та конфіденційності системи] в специфікації, проектуванні, розробці, впровадженні та зміні системи й компонентів системи.

No: 1

Name: sa_8_01

Type: string

Default: nil

Застосовуються принципи інжинірингу безпеки систем у специфікації системи та компонентів системи

No: 2

Name: sa_8_02

Type: string

Default: nil

Застосовуються принципи інжинірингу безпеки систем при розробці системи та її компонентів

No: 3

Name: sa_8_03

Type: string

Default: nil

Були застосовані принципи інжинірингу безпеки систем при розробці системи та компонентів систем

No: 4

Name: sa_8_04

Type: string

Default: nil

Застосовуються принципи інжинірингу безпеки систем при реалізації системи та компонентів систем

No: 5

Name: sa_8_05

Type: string

Default: nil

Застосовуються принципи інжинірингу безпеки систем при модифікації системи та компонентів систем

No: 6

Name: sa_8_06

Type: string

Default: nil

Застосовуються принципи інжинірингу конфіденційності у специфікації системи та компонентів систем; принципи інжинірингу конфіденційності SA-08[07] застосовуються принципи інжинірингу конфіденційності при розробці системи та компонентів систем

No: 7

Name: sa_8_08

Type: string

Default: nil

Застосовуються принципи інжинірингу конфіденційності при розробці системи та компонентів систем

No: 8

Name: sa_8_09

Type: string

Default: nil

Застосовуються принципи інжинірингу конфіденційності при реалізації системи та компонентів систем

No: 9

Name: sa_8_10

Type: string

Default: nil

Застосовуються принципи інжинірингу конфіденційності при модифікації системи та компонентів систем

No: 10

Name: sa_8_odp_01

Type: string

Default: nil

Визначені принципи інжинірингу безпеки систем

No: 11

Name: sa_8_odp_02

Type: string

Default: nil

Визначені системи

15.8.1. ЧІТКА АБСТРАКЦІЯ (SA-8(1))

No: 1

Name: sa_8_1_01

Type: string

Default: nil

Реалізовано принцип проектування безпеки чітких абстракцій

15.8.2. БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ НАЙМЕНШ ПОШИРЕНИЙ МЕХАНІЗМ (SA-8(2))

No: 1

Name: sa_8_2_01

Type: string

Default: nil

Реалізують системи або компоненти системи принцип побудови безпеки за принципом найменш поширеного механізму

No: 2

Name: sa_8_2_odp

Type: string

Default: nil

Реалізовано абстракцій. принцип проектування безпеки чітких

15.8.3. БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ МОДУЛЬНІСТЬ І БАГАТОРІВНЕВІСТЬ (SA-8(3))

No: 1

Name: sa_8_3_01

Type: string

Default: nil

БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ МОДУЛЬНІСТЬ І БАГАТОРІВНЕВІСТЬ ІНЖИНІРИНГУ - МЕТА ОЦІНКИ: Визначити, чи: SA08(03)_ODP[01] визначені системи або компоненти системи, реалізують принцип модульності дизайну безпеки; які SA08(03)_ODP[02] визначені системи або компоненти реалізують принцип багаторівневого безпеки

No: 2

Name: sa_8_3_02

Type: string

Default: nil

Системи або компоненти системи реалізують принцип багаторівневого проектування безпеки. системи, які проектування

15.8.4. БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ЧАСТКОВО ВПОРЯДКОВАНІ ЗАЛЕЖНОСТІ (SA-8(4))

No: 1

Name: sa_8_4_01

Type: integer

Default: 30

Системи або компоненти системи реалізують принцип проектування безпеки частково впорядкованих залежностей

No: 2

Name: sa_8_4_odp

Type: integer

Default: 30

Визначені системи або компоненти системи, які реалізують принцип проектування безпеки частково впорядкованих залежностей

15.8.5. БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ЕФЕКТИВНИЙ ОПОСЕРЕДКОВАНИЙ ДОСТУП (SA-8(5))

No: 1

Name: sa_8_5_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки ефективного опосередкованого доступу

No: 2

Name: sa_8_5_odp

Type: string

Default: nil

Визначені системи або її компоненти, які реалізують принцип проектування безпеки ефективного опосередкованого доступу

15.8.6. БЕЗПЕКА ТА ПРИВАТНІСТЬ МІНІМІЗОВАНИЙ ОБМІН (SA-8(6))

No: 1

Name: sa_8_6_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип побудови безпеки за принципом мінімізації спільного використання

No: 2

Name: sa_8_6_odp

Type: string

Default: nil

Визначені системи або компоненти системи, які реалізують принцип проектування безпеки, що полягає в мінімізації спільного використання

15.8.7. ЗНИЖЕНА СКЛАДНІСТЬ (SA-8(7))

No: 1

Name: sa_8_7_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки за принципом зниженої складності. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

No: 2

Name: sa_8_7_odp

Type: string

Default: nil

Визначені системи або компоненти системи, які реалізують принцип проектування безпеки за принципом зниженої складності

15.8.8. БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ЕВОЛЮЦІЯ БЕЗПЕКИ В СИСТЕМІ (SA-8(8))

No: 1

Name: sa_8_8_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип безпечного проектування безпечної еволюційності

No: 2

Name: sa_8_8_odp

Type: string

Default: nil

Визначені системи або компоненти системи, які реалізують принцип безпечного проектування безпечної еволюційності

15.8.9. ДОВІРЕНІ КОМПОНЕНТИ СИСТЕМИ (SA-8(9))

No: 1

Name: sa_8_9_01

Type: string

Default: nil

Системи або компоненти реалізують принцип побудови безпеки компонентів. системи довірених

No: 2

Name: sa_8_9_odp

Type: string

Default: nil

Визначені системи або компоненти системи, які реалізують принцип побудови безпеки довірених компонентів

15.8.10. РЕАЛІЗУЮТЬ ПРИНЦИП ІЄРАРХІЧНОЇ ДОВІРИ В ДИЗАЙНІ БЕЗПЕКИ (SA-8(10))

No: 1

Name: sa_8_10_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип ієрархічної довіри в дизайні безпеки. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

No: 2

Name: sa_8_10_odp

Type: string

Default: nil

Визначені системи або компоненти системи, які реалізують принцип ієрархічної довіри при проектуванні безпеки

15.8.11. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ ЗВОРОТНОГО ПОРОГУ МОДИФІКАЦІЇ (SA-8(11))

No: 1

Name: sa_8_11_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки зворотного порогу модифікації

No: 2

Name: sa_8_11_odp

Type: string

Default: nil

Визначені системи або компоненти системи, які реалізують принцип ієрархічної довіри при проектуванні безпеки

15.8.12. РЕАЛІЗУЮТЬ ПРИНЦИП ПОБУДОВИ ІЄРАРХІЧНОГО ЗАХИСТУ (SA-8(12))

No: 1
Name: sa_8_12_01
Type: string
Default: nil

Системи або компоненти системи реалізують принцип побудови ієрархічного захисту

No: 2
Name: sa_8_12_odp
Type: string
Default: nil

Визначені системи або компоненти системи, реалізують принцип ієрархічного дизайну безпеки; які

15.8.13. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ З МІНІМІЗАЦІЄЮ ЕЛЕМЕНТІВ БЕЗПЕКИ (SA-8(13))

No: 1
Name: sa_8_13_01
Type: string
Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки з мінімізацією елементів безпеки.
ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

No: 2
Name: sa_8_13_odp
Type: string
Default: nil

Визначено системи або компоненти системи, які реалізують принцип проектування безпеки за принципом мінімізації елементів безпеки

15.8.14. РЕАЛІЗУЮТЬ ПРИНЦИП ПОБУДОВИ БЕЗПЕКИ ЗА ПРИНЦИПОМ НАЙМЕНШИХ ПРИВІЛЕЇВ (SA-8(14))

No: 1
Name: sa_8_14_01
Type: string
Default: nil

Системи або компоненти системи реалізують принцип побудови безпеки за принципом найменших привілеїв

No: 2
Name: sa_8_14_odp
Type: string
Default: nil

Визначено системи або компоненти системи, які реалізують принцип побудови безпеки за принципом найменших привілеїв

15.8.15. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ ПОПЕРЕДНЬОГО ДОЗВОЛУ (SA-8(15))

No: 1

Name: sa_8_15_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки попереднього дозволу

No: 2

Name: sa_8_15_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип проектування безпеки попереднього дозволу

15.8.16. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ САМОДОСТАТНЬОЇ НАДІЙНОСТІ (SA-8(16))

No: 1

Name: sa_8_16_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки самодостатньої надійності. ПО-
ТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

No: 2

Name: sa_8_16_odp

Type: string

Default: nil

Визначено системи або компоненти реалізують принцип проектування ґрунтується на самодостатній надійності;
системи, безпеки, які що

15.8.17. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ ЗАХИЩЕНОГО РОЗПОДІЛЕНОГО ВМІСТУ (SA-8(17))

No: 1

Name: sa_8_17_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки захищеного розподіленого вмісту

No: 2

Name: sa_8_17_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип безпечного проектування захищеного
розподіленого вмісту

15.8.18. РЕАЛІЗУЮТЬ ПРИНЦИП ПОБУДОВИ БЕЗПЕКИ ДОВІРЕНИХ КАНАЛІВ ЗВ'ЯЗКУ (SA-8(18))

No: 1

Name: sa_8_18_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип побудови безпеки довірених каналів зв'язку

No: 2

Name: sa_8_18_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип побудови безпеки довірених каналів зв'язку

15.8.19. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ ДОВГОТРИВАЛОГО (SA-8(19))

No: 1

Name: sa_8_19_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки довготривалого захисту

No: 2

Name: sa_8_19_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які втілюють принцип проектування безпеки довготривалого захисту

15.8.20. РЕАЛІЗУЮТЬ ПРИНЦИП БЕЗПЕЧНОГО УПРАВЛІННЯ МЕТАДАНИМИ (SA-8(20))

No: 1

Name: sa_8_20_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип безпечного управління метаданими

No: 2

Name: sa_8_20_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип безпечного управління метаданими

15.8.21. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ НА ОСНОВІ САМОАНАЛІЗУ (SA-8(21))

No: 1

Name: sa_8_21_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки на основі самоаналізу

No: 2

Name: sa_8_21_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип самоаналізу при проектуванні безпеки

15.8.22. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕЧНИХ НАЛАШТУВАНЬ ЗА ЗАМОВЧУВАННЯМ (SA-8(23))

No: 1

Name: sa_8_23_odp

Type: string

Default: nil

Визначено системи або компоненти системи, реалізують принцип безпечних налаштувань за замовчуванням; які за SA-8(23) системи або компоненти системи реалізують принцип проектування безпечних налаштувань за замовчуванням

15.8.23. <SA-08(25)_ODP системи або компоненти реалізують принцип безпеки економіки. (SA-8(25))

No: 1

Name: sa_8_25_01

Type: string

Default: nil

Системи або компоненти реалізують принцип безпеки економіки. які системи

No: 2

Name: sa_8_25_odp

Type: string

Default: nil

Визначено системи або компоненти реалізують принцип безпеки економіки; системи,

15.8.24. <SA-08(26)_ODP системи або компоненти реалізують принцип безпеки продуктивності. (SA-8(26))

No: 1

Name: sa_8_26_01

Type: string

Default: nil

Системи або компоненти реалізують принцип безпеки продуктивності. які системи

No: 2

Name: sa_8_26_odp

Type: string

Default: nil

Визначено системи або компоненти системи, реалізують принцип безпеки продуктивності

15.8.25. РЕАЛІЗУЮТЬ ПРИНЦИП БЕЗПЕКИ З УРАХУВАННЯМ ЛЮДСЬКОГО ФАКТОРУ (SA-8(27))

No: 1

Name: sa_8_27_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип безпеки з урахуванням людського фактору

No: 2

Name: sa_8_27_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип безпеки з урахуванням людського фактору

15.8.26. <SA-08(28)_ODP системи або компоненти реалізують принцип прийнятного рівня безпеки. (SA-8(28))

No: 1

Name: sa_8_28_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип повторюваних та задокументованих процедур

No: 2

Name: sa_8_28_odp

Type: string

Default: nil

Визначено системи або компоненти системи, реалізують принцип прийнятного рівня безпеки

15.8.27. РЕАЛІЗУЮТЬ ПРИНЦИП БЕЗПЕЧНОЇ МОДИФІКАЦІЇ СИСТЕМ (SA-8(31))

No: 1

Name: sa_8_31_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип безпечної модифікації систем

No: 2

Name: sa_8_31_odp

Type: string

Default: nil

Визначено системи або компоненти системи, реалізують принцип безпечної модифікації систем; які

15.8.28. РЕАЛІЗУЮТЬ ПРИНЦИП ДОСТАТНЬОЇ ДОПУСКНОЇ ДОКУМЕНТАЦІЇ (SA-8(32))

No: 1

Name: sa_8_32_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип достатньої допускної документації

No: 2

Name: sa_8_32_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип достатньої допускної документації

15.8.29. <SA-08(33)_ODP системи або компоненти реалізують принцип мінімізації конфіденційності. (SA-8(33))

No: 1

Name: sa_8_33_odp

Type: string

Default: nil

Визначено системи або компоненти системи, реалізують принцип мінімізації конфіденційності; які SA-08(33) системи або компоненти реалізують принцип мінімізації конфіденційності. системи

15.9. ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ (SA-9)

а. Вимагати, щоб постачальники зовнішніх послуг для системи відповідали вимогам безпеки та приватності в організації та застосовували такі заходи захисту [Призначення: встановлені організацією заходи безпеки та приватності].

б. Визначити та задокументувати нагляд організаціїповноваження та обов'язки користувачів щодо зовнішніх послуг для системи.

с. Використовувати наступні процеси, методи та техніки для постійного моніторингу дотримання контролю зовнішніми постачальниками послуг: [Призначення: визначені організацією процеси, методи та техніки].

No: 1

Name: sa_9_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначені засоби контролю, які будуть застосовуватися зовнішніми постачальниками системних послуг

No: 2

Name: sa_9_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначені процеси, методи та техніки, що застосовуються для моніторингу дотримання вимог контролю зовнішніми постачальниками послуг; SA-09a.[01] дотримуються постачальники зовнішніх системних послуг

вимог організаційної безпеки; SA-09a.[02] дотримуються постачальники зовнішніх системних послуг вимог приватності організації; SA-09a.[03] використовують постачальники зовнішніх системних послуг елементи керування; SA-09b.[01] визначено та задокументовано організаційний нагляд за зовнішніми системними послугами; SA-09b.[02] визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних сервісів; SA-09c. визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних послуг

15.9.1. ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ- ОЦІНЮВАННЯ РИЗИКІВ ТА ОРГАНІЗАЦІЙНІ ПОГОДЖЕННЯ (SA-9(1))

(a) Проводити організаційне оцінювання ризиків перед придбанням або передаванням послуг інформаційної безпеки служб інформаційної безпеки.

(b) Переконатися, що придбання або передача спеціалізованих служб інформаційної безпеки погоджені [Призначення: визначеним організацією персоналом або посадовими особами].

No: 1

Name: sa_9_1_a

Type: string

Default: nil

Проводиться організаційна оцінка ризиків перед придбанням або передачею послуг з інформаційної безпеки

No: 2

Name: sa_9_1_b

Type: list

Default: ["admin", "security_officer"]

Схвалюють персонал або ролі придбання або передачу спеціальних послуг з інформаційної безпеки

No: 3

Name: sa_9_1_odp

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які схвалюють придбання або передачу спеціальних послуг з інформаційної безпеки

15.9.2. ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ- ВИЗНАЧЕННЯ ФУНКЦІЙ, ПОРТІВ, ПРОТОКОЛІВ ТА СЛУЖБ (SA-9(2))

Вимагати від постачальників наведених нижче зовнішніх послуг для системи [Призначення: визначених організацією зовнішніх послуг для системи] визначити функції, порти, протоколи та інші служби, необхідні для використання таких служб.

No: 1

Name: sa_9_2_01

Type: string

Default: "TLS 1.3"

Необхідно постачальникам зовнішніх системних послуг ідентифікувати функції, порти, протоколи та інші послуги, необхідні для використання таких послуг

No: 2

Name: sa_9_2_odp

Type: string

Default: "TLS 1.3"

Визначені зовнішні системні сервіси, які потребують ідентифікації функцій, портів, протоколів та інших сервісів

15.9.3. СТВОРЕННЯ ТА ПІДТРИМКА ДОВІРЧИХ ВІДНОСИН З ПОСТАЧАЛЬНИКАМИ (SA-9(3))

Створити, задокументувати та підтримувати довірчі відносини із зовнішніми постачальниками послуг на основі таких вимог, властивостей, факторів або умов: [Призначення: визначених організацією вимог, властивостей, факторів або умов щодо безпеки та приватності, що визначають прийнятні довірчі відносини].

No: 1

Name: sa_9_3_01

Type: string

Default: nil

Встановлені та задокументовані довірчі відносини з зовнішніми постачальниками послуг на основі вимог, властивостей, факторів або умов безпеки

No: 2

Name: sa_9_3_02

Type: string

Default: nil

Підтримуються довірчі відносини з зовнішніми постачальниками послуг на основі вимог, властивостей, факторів або умов безпеки

No: 3

Name: sa_9_3_03

Type: string

Default: nil

Встановлені та задокументовані довірчі відносини із зовнішніми постачальниками послуг на основі вимог, властивостей, факторів або умов конфіденційності

No: 4

Name: sa_9_3_04

Type: string

Default: nil

Підтримуються довірчі відносини із зовнішніми постачальниками послуг на основі вимог, властивостей, факторів або умов конфіденційності

15.9.4. ЗОВНІШНІ СИСТЕМНІ СЛУЖБИ СПОЖИВАЧІВ І ПОСТАЧАЛЬНИКІВ (SA-9(4))

Виконайте такі дії, щоб переконатися, що інтереси [Призначення: визначених організацією зовнішніх постачальників послуг] узгоджуються з інтересами організації та відображають їх: [Призначення: дії, визначені організацією].

No: 1

Name: sa_9_4_01

Type: list

Default: ["login", "logout", "failed_attempt"]

Вживаються дії для перевірки того, що інтереси зовнішніх постачальників послуг узгоджуються з інтересами організації та відображають їх

15.9.5. ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ- МІСЦЕ ОБРОБКИ, ЗБЕРІГАННЯ ТА ОБСЛУГОВУВАННЯ (SA-9(5))

Обмежити розташування [Вибір (один або більше): обробка інформації; інформація або дані; системні служби] до [Призначення: визначені організацією місця] на основі [Призначення: визначених організацією вимог або умов].

Немає параметрів для цього контролю.

15.9.6. ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ- КРИПТОГРАФІЧНІ КЛЮЧІ, КЕРОВАНІ ОРГАНІЗАЦІЄЮ (SA-9(6))

Зберігати контроль над криптографічними ключами для зашифрованої інформації, яка зберігається або передається через зовнішню систему.

No: 1

Name: sa_9_6_01

Type: string

Default: "AES-256-GCM"

Зберігається ексклюзивний контроль над криптографічними ключами для зашифрованих матеріалів, що зберігаються або передаються через зовнішню систему

15.9.7. ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ- ПЕРЕВІРКА ЦІЛІСНОСТІ, ЩО КОНТРОЛЮЄТЬСЯ ОРГАНІЗАЦІЄЮ (SA-9(7))

Забезпечити можливість перевірки цілісності інформації в організації під час її перебування в зовнішній системі.

No: 1

Name: sa_9_7_01

Type: integer

Default: 30

Передбачена можливість перевірки цілісності інформації під час її перебування у зовнішній системі

15.9.8. ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИЗБЕРІГАННЯ – ЮРИСДИКЦІЯ УКРАЇНИ (SA-9(8))

Обмежити географічне розміщення обробки та зберігання даних об'єктами, розташованими в межах юридичної юрисдикції України.

No: 1

Name: sa_9_8_01

Type: string

Default: nil

Обмежується географічне розміщення обробки інформації та зберігання даних об'єктами, розташованими в межах юридичної юрисдикції України

15.10. УПРАВЛІННЯ КОНФІГУРАЦІЄЮ РОЗРОБНИКА (SA-10)

Вимагати від розробника системи, системного компонента або системної служби:

- a. виконання управління конфігурацією під час [Вибір (один або кілька): проектування; розробки; реалізації; експлуатації; видалення] системи, компонента або служби;
- b. документувати, керувати та контролювати цілісність змін у [Призначення: визначених організацією елементах конфігурації при управлінні конфігурацією];
- c. впроваджувати тільки схвалені організацією зміни в системі, компоненті або службі;
- d. документувати зміни в системі, компоненті або службі та можливі наслідки таких змін для безпеки та приватності;
- e. відстежувати недоліки безпеки та усунення дефектів у системі, компоненті або службі та повідомляти про результати [Призначення: визначений організацією персонал].

No: 1

Name: sa_10_odp_02

Type: string

Default: nil

Визначено елементи конфігурації під керуванням

15.10.1. Управління конфігурацією розробника — Перевірка цілісності програмного забезпечення та мікропрограм (SA-10(1))

No: 1

Name: sa_10_1_01

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної служби забезпечити перевірку цілісності програмного забезпечення та компонентів програмного забезпечення

15.10.2. Управління конфігурацією розробника — Довірене постачання (SA-10(6))

No: 1

Name: sa_10_6_01

Type: string

Default: "автоматизований засіб моніторингу"

Повинен розробник системи, системного компонента або системної служби виконувати процедури для забезпечення того, щоб апаратні засоби, програмне забезпечення й оновлення прошивки, що стосуються безпеки й оновлюються в організації, точно відповідали оригінальним копіям

15.11. УПРАВЛІННЯ КОНФІГУРАЦІЄЮ РОЗРОБНИКА - ПРЕДСТАВНИКИ БЕЗПЕКИ ТА ПРИВАТНОСТІ (SA-11)

Вимагати від розробника системи, системного компонента або системної служби на всіх етапах проєктування та життєвого циклу розробки системи:

- a. створити та впровадити план з оцінювання безпеки та приватності;
- b. виконати [Вибір (один або кілька): одиниця; інтеграція; система; регресія] тестування/оцінювання [Призначення: з визначеною організацією частотою] з [Призначення: визначена організацією глибиною та охопленням];
- c. надати докази (свідчення) виконання плану оцінювання та результати тестування й оцінювань;
- d. впровадити перевірку процесу виправлення недоліків;
- e. виправити дефекти, виявлені під час тестування та оцінювання.

No: 1

Name: sa_11_odp_01

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {одиниця; інтеграція; система; регресія}

15.11.1. Тестування та оцінювання розробника — Моделювання загроз і аналіз вразливостей (SA-11(2))

No: 1

Name: sa_11_2_a_01

Type: integer

Default: 30

Повинен розробник системи, компонента системи або системного сервісу виконувати моделювання загроз під час розробки системи, компонента або сервісу, що використовує <SA-11(02)_ODP[01]_інформацію>

No: 2

Name: sa_11_2_a_02

Type: integer

Default: 30

Повинен розробник системи, системного компонента або системної служби виконувати аналіз вразливостей під час розробки системи, компонента або служби, які використовують <SA-11(02)_ODP[01]_інформацію>

No: 3

Name: sa_11_2_a_03

Type: integer

Default: 30

Повинен розробник системи, компонента системи або системного сервісу виконувати моделювання загроз під час подальшого тестування та оцінювання системи, компонента або сервісу, що використовує <SA-11(02)_ODP[01]_інформацію>

No: 4

Name: sa_11_2_a_04

Type: integer

Default: 30

Повинен розробник системи, системного компонента або системного сервісу виконувати аналіз вразливостей під час подальшого тестування та оцінювання системи, компонента або сервісу, що використовує <SA11(02)_ODP[01]_інформацію>

No: 5

Name: sa_11_2_b_01

Type: integer

Default: 30

Повинен розробник системи, компонента системи або системного сервісу виконувати моделювання загроз під час розробки системи, компонента або сервісу, що використовує засоби та методи

No: 6

Name: sa_11_2_b_02

Type: integer

Default: 30

Повинен розробник системи, компонента системи або системного сервісу виконувати моделювання загроз під час подальшого тестування та оцінювання системи, компонента або сервісу, що використовує інструменти та методи

No: 7

Name: sa_11_2_b_03

Type: integer

Default: 30

Повинен розробник системи, компонента системи або системної служби виконувати аналіз вразливостей під час розробки системи, компонента або служби, яка використовує інструменти та методи

No: 8

Name: sa_11_2_b_04

Type: integer

Default: 30

Повинен розробник системи, системного компонента або системного сервісу виконувати аналіз вразливостей під час подальшого тестування та оцінювання системи, компонента або сервісу, що використовує інструменти та методи

No: 9

Name: sa_11_2_c_01

Type: integer

Default: 30

Повинен розробник системи, системного компонента або системної служби виконувати моделювання загроз на широті та глибині під час розробки системи, компонента або сервісу

No: 10

Name: sa_11_2_c_02

Type: integer

Default: 30

Зобов'язаний розробник системи, компонента системи або системної служби виконувати аналіз вразливостей під час подальшого тестування та оцінювання системи, компонента або сервісу, який проводить моделювання та аналіз на ширину та глибину

No: 11

Name: sa_11_2_d_01

Type: integer

Default: 30

Повинен розробник системи, компонента системи або системної служби виконувати моделювання загроз під час розробки системи, компонента або сервісу, що дає змогу отримати докази, які відповідають критеріям прийнятності

No: 12

Name: sa_11_2_d_02

Type: integer

Default: 30

Повинен розробник системи, компонента системи або системної служби виконувати моделювання загроз під час подальшого тестування та оцінювання системи, компонента або сервісу, що дає змогу отримати докази, які відповідають критеріям прийнятності

No: 13

Name: sa_11_2_d_03

Type: integer

Default: 30

Повинен розробник системи, системного компонента або системної служби виконувати аналіз вразливостей під час розробки системи, компонента або служби, який надає докази, що відповідають прийнятності>

No: 14

Name: sa_11_2_d_04

Type: integer

Default: 30

Критеріям повинен розробник системи, системного компонента або системної служби виконувати аналіз вразливостей під час подальшого тестування та оцінювання системи, компонента або сервісу, який надає докази, що відповідають <SA11(02)_ODP[06] критеріям прийнятності

15.11.2. ATE_IND.2 EAL2 Незалежне тестування EAL3 Незалежне тестування — EAL4 EAL5 EAL6 зразок (SA-11(3))

No: 1

Name: sa_11_3_a_01

Type: integer

Default: 30

Потрібен незалежний агент, який відповідатиме критеріям незалежності для перевірки правильності виконання плану оцінки безпеки розробника та доказів, отриманих під час тестування та оцінки

No: 2

Name: sa_11_3_a_02

Type: integer

Default: 30

Потрібен незалежний агент, який відповідатиме критеріям незалежності для перевірки правильності виконання плану оцінювання конфіденційності розробника та доказів, отриманих під час тестування та оцінювання

No: 3

Name: sa_11_3_b

Type: string

Default: nil

Надано незалежному агенту достатньо інформації для завершення процесу перевірки, чи надано йому повноваження для отримання такої інформації

No: 4

Name: sa_11_3_odp

Type: list

Default: []

Визначені критерії незалежності, відповідати незалежний агент; яким повинен

15.11.3. Тестування та оцінювання розробника — Тестування на проникнення (SA-11(5))

No: 1

Name: sa_11_5_a_01

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної служби виконувати тестування на проникнення на наступному рівні суворості: ширина

No: 2

Name: sa_11_5_a_02

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної служби виконувати тестування на проникнення на наступному рівні суворості: глибина

No: 3

Name: sa_11_5_b

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної служби проводити тестування на проникнення в умовах <SA-11(05)_ODP[03]_обмежень>

15.11.4. Покриття Аналіз покриття (SA-11(7))

No: 1

Name: sa_11_7_01

Type: string

Default: nil

Повинен розробник системи, системного компонента або системної служби перевіряти, що обсяг тестування та оцінювання забезпечує повне покриття необхідних засобів контролю на ширину

No: 2

Name: sa_11_7_02

Type: string

Default: nil

Повинен розробник системи, системного компонента або системної служби перевіряти, що обсяг тестування та оцінювання забезпечує повне покриття необхідних засобів контролю на глибину

15.11.5. ДИНАМІЧНИЙ АНАЛІЗ КОДУ (SA-11(8))

No: 1

Name: sa_11_8_01

Type: string

Default: nil

Повинен розробник системи, системного компонента або системної служби використовувати інструменти динамічного аналізу коду для виявлення недоліків помилок

No: 2

Name: sa_11_8_02

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної служби документувати результати аналізу

15.12. КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SA-12)

No: 1

Name: sa_12_01

Type: integer

Default: 30

КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ [Вилучено: включено до SR]. SA12(1) КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ - СТРАТЕГІЇ, ІНСТРУМЕНТИ ТА МЕТОДИ ЗАКУПІВЕЛЬ [Вилучено: включено до SR-5]. SA12(2) КЕРУВАННЯ РИЗИКАМИ ПОСТАЧАЛЬНИКІВ [Вилучено: включено до SR-6]. SA12(3) КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ - НАДІЙНЕ ПЕРЕВЕЗЕННЯ ТА ЗБЕРІГАННЯ [Вилучено: включено до SR-3]. SA12(4) КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ДИВЕРСИФІКАЦІЯ ПОСТАЧАЛЬНИКІВ [Вилучено: включено до SR-3 (1)]. SA12(5) КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ - ОБМЕЖЕННЯ ШКОДИ [Вилучено: включено до SR-3 (2)]. SA12(6) КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ - МІНІМІЗАЦІЯ ЧАСУ ЗАКУПІВЕЛЬ [Вилучено: включено до SR-5 (1)]. SA12(7) КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ - ОЦІНЮВАННЯ ПЕРЕД ВИБОРОМ, ПРИЙНЯТТЯМ ТА ОНОВЛЕННЯМ [Вилучено: включено до SR-5 (2)]. SA12(8) КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ ВИКОРИСТАННЯ ВСЕБІЧНОЇ РОЗВІДУВАЛЬНОЇ ІНФОРМАЦІЇ [Вилучено: включено до SR-3 (2)]. ЛАНЦЮГА ПОСТАЧАННЯ - АНАЛІЗ ПОСТАЧАННЯ - SA12(9) КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ - ОПЕРАЦІЙНА БЕЗПЕКА [Вилучено: включено до SR-7]. SA12(10) КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ - ПЕРЕВІРКА НА СПРАВЖНІСТЬ І НЕЗМІНЕНІСТЬ [Вилучено: включено до SR-4 (3)]. SA12(11) КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ - ПЕРЕВІРКА НА СПРАВЖНІСТЬ І НЕЗМІНЕНІСТЬ [Вилучено: включено до SR-6 (1)]. SA12(12) КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ - УГОДИ ПРО ПОВІДОМЛЕННЯ [Вилучено: включено до SR-8]. SA12(13) КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ - КОМПОНЕНТИ КРИТИЧНИХ СИСТЕМ [Вилучено: включено до МА-6 та РА-9]. SA12(14) КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ - ІДЕНТИЧНІСТЬ ТА ПРОСТЕЖУВАНІСТЬ [Вилучено: включено до SR-4 (1) та SR-4(2)]. SA12(15) КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ - ПРОЦЕСИ ДЛЯ УСУНЕННЯ НЕДОЛІКІВ АБО ДЕФЕКТІВ [Вилучено: включено до SR-3]

15.13. ДОВІРЧИСТЬ (SA-13)

No: 1

Name: sa_13_01

Type: string

Default: nil

ДОВІРЧИСТЬ [Вилучено: включено до SA-8]

15.14. АНАЛІЗ КРИТИЧНОСТІ (SA-14)

No: 1

Name: sa_14_01

Type: string

Default: nil

АНАЛІЗ КРИТИЧНОСТІ [Вилучено: включено до RA-9]. SA14(1) КРИТИЧНІ КОМПОНЕНТИ БЕЗ ЖИТ-ТЄЗДАТНИХ АЛЬТЕРНАТИВНИХ ДЖЕРЕЛ [Вилучено: включено до SA-20]

15.15. ПРОЦЕСИ, СТАНДАРТИ ТА ІНСТРУМЕНТИ РОЗРОБКИ (SA-15)

a.

b. Вимагати від розробника системи, системного компонента або системної служби слідувати документованому процесу розробки, який:

1. явно відповідає вимогам безпеки та приватності;
2. визначає стандарти й інструменти, які використовуються в процесі розробки;
3. документує конкретні параметри та конфігурації інструментарію, що використовуються в процесі розробки;
4. документує, управляє та забезпечує цілісність змін у процесі та/або інструментах, які використовуються в процесі розробки. Ознайомитися з процесом розробки, стандартами, інструментами, параметрами інструментарію і конфігураціями інструментів [Призначення: визначена організацією частота], щоб визначити, чи можуть вибрані й використовувані процеси, стандарти, інструменти, параметри та конфігурації інструментів задовольнити [Призначення: визначені організацією вимоги до безпеки та приватності].

No: 1

Name: sa_15_odp_01

Type: string

Default: "щорічно"

Визначено періодичність перегляду процесу розробки, стандартів, інструментів, опцій інструментів та конфігурацій інструментів

No: 2

Name: sa_15_odp_02

Type: string

Default: nil

Визначені вимоги до безпеки, яким має відповідати процес, стандарти, інструменти, опції інструментів та конфігурації інструментів

No: 3

Name: sa_15_odp_03

Type: integer

Default: 30

Визначені вимоги до конфіденційності, яким має відповідати процес, стандарти, інструменти, опції інструментів та конфігурації інструментів; SA-15a.01[01] зобов'язаний розробник системи, системного компонента або системної служби дотримуватися задокументованого процесу розробки, який явно враховує вимоги безпеки; SA-15a.01[02] зобов'язаний розробник системи, системного компонента або системної служби дотримуватися задокументованого процесу розробки, який чітко враховує вимоги щодо конфіденційності; SA-15a.02[01] повинен розробник системи, системного компонента або системної служби дотримуватися задокументованого процесу розробки, який визначає стандарти, що використовуються в процесі розробки; SA-15a.02[02] повинен розробник системи, системного компонента або системного служби дотримуватися задокументованого процесу розробки, який визначає інструменти, що використовуються в процесі розробки; SA-15a.03[01] повинен розробник системи, системного компонента або системної служби дотримуватися задокументованого процесу розробки, який документує конкретний інструмент, що використовується в процесі розробки; SA-15a.03[02] повинен розробник системи, системного компонента або системної служби дотримуватися задокументованого процесу розробки, який документує конкретні конфігурації інструментів, що використовуються в процесі розробки; SA-15a.04

повинен розробник системи, системного компонента або системної служби дотримуватися задокументованого процесу розробки, який документує, управляє та забезпечує цілісність змін у процесі та/або інструментах, що використовуються під час розробки; SA-15b.[01] повинен розробник системи, системного компонента або системної служби дотримуватися задокументованого процесу розробки, в якому процес розробки, стандарти, інструменти, опції інструментів та конфігурації інструментів переглядаються з частотою, щоб визначити, що процес, стандарти, інструменти, опції інструментів та конфігурації інструментів, вибрані та застосовані, задовольняють вимоги безпеки; SA-15b.[02] повинен розробник системи, системного компонента або системної служби дотримуватися задокументованого процесу розробки, в якому процес розробки, стандарти, інструменти, опції інструментів та конфігурації інструментів переглядаються з частотою, щоб визначити, що процес, стандарти, інструменти, опції інструментів та конфігурації інструментів, обрані та застосовані, задовольняють вимоги щодо конфіденційності

15.15.1. ЗМЕНШЕННЯ ПОВЕРХНІ АТАКИ (SA-15(5))

No: 1

Name: sa_15_5_01

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної служби зменшити поверхню атаки до межі

No: 2

Name: sa_15_5_odp

Type: string

Default: nil

Визначені порогові значення, до яких необхідно зменшити поверхню атаки

15.15.2. ПОСТІЙНЕ ВДОСКОНАЛЕННЯ (SA-15(6))

No: 1

Name: sa_15_6_01

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної служби впроваджувати чіткий процес постійного вдосконалення процесу розробки

15.15.3. Співбесіда: [ВИБІР: Персонал організації, який відповідає за придбання систем та послуг; персонал організації, який відповідає за інформаційну ПРОЦЕС, СТАНДАРТИ ТА ІНСТРУМЕНТИ РОЗРОБКИ безпеку; розробник системи]. АНАЛІЗ ВРАЗЛИВОСТЕЙ АВТОМАТИЗОВАНИЙ (SA-15(7))

No: 1

Name: sa_15_7_a

Type: string

Default: "щорічно"

Зобов'язаний розробник системи, системного компонента або системного сервісу виконувати автоматизований аналіз вразливостей частота з використанням інструментарію

No: 2

Name: sa_15_7_b

Type: string

Default: "щорічно"

Зобов'язаний розробник системи, системного компоненту або системної служби визначати потенціал використання виявлених вразливостей частота

No: 3

Name: sa_15_7_c

Type: string

Default: "щорічно"

Повинен розробник системи, системного компоненту або системної служби визначати потенційні заходи зменшення ризику частота для наданих вразливостей

No: 4

Name: sa_15_7_d

Type: list

Default: ["admin", "security_officer"]

Повинен розробник системи, системного компонента або системної послуги надавати вихідні дані інструментів і результати аналізу частота персоналу або ролям

15.15.4. ПОВТОРНЕ ВИКОРИСТАННЯ ІНФОРМАЦІЇ ПРО ЗАГРОЗИ ТА ВРАЗЛИВОСТІ (SA-15(8))

No: 1

Name: sa_15_8_01

Type: string

Default: nil

Повинен розробниксистеми, системного компонента або системної служби використовувати моделювання загроз з подібних систем, компонентів або служб для інформування про поточний процес розробки

No: 2

Name: sa_15_8_02

Type: string

Default: nil

Повинен розробник системи, системного компонента або системних служб використовувати аналіз вразливостей аналогічних систем, компонентів або служб для інформування поточного процесу розробки

15.15.5. ПРОЦЕС, СТАНДАРТИ ТА ІНСТРУМЕНТИ ВИКОРИСТАННЯ РЕАЛЬНИХ ДАНИХ (SA-15(9))

No: 1

Name: sa_15_9_01

Type: string

Default: nil

ПРОЦЕС, СТАНДАРТИ ТА ІНСТРУМЕНТИ ВИКОРИСТАННЯ РЕАЛЬНИХ ДАНИХ [Вилучено: включено до SA-3(2)]

15.16. НАВЧАННЯ, ЩО НАДАЄТЬСЯ РОЗРОБНИКАМИ (SA-16)

Вимагати від розробника системи, системного компонента або системної служби забезпечити наступне навчання щодо правильного використання та функціонування реалізованих функцій, заходів і механізмів безпеки та приватності [Призначення: визначене організацією навчання].

No: 1

Name: sa_16_01

Type: string

Default: nil

Повинен розробник системи, системного компонента або системної служби проводити навчання щодо правильного використання та експлуатації впроваджених функцій, засобів управління та/або механізмів безпеки та приватності

No: 2

Name: sa_16_odp

Type: string

Default: nil

Визначено навчання щодо правильного використання та експлуатації впроваджених функцій безпеки та приватності, засобів контролю та/або механізмів, що надаються розробником системи, системного компонента або системної служби

15.17. ПРОЄКТ ТА АРХІТЕКТУРА РОЗРОБНИКА (SA-17)

Вимагати від розробника системи, системного компонента або системної служби створення специфікації проєкту та архітектури безпеки та приватності, яка:

- a. узгоджується з архітектурою безпеки та приватності організації яка є невід'ємною частиною корпоративної архітектури організації;
- b. точно та повністю описує необхідні функції безпеки та приватності, а також розподіл заходів захисту між фізичними та логічними компонентами;
- c. пояснює, як разом працюють окремі функції, механізми та служби безпеки для забезпечення необхідних можливостей безпеки та єдиного підходу до захисту.

No: 1

Name: sa_17_a_01

Type: integer

Default: 30

Повинен розробник системи, системного компонента або системної служби створювати специфікації проєкту та архітектури безпеки, які відповідають архітектурі безпеки організації, що є невід'ємною частиною архітектури підприємства організації

No: 2

Name: sa_17_a_02

Type: integer

Default: 30

Повинен розробник системи, системного компонента або системної служби створювати проєкту та архітектури безпеки приватності, які відповідають архітектурі приватності організації, що є невід'ємною частиною корпоративної архітектури організації

No: 3

Name: sa_17_b_01

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної служби підготувати специфікацію проєкту та архітектуру безпеки, які точно і повно описують необхідну функціональність безпеки та розподіл засобів контролю між фізичними та логічними компонентами

No: 4

Name: sa_17_b_02

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної служби підготувати специфікацію проєкту та архітектуру приватності, які точно і повно описують необхідну функціональність приватності та розподіл засобів контролю між фізичними та логічними компонентами

No: 5

Name: sa_17_c_01

Type: string

Default: "автоматизований засіб моніторингу"

Повинен розробник системи, системного компонента або системного сервісу створювати проєктну специфікацію та архітектуру безпеки, які описують, як окремі функції, механізми та сервіси безпеки працюють разом для забезпечення необхідних можливостей безпеки та єдиного підходу до захисту

No: 6

Name: sa_17_c_02

Type: string

Default: "автоматизований засіб моніторингу"

Повинен розробник системи, системного компонента або системної служби створювати специфікацію проєкту та архітектуру приватності, які описують, як окремі функції, механізми та служби конфіденційності працюють разом для забезпечення необхідних можливостей приватності та єдиного підходу до захисту

15.17.1. Проєкт і архітектура безпеки розробника — Формальна модель політики (SA-17(1))

No: 1

Name: sa_17_1_a_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Повинен розробник системи, системного компонента або системної служби, як невід'ємну частину процесу розробки, створювати формальну модель політики, що описує організаційну політику конфіденційності, яка підлягає виконанню

No: 2

Name: sa_17_1_b_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Повинен розробник системи, системного компонента або системної служби доводити, що формальна модель політики є внутрішньо узгодженою і достатньою для забезпечення дотримання визначених елементів політики безпеки організації при її впровадженні

No: 3

Name: sa_17_1_b_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Повинен розробник системи, системного компонента або системної служби доводити, що формальна модель політики є внутрішньо узгодженою і достатньою для забезпечення дотримання визначених елементів організаційної політики приватності при її впровадженні

15.17.2. Проект і архітектура безпеки розробника — Компоненти, що необхідні для забезпечення безпеки (SA-17(2))

No: 1

Name: sa_17_2_a_01

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної служби визначати апаратне забезпечення, що має відношення до безпеки

No: 2

Name: sa_17_2_a_02

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної служби визначати програмне забезпечення, що має відношення до безпеки; SA-17(02)(a)[03] зобов'язаний розробник системи, системного компонента або системної служби визначати мікропрограмне забезпечення, що мають відношення до безпеки

No: 3

Name: sa_17_2_b

Type: string

Default: nil

Повинен розробник системи, системного компонента або системної служби надавати обґрунтування того, що визначення обладнання, програмного забезпечення та мікропрограмного забезпечення, що мають відношення до безпеки, є повним

15.17.3. Проект і архітектура безпеки розробника — Формальна відповідність (SA-17(3))

No: 1

Name: sa_17_3_a_01

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної служби визначати апаратне забезпечення, що має відношення до безпеки

No: 2

Name: sa_17_3_a_02

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної служби визначати програмне забезпечення, що має відношення до безпеки

No: 3

Name: sa_17_3_a_03

Type: string

Default: nil

Зобов'язаний розробник системи, системного компонента або системної служби визначати мікропрограми, що мають відношення до безпеки

No: 4

Name: sa_17_3_b

Type: string

Default: nil

Повинен розробник системи, системного компонента або системної служби надавати обґрунтування того, що визначення обладнання, програмного забезпечення та мікропрограмного забезпечення, що мають відношення до безпеки, є повним

No: 5

Name: sa_17_3_c

Type: string

Default: nil

Повинен розробник системи, системного компонента або системної служби демонструвати за допомогою неформальної демонстрації, що формальна специфікація верхнього рівня повністю охоплює інтерфейси до обладнання, програмного забезпечення та мікропрограмного забезпечення, що мають відношення до безпеки

No: 6

Name: sa_17_3_d

Type: string

Default: nil

Повинен розробник системи, системного компонента або системної служби доводити, що формальна специфікація верхнього рівня є точним описом впровадженого обладнання, програмного забезпечення та мікропрограмного забезпечення, що мають відношення до безпеки

No: 7

Name: sa_17_3_e

Type: string

Default: "автоматизований засіб моніторингу"

Повинен розробник системи, системного компонента або системної служби описувати релевантні для безпеки апаратні, програмні та мікропрограмні механізми, які не розглядаються у формальній специфікації верхнього рівня, але є суто внутрішніми для релевантних для безпеки апаратних, програмних та мікропрограмних засобів

15.17.4. Проєкт і архітектура безпеки розробника — Неформальна відповідність (SA-17(4))

No: 1

Name: sa_17_4_a_01

Type: integer

Default: 30

Повинен розробник системи, системного компонента або системної служби, як невід'ємну частину процесу розробки, створювати неформальну описову специфікацію верхнього рівня, яка визначає інтерфейси до релевантного для безпеки апаратного, програмного та мікропрограмного забезпечення з точки зору винятків

No: 2

Name: sa_17_4_a_02

Type: integer

Default: 30

Повинен розробник системи, системного компонента або системної служби, як невід'ємну частину процесу розробки, створювати неформальну описову специфікацію верхнього рівня, яка визначає інтерфейси до релевантного для безпеки апаратного, програмного та мікропрограмного забезпечення в термінах повідомлень про помилки

No: 3

Name: sa_17_4_a_03

Type: integer

Default: 30

Повинен розробник системи, системного компонента або системної служби, як невід'ємну частину процесу розробки, створювати неформальну описову специфікацію верхнього рівня, яка визначає інтерфейси до релевантного для безпеки обладнання, програмного забезпечення та мікропрограмного забезпечення з точки зору наслідків

No: 4

Name: sa_17_4_c

Type: string

Default: nil

Повинен розробник системи, системного компонента або системної служби демонструвати за допомогою неформальної демонстрації, що описова специфікація верхнього рівня повністю охоплює інтерфейси до апаратного, програмного та мікропрограмного забезпечення, що мають відношення до безпеки

No: 5

Name: sa_17_4_d

Type: string

Default: nil

Повинен розробник системи, системного компонента або системної служби показувати, що описова специфікація верхнього рівня є точним описом інтерфейсів до релевантного для безпеки апаратного, програмного та мікропрограмного забезпечення

No: 6

Name: sa_17_4_e

Type: string

Default: "автоматизований засіб моніторингу"

Повинен розробник системи, системного компонента або системної служби описувати релевантні для безпеки апаратні, програмні та мікропрограмні механізми, які не розглядаються в описовій специфікації верхнього рівня, але є суто внутрішніми для релевантних для безпеки апаратних, програмних та мікропрограмних засобів

No: 7

Name: sa_17_4_odp

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРА: {неформальна описова специфікація, переконливий аргумент за допомогою формальних методів як можлива}

15.18. ЗАХИСТ ТА ВИЯВЛЕННЯ ПІДРОБКИ (SA-18)

No: 1

Name: sa_18_01

Type: string

Default: nil

ЗАХИСТ ТА ВИЯВЛЕННЯ ПІДРОБКИ [Вилучено: включено до SR-9]. SA18(1) ЗАХИСТ ТА ВИЯВЛЕННЯ ПІДРОБКИ - ЕТАПИ ЖИТТЄВОГО ЦИКЛУ РОЗРОБКИ СИСТЕМИ [Вилучено: включено до SR-9 (1)]. SA18(2) ЗАХИСТ ТА ВИЯВЛЕННЯ ПІДРОБКИ - ПЕРЕВІРКА СИСТЕМ АБО КОМПОНЕНТІВ [Вилучено: включено до SR-10]

15.19. СПРАВЖНІСТЬ КОМПОНЕНТА (SA-19)

No: 1

Name: sa_19_01

Type: string

Default: nil

СПРАВЖНІСТЬ КОМПОНЕНТА [Вилучено: включено до SR-11]. SA19(1) СПРАВЖНІСТЬ КОМПОНЕНТА ПІДРОБЛЕННЯМ [Вилучено: включено до SR-11 (1)]. SA19(2) СПРАВЖНІСТЬ КОМПОНЕНТА - УПРАВЛІННЯ КОНФІГУРАЦІЄЮ ДЛІЯ ОБСЛУГОВУВАННЯ ТА РЕМОНТУ КОМПОНЕНТІВ [Вилучено: включено до SR-11 (2)]. SA19(3) СПРАВЖНІСТЬ КОМПОНЕНТА - УТИЛІЗАЦІЯ КОМПОНЕНТІВ - НАВЧАННЯ БОРОТЬБИ З [Вилучено: включено до SR-12]. SA19(4) СПРАВЖНІСТЬ КОМПОНЕНТА - СКАНУВАННЯ НА ПІДРОБКУ [Вилучено: включено до SR-11 (3)]

15.20. ІНДИВІДУАЛЬНА РОЗРОБКА КРИТИЧНИХ КОМПОНЕНТІВ (SA-20)

Повторно реалізувати або налаштувати [Призначення: визначені організацією критичні компоненти системи].

No: 1

Name: sa_20_01

Type: string

Default: nil

Критична система повторно реалізувати або налаштувати на замовлення

No: 2

Name: sa_20_odp

Type: string

Default: nil

Потрібно повторно реалізувати або налаштувати на замовлення критичні компоненти системи

15.21. ПЕРЕВІРКА РОЗРОБНИКА (SA-21)

Вимагати, щоб розробник [Призначення: визначених організацією системи, компонент системи або послуги]:

- a. мав відповідні дозволи доступу, як визначено призначеним [Призначення: визначеним організацією уповноваженим органом];
- b. відповідає таким додатковим критеріям перевірки персоналу: [Призначення: визначені організацією додаткові критерії перевірки персоналу].

No: 1

Name: sa_21_odp_01

Type: string

Default: nil

Визначена система, компонент системи або системна служба, до яких має доступ розробник

No: 2

Name: sa_21_odp_02

Type: string

Default: nil

Визначені офіційні обов'язки, покладені на розробника

No: 3

Name: sa_21_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначені додаткові розробників; SA-21a. повинен розробник системи, системного компонента або системної служби мати відповідні повноваження доступу, як визначено призначеними уповноваженим органом організації; SA-21b. повинен розробник системи, системного компонента або системної служби відповідати додатковим критеріям перевірки персоналу. критерії перевірки персоналу

15.22. КОМПОНЕНТИ СИСТЕМИ, ЩО НЕ ПІДТРИМУЮТЬСЯ (SA-22)

- a. Замінювати компоненти системи, якщо підтримка компонентів більше не доступна розробнику, постачальнику або виробнику.
- b. Надавати такі варіанти альтернативних джерел для подальшої підтримки непідтримуваних компонентів [Вибір (один або більше): внутрішня підтримка; [Призначення: підтримка, визначена організацією від зовнішніх постачальників]].

No: 1

Name: sa_22_odp_01

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {внутрішня підтримка; підтримка від зовнішніх постачальників}

15.23. СПЕЦІАЛІЗАЦІЯ (SA-23)

Покращення [Вибір (один або кілька): проектування; модифікація; збільшення; реконфігурація] на [Призначення: системи або системні компоненти, визначені організацією], які підтримують важливі служби або функції для підвищення надійності цих систем або компонентів.

No: 1

Name: sa_23_odp_01

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {модифікація дизайну; доповнення; реконфігурація}

No: 2

Name: sa_23_odp_02

Type: string

Default: nil

Визначені системи або компоненти системи, підтримують важливі для місії послуги або функції

16. SC

Клас заходів захисту SC — ЗАХИСТ ІНФОРМАЦІЙНОЇ СИСТЕМИ ТА

Цей клас охоплює механізми захисту інформації під час її передачі мережами зв'язку, криптографічний захист та ізоляцію критичних компонентів.

Перелік заходів захисту: Політика та процедури захисту системи та комунікацій (SC-1); Розділення функцій (SC-2); Інтерфейси для непривілейованих користувачів (SC-2(1)); Відокремлення (SC-2(2)); Ізоляція функцій безпеки (SC-3); Ізоляція функцій забезпечення (SC-3(1)); Функції управління доступом та потоком (SC-3(2)); Мінімізація функціональності (SC-3(3)); Ізоляція функцій зв'язності (SC-3(4)); Багаторівнева структура (SC-3(5)); Інформація в загальних системних ресурсах (SC-4); Рівні безпеки (SC-4(1)); Інформація в загальних системних багаторівнева або періодична обробка (SC-4(2)); Захист від атак «відмова в обслуговуванні» (SC-5); Обмеження внутрішніх користувачів (SC-5(1)); Захист від атак «відмова в обслуговуванні» продуктивність, пропускна здатність та надмірність (SC-5(2)); Виявлення та моніторинг (SC-5(3)); Доступність ресурсів (SC-6); Доступність ресурсів (SC-7); Фізично відділені підмережі (SC-7(1)); Публічний доступ (SC-7(2)); Точки доступу (SC-7(3)); Зовнішні комунікаційні служби (SC-7(4)); Відмова за замовчуванням - дозвіл за винятком (SC-7(5)); Відповідь на розпізнані помилки (SC-7(6)); Запобігання поділу тунелювання для віддалених пристроїв (SC-7(7)); Захист периметра - маршрутизація автентифікованих проксі-серверів (SC-7(8)); Захист (SC-7(9)); Ізольовані від інших внутрішніх компонентів системи шляхом впровадження фізично відокремлених підмереж з керованими інтерфейсами до інших компонентів системи (SC-7(13)); Конфіденційність та цілісність передачі (SC-8); Конфіденційність та цілісність криптографічний захист повідомлень (SC-8(3)); Приховування або рандомізація комунікації (SC-8(4)); Конфіденційність та система розподілу (SC-8(5)); Конфіденційність передачі (SC-9); Відключення мережі (SC-10); Довірений канал зв'язку (SC-11); Встановлення ключами (SC-12); Криптографічний захист (SC-13); Захист громадського доступу (SC-14); Спільні обчислювальні пристрої та застосунки (SC-15); Передача атрибутів безпеки та приватності (SC-16); Сертифікати інфраструктури відкритих ключів (SC-17); Мобільний код (SC-18); Інтернет-протокол голосового зв'язку (SC-19); БЕЗПЕЧНА СЛУЖБА ІМЕН, АДРЕС (УПОВНОВАЖЕНЕ ДЖЕРЕЛО) (SC-20); БЕЗПЕЧНА СЛУЖБА ІМЕН, АДРЕС (УПОВНОВАЖЕНЕ ДЖЕРЕЛО) ДЖЕРЕЛО ДАНИХ ТА ЦІЛІСНІСТЬ (SC-21); (рекурсивний або джерело даних та (SC-22); Автентифікація сесії (SC-23); Уведення у відомий стан (SC-24); Тонкі вузли (SC-25); ПРИМАНКА ДЛЯ ЗЛОВМИСНИКІВ (DECOYS) (SC-26); Незалежні від платформи застосунки (SC-27); Захист інформації в стані спокою (SC-28); ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ | КРИПТОГРАФІЧНИЙ ЗАХИСТ; Гетерогенність (SC-29); Маскування та хибний напрям (SC-30); Аналіз прихованого каналу (SC-31); Поділ системи на частини (SC-32); Підготовка цілісності передачі (SC-33); Незмінювані виконавчі програми (SC-34); РОЗПІЗНАВАННЯ ПРИМАНОК ДЛЯ ЗЛОВМИСНИКІВ (HONEYCLIENT) (SC-35); Розподілена обробка та зберігання (SC-36); Позасмугові канали (SC-37); Безпека операцій (SC-38); Ізоляція процесу (SC-39); Захист бездротового з'єднання (SC-40); Доступ до портів та пристроїв введення, виведення (SC-41); Захист бездротового з'єднання доступ до портів і пристроїв введення/виведення можливості датчика та дані (SC-42); Обмеження використання (SC-43); Екрановані камери (SC-44); Синхронізація системи з часом (SC-45); Забезпечення виконання міждоменої політики (SC-46); Альтернативний шлях зв'язку (SC-47); Переміщення датчика (SC-48); Динамічно переміщуються до за (SC-48(1)); Примусове апаратне забезпечення виконання (SC-49); Примусове програмне забезпечення виконання (SC-50); Апаратний захист (SC-51).

16.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ЗАХИСТУ СИСТЕМИ ТА КОМУНІКАЦІЙ (SC-1)

a. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посадових осіб]:

1. 2. Політику захисту системи та комунікацій, яка:

(a) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance);

(b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам та керівним принципам. Процедури для сприяння впровадженню політики в області захисту систем і комунікацій, а також пов'язаних з ними систем і засобів захисту зв'язку.

b. Призначити [Призначення: визначена організацією посадову особу] для управління політикою та процедурами захисту системи та комунікацій.

c. Переглядати та оновлювати:

1. поточну політику захисту системи та комунікацій [Призначення: визначена організацією частота];

2. поточні процедури захисту системи та комунікацій [Призначення: визначена організацією частота].

No: 1

Name: sc_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких має бути доведена політика захисту системи та комунікацій

No: 2

Name: sc_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури захисту системи та комунікацій

No: 3

Name: sc_1_odp_03

Type: string

Default: nil

Вибрано жодне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: sc_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами захисту системи та комунікацій

No: 5

Name: sc_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначена періодичність перегляду та оновлення поточної політики захисту системи та комунікацій

No: 6

Name: sc_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Є події, які вимагають перегляду та оновлення поточної політики захисту системи та комунікацій

No: 7

Name: sc_1_odp_07

Type: string

Default: "щорічно"

Визначена періодичність перегляду та оновлення поточних процедур захисту системи та засобів зв'язку

16.2. РОЗДІЛЕННЯ ФУНКЦІЙ (SC-2)

Розділяти функціональність користувача, включно зі службами, що призначені для користувача інтерфейсу, від функціональності системного управління.

No: 1

Name: sc_2_01

Type: string

Default: nil

Розділена функціональність користувача, включаючи сервіси користувацького інтерфейсу, від функціональності управління системою. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

16.2.1. ІНТЕРФЕЙСИ ДЛЯ НЕПРИВІЛЕЙОВАНИХ КОРИСТУВАЧІВ (SC-2(1))

No: 1

Name: sc_2_1_01

Type: string

Default: nil

Запобігається представлення функціональності управління системою в інтерфейсі непривілейованим користувачам

16.2.2. ВІДОКРЕМЛЕННЯ (SC-2(2))

No: 1

Name: sc_2_2_01

Type: string

Default: nil

Зберігається інформація окремо від додатків та програмного забезпечення

16.3. ІЗОЛЯЦІЯ ФУНКЦІЙ БЕЗПЕКИ (SC-3)

Ізолювати функції безпеки від інших функцій.

No: 1

Name: sc_3_01

Type: string

Default: nil

Ізольовані функції безпеки від інших функцій

16.3.1. ІЗОЛЯЦІЯ ФУНКЦІЙ ЗАБЕЗПЕЧЕННЯ (SC-3(1))

No: 1

Name: sc_3_1_01

Type: string

Default: "автоматизований засіб моніторингу"

Застосовуються механізми розділення апаратних засобів для реалізації ізоляції функцій безпеки

16.3.2. ФУНКЦІЇ УПРАВЛІННЯ ДОСТУПОМ ТА ПОТОКОМ (SC-3(2))

No: 1

Name: sc_3_2_01

Type: string

Default: nil

Ізольовані функції безпеки, що забезпечують управління доступом, які не пов'язані з безпекою

No: 2

Name: sc_3_2_02

Type: string

Default: nil

Ізольовані функції безпеки, що забезпечують контроль доступу, від інших функцій безпеки

No: 3

Name: sc_3_2_03

Type: string

Default: nil

Ізольовані функції безпеки, які не пов'язані з безпекою забезпечують контроль інформаційних потоків

No: 4

Name: sc_3_2_04

Type: string

Default: nil

Ізольовані функції безпеки, що забезпечують контроль інформаційних потоків, від інших функцій безпеки

16.3.3. МІНІМІЗАЦІЯ ФУНКЦІОНАЛЬНОСТІ (SC-3(3))

No: 1

Name: sc_3_3_01

Type: integer

Default: 3

Мінімізовано кількість функцій, не пов'язаних з безпекою, що входять до сфери ізоляції, яка містить функції безпеки

16.3.4. ІЗОЛЯЦІЯ ФУНКЦІЙ ЗВ'ЯЗНІСТЬ (SC-3(4))

No: 1

Name: sc_3_4_02

Type: string

Default: nil

Реалізовані функції безпеки як значною мірою незалежні модулі, які мінімізують зв'язок між модулями

16.3.5. БАГАТОРІВНЕВА СТРУКТУРА (SC-3(5))

No: 1

Name: sc_3_5_01

Type: string

Default: nil

Реалізовані функції безпеки як багаторівнева структура, що мінімізує взаємодію між шарами дизайну та уникає будь-якої залежності нижчих шарів від функціональності або коректності вищих шарів

16.4. ІНФОРМАЦІЯ В ЗАГАЛЬНИХ СИСТЕМНИХ РЕСУРСАХ (SC-4)

Запобігати несанкціонованій та ненавмисній передачі інформації через спільні системні ресурси.

No: 1

Name: sc_4_01

Type: string

Default: nil

Запобігається несанкціонована передача інформації через спільні системні ресурси

No: 2

Name: sc_4_02

Type: string

Default: nil

Запобігається ненавмисна передача інформації через спільні системні ресурси. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

16.4.1. РІВНІ БЕЗПЕКИ (SC-4(1))

No: 1

Name: sc_4_1_01

Type: string

Default: nil

ІНФОРМАЦІЯ В ЗАГАЛЬНИХ СИСТЕМНИХ РЕСУРСАХ - РІВНІ БЕЗПЕКИ [Вилучено: включено до SC-4]

16.4.2. ІНФОРМАЦІЯ В ЗАГАЛЬНИХ СИСТЕМНИХ БАГАТОРІВНЕВА АБО ПЕРІОДИЧНА ОБРОБКА (SC-4(2))

No: 1

Name: sc_4_2_01

Type: string

Default: nil

Запобігається несанкціонована передача інформації через спільні ресурси відповідно до процедур, коли системна обробка явно перемикається між різними рівнями класифікації інформації або категоріями безпеки

No: 2

Name: sc_4_2_odp

Type: string

Default: nil

Визначені процедури для запобігання несанкціонованій передачі інформації через спільні ресурси

16.5. ЗАХИСТ ВІД АТАК «ВІДМОВА В ОБСЛУГОВУВАННІ» (SC-5)

- a. [Призначення: захистити від; Обмежити] наслідки наступних типів подій відмови в обслуговуванні (DoS): [Призначення: визначені організацією типи подій відмови в обслуговуванні];
- b. Застосувати наступні заходи захисту для досягнення мети відмови обслуговування [Призначення: заходи захисту визначені організацією, за типом події відмови в обслуговуванні].

No: 1

Name: sc_5_odp_01

Type: string

Default: nil

Визначені типи подій відмов в обслуговуванні, від яких потрібно захищати або обмежувати; SC-05_ODP[02] вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {захистити від; обмежити}

16.5.1. ОБМЕЖЕННЯ ВНУТРІШНІХ КОРИСТУВАЧІВ (SC-5(1))

No: 1

Name: sc_5_1_01

Type: string

Default: nil

Обмежена можливість окремих осіб здійснювати атаки на відмову в обслуговуванні проти інших систем

No: 2

Name: sc_5_1_odp

Type: list

Default: ["admin", "security_officer"]

Визначені атаки на відмову в обслуговуванні, для яких необхідно обмежити можливість їх запуску окремими особами

16.5.2. ЗАХИСТ ВІД АТАК «ВІДМОВА В ОБСЛУГОВУВАННІ» ПРОДУКТИВНІСТЬ, ПРОПУСКНА ЗДАТНІСТЬ ТА НАДМІРНІСТЬ (SC-5(2))

No: 1

Name: sc_5_2_01

Type: string

Default: nil

Здійснюється управління ємністю, пропускну здатністю або іншими надлишковими ресурсами для обмеження наслідків інформаційних атак на відмову в обслуговуванні

16.5.3. ВИЯВЛЕННЯ ТА МОНІТОРИНГ (SC-5(3))

No: 1

Name: sc_5_3_a

Type: string

Default: "автоматизований засіб моніторингу"

Використовуються засоби моніторингу для виявлення ознак атак на відмову в обслуговуванні, спрямованих на систему або запущених з неї

No: 2

Name: sc_5_3_b

Type: string

Default: nil

Здійснюється моніторинг системних ресурсів для визначення наявності достатніх ресурсів для запобігання ефективним атакам на відмову в обслуговуванні

16.6. ДОСТУПНІСТЬ РЕСУРСІВ (SC-6)

Забезпечити захист доступності ресурсів, виділивши [Призначення: визначені організацією ресурси], по [Вибір (один або кілька); пріоритет; квоти; [Призначення: визначені організацією заходи з безпеки]].

No: 1

Name: sc_6_01

Type: string

Default: nil

Захищено доступність ресурсів шляхом розподілу ресурсів за ВИБІРКОВИМ ЗНАЧЕННЯМ ПАРАМЕТРА(iv)

No: 2

Name: sc_6_odp_01

Type: string

Default: nil

Визначені ресурси, які необхідно виділити для захисту доступності ресурсів

No: 3

Name: sc_6_odp_02

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {priority; quota; controls}

No: 4

Name: sc_6_odp_03

Type: string

Default: "автоматизований засіб моніторингу"

Визначені засоби контролю для захисту доступності ресурсів (якщо вибрано)

16.7. ДОСТУПНІСТЬ РЕСУРСІВ (SC-7)

а. Контролювати та управляти зв'язком на зовнішньому периметрі системи та на ключових внутрішніх периметрах всередині системи.

б. Реалізувати підмережі для загальнодоступних компонентів системи, які є [Вибір: фізично;

логічно] відділені від внутрішніх мереж організації.

с. Підключатися до зовнішніх мереж або систем тільки через керовані інтерфейси, що складаються з пристроїв захисту периметру, і розташованих відповідно до архітектури безпеки та приватності організації.

Немає параметрів для цього контролю.

16.7.1. ФІЗИЧНО ВІДДІЛЕНІ ПІДМЕРЕЖІ (SC-7(1))

No: 1

Name: sc_7_1_01

Type: string

Default: nil

ЗАХИСТ ПЕРИМЕТРА - ФІЗИЧНО ВІДДІЛЕНІ ПІДМЕРЕЖІ [Вилучено: включено до SC-7]]

16.7.2. ПУБЛІЧНИЙ ДОСТУП (SC-7(2))

No: 1

Name: sc_7_2_01

Type: string

Default: nil

ЗАХИСТ ПЕРИМЕТРА - ПУБЛІЧНИЙ ДОСТУП [Вилучено: включено до SC-7]]

16.7.3. ТОЧКИ ДОСТУПУ (SC-7(3))

No: 1

Name: sc_7_3_01

Type: integer

Default: 3

Обмежена кількість зовнішніх мережових підключень до системи

16.7.4. ЗОВНІШНІ КОМУНІКАЦІЙНІ СЛУЖБИ (SC-7(4))

No: 1

Name: sc_7_4_a

Type: string

Default: nil

Реалізовано керований інтерфейс для кожної зовнішньої телекомунікаційної послуги

No: 2

Name: sc_7_4_b

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Встановлена політика потоку трафіку для кожного керованого інтерфейсу

No: 3

Name: sc_7_4_c_01

Type: string

Default: nil

Захищена конфіденційність інформації, що передається через кожен інтерфейс

No: 4

Name: sc_7_4_c_02

Type: string

Default: nil

Захищена цілісність інформації, що передається через кожен інтерфейс

No: 5

Name: sc_7_4_d

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Задokumentовано кожен виняток з політики управління трафіком з обґрунтуванням місії або бізнес-потреби, а також тривалості такої потреби

No: 6

Name: sc_7_4_e_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Переглядаються винятки з політики потоку трафіку частота

No: 7

Name: sc_7_4_e_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Потрібно видалити винятки з політики потоку трафіку, які більше не підтримуються чітко визначеною місією або бізнеспотребою

No: 8

Name: sc_7_4_f

Type: string

Default: nil

Запобігається несанкціонований обмін управління із зовнішніми мережами

No: 9

Name: sc_7_4_g

Type: string

Default: nil

Публікується інформація, яка дозволяє віддаленим мережам виявляти несанкціонований трафік площини керування з внутрішніх мереж

No: 10

Name: sc_7_4_h

Type: string

Default: nil

Фільтрується несанкціонований трафік з зовнішніх мереж. трафіком плану

No: 11

Name: sc_7_4_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено періодичність перегляду винятків з політики управління інформаційними потоками

16.7.5. ВІДМОВА ЗА ЗАМОВЧУВАННЯМ - ДОЗВІЛ ЗА ВИНЯТКОМ (SC-7(5))

Немає параметрів для цього контролю.

16.7.6. ВІДПОВІДЬ НА РОЗПІЗНАНІ ПОМИЛКИ (SC-7(6))

No: 1
Name: sc_7_6_01
Type: string
Default: nil

ЗАХИСТ ПЕРИМЕТРА - ВІДПОВІДЬ НА РОЗПІЗНАНІ ПОМИЛКИ [Вилучено: включено до SC-7(18)]

16.7.7. ЗАПОБІГАННЯ ПОДІЛУ ТУНЕЛЮВАННЯ ДЛЯ ВІДДАЛЕНИХ ПРИСТРОЇВ (SC-7(7))

No: 1
Name: sc_7_7_01
Type: string
Default: "автоматизований засіб моніторингу"

Запобігається розділеному тунелюванню для віддалених пристроїв, що підключаються до систем організації, якщо розділене тунелюванню не захищено за допомогою засоби захисту

No: 2
Name: sc_7_7_odp
Type: string
Default: nil

Визначені гарантії безпечного прокладання розділеному тунелюванню

16.7.8. ЗАХИСТ ПЕРИМЕТРА -МАРШРУТИЗАЦІЯ АВТЕНТИФІКОВАНИХ ПРОКСІ-СЕРВЕРІВ (SC-7(8))

No: 1
Name: sc_7_8_01
Type: string
Default: nil

SC-07(08) _ODP[01] внутрішній комунікаційний трафік> спрямовується до <SC-07(08) _ODP[02] зовнішніх мереж> через автентифіковані проксі-сервери на керованих інтерфейсах

16.7.9. ЗАХИСТ (SC-7(9))

No: 1
Name: sc_7_9_a_01
Type: string
Default: nil

Виявлено вихідний комунікаційний трафік, що становить загрозу для зовнішніх систем

No: 2
Name: sc_7_9_a_02

Type: string

Default: nil

Заборонено вихідний комунікаційний трафік, що становить загрозу для зовнішніх систем

No: 3

Name: sc_7_9_b

Type: string

Default: nil

Перевіряється ідентичність внутрішніх пов'язаних з відмовою у зв'язку користувачів,

16.7.10. ІЗОЛЬОВАНИ ВІД ІНШИХ ВНУТРІШНІХ КОМПОНЕНТІВ СИСТЕМИ ШЛЯХОМ ВПРОВАДЖЕННЯ ФІЗИЧНО ВІДОКРЕМЛЕНИХ ПІДМЕРЕЖ З КЕРОВАНИМИ ІНТЕРФЕЙСАМИ ДО ІНШИХ КОМПОНЕНТІВ СИСТЕМИ (SC-7(13))

No: 1

Name: sc_7_13_01

Type: string

Default: "автоматизований засіб моніторингу"

Ізольовані засоби, механізми та компоненти підтримки інформаційної безпеки від інших внутрішніх компонентів системи шляхом впровадження фізично відокремлених підмереж з керованими інтерфейсами до інших компонентів системи

No: 2

Name: sc_7_13_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначені інструменти, механізми та компоненти підтримки інформаційної безпеки, які мають бути ізольовані від інших внутрішніх компонентів системи

16.8. КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ ПЕРЕДАЧІ (SC-8)

Забезпечити [Вибір (один або кілька): конфіденційність; цілісність] інформації, що передається.

Немає параметрів для цього контролю.

16.8.1. КОНФІДЕНЦІЙНІСТЬ ТА КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-8(1))

No: 1

Name: sc_8_1_odp

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {запобігти несанкціонованому розголошенню інформації; виявити зміни в інформації}

16.8.2. ПОПЕРЕДНЯ І ПОСТОБРОБКА (SC-8(2))

No: 1

Name: sc_8_2_01

Type: string

Default: nil

КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ ПЕРЕДАЧІ - ПОПЕРЕДНЯ І ПОСТОБРОБКА МЕТА ОЦІНКИ:
Визначити, чи:

No: 2

Name: sc_8_2_odp

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {конфіденційність; цілісність}

16.8.3. КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ КРИПТОГРАФІЧНИЙ ЗАХИСТ ПОВІДОМЛЕНЬ (SC-8(3))

No: 1

Name: sc_8_3_01

Type: string

Default: "AES-256-GCM"

Впроваджено криптографічні механізми для захисту зовнішніх повідомлень, якщо інше не захищено альтернативні фізичні засоби контролю

No: 2

Name: sc_8_3_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначено альтернативні фізичні засоби контролю для захисту зовнішніх повідомлень

16.8.4. ПРИХОВУВАННЯ АБО РАНДОМІЗАЦІЯ КОМУНІКАЦІЇ (SC-8(4))

No: 1

Name: sc_8_4_01

Type: string

Default: "AES-256-GCM"

Застосовуються криптографічні механізми для приховування або рандомізації шаблонів комунікації, якщо інше не захищено альтернативні фізичні засоби контролю

No: 2

Name: sc_8_4_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначені альтернативні фізичні засоби контролю для захисту від несанкціонованого розкриття шаблонів комунікації

16.8.5. КОНФІДЕНЦІЙНІСТЬ ТА СИСТЕМА РОЗПОДІЛУ (SC-8(5))

Немає параметрів для цього контролю.

16.9. КОНФІДЕНЦІЙНІСТЬ ПЕРЕДАЧІ (SC-9)

No: 1

Name: sc_9_01

Type: string

Default: nil

КОНФІДЕНЦІЙНІСТЬ ПЕРЕДАЧІ [Вилучено: включено до SC-8]

16.10. ВІДКЛЮЧЕННЯ МЕРЕЖІ (SC-10)

Завершити з'єднання з мережею, яке пов'язане із сеансом зв'язку в кінці сеансу або після [Призначення: визначений організацією період часу] бездіяльності.

No: 1

Name: sc_10_odp

Type: integer

Default: 30

Визначено період бездіяльності, після якого система розриває мережеве з'єднання, пов'язане з сеансом зв'язку; SC08(05)_ODP[02] мережеве з'єднання, пов'язане з сеансом зв'язку, розірвано в кінці сеансу або після період часу бездіяльності

16.11. ДОВІРЕНИЙ КАНАЛ ЗВ'ЯЗКУ (SC-11)

- a. Надати [Вибір: фізично; логічно] ізолюваний надійний канал зв'язку для зв'язку між користувачем і довіреними компонентами системи.
- b. Дозволити користувачам запросити довірений канал зв'язку для обміну даними між користувачем і наступними функціями безпеки системи, включно з, як мінімум, автентифікацією та повторною автентифікацією: [Призначення: визначені організацією функції безпеки].

No: 1

Name: sc_11_odp_01

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {фізично; логічно}

16.12. ВСТАНОВЛЕННЯ КЛЮЧАМИ (SC-12)

Встановити та управляти криптографічними ключами для криптографічних засобів, які використовуються в системі відповідно до [Призначення: визначені організацією вимоги до генерації, поширення, зберігання, доступу та знищення ключів].

No: 1

Name: sc_12_01

Type: string

Default: "AES-256-GCM"

Встановлюються криптографічні ключі, коли в системі використовується криптографія відповідно до < SC-12_ ODP вимог >

No: 2

Name: sc_12_02

Type: string

Default: "AES-256-GCM"

Здійснюється управління криптографічними ключами, коли в системі використовується криптографія, відповідно до вимог

No: 3

Name: sc_12_odp

Type: string

Default: nil

Визначені вимоги до генерації, розповсюдження, зберігання, доступу та знищення ключів

16.13. КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-13)

- a. Визначити [Призначення: використання криптографічних засобів, визначених організацією];
- b. Впровадити [Завдання: визначені організацією види криптографії для кожного визначеного криптографічного використання].

No: 1

Name: sc_13_01

Type: string

Default: "AES-256-GCM"

КРИПТОГРАФІЧНИЙ ЗАХИСТ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: sc_13_odp_01

Type: string

Default: "AES-256-GCM"

Визначено використання криптографічних засобів

No: 3

Name: sc_13_odp_02

Type: string

Default: "AES-256-GCM"

Визначено типи криптографії для кожного вказаного криптографічного використання; SC-13a. ідентифіковано використання>; SC-13b. реалізовано типи криптографії для кожного вказаного криптографічного використання (визначеного в SC-13_ ODP[01]). криптографічне <SC-13_ ODP[01]

16.14. ЗАХИСТ ГРОМАДСЬКОГО ДОСТУПУ (SC-14)

No: 1

Name: sc_14_01

Type: string

Default: nil

ЗАХИСТ ГРОМАДСЬКОГО ДОСТУПУ [Вилучено: включено до AC-2, AC-3, AC-5, AC-6, SI-3, SI-4, SI-5, SI-7, SI-10]

16.15. СПІЛЬНІ ОБЧИСЛЮВАЛЬНІ ПРИСТРОЇ ТА ЗАСТОСУНКИ (SC-15)

а. Заборонити віддалену активацію спільних обчислювальних пристроїв (хмар) та застосунків з такими виключеннями: [Призначення: визначені організацією виключення, у яких дозволена віддалена активація].

б. Надати явну вказівку щодо використання користувачами фізично присутніми пристроями.

Немає параметрів для цього контролю.

16.16. ПЕРЕДАЧА АТРИБУТІВ БЕЗПЕКИ ТА ПРИВАТНОСТІ (SC-16)

Пов'язувати [Призначення: визначені організацією атрибути безпеки та приватності] з інформацією, яка передається між системами та компонентами системи.

No: 1

Name: sc_16_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Пов'язані атрибути інформацією, якою обмінюються системи; безпеки з

No: 2

Name: sc_16_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Пов'язані атрибути безпеки інформацією, якою обмінюються компоненти системи; з

No: 3

Name: sc_16_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Пов'язані атрибути приватності інформацією, якою обмінюються системи; з

No: 4

Name: sc_16_04

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Пов'язані атрибути приватності інформацією, якою обмінюються компоненти системи. з

No: 5

Name: sc_16_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначені атрибути безпеки, які будуть пов'язані з інформацією, що обмінюється

No: 6

Name: sc_16_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначені атрибути приватності, які будуть пов'язані з інформацією, що обмінюється

16.17. СЕРТИФІКАТИ ІНФРАСТРУКТУРИ ВІДКРИТИХ КЛЮЧІВ (SC-17)

- a. Випускати сертифікати відкритого ключа відповідно до [Призначення: визначеної організацією політики сертифікації];
- b. Отримувати сертифікати відкритого ключа від затвердженого постачальника послуг.

Немає параметрів для цього контролю.

16.18. МОБІЛЬНИЙ КОД (SC-18)

- a. Визначати прийнятні та неприйнятні мобільні коди та технології мобільних кодів.
- b. Проводити авторизацію, відстежувати та контролювати використання мобільного коду всередині системи.

Немає параметрів для цього контролю.

16.19. ІНТЕРНЕТ-ПРОТОКОЛ ГОЛОСОВОГО ЗВ'ЯЗКУ (SC-19)

No: 1

Name: sc_19_01

Type: string

Default: "TLS 1.3"

ІНТЕРНЕТ-ПРОТОКОЛ ГОЛОСОВОГО ЗВ'ЯЗКУ [Вилучено: залежить від технології; розглядається як будь-яка інша технологія або протокол]

16.20. БЕЗПЕЧНА СЛУЖБА ІМЕН, АДРЕС (УПОВНОВАЖЕНЕ ДЖЕРЕЛО) (SC-20)

- a. Надати додаткові дані автентифікації та перевірки цілісності джерела даних разом з офіційними даними розпізнавання імен, які система повертає у відповідь на запити дозволу імен/адрес.
- b. Надати засоби для вказання статусу безпеки дочірніх зон і (якщо дочірня зона підтримує служби безпечного дозволу) забезпечити перевірку ланцюга довіри між батьківськими та дочірніми доменами при роботі в складі розподіленого ієрархічного простору імен.

Немає параметрів для цього контролю.

16.21. БЕЗПЕЧНА СЛУЖБА ІМЕН, АДРЕС (УПОВНОВАЖЕНЕ ДЖЕРЕЛО) ДЖЕРЕЛО ДАНИХ ТА ЦІЛІСНІСТЬ (SC-21)

Зробити запит та виконати перевірку автентичності джерела даних і перевірку цілісності даних у відповідях на дозвіл імен/адрес, які система отримує від уповноважених джерел.

No: 1
Name: sc_21_01
Type: string
Default: nil

Реалізується запит перевірки автентичності джерела даних для відповідей на запит дозволу імен/адрес, які система отримує від авторитетних джерел

No: 2
Name: sc_21_02
Type: string
Default: nil

Реалізується запит автентифікація походження даних на основі відповідей з дозволу імен/адрес, які система отримує від авторитетних джерел

No: 3
Name: sc_21_03
Type: string
Default: nil

Реалізується запит перевірки цілісності даних для відповідей на запит дозволу імен/адрес, які система отримує від авторитетних джерел

No: 4
Name: sc_21_04
Type: string
Default: nil

Виконується перевірка цілісності даних для відповідей на запит про дозвіл імен/адрес, які система отримує від авторитетних джерел

16.22. (РЕКУРСИВНИЙ АБО ДЖЕРЕЛО ДАНИХ ТА (SC-22)

Переконатися, що системи, які спільно надають послуги розпізнавання імен/адрес для організації, є відмовостійкими та забезпечують поділ внутрішніх і зовнішніх ролей.

No: 1
Name: sc_22_01
Type: string
Default: nil

Є системи, які спільно надають послуги з визначення імен/адрес для організації, відмовостійкими

No: 2
 Name: sc_22_02
 Type: string
 Default: nil

Реалізовано в системах, які спільно надають послуги з вирішення імен/адрес для організації, внутрішній розподіл ролей

No: 3
 Name: sc_22_03
 Type: string
 Default: nil

Реалізовано в системах, які спільно надають послуги з вирішення імен/адрес для організації, зовнішній розподіл ролей

16.23. АВТЕНТИФІКАЦІЯ СЕСІЇ (SC-23)

Забезпечити автентифікацію сеансів зв'язку.

No: 1
 Name: sc_23_01
 Type: string
 Default: nil

Захищено автентифікацію сеансів зв'язку

16.24. УВЕДЕННЯ У ВІДОМИЙ СТАН (SC-24)

Увести систему в [Призначення: визначений організацією відомий стан системи] у разі [Призначення: визначені організацією типи збоїв системи] зі збереженням [Призначення: визначена організацією інформація про стан системи] при збої.

No: 1
 Name: sc_24_01
 Type: string
 Default: nil

Типи системних збоїв на компонентах системи призводять до відомого стану системи, зберігаючи при цьому інформацію про стан системи у збої

No: 2
 Name: sc_24_odp_01
 Type: string
 Default: nil

Визначені типи відмов системи, за яких компоненти системи переходять до відомого стану

No: 3
 Name: sc_24_odp_02
 Type: string
 Default: nil

Відомий стан системи, до якого переходять компоненти системи у випадку її відмови

No: 4
 Name: sc_24_odp_03

Type: string

Default: nil

Потрібно зберігати інформацію про стан системи у випадку її збою

16.25. ТОНКІ ВУЗЛИ (SC-25)

Використовувати [Призначення: визначені організацією системні компоненти] з мінімальною функціональністю та зберіганням інформації.

No: 1

Name: sc_25_01

Type: string

Default: nil

Використовується мінімальна функціональність для компонентів системи

No: 2

Name: sc_25_02

Type: string

Default: nil

Виділено мінімальне сховище інформації на компоненти системи

No: 3

Name: sc_25_odp

Type: string

Default: nil

Потрібно використовувати компоненти системи з мінімальною функціональністю та обсягом зберігання інформації

16.26. ПРИМАНКА ДЛЯ ЗЛОВМИСНИКІВ (DECOYS) (SC-26)

Вносити в систему компоненти, які спеціально призначені як об'єкти атак, з метою виявлення, відбиття й аналізу таких атак.

No: 1

Name: sc_26_01

Type: string

Default: "автоматизований засіб моніторингу"

Є в системах організації компоненти, спеціально розроблені для того, щоб стати мішенню зловмисних атак, і чи є в них засоби для виявлення таких атак

No: 2

Name: sc_26_02

Type: string

Default: "автоматизований засіб моніторингу"

Є в організаційних компонентах системи, спеціально розроблені для того, щоб стати мішенню зловмисних атак, і чи є в них засоби для відбиття таких атак

No: 3

Name: sc_26_03

Type: string

Default: nil

Включені в організаційні компоненти системи, спеціально розроблені для того, щоб бути мішенню зловмисних атак, для аналізу таких атак

16.27. НЕЗАЛЕЖНІ ВІД ПЛАТФОРМИ ЗАСТОСУНКИ (SC-27)

Внести до системи: [Призначення: визначені організацією незалежні від платформи застосунки].

No: 1

Name: sc_27_01

Type: string

Default: nil

Включені незалежні від платформи додатки в системи організації

No: 2

Name: sc_27_odp

Type: string

Default: nil

Визначені незалежні від платформи додатки, які мають бути включені в системи організації

16.28. ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ (SC-28)

Забезпечити [Вибір (один або кілька): конфіденційність; цілісність] [Призначення: визначена організацією інформація] в стані спокою.

No: 1

Name: sc_28_odp

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {конфіденційність; цілісність}

No: 2

Name: sc_28_odp_02

Type: string

Default: nil

Є інформація в стані спокою, яка потребує захисту

16.28.1. ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ | КРИПТОГРАФІЧНИЙ ЗАХИСТ

No: 1

Name: sc_28_1_01

Type: string

Default: "AES-256-GCM"

Реалізовані криптографічні механізми для запобігання несанкціонованому розкриттю інформації, що знаходиться в стані спокою на системних компонентах або носіях

No: 2

Name: sc_28_1_02

Type: string

Default: "AES-256-GCM"

Реалізовані криптографічні механізми для запобігання несанкціонованій модифікації інформації, що знаходиться в стані спокою на системних компонентах або носіях

16.29. ГЕТЕРОГЕННІСТЬ (SC-29)

Використовувати різноманітний набір інформаційних технологій для [Призначення: визначені організацією системні компоненти] при впровадженні системи.

No: 1

Name: sc_29_01

Type: string

Default: nil

Використовується різноманітний набір інформаційних технологій для компоненти системи при впровадженні системи

No: 2

Name: sc_29_odp

Type: string

Default: nil

Визначені компоненти системи, які потребують різноманітного набору інформаційних технологій, що мають бути використані при впровадженні системи

16.30. МАСКУВАННЯ ТА ХИБНИЙ НАПРЯМ (SC-30)

Використовувати [Призначення: визначені організацією методи маскування та хибного напрямку] для [Призначення: визначені організацією системи] у [Призначення: визначений організацією період часу], щоб заплутати та ввести в оману злоумисників.

No: 1

Name: sc_30_01

Type: integer

Default: 30

Застосовуються методи маскування та хибного напрямку для систем протягом періодів часу, щоб заплутати та ввести супротивника в оману. застосування методів

No: 2

Name: sc_30_odp_01

Type: string

Default: nil

Визначені методи маскування та хибного напрямку, які будуть застосовані для того, щоб заплутати і ввести в оману супротивників, які потенційно можуть націлитися на системи

No: 3

Name: sc_30_odp_02

Type: string

Default: nil

Визначені системи, для яких повинні застосовуватися методи маскування та хибного напрямку

No: 4

Name: sc_30_odp_03

Type: integer

Default: 30

Визначені часові періоди для маскування та хибного напрямку

16.31. АНАЛІЗ ПРИХОВАНОГО КАНАЛУ (SC-31)

а. Проводити аналіз прихованого каналу, щоб визначити ті аспекти комунікацій у системі, які володіють потенційними можливостями для реалізації прихованих каналів [Вибір (один або кілька): зберігання; синхронізації].

б. Оцінювати максимальну пропускну здатність цих каналів.

Немає параметрів для цього контролю.

16.32. ПОДІЛ СИСТЕМИ НА ЧАСТИНИ (SC-32)

Розділити систему на [Призначення: визначені організацією системні компоненти], що розміщені в окремих фізичних доменах або середовищах на основі [Призначення: визначені організацією умови для фізичного поділу компонентів].

No: 1

Name: sc_32_01

Type: string

Default: nil

Розділена система на компоненти системи, що знаходяться в окремих ЗНАЧЕННЯ ВИБРАНОГО ПАРАМЕТРА доменах або середовищах на основі обставин для фізичного або логічного поділу компонентів. фізичного або логічного

No: 2

Name: sc_32_odp_01

Type: string

Default: nil

Повинні компоненти системи перебувати в окремих фізичних або логічних доменах або середовищах, виходячи з обставин фізичного або логічного поділу компонентів

No: 3

Name: sc_32_odp_02

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРА: {фізичний; логічний}

No: 4

Name: sc_32_odp_03

Type: string

Default: nil

Визначені обставини для розділення компонентів

16.33. ПІДГОТОВКА ЦІЛІСНОСТІ ПЕРЕДАЧІ (SC-33)

No: 1

Name: sc_33_01

Type: string

Default: nil

ПІДГОТОВКА ЦІЛІСНОСТІ ПЕРЕДАЧІ [Вилучено: включено до SC-8]

16.34. НЕЗМІНЮВАНІ ВИКОНАВЧІ ПРОГРАМИ (SC-34)

У [Призначення: визначені організацією системні компоненти]:

а. Завантажити та виконати операційне середовище з апаратного носія, що працює в режимі лише для зчитування.

б. Завантажити та виконати [Призначення: визначені організацією застосунки] з апаратного носія, що працює в режимі лише для зчитування.

No: 1

Name: sc_34_odp_01

Type: string

Default: nil

Визначені компоненти системи, для яких операційне середовище та додатки мають завантажуватися та виконуватися з апаратних носіїв, призначених лише для читання

No: 2

Name: sc_34_odp_02

Type: string

Default: nil

Визначено додатки, які мають завантажуватися та виконуватися з апаратних носіїв, призначених лише для читання; SC-34a. завантажується та виконується операційне середовище для системних компонентів з апаратного носія, доступного лише для читання; SC-34b. додатки для компонентів системи завантажуються та виконуються з апаратного носія, доступного лише для читання. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

16.35. РОЗПІЗНАВАННЯ ПРИМАНОК ДЛЯ ЗЛОВМИСНИКІВ (HONEYCLIENT) (SC-35)

Ввімкнути системні компоненти, які активно намагаються ідентифікувати мережевий шкідливий код та шкідливі вебсайти.

No: 1

Name: sc_35_01

Type: string

Default: nil

Ввімкнуті компоненти системи, які активно намагаються ідентифікувати мережевий шкідливий код та шкідливі вебсайти

16.36. РОЗПОДІЛЕНА ОБРОБКА ТА ЗБЕРІГАННЯ (SC-36)

Розподіліть наведені нижче компоненти обробки та зберігання в кількох [Вибір: фізичні локації; логічні домени]: [Призначення: компоненти обробки та зберігання, визначені організацією].

No: 1

Name: sc_36_odp_01

Type: string

Default: nil

Потрібно розподіляти компоненти обробки між кількома локаціями/доменами

No: 2

Name: sc_36_odp_02

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {фізичні локації; логічні домени}

No: 3

Name: sc_36_odp_03

Type: string

Default: nil

Потрібно розподіляти компоненти сховища між кількома локаціями/доменами

No: 4

Name: sc_36_odp_04

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {фізичні локації; логічні домени}

16.37. ПОЗАСМУГОВІ КАНАЛИ (SC-37)

Використовувати [Призначення: визначені організацією позасмугові канали] для фізичного доставлення або електронної передачі [Призначення: визначена організацією інформація, системні компоненти або пристрої] до [Призначення: визначені організацією особи або системи].

No: 1

Name: sc_37_odp_01

Type: string

Default: nil

Використовуються позасмугові канали для фізичної доставки або електронної передачі інформації, системних компонентів або пристроїв до осіб або систем

No: 2

Name: sc_37_odp_02

Type: string

Default: nil

Визначено інформацію, компоненти системи або пристрої для використання позасмугових каналів для фізичної доставки або електронної передачі

No: 3

Name: sc_37_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначені особи або системи, до яких фізична доставка або електронна передача інформації, системних компонентів або пристроїв має бути досягнута за допомогою використання позасмугових каналів

16.38. БЕЗПЕКА ОПЕРАЦІЙ (SC-38)

Впровадити [Призначення: визначені організацією заходи з безпеки операцій] для захисту ключової організаційної інформації протягом усього життєвого циклу розробки системи.

No: 1

Name: sc_38_01

Type: string

Default: "автоматизований засіб моніторингу"

Застосовуються засоби контролю заходів з безпеки операцій для захисту ключової інформації організації протягом життєвого циклу розробки системи

No: 2

Name: sc_38_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначені засоби контролю заходів з безпеки операцій, які будуть застосовуватися для захисту ключової інформації організації протягом усього життєвого циклу розробки системи

16.39. ІЗОЛЯЦІЯ ПРОЦЕСУ (SC-39)

Підтримувати окремий домен виконання для кожного процесу, що виконується в системі.

No: 1

Name: sc_39_01

Type: string

Default: nil

Підтримується окремий домен виконання для кожного процесу, що виконується в системі

16.40. ЗАХИСТ БЕЗДРОТОВОГО З'ЄДНАННЯ (SC-40)

Забезпечити захист зовнішніх і внутрішніх [Призначення: визначені організацією бездротові з'єднання] від [Призначення: визначені організацією типи атак з параметрами сигналів або посилення на джерела для таких атак].

No: 1

Name: sc_40_01

Type: string

Default: nil

Захищені зовнішні бездротові з'єднання від типів атак на параметри сигналу або посилення на джерела таких атак. SC-40[02] захищені внутрішні бездротові з'єднання від типів атак на параметри сигналу або посилення на джерела для таких атак

No: 2

Name: sc_40_odp_01

Type: string

Default: nil

Потрібно захищати зовнішні бездротові з'єднання від певних типів атак на параметри сигналу

No: 3

Name: sc_40_odp_02

Type: string

Default: nil

Визначено типи атак на параметри сигналу або посилання на джерела таких атак, від яких потрібно захищати зовнішні бездротові з'єднання

No: 4

Name: sc_40_odp_03

Type: string

Default: nil

Потрібно захищати внутрішні бездротові з'єднання від певних типів атак на параметри сигналу

No: 5

Name: sc_40_odp_04

Type: string

Default: nil

Визначені типи атак на параметри сигналу або посилання на джерела таких атак, від яких потрібно захищати внутрішні бездротові з'єднання

16.41. ДОСТУП ДО ПОРТІВ ТА ПРИСТРОЇВ ВВЕДЕННЯ, ВИВЕДЕННЯ (SC-41)

[Вибір: фізично або логічно] відключити або видалити [Призначення: визначені організацією, порти підключення або пристрої введення/виводу] у [Призначення: визначені організацією системи або системні компоненти].

No: 1

Name: sc_41_odp_01

Type: string

Default: nil

Визначено порти підключення або пристрої вводу/виводу, які потрібно відключити або видалити

No: 2

Name: sc_41_odp_02

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {фізично; логічно}

No: 3

Name: sc_41_odp_03

Type: string

Default: nil

Визначені системи або компоненти системи з портами підключення або пристроями вводу/виводу, які потрібно відключити або видалити

16.42. Захист бездротового з'єднання Доступ до портів і пристроїв введення/виведення Можливості датчика та дані (SC-42)

- a. Заборонити дистанційну активацію можливостей зондування навколишнього середовища в системах організації або компонентах системи за такими виключеннями: [Призначення: визначені організацією виключення, в яких допускається дистанційна активація датчиків].
- b. Забезпечити явну вказівку використання датчика для [Призначення: визначений організацією клас користувачів].

No: 1

Name: sc_42_01

Type: string

Default: "автоматизований засіб моніторингу"

Механізми, що перешкоджають МОЖЛИВОСТІ ДАТЧИКА ТА ДАНІ

No: 2

Name: sc_42_odp_01

Type: string

Default: nil

Вибрано одне або більше з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {використання пристроїв, що мають <SC-42_ODP[02] можливості зондування довкілля> на об'єктах, територіях або системах}; дистанційна активація можливостей зондування довкілля на організаційних системах або системних компонентах з наступними винятками: <SC-42_ODP[04] винятки, де дозволяється дистанційна активація датчиків}

No: 3

Name: sc_42_odp_02

Type: string

Default: nil

Визначені можливості зондування навколишнього середовища в пристроях (якщо вибрано)

No: 4

Name: sc_42_odp_03

Type: string

Default: nil

Визначені об'єкти, зони або системи, на яких заборонено використання пристроїв, що мають можливості зондування навколишнього середовища (якщо вони були обрані)

No: 5

Name: sc_42_odp_04

Type: string

Default: nil

Визначено винятки, коли дозволено віддалену активацію датчиків (якщо вибрано)

16.43. ОБМЕЖЕННЯ ВИКОРИСТАННЯ (SC-43)

- a. Встановити обмеження на використання та рекомендації щодо впровадження для [Призначення: визначених організацією компонентів системи].
- b. Проводити авторизацію, спостереження та контроль використання таких компонентів у системі.

No: 1

Name: sc_43_odp

Type: string

Default: nil

Визначені компоненти, для яких мають бути встановлені обмеження на використання та настанови щодо впровадження; SC-43a. встановлені обмеження на використання та настанови щодо впровадження для компонентів; SC-43b.[01] дозволено системі; SC-43b.[02] здійснюється моніторинг компонентів> в системі; SC-43b.[03] контролюється використання компонентів в системі. використання компонентів використання у <SC-43_ODP

16.44. ЕКРАНОВАНІ КАМЕРИ (SC-44)

Впровадити екрановані камери в [Призначення: визначену організацією систему, компонент системи або місце розташування].

No: 1

Name: sc_44_01

Type: string

Default: nil

Використовується в системі <SC-44_ODP, компоненті або місці розташування> застосування екранованої камери системному можливість

No: 2

Name: sc_44_odp

Type: string

Default: nil

Визначена система, компонент системи або місце, де має бути застосований потенціал екранованої камери

16.45. СИНХРОНІЗАЦІЯ СИСТЕМИ З ЧАСОМ (SC-45)

Синхронізація системного годинника в системі та компонентах системи і між ними.

No: 1

Name: sc_45_01

Type: integer

Default: 30

Синхронізовані системні годинники всередині системи та між системами і системними компонентами

16.46. ЗАБЕЗПЕЧЕННЯ ВИКОНАННЯ МІЖДОМЕННОЇ ПОЛІТИКИ (SC-46)

Впровадити механізм примусового виконання політики [Вибір: фізично; логічно] між фізичними та/або мережевими інтерфейсами для підключених доменів безпеки.

No: 1

Name: sc_46_odp

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {фізично; логічно}

16.47. АЛЬТЕРНАТИВНИЙ ШЛЯХ ЗВ'ЯЗКУ (SC-47)

Встановіть [Призначення: альтернативні шляхи зв'язку, визначені організацією] для організаційного управління та контролю операцій системи.

No: 1

Name: sc_47_01

Type: string

Default: nil

Встановлені альтернативні шляхи зв'язку для системних операцій та контролю операцій системи

No: 2

Name: sc_47_odp

Type: string

Default: nil

Визначені альтернативні шляхи зв'язку для системних операцій та контролю операцій системи

16.48. ПЕРЕМІЩЕННЯ ДАТЧИКА (SC-48)

Перенесіть [Призначення: датчики та можливості моніторингу, визначені організацією] до [Призначення: місця, визначені організацією] за таких умов або обставин: [Призначення: умови або обставини, визначені організацією].

No: 1

Name: sc_48_01

Type: string

Default: "автоматизований засіб моніторингу"

Переміщуються датчики і засоби моніторингу до місць розташування за умов або обставин

No: 2

Name: sc_48_odp_01

Type: string

Default: nil

Визначені датчики та можливості необхідно перемістити; моніторингу, які

No: 3

Name: sc_48_odp_02

Type: string

Default: "автоматизований засіб моніторингу"

Визначені місця, куди будуть переміщені датчики та засоби моніторингу

No: 4

Name: sc_48_odp_03

Type: list

Default: []

Визначені умови або обставини для переміщення датчиків і можливостей моніторингу

16.48.1. ДИНАМІЧНО ПЕРЕМІЩУЮТЬСЯ ДО ЗА (SC-48(1))

No: 1

Name: sc_48_1_01

Type: string

Default: "автоматизований засіб моніторингу"

Датчики та засоби моніторингу динамічно переміщуються до місць розташування за умов або обставин.
ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

16.49. ПРИМУСОВЕ АПАРАТНЕ ЗАБЕЗПЕЧЕННЯ ВИКОНАННЯ (SC-49)

Впровадити механізми апаратного поділу та застосування політики між [Призначення: домени безпеки, визначені організацією].

No: 1

Name: sc_49_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Впроваджено механізми апаратного розділення та застосування політик між доменами безпеки

No: 2

Name: sc_49_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначені домени безпеки, які потребують апаратного розділення та механізмів забезпечення дотримання політики

16.50. ПРИМУСОВЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ ВИКОНАННЯ (SC-50)

Впровадити програмне розділення та механізми застосування політики між [Призначення: домени безпеки, визначені організацією].

No: 1

Name: sc_50_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Впроваджено програмне розділення та механізми застосування політик між доменами безпеки. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

No: 2

Name: sc_50_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначені домени безпеки, які потребують програмного розділення та механізмів забезпечення дотримання політик

16.51. АПАРАТНИЙ ЗАХИСТ (SC-51)

- a. Перевіряти правильність роботи [Призначення: визначені організацією функції безпеки та приватності].
- b. Виконувати перевірку [Вибір (один або кілька): [Призначення: визначені організацією системні перехідні стани]; за командою користувача з відповідними повноваженнями; [Призначення: визначена організацією частота]].
- c. Повідомляти [Призначення: визначені організацією персонал або посадові особи] про невдалі перевірки безпеки та приватності.
- d. [Вибір (один або кілька): Вимкнути систему; Перезапустити систему; [Призначення: визначені організацією альтернативні дії]], коли виявляються аномалії.

No: 1

Name: sc_51_odp_01

Type: string

Default: nil

Визначено компоненти системної прошивки, потребують апаратного захисту від запису; які

No: 2

Name: sc_51_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначені уповноважені особи, які повинні виконувати процедури вимкнення та повторного увімкнення апаратного захисту від запису; SC-51a. використовується апаратний захист від запису для компонентів мікропрограми системи; SC-51b.[01] впроваджено спеціальні процедури для уповноважених осіб для ручного вимкнення апаратного захисту від запису для модифікацій мікропрограми; SC-51b.[02] реалізовано спеціальні процедури для уповноважених осіб для повторного увімкнення захисту від запису перед поверненням до робочого режиму

17. SI

Клас заходів захисту SI — ЦІЛІСНІСТЬ СИСТЕМИ ТА ІНФОРМАЦІЇ

Цей клас спрямований на захист системи від шкідливого коду, виявлення вразливостей та запобігання несанкціонованим змінам інформації.

Перелік заходів захисту: Політика і процедури цілісності інформації (SI-1); Виправлення дефектів (SI-2); Централізоване управління (SI-2(1)); Автоматизоване виправлення дефектів (SI-2(2)); Час для усунення дефектів та орієнтири для коригувальних дій (SI-2(3)); Автоматичні засоби управління виправленнями (SI-2(4)); Виправлення дефектів автоматичне оновлення програмного забезпечення та вбудованого програмного забезпечення (SI-2(5)); Видалення попередніх версій програмного забезпечення та вбудованого програмного забезпечення (SI-2(6)); Захист від шкідливого коду (SI-3); Централізоване управління (SI-3(1)); Автоматичні оновлення (SI-3(2)); Захист від шкідливого користувачі (SI-3(3)); Захист від шкідливого коду привілейованими користувачами (SI-3(4)); Захист від шкідливого зберігання даних (SI-3(5)); Тестування та верифікація (SI-3(6)); Виявлення без підпису (SI-3(7)); Виявлення неавторизованих команд (SI-3(8)); Автентифікація віддалених команд (SI-3(9)); Аналіз шкідливого коду (SI-3(10)); Моніторинг системи (SI-4); **МОНІТОРИНГ СИСТЕМИ ВИЯВЛЕННЯ ВТОРГНЕНЬ (IDS)** (SI-4(1)); Автоматизовані механізми аналізу в реальному часі (SI-4(2)); Моніторинг системи механізми інтеграції (SI-4(3)); Моніторинг системи комунікацій (SI-4(4)); Системні сповіщення (SI-4(5)); Заборона для непривілейованих користувачів (SI-4(6)); Моніторинг системи підозрілі події (SI-4(7)); Захист інформації моніторингу (SI-4(8)); Тестування засобів і механізмів моніто-

рингу (SI-4(9)); Моніторинг комунікацій (SI-4(10)); Моніторинг системи комунікацій (SI-4(11)); Моніторинг системи автоматизовані сповіщення (SI-4(12)); Аналіз трафіку та шаблонів подій (SI-4(13)); Моніторинг вторгнення (SI-4(14)); Перехід від бездротового зв'язку до провідних мереж (SI-4(15)); Моніторинг моніторингу (SI-4(16)); Моніторинг обізнаність (SI-4(17)); Аналіз трафіку та прихованої ексфільтрації (SI-4(18)); Особи, які представляють більший ризик (SI-4(19)); Привілейовані користувачі (SI-4(20)); Випробувальні терміни (SI-4(21)); Несанкціоновані послуги мережі (SI-4(22)); Пристрої на основі хоста (SI-4(23)); Індикатори компрометації (SI-4(24)); Аналіз мережевого трафіку (SI-4(25)); Попередження, рекомендації та директиви з безпеки (SI-5); Попередження, рекомендації та директиви з безпеки автоматичні попередження та рекомендації (SI-5(1)); Перевірка функцій безпеки та приватності (SI-6); Сповіщення про неуспішне проходження тестів з безпеки (SI-6(1)); Перевірка безпеки та функцій приватності автоматизована підтримка розподіленого тестування (SI-6(2)); Перевірка безпеки та функцій приватності повідомлення про результати перевірки (SI-6(3)); Цілісність програмного забезпечення, програмного забезпечення та інформації (SI-7); Перевірка цілісності (SI-7(1)); Автоматичні сповіщення про порушення цілісності (SI-7(2)); Інструменти цілісності з централізованим управлінням (SI-7(3)); Цілісність програмного забезпечення, вбудованого програмного забезпечення та інформації – пакування з індикацією ознак її несанкціонованого розкриття (SI-7(4)); Автоматичні відповіді про порушення цілісності (SI-7(5)); Цілісність програмного забезпечення, вбудованого програмного забезпечення та інформації криптографічний захист (SI-7(6)); Інтеграція виявлення і реагування (SI-7(7)); Аудит важливих подій (SI-7(8)); Перевірка процесу завантаження (SI-7(9)); Захист завантажувального вбудованого програмного забезпечення (SI-7(10)); Обмежене середовище з обмеженими привілеями (SI-7(11)); Перевірка цілісності (SI-7(12)); Виконання коду в захищених середовищах (SI-7(13)); Двійковий або машинно-виконуваний код (SI-7(14)); Цілісність програмного забезпечення, вбудованого програмного забезпечення та інформації автентифікація коду (SI-7(15)); Термін виконання процесу без нагляду (SI-7(16)); Цілісність програмного забезпечення, вбудованого програмного забезпечення та інформації – самозахист програм від самовільного виконання (SI-7(17)); Захист від спаму (SI-8); Централізоване управління (SI-8(1)); Автоматичні оновлення (SI-8(2)); Безперервне навчання (SI-8(3)); Обмеження на введення інформації (SI-9); Перевірка вводу інформації (SI-10); Перевірка вводу перевизначення (SI-10(1)); Перевірка вводу інформації помилок (SI-10(2)); Передбачувана поведінка (SI-10(3)); Часові взаємодії (SI-10(4)); Обмеження вхідних даних довіреними джерелами і затвердженими форматами (SI-10(5)); Профілактика вводу даних (SI-10(6)); Обробка помилок (SI-11); Управління та збереження інформації (SI-12); Управління та збереження інформації елементів персональних даних (SI-12(1)); Мінімізація використання персональних даних під час тестування, навчання та дослідженні (SI-12(2)); Управління інформації (SI-12(3)); Передбачуване запобігання збоїв (SI-13); Відповідальність за передачу функцій компонентів (SI-13(1)); Термін виконання процесу без нагляду (SI-13(2)); Запобігання передбачуваних функцій компонентів (SI-13(3)); Запобігання передбачуваних збоїв резервних компонентів та оповіщення (SI-13(4)); Запобігання передбачуваних аварійного перемикання (SI-13(5)); Нестійкість (SI-14); Оновлення з надійних джерел (SI-14(1)); Нестійка інформація (SI-14(2)); Нестійкі підключення (SI-14(3)); Фільтрація вихідних даних (SI-15); Захист пам'яті (SI-16); Відмовостійкі процедури (SI-17); Операції забезпечення якості даних (SI-18); Операції забезпечення підтримка (SI-18(1)); Тегування даних (SI-18(2)); Збирання (SI-18(3)); Операції запити (SI-18(4)); Повідомлення про виправлення чи видалення (SI-18(5)); Деідентифікація (SI-19); Збір (SI-19(1)); Архівація (SI-19(2)); Видалення (SI-19(3)); Видалення, маскування, шифрування, хешування або заміна прямих ідентифікаторів (SI-19(4)); Контроль статистичного розкриття (SI-19(5)); Диференційована конфіденційність (SI-19(6)); Перевірене програмне забезпечення (SI-19(7)); Мотивований порушник (SI-19(8)); Псування (SI-20); Оновлення інформації (SI-21); Різновиди інформації (SI-22); Фрагментація інформації (SI-23).

17.1. ПОЛІТИКА І ПРОЦЕДУРИ ЦІЛІСНОСТІ ІНФОРМАЦІЇ (SI-1)

No: 1

Name: si_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких має бути доведена політика цілісності системи та інформації

No: 2

Name: si_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури цілісності системи та інформації

No: 3

Name: si_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: si_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, відповідальну за управління системою та політикою і процедурами цілісності інформації

No: 5

Name: si_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено періодичність перегляду та оновлення поточної політики цілісності системи та інформації

No: 6

Name: si_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Є події, які вимагають перегляду та оновлення поточної політики цілісності системи та інформації

No: 7

Name: si_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні цілісності системи та інформації

17.2. ВИПРАВЛЕННЯ ДЕФЕКТІВ (SI-2)

No: 1

Name: si_2_odp

Type: integer

Default: 30

Визначено період часу, протягом якого необхідно встановити оновлення програмного забезпечення, пов'язані з безпекою, після виходу оновлень; SI-02a.[01] виявлено недоліки системи; SI-02a.[02] повідомляється про недоліки системи; SI-02a.[03] виправлені недоліки системи; SI-02b.[01] перевіряються оновлення програмного забезпечення, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[02] перевіряються оновлення програмного забезпечення, пов'язані з виправленням дефектів, на наявність потенційних побічних ефектів перед встановленням; SI-02b.[03] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[04] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на наявність потенційних побічних ефектів перед встановленням; SI-02c.[01] встановлено оновлення програмного забезпечення, що стосуються безпеки, протягом часовий проміжок з моменту випуску оновлень; SI-02c.[02] встановлено оновлення мікропрограми, що стосуються безпеки, протягом часового періоду з моменту випуску оновлень; SI-02d. включено відновлення порушених прав у процес управління організаційною конфігурацією

17.2.1. ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ (SI-2(1))

No: 1

Name: si_2_1_01

Type: string

Default: nil

ВИПРАВЛЕННЯ ДЕФЕКТІВ - ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ [Вилучено: перенесено до PL-09]

17.2.2. АВТОМАТИЗОВАНЕ ВИПРАВЛЕННЯ ДЕФЕКТІВ (SI-2(2))

No: 1

Name: si_2_2_01

Type: integer

Default: 30

Встановлені на компонентах системи відповідні оновлення програмного забезпечення та мікропрограми, що стосуються безпеки, з частотою за допомогою автоматизованих механізмів

17.2.3. ЧАС ДЛЯ УСУНЕННЯ ДЕФЕКТІВ ТА ОРІЄНТИРИ ДЛЯ КОРИГУВАЛЬНИХ ДІЙ (SI-2(3))

No: 1

Name: si_2_3_a

Type: integer

Default: 30

Вимірюється час між виявленням дефекту та його усуненням; SI-02(03)(b) були встановлені орієнтири для вжиття коригувальних дій

No: 2

Name: si_2_3_odp

Type: string

Default: nil

Визначені контрольні коригувальних заходів; показники для вжиття

17.2.4. АВТОМАТИЧНІ ЗАСОБИ УПРАВЛІННЯ ВИПРАВЛЕННЯМИ (SI-2(4))

No: 1

Name: si_2_4_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначені компоненти системи, які потребують автоматизованих інструментів управління виправленнями для полегшення усунення дефектів; SI-02(04)] застосовуються автоматизовані засоби управління виправленнями для полегшення виправлення недовірок у компонентах

17.2.5. ВИПРАВЛЕННЯ ДЕФЕКТІВ АВТОМАТИЧНЕ ООНОВЛЕННЯ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ВБУДОВАНОГО ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ (SI-2(5))

No: 1

Name: si_2_5_01

Type: string

Default: nil

SI-02(05) _ODP[01] оновлення програмного забезпечення та мікропрограми, що стосуються безпеки>, встановлено автоматично до <SI-02(05) _ODP[02] компонентів системи>

17.2.6. ВИДАЛЕННЯ ПОПЕРЕДНІХ ВЕРСІЙ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ВБУДОВАНОГО ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ (SI-2(6))

No: 1

Name: si_2_6_01

Type: string

Default: nil

Видаляються попередні версії програмне забезпечення та компоненти мікропрограми після встановлення оновлених версій

No: 2

Name: si_2_6_odp

Type: string

Default: nil

Потрібно видаляти компоненти програмного забезпечення та мікропрограми після встановлення оновлених версій

17.3. ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ (SI-3)

No: 1

Name: si_3_odp_01

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {підписаний; непідписаний}

No: 2

Name: si_3_odp_02

Type: integer

Default: 30

Визначено частоту, з якою механізми шкідливого коду виконують сканування

No: 3

Name: si_3_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {кінцева точка; точки входу та виходу з мережі}

No: 4

Name: si_3_odp_04

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {block malicious code; quarantitne malicious code; take action}

No: 5

Name: si_3_odp_05

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено дії, яких слід вжити у відповідь на виявлення шкідливого коду (якщо вибрано)

17.3.1. ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ (SI-3(1))

No: 1

Name: si_3_1_01

Type: string

Default: nil

ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ - ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ [Вилучено: включено до PL-9]

17.3.2. АВТОМАТИЧНІ ОНОВЛЕННЯ (SI-3(2))

No: 1

Name: si_3_2_01

Type: string

Default: nil

ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ - АВТОМАТИЧНІ ОНОВЛЕННЯ [Вилучено: включено до SI-03]

17.3.3. ЗАХИСТ ВІД ШКІДЛИВОГО КОРИСТУВАЧІ (SI-3(3))

No: 1

Name: si_3_3_01

Type: string

Default: nil

ЗАХИСТ ВІД ШКІДЛИВОГО КОРИСТУВАЧІ [Вилучено: включено до AC-6(10)]. КОДУ - НЕПРИВІЛЕЙОВАНІ SI-3(4) ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ ПРИВІЛЕЙОВАНИМИ КОРИСТУВАЧАМИ

ОНОВЛЕННЯ ТІЛЬКИ

17.3.4. ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ ПРИВІЛЕЙОВАНИМИ КОРИСТУВАЧАМИ (SI-3(4))

No: 1

Name: si_3_4_01

Type: string

Default: "автоматизований засіб моніторингу"

Оновлюються механізми захисту від шкідливого коду лише за вказівкою привілейованого користувача

17.3.5. ЗАХИСТ ВІД ШКІДЛИВОГО ЗБЕРІГАННЯ ДАНИХ (SI-3(5))

No: 1

Name: si_3_5_01

Type: string

Default: nil

ЗАХИСТ ВІД ШКІДЛИВОГО ЗБЕРІГАННЯ ДАНИХ [Вилучено: включено до МР-7]. КОДУ

17.3.6. ТЕСТУВАННЯ ТА ВЕРИФІКАЦІЯ (SI-3(6))

No: 1

Name: si_3_6_a

Type: string

Default: "щорічно"

Перевіряються механізми захисту від шкідливого коду частота шляхом введення в систему відомого доброякісного коду

No: 2

Name: si_3_6_b_01

Type: string

Default: nil

Відбувається виявлення (доброякісний тест) коду

No: 3

Name: si_3_6_b_02

Type: string

Default: nil

Відбувається відповідне звітування про інцидент

No: 4

Name: si_3_6_odp

Type: string

Default: "щорічно"

Визначено періодичність тестування механізмів захисту від зловмисного коду

17.3.7. ВИЯВЛЕННЯ БЕЗ ПІДПИСУ (SI-3(7))

No: 1

Name: si_3_7_01

Type: string

Default: nil

ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ - ВИЯВЛЕННЯ БЕЗ ПІДПISУ [Вилучено: включено до SI-3]

17.3.8. ВИЯВЛЕННЯ НЕАВТОРИЗОВАНИХ КОМАНД (SI-3(8))

No: 1

Name: si_3_8_a

Type: string

Default: nil

Виявлено <SI-03(08) _ODP[01] неавторизовані команди операційної системи> через інтерфейс прикладного програмування ядра на <SI-03(08) _ODP[02] апаратних компонентах системи>

17.3.9. АВТЕНТИФІКАЦІЯ ВІДДАЛЕНИХ КОМАНД (SI-3(9))

No: 1

Name: si_3_9_01

Type: string

Default: nil

ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ - АВТЕНТИФІКАЦІЯ ВІДДАЛЕНИХ КОМАНД [Вилучено: включено до AC-17(10)]

17.3.10. АНАЛІЗ ШКІДЛИВОГО КОДУ (SI-3(10))

No: 1

Name: si_3_10_a

Type: string

Default: nil

Використовуються інструменти та методи для аналізу характеристик та поведінки шкідливого коду

No: 2

Name: si_3_10_b_01

Type: string

Default: nil

Включені результати аналізу шкідливого коду в організаційні процеси реагування на інциденти

No: 3

Name: si_3_10_b_02

Type: string

Default: nil

Включені результати аналізу шкідливого коду в організаційні процеси виправлення недоліків

No: 4

Name: si_3_10_odp

Type: string

Default: nil

Визначені інструменти та методи, які будуть використовуватися для аналізу характеристик та поведінки шкідливого коду

17.4. МОНІТОРИНГ СИСТЕМИ (SI-4)

No: 1

Name: si_4_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначені методи та способи, що використовуються для виявлення несанкціонованого використання системи

No: 2

Name: si_4_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначена інформація про моніторинг системи, яка повинна надаватися персоналу або ролям

No: 3

Name: si_4_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, яким має надаватися інформація про моніторинг системи

No: 4

Name: si_4_odp_05

Type: string

Default: "щорічно"

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {за потребою; частота}

17.4.1. МОНІТОРИНГ СИСТЕМИ ВІЯВЛЕННЯ ВТОРГНЕНЬ (IDS) (SI-4(1))

No: 1

Name: si_4_1_01

Type: string

Default: "автоматизований засіб моніторингу"

Підключені окремі засоби виявлення вторгнень загальносистемної системи виявлення вторгнень; до

No: 2

Name: si_4_1_02

Type: string

Default: nil

Об'єднані окремі інструменти виявлення вторгнень загальносистемну систему виявлення вторгнень. у

17.4.2. АВТОМАТИЗОВАНІ МЕХАНІЗМИ АНАЛІЗУ В РЕАЛЬНОМУ ЧАСІ (SI-4(2))

Немає параметрів для цього контролю.

17.4.3. МОНІТОРИНГ СИСТЕМИ МЕХАНІЗМИ ІНТЕГРАЦІЇ (SI-4(3))

No: 1

Name: si_4_3_01

Type: string

Default: "автоматизований засіб моніторингу"

Використовуються автоматизовані інструменти та механізми для інтеграції інструментів та механізмів виявлення вторгнень у механізми контролю доступу

No: 2

Name: si_4_3_02

Type: string

Default: "автоматизований засіб моніторингу"

Використовуються автоматизовані інструменти та механізми для інтеграції інструментів та механізмів виявлення вторгнень у механізми контролю потоків

17.4.4. МОНІТОРИНГ СИСТЕМИ КОМУНІКАЦІЙ (SI-4(4))

No: 1

Name: si_4_4_a_01

Type: list

Default: []

Визначені критерії незвичної або несанкціонованої діяльності або умови для вхідного трафіку зв'язку

No: 2

Name: si_4_4_a_02

Type: list

Default: []

Визначені критерії незвичної або несанкціонованої діяльності або умови для вихідного трафіку зв'язку

No: 3

Name: si_4_4_b_01

Type: string

Default: "щорічно"

Здійснюється моніторинг вхідного комунікаційного трафіку частота на предмет незвичних або несанкціонованих дій або умов

No: 4

Name: si_4_4_b_02

Type: string

Default: "щорічно"

Контролюється вихідний трафік зв'язку частота на предмет незвичних або несанкціонованих дій або умов. вихідного виявлення

17.4.5. СИСТЕМНІ СПОВІЩЕННЯ (SI-4(5))

No: 1

Name: si_4_5_01

Type: list

Default: ["admin", "security_officer"]

Відбувається оповіщення <SI-04(05) _ODP[01] персоналу або ролей> при виникненні згенерованих системою <SI-04(05) _ODP[02] індикаторів компрометації>

17.4.6. ЗАБОРОНА ДЛЯ НЕПРИВІЛЕЙОВАНИХ КОРИСТУВАЧІВ (SI-4(6))

No: 1

Name: si_4_6_01

Type: string

Default: nil

МОНІТОРИНГ СИСТЕМИ - ЗАБОРОНА ДЛЯ НЕПРИВІЛЕЙОВАНИХ КОРИСТУВАЧІВ [Вилучено: включено до AC-6(10)]

17.4.7. МОНІТОРИНГ СИСТЕМИ ПІДОЗРІЛІ ПОДІЇ (SI-4(7))

No: 1

Name: si_4_7_a

Type: list

Default: ["admin", "security_officer"]

Повідомляється персонал з реагування на інциденти про виявлені підозрілі події

No: 2

Name: si_4_7_b

Type: list

Default: ["login", "logout", "failed_attempt"]

Вживаються найменш руйнівні дії при виявленні підозрілих подій

17.4.8. ЗАХИСТ ІНФОРМАЦІЇ МОНІТОРИНГУ (SI-4(8))

No: 1

Name: si_4_8_01

Type: string

Default: nil

МОНІТОРИНГ СИСТЕМИ - ЗАХИСТ ІНФОРМАЦІЇ МОНІТОРИНГУ [Вилучено: включено до SI-4]

17.4.9. ТЕСТУВАННЯ ЗАСОБІВ І МЕХАНІЗМІВ МОНІТОРИНГУ (SI-4(9))

No: 1

Name: si_4_9_01

Type: string

Default: "щорічно"

Тестуються інструменти та механізми моніторингу вторгнень <SI-04(09)_ ODP періодичність>

No: 2

Name: si_4_9_odp

Type: string

Default: "щорічно"

Визначена періодичність тестування механізмів моніторингу вторгнень; інструментів і

17.4.10. МОНІТОРИНГ КОМУНІКАЦІЙ (SI-4(10))

No: 1

Name: si_4_10_01

Type: string

Default: nil

Передбачено, щоб <SI-04(10) _ODP[01] зашифрований трафік зв'язку> був видимим для <SI-04(10) _ODP[02] засобів та механізмів моніторингу системи>

17.4.11. МОНІТОРИНГ СИСТЕМИ КОМУНІКАЦІЙ (SI-4(11))

No: 1

Name: si_4_11_01

Type: string

Default: nil

Аналізується вихідний комунікаційний трафік на зовнішніх інтерфейсах системи для виявлення аномалій

No: 2

Name: si_4_11_02

Type: string

Default: nil

Аналізується вихідний трафік зв'язку в внутрішніх точках для виявлення аномалій

No: 3

Name: si_4_11_odp

Type: string

Default: nil

Визначені внутрішні точки в системі, в яких необхідно аналізувати комунікаційний трафік

17.4.12. МОНІТОРИНГ СИСТЕМИ АВТОМАТИЗОВАНІ СПОВІЩЕННЯ (SI-4(12))

No: 1

Name: si_4_12_01

Type: list

Default: ["admin", "security_officer"]

Оповідяється <SI-04(12) _ODP[01] персонал або ролі> за допомогою <SI-04(12) _ODP[02] автоматизованих механізмів>, коли <SI-04(12) _ODP[03] дії, що викликають оповіщення> вказують на невідповідну або незвичну викликають оповіщення персоналу, або діяльність, що має вплив на безпеку або приватне життя

17.4.13. АНАЛІЗ ТРАФІКУ ТА ШАБЛОНІВ ПОДІЙ (SI-4(13))

No: 1

Name: si_4_13_a_01

Type: string

Default: nil

Аналізується трафік для системи

No: 2

Name: si_4_13_a_02

Type: string

Default: nil

Проаналізовано патерни подій для системи

No: 3

Name: si_4_13_b_01

Type: string

Default: nil

Розроблені профілі, що представляють загальний трафік

No: 4

Name: si_4_13_b_02

Type: string

Default: nil

Розроблені профілі, що представляють патерни подій

No: 5

Name: si_4_13_c_01

Type: string

Default: nil

Використовуються профілі трафіку пристроїв системного моніторингу

No: 6

Name: si_4_13_c_02

Type: string

Default: nil

Використовуються профілі подій при налаштуванні пристроїв системного моніторингу при налаштуванні

17.4.14. МОНІТОРИНГ ВТОРГНЕННЯ (SI-4(14))

No: 1

Name: si_4_14_01

Type: string

Default: nil

Використовується система виявлення бездротових вторгнень для виявлення несанкціонованих бездротових пристроїв

No: 2

Name: si_4_14_02

Type: integer

Default: 3

Використовується бездротова система виявлення вторгнень для виявлення спроб атак на систему

No: 3

Name: si_4_14_03

Type: string

Default: nil

Використовується бездротова система виявлення вторгнень для виявлення потенційних компрометації або порушень в системі

17.4.15. ПЕРЕХІД ВІД БЕЗДРОТОВОГО ЗВ'ЯЗКУ ДО ПРОВІДНИХ МЕРЕЖ (SI-4(15))

Немає параметрів для цього контролю.

17.4.16. МОНІТОРИНГ МОНІТОРИНГУ (SI-4(16))

No: 1
Name: si_4_16_01
Type: string
Default: nil

Співвідноситься інформація з інструментів моніторингу та механізмів, що застосовуються в системі

17.4.17. МОНІТОРИНГ ОБІЗНАНІСТЬ (SI-4(17))

No: 1
Name: si_4_17_01
Type: string
Default: nil

Співвідноситься інформація, отримана в результаті моніторингу фізичної, кібернетичної діяльності та діяльності ланцюга поставок, з метою досягнення інтегрованої, загальноорганізаційної ситуаційної обізнаності

17.4.18. АНАЛІЗ ТРАФІКУ ТА ПРИХОВАНОЇ ЕКСФІЛЬТРАЦІЇ (SI-4(18))

No: 1
Name: si_4_18_01
Type: string
Default: nil

Аналізується вихідний комунікаційний трафік на зовнішніх по відношенню до системи інтерфейсах для виявлення прихованого витоку інформації

No: 2
Name: si_4_18_02
Type: string
Default: nil

Аналізується вихідний трафік зв'язку в внутрішніх точках для виявлення прихованого витоку інформації

No: 3
Name: si_4_18_0dp
Type: string
Default: nil

Визначені внутрішні точки в системі, в яких необхідно аналізувати комунікаційний трафік

17.4.19. ОСОБИ, ЯКІ ПРЕДСТАВЛЯЮТЬ БІЛЬШИЙ РИЗИК (SI-4(19))

No: 1
Name: si_4_19_01
Type: string
Default: nil

Здійснюється <SI-04(19) _ODP[01] додатковий моніторинг> щодо осіб, які були ідентифіковані джерелами <SI-04(19) _ODP[02] як такі, що становлять підвищений рівень ризику>

17.4.20. ПРИВІЛЕЙОВАНІ КОРИСТУВАЧІ (SI-4(20))

No: 1

Name: si_4_20_01

Type: string

Default: nil

Реалізовано привілейованих користувачів. привілейованих додатковий моніторинг

No: 2

Name: si_4_20_odp

Type: string

Default: nil

Визначено додатковий користувачів; моніторинг

17.4.21. ВИПРОБУВАЛЬНІ ТЕРМІНИ (SI-4(21))

No: 1

Name: si_4_21_01

Type: integer

Default: 30

Здійснюється <SI-04(21) _ODP[01] додатковий моніторинг> осіб під час <SI-04(21) _ODP[02] випробувального терміну>

17.4.22. НЕСАНКЦІОНОВАНІ ПОСЛУГИ МЕРЕЖІ (SI-4(22))

No: 1

Name: si_4_22_a

Type: string

Default: nil

Виявлено послуги мережі, які не було авторизовано або схвалено відповідно до процесів авторизації або схвалення

17.4.23. ПРИСТРОЇ НА ОСНОВІ ХОСТА (SI-4(23))

No: 1

Name: si_4_23_01

Type: string

Default: "автоматизований засіб моніторингу"

Реалізовано <SI-04(23) _ODP[01] механізми моніторингу на основі хостів> на <SI-04(23) _ODP[02] компоненти системи>

17.4.24. ІНДИКАТОРИ КОМПРОМЕТАЦІЇ (SI-4(24))

No: 1

Name: si_4_24_01

Type: string

Default: nil

Виявлено індикатори компрометації, 04(24) _ODP[01] джерелами>

No: 2

Name: si_4_24_02

Type: string

Default: nil

Збираються індикатори компрометації, що надаються джерелами

No: 3

Name: si_4_24_03

Type: list

Default: ["admin", "security_officer"]

Індикатори компрометації, надані <SI-04(24) джерелами>, поширюються на <SI-04(24) персонал або ролі>. надані <SI- _ODP[01] _ODP[02]

17.4.25. АНАЛІЗ МЕРЕЖЕВОГО ТРАФІКУ (SI-4(25))

No: 1

Name: si_4_25_01

Type: string

Default: nil

Забезпечується видимість мережевого трафіку на зовнішніх системних інтерфейсах для оптимізації ефективності пристроїв моніторингу

No: 2

Name: si_4_25_02

Type: string

Default: nil

Забезпечено видимість мережевого трафіку на ключових внутрішніх інтерфейсах системи для оптимізації ефективності пристроїв моніторингу

17.5. ПОПЕРЕДЖЕННЯ, РЕКОМЕНДАЦІЇ ТА ДИРЕКТИВИ З БЕЗПЕКИ (SI-5)

No: 1

Name: si_5_odp_01

Type: string

Default: nil

Визначені зовнішні організації, від яких необхідно постійно отримувати оповіщення, поради та директиви щодо безпеки системи

No: 2

Name: si_5_odp_02

Type: list

Default: ["admin", "security_officer"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {персонал або ролі; елементи; зовнішні організації}

No: 3

Name: si_5_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких мають бути доведені попередження, поради та директиви з безпеки (якщо визначено)

No: 4
Name: si_5_odp_04
Type: string
Default: nil

Визначені елементи в організації, до яких мають надсилатися оповіщення, поради та директиви з безпеки (якщо вони були обрані)

17.5.1. ПОПЕРЕДЖЕННЯ, РЕКОМЕНДАЦІЇ ТА ДИРЕКТИВИ З БЕЗПЕКИ АВТОМАТИЧНІ ПОПЕРЕДЖЕННЯ ТА РЕКОМЕНДАЦІЇ (SI-5(1))

No: 1
Name: si_5_1_01
Type: string
Default: "автоматизований засіб моніторингу"

Використовуються автоматизовані механізми для трансляції попередження та рекомендації інформації з питань безпеки по всій організації

No: 2
Name: si_5_1_odp
Type: string
Default: "автоматизований засіб моніторингу"

Визначені автоматизовані механізми, які використовуються для трансляції попередження та рекомендації інформації про безпеку в організації

17.6. ПЕРЕВІРКА ФУНКЦІЙ БЕЗПЕКИ ТА ПРИВАТНОСТІ (SI-6)

No: 1
Name: si_6_odp_01
Type: string
Default: nil

Визначені функції безпеки, які необхідно перевірити на коректність роботи

No: 2
Name: si_6_odp_02
Type: string
Default: nil

Визначені функції приватності, які потрібно перевіряти на коректність роботи

No: 3
Name: si_6_odp_03
Type: string
Default: "щорічно"

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {перехідні стани системи; за командою користувача з відповідним привілеєм; частота}

No: 4
Name: si_6_odp_04

Type: string

Default: nil

Визначені перехідні стани системи, що вимагають перевірки функцій безпеки та конфіденційності; (якщо вибрано)

No: 5

Name: si_6_odp_05

Type: string

Default: "щорічно"

Визначена періодичність перевірки правильності роботи функцій безпеки та приватності; (якщо вибрано)

No: 6

Name: si_6_odp_06

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які мають бути сповіщені про невдачу перевірку безпеки та приватності

No: 7

Name: si_6_odp_07

Type: list

Default: ["login", "logout", "failed_attempt"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {вимкнути систему; перезапустити систему; альтернативна дія (дії)}

17.6.1. СПОВІЩЕННЯ ПРО НЕУСПІШНЕ ПРОХОДЖЕННЯ ТЕСТІВ З БЕЗПЕКИ (SI-6(1))

No: 1

Name: si_6_1_01

Type: string

Default: nil

ПЕРЕВІРКА БЕЗПЕКИ ТА ФУНКЦІЙ ПРИВАТНОСТІ - СПОВІЩЕННЯ ПРО НЕУСПІШНЕ ПРОХОДЖЕННЯ ТЕСТІВ З БЕЗПЕКИ [Вилучено: включено до SI-6]

17.6.2. ПЕРЕВІРКА БЕЗПЕКИ ТА ФУНКЦІЙ ПРИВАТНОСТІ АВТОМАТИЗОВАНА ПІДТРИМКА РОЗПОДІЛЕНОГО ТЕСТУВАННЯ (SI-6(2))

No: 1

Name: si_6_2_01

Type: string

Default: "автоматизований засіб моніторингу"

Впроваджені автоматизовані механізми для розподіленого тестуванням функцій безпеки; підтримки

No: 2

Name: si_6_2_02

Type: string

Default: "автоматизований засіб моніторингу"

Проваджені автоматизовані механізми для розподіленого тестуванням функцій приватності. підтримки

17.6.3. ПЕРЕВІРКА БЕЗПЕКИ ТА ФУНКЦІЙ ПРИВАТНОСТІ ПОВІДОМЛЕННЯ ПРО РЕЗУЛЬТАТИ ПЕРЕВІРКИ (SI-6(3))

No: 1

Name: si_6_3_01

Type: list

Default: ["admin", "security_officer"]

Повідомляються результати перевірки функцій безпеки персоналу або ролям

No: 2

Name: si_6_3_odp

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, призначені для отримання результатів перевірки функцій безпеки та приватності

17.7. ЦІЛІСНІСТЬ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ, ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ІНФОРМАЦІЇ (SI-7)

a. Впровадити механізми захисту від спаму в точках входу та виходу системи, щоб виявляти та протидіяти небажаним повідомленням.

b. Оновлювати механізми захисту від спаму, коли доступні нові механізми відповідно до організаційної політики та процедур управління конфігурацією.

No: 1

Name: si_7_odp_01

Type: string

Default: nil

Визначено програмне забезпечення, яке потребує застосування засобів перевірки цілісності для виявлення несанкціонованих змін

No: 2

Name: si_7_odp_02

Type: string

Default: nil

Визначено прошивку, яка потребує застосування інструментів перевірки цілісності для виявлення несанкціонованих змін

No: 3

Name: si_7_odp_03

Type: string

Default: nil

Визначена інформація, яка потребує застосування засобів перевірки цілісності для виявлення несанкціонованих змін

No: 4

Name: si_7_odp_04

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначені дії, яких слід вжити при виявленні несанкціонованих змін у програмному забезпеченні

No: 5

Name: si_7_odp_05

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначені дії, яких слід вжити несанкціонованих змін у прошивці; при виявленні SI-07_ODP[06] визначені дії, яких слід вжити несанкціонованих змін до інформації; при виявленні SI-07a.[01] використовуються засоби перевірки цілісності для виявлення несанкціонованих змін у програмному забезпеченні; SI-07a.[02] використовуються засоби перевірки цілісності для виявлення несанкціонованих змін у мікропрограмі; SI-07a.[03] використовуються засоби перевірки цілісності для виявлення несанкціонованих змін до інформації; SI-07b.[01] виконуються дії при виявленні несанкціонованих змін у програмному забезпеченні; SI-07b.[02] виконуються дії несанкціонованих змін у прошивці; при виявленні SI-07b.[03] виконуються дії несанкціонованих змін в інформації. при виявленні

17.7.1. ПЕРЕВІРКА ЦІЛІСНОСТІ (SI-7(1))

Немає параметрів для цього контролю.

17.7.2. АВТОМАТИЧНІ СПОВІЩЕННЯ ПРО ПОРУШЕННЯ ЦІЛІСНОСТІ (SI-7(2))

No: 1

Name: si_7_2_01

Type: list

Default: ["admin", "security_officer"]

Застосовуються автоматизовані інструменти, які надають повідомлення персоналу або ролям при виявленні розбіжностей під час перевірки цілісності

No: 2

Name: si_7_2_odp

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, яким необхідно повідомляти про виявлення розбіжностей під час перевірки цілісності

17.7.3. ІНСТРУМЕНТИ ЦІЛІСНОСТІ З ЦЕНТРАЛІЗОВАНИМ УПРАВЛІННЯМ (SI-7(3))

No: 1

Name: si_7_3_01

Type: string

Default: nil

Застосовуються інструменти цілісності з централізованим управлінням

17.7.4. ЦІЛІСНІСТЬ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ, ВБУДОВАНОГО ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ІНФОРМАЦІЇ – ПАКУВАННЯ З ІНДИКАЦІЄЮ ОЗНАК ЇЇ НЕСАНКЦІОНОВАНОГО РОЗКРИТТЯ (SI-7(4))

No: 1

Name: si_7_4_01

Type: string

Default: nil

ЦІЛІСНІСТЬ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ, ВБУДОВАНОГО ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ
ТА ІНФОРМАЦІЇ – ПАКУВАННЯ З ІНДИКАЦІЄЮ ОЗНАК ЇЇ НЕСАНКЦІОНОВАНОГО РОЗКРИТТЯ
[Вилучено: включено до SA-12]

17.7.5. АВТОМАТИЧНІ ВІДПОВІДІ ПРО ПОРУШЕННЯ ЦІЛІСНОСТІ (SI-7(5))

Немає параметрів для цього контролю.

17.7.6. ЦІЛІСНІСТЬ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ, ВБУДОВАНОГО ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ІНФОРМАЦІЇ КРИПТОГРАФІЧНИЙ ЗАХИСТ (SI-7(6))

No: 1

Name: si_7_6_01

Type: string

Default: "AES-256-GCM"

Впроваджені криптографічні механізми для виявлення несанкціонованих змін у програмному забезпеченні

No: 2

Name: si_7_6_02

Type: string

Default: "AES-256-GCM"

Реалізовані криптографічні механізми несанкціонованих змін у прошивці; для виявлення

No: 3

Name: si_7_6_03

Type: string

Default: "AES-256-GCM"

Впроваджені криптографічні механізми несанкціонованих змін інформації. для виявлення

17.7.7. ІНТЕГРАЦІЯ ВИЯВЛЕННЯ І РЕАГУВАННЯ (SI-7(7))

No: 1

Name: si_7_7_01

Type: string

Default: nil

Виявлення змін включено до можливості організації реагування на інциденти

No: 2
Name: si_7_7_odp
Type: string
Default: nil

Визначені зміни в системі, що мають відношення до безпеки

17.7.8. АУДИТ ВАЖЛИВИХ ПОДІЙ (SI-7(8))

No: 1
Name: si_7_8_01
Type: string
Default: nil

Передбачена можливість аудиту потенційного порушення цілісності

17.7.9. ПЕРЕВІРКА ПРОЦЕСУ ЗАВАНТАЖЕННЯ (SI-7(9))

No: 1
Name: si_7_9_01
Type: string
Default: nil

Перевіряється цілісність процесу завантаження 07(09)_ODP системних компонентів>. <SI-

No: 2
Name: si_7_9_odp
Type: string
Default: nil

Визначено компоненти системи, які потребують перевірки цілісності процесу завантаження

17.7.10. ЗАХИСТ ЗАВАНТАЖУВАЛЬНОГО ВБУДОВАНОГО ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ (SI-7(10))

No: 1
Name: si_7_10_01
Type: string
Default: "автоматизований засіб моніторингу"

Реалізовано <SI-07(10) _ODP[01] механізми> для захисту цілісності завантажувальної прошивки у <SI-07(10) _ODP[02] системних компонентах>. компоненти системи, захисту цілісності які потребують завантажувальної

17.7.11. ОБМЕЖЕНЕ СЕРЕДОВИЩЕ З ОБМЕЖЕНИМИ ПРИВІЛЕЯМИ (SI-7(11))

No: 1
Name: si_7_11_01
Type: string
Default: nil

ЦІЛІСНІСТЬ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ, ВБУДОВАНОГО ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ІНФОРМАЦІЇ - ОБМЕЖЕНЕ СЕРЕДОВИЩЕ З ОБМЕЖЕНИМИ ПРИВІЛЕЯМИ [Вилучено: включено до СМ-7(6)]

17.7.12. ПЕРЕВІРКА ЦІЛІСНОСТІ (SI-7(12))

No: 1

Name: si_7_12_01

Type: string

Default: nil

Перевіряється забезпечення, виконанням. цілісність програмне встановлене користувачем перед

No: 2

Name: si_7_12_odp

Type: string

Default: nil

Визначено програмне забезпечення, встановлене користувачем, яке потребує перевірки цілісності перед виконанням

17.7.13. ВИКОНАННЯ КОДУ В ЗАХИЩЕНИХ СЕРЕДОВИЩАХ (SI-7(13))

No: 1

Name: si_7_13_01

Type: string

Default: nil

ЦІЛІСНІСТЬ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ, ВБУДОВАНОГО ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ІНФОРМАЦІЇ - ВИКОНАННЯ КОДУ В ЗАХИЩЕНИХ СЕРЕДОВИЩАХ [Вилучено: включено до СМ-7(7)]

17.7.14. ДВІЙКОВИЙ АБО МАШИННО-ВИКОНУВАНИЙ КОД (SI-7(14))

No: 1

Name: si_7_14_01

Type: string

Default: nil

ЦІЛІСНІСТЬ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ, ВБУДОВАНОГО ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ІНФОРМАЦІЇ - ДВІЙКОВИЙ АБО МАШИННО-ВИКОНУВАНИЙ КОД [Вилучено: включено до СМ-7(8)]

17.7.15. ЦІЛІСНІСТЬ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ, ВБУДОВАНОГО ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ІНФОРМАЦІЇ АВТЕНТИФІКАЦІЯ КОДУ (SI-7(15))

No: 1

Name: si_7_15_01

Type: string

Default: "AES-256-GCM"

Реалізовано криптографічні механізми для автентифікації програмного забезпечення або компонентів мікропрограми перед інсталяцією

No: 2

Name: si_7_15_odp

Type: string

Default: "AES-256-GCM"

Визначено компоненти програмного забезпечення або мікропрограми, які мають бути автентифіковані за допомогою криптографічних механізмів перед встановленням

17.7.16. ТЕРМІН ВИКОНАННЯ ПРОЦЕСУ БЕЗ НАГЛЯДУ (SI-7(16))

No: 1

Name: si_7_16_01

Type: integer

Default: 30

Заборонено процесам виконуватися без нагляду довше, ніж часовий період

No: 2

Name: si_7_16_odp

Type: integer

Default: 30

Визначено максимальний період часу, протягом якого процеси можуть виконуватися без нагляду

17.7.17. ЦІЛІСНІСТЬ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ, ВБУДОВАНОГО ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ІНФОРМАЦІЇ – САМОЗАХИСТ ПРОГРАМ ВІД САМОВІЛЬНОГО ВИКОНАННЯ (SI-7(17))

No: 1

Name: si_7_17_odp

Type: integer

Default: 30

Визначено елементи керування, які потрібно реалізувати для самозахисту програми під час виконання

17.8. ЗАХИСТ ВІД СПАМУ (SI-8)

Немає параметрів для цього контролю.

17.8.1. ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ (SI-8(1))

No: 1

Name: si_8_1_01

Type: string

Default: nil

ЗАХИСТ ВІД СПАМУ - ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ [Вилучено: включено до PL-9]. SI-8(2) ЗАХИСТ ВІД СПАМУ - АВТОМАТИЧНІ ОНОВЛЕННЯ

17.8.2. АВТОМАТИЧНІ ОНОВЛЕННЯ (SI-8(2))

No: 1

Name: si_8_2_01

Type: string

Default: "щорічно"

Автоматично оновлюються механізми захисту від спаму частота

No: 2

Name: si_8_2_odp

Type: string

Default: "щорічно"

Визначено періодичність автоматичного механізмів захисту від спаму; оновлення

17.8.3. БЕЗПЕРЕРВНЕ НАВЧАННЯ (SI-8(3))

No: 1

Name: si_8_3_01

Type: string

Default: "автоматизований засіб моніторингу"

Впроваджені механізми захисту від спаму з можливістю навчання для більш ефективного визначення законного комунікаційного трафіку

17.9. ОБМЕЖЕННЯ НА ВВЕДЕННЯ ІНФОРМАЦІЇ (SI-9)

Немає параметрів для цього контролю.

17.10. ПЕРЕВІРКА ВВОДУ ІНФОРМАЦІЇ (SI-10)

Перевіряти дійсність [Призначення: визначена організацією введена інформація].

No: 1

Name: si_10_01

Type: string

Default: nil

Перевіряється дійсність синтаксису вхідної інформації

No: 2

Name: si_10_odp

Type: string

Default: nil

Визначено вхідні дані до системи, які перевірки достовірності; потребують

17.10.1. ПЕРЕВІРКА ВВОДУ ПЕРЕВИЗНАЧЕННЯ (SI-10(1))

No: 1

Name: si_10_1_a

Type: string

Default: nil

Передбачена можливість ручного перевизначення валідації інформаційних входів

No: 2
Name: si_10_1_b
Type: list
Default: ["admin", "security_officer"]

Використання можливості ручного перевизначення обмежено лише уповноваженими особами

No: 3
Name: si_10_1_c
Type: string
Default: nil

Проводиться аудит перевизначення. використання можливості для ручного

No: 4
Name: si_10_1_odp
Type: string
Default: nil

Визначено авторизованих осіб, які можуть користуватися можливістю ручного перевизначення

17.10.2. ПЕРЕВІРКА ВВОДУ ІНФОРМАЦІЇ ПОМИЛОК (SI-10(2))

No: 1
Name: si_10_2_01
Type: integer
Default: 30

Переглядаються помилки валідації вхідних даних протягом часового періоду

No: 2
Name: si_10_2_02
Type: integer
Default: 30

Помилки валідації вводу вирішуються 10(02)_ODP[02] часового проміжку>. протягом <SI-

17.10.3. ПЕРЕДБАЧУВАНА ПОВЕДІНКА (SI-10(3))

No: 1
Name: si_10_3_02
Type: string
Default: nil

Система поводить задокументованим чином при отриманні недійсних вхідних даних

17.10.4. ЧАСОВІ ВЗАЄМОДІЇ (SI-10(4))

No: 1
Name: si_10_4_01
Type: integer
Default: 30

Враховується часова взаємодія між компонентами системи при визначенні відповідної реакції на невірні вхідні дані

17.10.5. ОБМЕЖЕННЯ ВХІДНИХ ДАНИХ ДОВІРЕНИМИ ДЖЕРЕЛАМИ І ЗАТВЕРДЖЕНИМИ ФОРМАТАМИ (SI-10(5))

Немає параметрів для цього контролю.

17.10.6. ПРОФІЛАКТИКА ВВОДУ ДАНИХ (SI-10(6))

No: 1

Name: si_10_6_01

Type: integer

Default: 30

Визначено елементи керування, які потрібно реалізувати для самозахисту програми під час виконання

17.11. ОБРОБКА ПОМИЛОК (SI-11)

- a. Створити повідомлення про помилки, які надають інформацію, необхідну для реалізації виправних дій, без виявлення інформації, що може бути використана.
- b. Показувати повідомлення про помилки лише [Призначення: визначений організацією персонал або посадові особи].

No: 1

Name: si_11_odp

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, яким слід повідомляти про повідомлення про помилки; SI-11a. генеруються повідомлення про помилки, які надають інформацію, необхідну для коригувальних дій, без розкриття інформації, яка може бути використана; SI-11b. показувати повідомлення про помилки лише для персонал або ролі

17.12. УПРАВЛІННЯ ТА ЗБЕРЕЖЕННЯ ІНФОРМАЦІЇ (SI-12)

Управляти та зберігати інформацію всередині системи та виводити інформацію із системи відповідно до чинного законодавства, виконавчих наказів, директив, правил, політик, стандартів, керівних принципів та експлуатаційних вимог.

No: 1

Name: si_12_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Здійснюється управління інформацією в системі відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог

No: 2

Name: si_12_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Зберігається інформація в системі відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог

No: 3

Name: si_12_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Управління інформацією, що виводиться з системи, здійснюється відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та операційних вимог

No: 4

Name: si_12_04

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Зберігається інформація, що виводиться з системи, відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог

17.12.1. УПРАВЛІННЯ ТА ЗБЕРЕЖЕННЯ ІНФОРМАЦІЇ ЕЛЕМЕНТІВ ПЕРСОНАЛЬНИХ ДАНИХ (SI-12(1))

No: 1

Name: si_12_1_01

Type: list

Default: ["admin", "security_officer"]

Обмежується обробка персональних даних у життєвому циклі інформації в життєвому циклі інформації, елементами інформації, що ідентифікує особу

No: 2

Name: si_12_1_odp

Type: list

Default: ["admin", "security_officer"]

Визначені елементи персональних даних у життєвому циклі інформації

17.12.2. МІНІМІЗАЦІЯ ВИКОРИСТАННЯ ПЕРСОНАЛЬНИХ ДАНИХ ПІД ЧАС ТЕСТУВАННЯ, НАВЧАННЯ ТА ДОСЛІДЖЕННЯ (SI-12(2))

No: 1

Name: si_12_2_01

Type: list

Default: ["admin", "security_officer"]

Використовуються методи для мінімізації використання персональних даних для досліджень; SI-12(02)[02]
використовуються методи для мінімізації використання персональних даних для тестування

No: 2

Name: si_12_2_03

Type: list

Default: ["admin", "security_officer"]

Застосовуються методи для мінімізації використання персональних даних для навчання

17.12.3. УПРАВЛІННЯ ІНФОРМАЦІЇ (SI-12(3))

No: 1

Name: si_12_3_01

Type: string

Default: nil

Використовуються методи для знищення інформації після закінчення терміну зберігання

No: 2

Name: si_12_3_02

Type: string

Default: nil

Використовуються методи для знищення інформації після закінчення терміну зберігання

No: 3

Name: si_12_3_03

Type: integer

Default: 30

Використовуються методи для стирання інформації після закінчення періоду зберігання

17.13. ПЕРЕДБАЧУВАНЕ ЗАПОБІГАННЯ ЗБОЇВ (SI-13)

а. Визначити середній час до збою (MTTF) для [Призначення: визначені організацією компоненти системи] в певних середовищах роботи.

б. Надати замінні компоненти системи та засоби для заміни активних компонентів резервними компонентами відповідно до [Призначення: визначені організацією критерії заміни].

No: 1

Name: si_13_odp_01

Type: integer

Default: 30

Визначені компоненти системи, для яких необхідно визначити середній час до збою (MTTF)

No: 2

Name: si_13_odp_02

Type: list

Default: []

Визначені критерії заміни за середнім часом напрацювання до збою (MTTF), які будуть використовуватися для заміни активних і резервних компонентів; SI-13a. визначено середній час напрацювання до збою (MTTF) для системних компонентів у конкретних умовах експлуатації; SI-13b. передбачені замінні компоненти системи та засоби заміни активних і резервних компонентів відповідно до критеріїв заміни середнього часу напрацювання на відмову (MTTF)

17.13.1. ВІДПОВІДАЛЬНІСТЬ ЗА ПЕРЕДАЧУ ФУНКЦІЙ КОМПОНЕНТІВ (SI-13(1))

No: 1

Name: si_13_1_01

Type: integer

Default: 30

Виводяться компоненти системи з експлуатації шляхом передачі обов'язків компонентів на запасні компоненти не пізніше, ніж частка або відсоток середнього напрацювання на відмову

No: 2

Name: si_13_1_odp

Type: integer

Default: 30

Визначено частку або напрацювання до збою, відсоток середнього часу в межах якого обов'язки компонента системи можуть бути передані компоненту, що замінює його

17.13.2. ТЕРМІН ВИКОНАННЯ ПРОЦЕСУ БЕЗ НАГЛЯДУ (SI-13(2))

No: 1

Name: si_13_2_01

Type: string

Default: nil

ЗАПОБІГАННЯ ПЕРЕДБАЧУВАНИХ ЗБОЇВ - ТЕРМІН ВИКОНАННЯ ПРОЦЕСУ БЕЗ НАГЛЯДУ [Вилучено: включено до SI-7 (16)]

17.13.3. ЗАПОБІГАННЯ ПЕРЕДБАЧУВАНИХ ФУНКЦІЙ КОМПОНЕНТІВ (SI-13(3))

No: 1

Name: si_13_3_01

Type: integer

Default: 30

Ініціюються вручну передачі між активним та резервним компонентами системи, коли використання активного компонента досягає відсоток від середнього часу напрацювання до збою

No: 2

Name: si_13_3_odp

Type: integer

Default: 30

Визначено відсоток середнього часу напрацювання на відмову для передач, які потрібно ініціювати вручну

17.13.4. ЗАПОБІГАННЯ ПЕРЕДБАЧУВАНИХ ЗБОЇВ РЕЗЕРВНИХ КОМПОНЕНТІВ ТА ОПОВІЩЕННЯ (SI-13(4))

No: 1

Name: si_13_4_a

Type: integer

Default: 30

Успішно і прозоро встановлюються резервні компоненти протягом часу, якщо виявлено збої у роботі системних компонентів

17.13.5. ЗАПОБІГАННЯ ПЕРЕДБАЧУВАНИХ АВАРІЙНОГО ПЕРЕМИКАННЯ (SI-13(5))

Немає параметрів для цього контролю.

17.14. НЕСТІЙКІСТЬ (SI-14)

Реалізувати нестійкі [Призначення: визначені організацією компоненти системи та служби], які ініціюються у відомих станах і завершуються [Вибір (один або кілька): після закінчення сеансу використання; періодично з [Призначення: визначена організацією частота]].

No: 1

Name: si_14_01

Type: string

Default: nil

Реалізовано непостійні компоненти системи та сервіси, які ініціюються у відомому стані

No: 2

Name: si_14_odp_01

Type: string

Default: nil

Визначені непостійні компоненти системи та сервіси, які необхідно застосовувати

No: 3

Name: si_14_odp_02

Type: string

Default: "щорічно"

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {по закінченні сеансу використання; частота}

No: 4

Name: si_14_odp_03

Type: integer

Default: 30

Визначено частоту завершення роботи непостійних компонентів і сервісів, які ініціюються у відомому стані (якщо вибрано)

17.14.1. ОНОВЛЕННЯ З НАДІЙНИХ ДЖЕРЕЛ (SI-14(1))

No: 1

Name: si_14_1_01

Type: integer

Default: 30

Програмне забезпечення та дані, що використовуються під час оновлення системних компонентів та служб, отримані з довірених джерел

No: 2

Name: si_14_1_odp

Type: string

Default: nil

Визначені надійні джерела для отримання програмного забезпечення та даних для оновлення системних компонентів і служб

17.14.2. НЕСТІЙКА ІНФОРМАЦІЯ (SI-14(2))

No: 1

Name: si_14_2_b

Type: string

Default: nil

Видаляється інформація, коли вона більше не потрібна

17.14.3. НЕСТІЙКІ ПІДКЛЮЧЕННЯ (SI-14(3))

No: 1

Name: si_14_3_01

Type: string

Default: nil

Встановлюються з'єднання з системою на вимогу

No: 2

Name: si_14_3_odp

Type: integer

Default: 30

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРА: {завершення запиту; період невикористання}

17.15. ФІЛЬТРАЦІЯ ВИХІДНИХ ДАНИХ (SI-15)

Перевіряти інформацію, що виходить з [Призначення: визначені організацією програмні продукти та/або застосунки], щоб переконатися, що інформація відповідає очікуваному змісту.

No: 1

Name: si_15_01

Type: string

Default: nil

Перевіряється інформація, що виводиться з програмне забезпечення та/або додатки, щоб переконатися, що інформація відповідає очікуваному змісту

No: 2

Name: si_15_odp

Type: string

Default: nil

Визначені програми та/або додатки, виведення інформації з яких потребує перевірки

17.16. ЗАХИСТ ПАМ'ЯТІ (SI-16)

Виконати [Призначення: визначені організацією заходи безпеки] для захисту системної пам'яті від несанкціонованого коду, що виконується.

No: 1

Name: si_16_01

Type: string

Default: nil

Реалізовано контроль для захисту системної пам'яті від несанкціонованого виконання коду

No: 2

Name: si_16_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначено засоби контролю для захисту системної пам'яті від несанкціонованого виконання коду

17.17. ВІДМОВОСТІЙКІ ПРОЦЕДУРИ (SI-17)

Виконати [Призначення: визначені організацією відмовостійкі процедури], коли настають [Призначення: визначені організацією умови виявлення несправностей].

No: 1

Name: si_17_01

Type: list

Default: []

Реалізовано процедури захисту від збоїв при виникненні перелік умов збою. відмови, що вимагають

No: 2

Name: si_17_odp_01

Type: string

Default: nil

Визначені відмовостійкі процедури, пов'язані з умовами відмови

No: 3

Name: si_17_odp_02

Type: list

Default: []

Визначено перелік умов відмовостійких процедур

17.18. ОПЕРАЦІЇ ЗАБЕЗПЕЧЕННЯ ЯКОСТІ ДАНИХ (SI-18)

а. Перевіряти точність, актуальність, своєчасність і повноту персональної інформації протягом її життєвого циклу [Завдання: частота, визначена організацією];

б. Виправляти або видаляти неточну або застарілу персональну інформацію.

No: 1

Name: si_18_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено періодичність перевірки точності персональну інформацію протягом життєвого циклу інформації

No: 2

Name: si_18_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено періодичність перевірки актуальності персональної інформації протягом життєвого циклу інформації

No: 3

Name: si_18_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначено періодичність перевірки актуальності персональної інформації протягом життєвого циклу інформації

No: 4

Name: si_18_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено періодичність перевірки повноти персональної інформації протягом життєвого циклу інформації; SI-18a.[01] перевіряється точність персональної інформації протягом життєвого циклу інформації частота; SI-18a.[02] перевіряється актуальність персональної інформації протягом життєвого циклу інформації < SI-18_ODP[02] частота>; SI-18a.[03] перевіряється своєчасність персональної інформації протягом життєвого циклу інформації <частота SI-18_ODP[03]>; SI-18a.[04] перевіряється повнота персональної інформації протягом життєвого циклу інформації частота; SI-18b. потрібно виправити або видалити неточну або застарілу персональну інформацію

17.18.1. ОПЕРАЦІЇ ЗАБЕЗПЕЧЕННЯ ПІДТРИМКА (SI-18(1))

No: 1

Name: si_18_1_01

Type: list

Default: ["admin", "security_officer"]

Використовуються автоматизовані механізми для виправлення або видалення персональної інформації яка є неточною, застарілою, неправильно визначеною щодо впливу або неправильно деідентифікованою

No: 2

Name: si_18_1_odp

Type: list

Default: ["admin", "security_officer"]

Визначені автоматизовані механізми, які використовуються для виправлення або видалення персональної інформації яка є неточною, застарілою, неправильно визначеною щодо впливу або неправильно деідентифікованою

17.18.2. ТЕГУВАННЯ ДАНИХ (SI-18(2))

Немає параметрів для цього контролю.

17.18.3. ЗБИРАННЯ (SI-18(3))

Немає параметрів для цього контролю.

17.18.4. ОПЕРАЦІЇ ЗАПИТИ (SI-18(4))

No: 1

Name: si_18_4_01

Type: list

Default: ["admin", "security_officer"]

Виправляється або видаляється персональна інформація на вимогу осіб або їхніх уповноважених представників.
ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

17.18.5. ПОВІДОМЛЕННЯ ПРО ВИПРАВЛЕННЯ ЧИ ВИДАЛЕННЯ (SI-18(5))

No: 1

Name: si_18_5_01

Type: list

Default: ["admin", "security_officer"]

Одержувачі та фізичні особи повідомляються про виправлення або видалення персональної інформації

No: 2

Name: si_18_5_odp

Type: list

Default: ["admin", "security_officer"]

Визначені одержувачі персональних даних, які повинні бути повідомлені про виправлення або видалення персональних даних

17.19. ДЕІДЕНТИФІКАЦІЯ (SI-19)

а. Видалить такі елементи персональних даних з наборів даних: [Призначення: визначені організацією елементи персональних даних];

б. Оцініть [Призначення: деідентифікації. частота, визначена організацією] ефективність

No: 1

Name: si_19_odp_02

Type: string

Default: "щорічно"

Визначено частоту, з якою слід оцінювати ефективність деідентифікації; SI-19a. вилучено елементи з наборів даних; SI-19b. оцінюється ефективність деідентифікації частота

17.19.1. ЗБІР (SI-19(1))

No: 1

Name: si_19_1_01

Type: list

Default: ["admin", "security_officer"]

Деідентифікується набір даних після збору шляхом відмови від збору персональної інформації

17.19.2. АРХІВАЦІЯ (SI-19(2))

No: 1

Name: si_19_2_01

Type: list

Default: ["admin", "security_officer"]

Заборонено архівування елементів персональної інформації, якщо ці елементи в наборі даних не будуть потрібні після того, як набір даних буде заархівовано

17.19.3. ВИДАЛЕННЯ (SI-19(3))

No: 1

Name: si_19_3_01

Type: list

Default: ["admin", "security_officer"]

Видаляються елементи персональної інформації набору даних перед його оприлюдненням, якщо ці елементи в наборі даних не повинні бути частиною оприлюднення даних

17.19.4. ВИДАЛЕННЯ, МАСКУВАННЯ, ШИФРУВАННЯ, ХЕШУВАННЯ АБО ЗАМІНА ПРЯМИХ ІДЕНТИФІКАТОРІВ (SI-19(4))

Немає параметрів для цього контролю.

17.19.5. КОНТРОЛЬ СТАТИСТИЧНОГО РОЗКРИТТЯ (SI-19(5))

No: 1

Name: si_19_5_01

Type: list

Default: ["admin", "security_officer"]

Не маніпулюють числовими даними так, щоб у результатах аналізу не можна було ідентифікувати жодну особу чи організацію

No: 2

Name: si_19_5_02

Type: list

Default: ["admin", "security_officer"]

Не маніпулюють таблицями непередбачених обставин таким чином, щоб у результатах аналізу не можна було ідентифікувати жодну особу чи організацію

No: 3

Name: si_19_5_03

Type: list

Default: ["admin", "security_officer"]

Не маніпулюють статистичними даними так, щоб за результатами аналізу не можна було ідентифікувати жодну особу чи організацію

17.19.6. ДИФЕРЕНЦІЙОВАНА КОНФІДЕНЦІЙНІСТЬ (SI-19(6))

No: 1

Name: si_19_6_01

Type: list

Default: ["admin", "security_officer"]

Запобігає розголошенню персональної інформації, додавання недетермінованого шуму до результатів математичних операцій до того, як результати будуть повідомлені

17.19.7. ПЕРЕВІРЕНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ (SI-19(7))

No: 1

Name: si_19_7_01

Type: string

Default: "AES-256-GCM"

Виконується деідентифікація за допомогою перевірених алгоритмів

No: 2

Name: si_19_7_02

Type: string

Default: "AES-256-GCM"

Виконується деідентифікація за допомогою програмного забезпечення, яке пройшло валідацію для реалізації алгоритмів

17.19.8. МОТИВОВАНИЙ ПОРУШНИК (SI-19(8))

No: 1

Name: si_19_8_01

Type: string

Default: nil

Виконується тест мотивованого зломисника для деідентифікованого набору даних, щоб визначити, чи залишаються ідентифіковані дані або чи можна повторно ідентифікувати деідентифіковані дані

17.20. ПСУВАННЯ (SI-20)

Вбудуйте дані або можливості в такі системи або системні компоненти, щоб визначити, чи дані організації були викрадені або неналежним чином видалені з організації: [Призначення: визначені організацією системи або системні компоненти].

No: 1

Name: si_20_01

Type: string

Default: nil

Вбудовані дані або можливості в системи або компоненти системи, щоб визначити, чи були дані організації викрадені або неналежним чином видалені з організації

No: 2

Name: si_20_odp

Type: string

Default: nil

Визначені системи або компоненти системи з даними або можливостями, що підлягають застосуванню

17.21. ОНОВЛЕННЯ ІНФОРМАЦІЇ (SI-21)

Оновлюйте [Призначення: інформація, визначена організацією] з [Призначення: частота, визначена організацією] або згенеруйте інформацію за запитом і видаліть її, коли в ній більше не буде потреби.

No: 1
 Name: si_21_01
 Type: string
 Default: "щорічно"

Інформація оновлюється частота або генерується на вимогу і видаляється, коли більше не потрібна. з якими потрібно оновлювати

No: 2
 Name: si_21_odp_01
 Type: string
 Default: nil

Визначена інформація, яку потрібно оновити

No: 3
 Name: si_21_odp_02
 Type: integer
 Default: 30

Визначені частоти, інформацію

17.22. РІЗНОВИДИ ІНФОРМАЦІЇ (SI-22)

a. Визначити наступні альтернативні джерела інформації для [Завдання: основні функції та послуги, визначені організацією]: [Завдання: альтернативні, визначені організацією джерела інформації];

b. Використовуйте альтернативне джерело інформації для виконання основних функцій або послуг на [Призначення: визначені організацією системи або системні компоненти], коли основне джерело інформації пошкоджено або недоступне.

No: 1
 Name: si_22_odp_01
 Type: string
 Default: nil

Визначені альтернативні джерела інформації для основних функцій та послуг

No: 2
 Name: si_22_odp_02
 Type: string
 Default: nil

Визначені основні функції та послуги, які потребують альтернативних джерел інформації

No: 3
 Name: si_22_odp_03
 Type: string
 Default: nil

Визначені системи або компоненти системи, які потребують альтернативного джерела інформації для виконання основних функцій або послуг; SI-22a. визначені альтернативні джерела інформації для основних функцій та послуг; SI-22b. використовується альтернативне джерело інформації для виконання основних функцій або послуг у системах або компонентах системи, коли первинне джерело інформації пошкоджене або недоступне

17.23. ФРАГМЕНТАЦІЯ ІНФОРМАЦІЇ (SI-23)

No: 1

Name: si_23_odp_01

Type: string

Default: nil

Визначені обставини, інформації, які вимагають фрагментації

No: 2

Name: si_23_odp_02

Type: string

Default: nil

Визначена інформація, яка підлягає фрагментації

No: 3

Name: si_23_odp_03

Type: string

Default: nil

Визначені системи або компоненти системи, між якими має бути розподілена фрагментована інформація; SI-23a. за обставин, інформація є фрагментованою; SI-23b. за обставин фрагментована інформація розподіляється між системами або компонентами системи

18. SR

Клас заходів захисту SR — УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА

Цей клас встановлює вимоги для виявлення та мінімізації загроз, що виникають через зовнішніх постачальників продуктів та послуг.

Перелік заходів захисту: Політика та процедури управління ризиками ланцюга постачання (SR-1); План управління ризиками ланцюга постачання (SR-2); Створення команди постачання (SR-2(1)); Контроль ланцюга постачання і процесів (SR-3); Різні бази постачання (SR-3(1)); Обмеження шкоди (SR-3(2)); Перенесення заходів захисту управління ризиками ланцюга постачання до субпідрядників (SR-3(3)); Походження (SR-4); Ідентичність (SR-4(1)); Унікальна ідентифікація (SR-4(2)); Перевірка на справжність і відсутність внесення змін (SR-4(3)); Походження – перевірка ланцюга цілісності (SR-4(4)); Стратегії придбання, інструменти і методи (SR-5); Належне постачання (SR-5(1)); Оцінка перед відбором, прийняття, модифікація чи оновлення (SR-5(2)); Оцінка постачальників (SR-6); Тестування та аналіз (SR-6(1)); Безпека операцій ланцюга постачання (SR-7); Повідомлення про порушення ланцюга постачання (SR-8); Захист від злому та виявлення (SR-9); Етапи чи системи розвитку життєвого циклу (SR-9(1)); Перевірка системи і компонентів системи (SR-10); Автентичність компоненту (SR-11); Автентичність компоненту (SR-11(1)); Утилізація компоненту (SR-12).

18.1. ПОЛІТИКА ТА ПРОЦЕДУРИ УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-1)

а. Розробіть, задокументуйте та поширте [Призначення: персонал або ролі, визначені організацією]:

1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політика управління ризиками ланцюга постачання, яка: а) Розглядає мету, сферу діяльності,

ролі, відповідальність, зобов'язання керівництва, координацію між організаційними підрозділами та відповідність; b) Відповідає чинним законам, виконавчим наказам, директивам, положенням, політикам, стандартам і вказівкам;

2. Процедури для сприяння впровадженню політики управління ризиками ланцюга постачання та відповідних засобів контролю управління ризиками ланцюга постачання;

b. Призначити [Призначення: посадова особа, визначена організацією] для управління розробкою, документуванням і розповсюдженням політики та процедур управління ризиками ланцюга постачання;

c. Перегляньте та оновіть поточне управління ризиками ланцюга постачання:

1. Політика [Призначення: частота, визначена організацією] та наступне [Призначення: події, визначені організацією];

2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].

No: 1

Name: sr_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюється політика управління ризиками ланцюга постачання

No: 2

Name: sr_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури управління ризиками ланцюга постачання

No: 3

Name: sr_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень завдань/бізнеспроцесу; рівень системи}

No: 4

Name: sr_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначена посадова особа, відповідальна за розробку, документування та розповсюдження політики та процедур управління ризиками ланцюга постачання

No: 5

Name: sr_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначена періодичність перегляду та оновлення поточної політики управління ризиками ланцюга постачання

No: 6

Name: sr_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Є події, які вимагають перегляду та оновлення поточної політики управління ризиками ланцюга постачання

No: 7

Name: sr_1_odp_07

Type: string

Default: "щорічно"

Визначена періодичність перегляду та оновлення поточної процедури управління ризиками ланцюга постачання

18.2. ПЛАН УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-2)

- а. Розробіть план управління ризиками ланцюга постачання, пов'язаними з дослідженнями та розробкою, проектуванням, виробництвом, придбанням, доставкою, інтеграцією, експлуатацією та обслуговуванням, а також утилізацією таких систем, компонентів системи або послуг для системи: [Призначення: системи, визначені організацією, системні компоненти або системні служби];
- б. Перегляньте та оновіть план управління ризиками ланцюга постачання [Призначення: частота, визначена організацією] або за потреби для усунення загроз;
- с. Захистіть план управління ризиками ланцюга постачання від несанкціонованого розголошення та модифікації.

No: 1

Name: sr_2_odp_01

Type: string

Default: nil

Визначені системи, компоненти системи або системні послуги, для яких розробляється план управління ризиками ланцюга постачання

18.2.1. СТВОРЕННЯ КОМАНДИ ПОСТАЧАННЯ (SR-2(1))

No: 1

Name: sr_2_1_01

Type: list

Default: ["admin", "security_officer"]

Створена команда з управління ризиками ланцюга постачання, що складається з персонал, ролі та обов'язки для керівництва та підтримки діяльності з управління ризиками ланцюга постачання

18.3. КОНТРОЛЬ ЛАНЦЮГА ПОСТАЧАННЯ І ПРОЦЕСІВ (SR-3)

- а. Встановлення процесу або процесів для виявлення та усунення слабких місць або недоліків в елементах і процесах ланцюга постачання [Призначення: визначена організацією система або компонент системи] у координації з [Завдання: персонал ланцюга постачання, визначений організацією];
- б. Використовуйте такі заходи захисту, щоб захистити систему, компонент системи або системну службу від ризиків ланцюга постачання та обмежити шкоду чи наслідки від подій, пов'язаних із ланцюгом постачання: [Призначення: заходи захисту ланцюга постачання, визначені організацією];
- с. Задokumentуйте обрані та впроваджені процеси та заходи захисту ланцюгом постачання у [Вибір: плани безпеки та приватності; план управління ризиками ланцюга постачання; [Призначення: документ, визначений організацією]].

No: 1

Name: sr_3_odp_01

Type: string

Default: nil

Визначено систему або компонент системи, який потребує процесу або процесів для виявлення та усунення слабких місць або недоліків

No: 2

Name: sr_3_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал ланцюга поставок, з яким необхідно координувати процес або процеси виявлення та усунення слабких місць або недоліків в елементах і процесах ланцюга постачання

No: 3

Name: sr_3_odp_03

Type: string

Default: "автоматизований засіб моніторингу"

Визначені засоби контролю ланцюга постачання, що застосовуються для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання

No: 4

Name: sr_3_odp_04

Type: list

Default: ["admin", "security_officer"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {плани безпеки та конфіденційності; план управління ризиками ланцюга постачання; документ}; SR-03_ODP[05] визначено документ, що ідентифікує обрані та впроваджені процеси та засоби контролю ланцюга постачання (якщо обрано); SR-03a.[01] запроваджено процес або процеси для виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання; SR-03a.[02] процес або процеси виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання системи або компонента системи координується/координуються з персоналом ланцюга постачання; SR-03b. застосовуються засоби контролю ланцюга постачання для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання; SR-03c. задокументовані обрані та впроваджені процеси та засоби контролю ланцюга постачання в ЗНАЧЕННЯ ВИБІРКОВОГО ПАРАМЕТРА(ів)

No: 5

Name: sr_3_odp_05

Type: list

Default: ["admin", "security_officer"]

Визначено документ, що ідентифікує обрані та впроваджені процеси та засоби контролю ланцюга постачання (якщо обрано); SR-03a.[01] запроваджено процес або процеси для виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання; SR-03a.[02] процес або процеси виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання системи або компонента системи координується/координуються з персоналом ланцюга постачання; SR-03b. застосовуються засоби контролю ланцюга постачання для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання; SR-03c. задокументовані обрані та впроваджені процеси та засоби контролю ланцюга постачання в ЗНАЧЕННЯ ВИБІРКОВОГО ПАРАМЕТРА(ів)

18.3.1. РІЗНІ БАЗИ ПОСТАЧАННЯ (SR-3(1))

Немає параметрів для цього контролю.

18.3.2. ОБМЕЖЕННЯ ШКОДИ (SR-3(2))

No: 1

Name: sr_3_2_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначені засоби контролю для обмеження шкоди від потенційних супротивників ланцюга постачання; SR-03(02) застосовуються контроль для обмеження шкоди від потенційних супротивників, які ідентифікують та націлюються на ланцюг постачання організації

18.3.3. ПЕРЕНЕСЕННЯ ЗАХОДІВ ЗАХИСТУ УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ ДО СУБПІДРЯДНИКІВ (SR-3(3))

No: 1

Name: sr_3_3_01

Type: string

Default: "автоматизований засіб моніторингу"

Включені засоби контролю, передбачені в контрактах з основними підрядниками, також і в контрактах з субпідрядниками

18.4. ПОХОДЖЕННЯ (SR-4)

Документуйте, відстежуйте та підтримуйте справжнє походження таких систем, компонентів системи і пов'язаних даних: [Призначення: системи, визначені організацією, системні компоненти та пов'язані дані].

No: 1

Name: sr_4_01

Type: string

Default: nil

Задokumentовано дійсне походження для систем, компонентів системи та пов'язаних з ними даних

No: 2

Name: sr_4_02

Type: string

Default: nil

Відстежується дійсне походження для систем, компонентів системи та пов'язаних з ними даних

No: 3

Name: sr_4_03

Type: string

Default: nil

Підтримується дійсне походження для систем, компонентів системи та пов'язаних з ними даних

No: 4

Name: sr_4_odp

Type: string

Default: nil

Визначені системи, компоненти системи та пов'язані з ними дані, які потребують достовірного походження

18.4.1. ІДЕНТИЧНІСТЬ (SR-4(1))

No: 1

Name: sr_4_1_01

Type: list

Default: ["admin", "security_officer"]

Встановлена унікальна ідентифікація елементів ланцюга постачання, процесів та персоналу; SR-04(01)[02] підтримується унікальна ідентифікація елементів ланцюга постачання, процесів та персоналу

No: 2

Name: sr_4_1_02

Type: string

Default: nil

Зберігається унікальна ідентифікація систем та критично важливих системних компонентів для відстеження в ланцюгу постачання

No: 3

Name: sr_4_1_odp

Type: list

Default: ["admin", "security_officer"]

Визначені елементи ланцюга постачання, процеси та персонал, пов'язані з системами та критично важливими компонентами системи, які потребують унікальної ідентифікації

18.4.2. УНІКАЛЬНА ІДЕНТИФІКАЦІЯ (SR-4(2))

No: 1

Name: sr_4_2_01

Type: string

Default: nil

Встановлена унікальна ідентифікація систем та критичних системних компонентів для відстеження в ланцюгу постачання

No: 2

Name: sr_4_2_odp

Type: string

Default: nil

Визначені системи та критичні компоненти системи, які потребують унікальної ідентифікації для відстеження в ланцюгу постачання

18.4.3. ПЕРЕВІРКА НА СПРАВЖНІСТЬ І ВІДСУТНІСТЬ ВНЕСЕННЯ ЗМІН (SR-4(3))

No: 1

Name: sr_4_3_01

Type: string

Default: "автоматизований засіб моніторингу"

Застосовуються засоби контролю для перевірки того, що отримана система або компонент системи є справжніми

No: 2

Name: sr_4_3_02

Type: string

Default: "автоматизований засіб моніторингу"

Застосовуються засоби контролю для перевірки того, що отриману систему або компонент системи не було змінено

18.4.4. ПОХОДЖЕННЯ – ПЕРЕВІРКА ЛАНЦЮГА ЦІЛІСНОСТІ (SR-4(4))

No: 1

Name: sr_4_4_01

Type: string

Default: "автоматизований засіб моніторингу"

Застосовуються засоби контролю для забезпечення цілісності системи та її компонентів

No: 2

Name: sr_4_4_02

Type: string

Default: nil

Проводиться метод аналізу для забезпечення цілісності системи та компонентів системи

18.5. СТРАТЕГІЇ ПРИДБАННЯ, ІНСТРУМЕНТИ І МЕТОДИ (SR-5)

Використовуйте наступні стратегії придбання, контрактні інструменти та методи закупівель, щоб захистити від ризиків ланцюга постачання, визначити та пом'якшити їх: [Призначення: визначені організацією стратегії придбання, контрактні інструменти та методи закупівель].

No: 1

Name: sr_5_01

Type: string

Default: nil

Застосовуються стратегії, інструменти та методи для захисту від ризиків ланцюга постачання

No: 2

Name: sr_5_02

Type: string

Default: nil

Застосовуються стратегії, інструменти та методи для виявлення ризиків ланцюга постачання

No: 3

Name: sr_5_03

Type: string

Default: nil

Застосовуються стратегії, інструменти та методи для зменшення ризиків ланцюга постачання

No: 4

Name: sr_5_odp

Type: string

Default: nil

Визначені стратегії закупівель, контрактні інструменти та методи закупівель для захисту, виявлення та пом'якшення ризиків ланцюга постачання

18.5.1. НАЛЕЖНЕ ПОСТАЧАННЯ (SR-5(1))

No: 1

Name: sr_5_1_01

Type: string

Default: "автоматизований засіб моніторингу"

Застосовуються засоби контролю для забезпечення адекватного постачання критично важливих компонентів системи

18.5.2. ОЦІНКА ПЕРЕД ВІДБОРОМ, ПРИЙНЯТТЯ, МОДИФІКАЦІЯ ЧИ ОНОВЛЕННЯ (SR-5(2))

No: 1

Name: sr_5_2_01

Type: string

Default: nil

Оцінюється система, компонент системи або послуги системи перед відбором

No: 2

Name: sr_5_2_02

Type: string

Default: nil

Оцінюється система, компонент системи або послуги системи перед прийняттям

No: 3

Name: sr_5_2_03

Type: string

Default: nil

Оцінюється система, компонент системи або послуги системи перед модифікацією

No: 4

Name: sr_5_2_04

Type: string

Default: nil

Оцінюється система, компонент системи або послуги системи перед оновленням

18.6. ОЦІНКА ПОСТАЧАЛЬНИКІВ (SR-6)

Оцініть і перегляньте ризики ланцюга постачання, пов'язані з постачальниками або підрядниками, системою, системним компонентом або системною послугою, яку вони надають [Призначення: частота, визначена організацією].

No: 1

Name: sr_6_01

Type: string

Default: "щорічно"

Оцінюються та аналізуються ризики, пов'язані з ланцюгом постачання, які стосуються постачальників або підрядників та систем, компонентів системи або системних послуг, які вони надають < SR-06_ODP частота >

No: 2

Name: sr_6_odp

Type: string
Default: "щорічно"

Визначена періодичність оцінки та аналізу ризиків, пов'язаних з ланцюгом постачання, що стосуються постачальників або підрядників, а також систем, компонентів системи або системних послуг, які вони надають

18.6.1. ТЕСТУВАННЯ ТА АНАЛІЗ (SR-6(1))

Немає параметрів для цього контролю.

18.7. БЕЗПЕКА ОПЕРАЦІЙ ЛАНЦЮГА ПОСТАЧАННЯ (SR-7)

Використовуйте такі заходи захисту операційної безпеки (OPSEC), щоб захистити інформацію, пов'язану з ланцюгом постачання для системи, системного компонента чи системної служби: [Призначення: визначені організацією заходи захисту операційної безпеки (OPSEC)].

No: 1
Name: sr_7_01
Type: string
Default: "автоматизований засіб моніторингу"

Застосовуються засоби управління OPSEC для захисту інформації, пов'язаної з ланцюжком постачання для системи, системного компонента або системної служби

No: 2
Name: sr_7_odp
Type: string
Default: nil

Визначені заходи захисту операційної безпеки (OPSEC) для захисту інформації, пов'язаної з ланцюжком поставок, для системи, системного компонента або системної служби

18.8. Повідомлення про порушення ланцюга постачання (SR-8)

Затвердити угоди та процедури з суб'єктами, залученими до ланцюга постачання для системи, системного компонента або системної послуги для [Вибір (одного або кількох): повідомлення про порушення ланцюга постачання; результати оцінювання або аудитів; [Призначення: інформація, визначена організацією]].

No: 1
Name: sr_8_01
Type: string
Default: nil

Аналізу/тестування елементів, ПОВІДОМЛЕННЯ ПРО ПОРУШЕННЯ ЛАНЦЮГА ПОСТАЧАННЯ

No: 2
Name: sr_8_odp_01
Type: string
Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {повідомлення про порушення ланцюга постачання; результати оцінок або аудитів}

No: 3

Name: sr_8_odp_02

Type: string

Default: nil

Визначена інформація, для якої необхідно встановити угоди та процедури (якщо вибрано)

18.9. ЗАХИСТ ВІД ЗЛОМУ ТА ВИЯВЛЕННЯ (SR-9)

Впровадити програму захисту від несанкціонованого доступу для системи, системного компонента або системної служби.

No: 1

Name: sr_9_01

Type: string

Default: nil

Реалізована програма захисту від несанкціонованого доступу для системи, компонента системи або системної служби

18.9.1. ЕТАПИ ЧИ СИСТЕМИ РОЗВИТКУ ЖИТТЄВОГО ЦИКЛУ (SR-9(1))

No: 1

Name: sr_9_1_01

Type: string

Default: nil

Застосовуються технології, інструменти та методи захисту від втручання протягом усього життєвого циклу розробки системи

18.10. ПЕРЕВІРКА СИСТЕМИ І КОМПОНЕНТІВ СИСТЕМИ (SR-10)

Перевірте наступні системи або системні компоненти [Вибір (один або більше): випадковим чином обраних; на [Призначення: частота, визначена організацією], після [Призначення: визначені організацією ознаки необхідності перевірки]] для виявлення втручання: [Призначення: визначені організацією системи або компоненти системи].

No: 1

Name: sr_10_odp_01

Type: string

Default: nil

Визначені системи або компоненти системи, які потребують перевірки

No: 2

Name: sr_10_odp_02

Type: integer

Default: 30

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРА: {випадково; з частотою <SR-10_ODP[03]; за наявності вказівок на необхідність перевірки}

No: 3

Name: sr_10_odp_03

Type: string

Default: "щорічно"

Визначена періодичність проведення перевірок систем або компонентів системи (якщо вибрано)

No: 4

Name: sr_10_odp_04

Type: string

Default: nil

Визначені ознаки необхідності перевірки систем або компонентів системи (якщо вони були обрані)

18.11. АВТЕНТИЧНІСТЬ КОМПОНЕНТУ (SR-11)

- a. Розробити та впровадити політику та процедури боротьби з підробками, які включають засоби для виявлення та запобігання потраплянню підроблених компонентів у систему;
- b. Повідомляти про підроблені системні компоненти [Вибір (один або кілька): джерело підробленого компонента; [Призначення: зовнішні звітні організації, визначені організацією]; [Призначення: персонал або ролі, визначені організацією]].

No: 1

Name: sr_11_odp_01

Type: list

Default: ["admin", "security_officer"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРА: {джерело підробленого компонента; зовнішні підзвітні організації; персонал або ролі}

No: 2

Name: sr_11_odp_02

Type: string

Default: nil

Визначені зовнішні підзвітні організації, яким слід повідомляти про підроблені компоненти системи (якщо вони були обрані)

18.11.1. АВТЕНТИЧНІСТЬ КОМПОНЕНТУ (SR-11(1))

No: 1

Name: sr_11_1_01

Type: list

Default: ["admin", "security_officer"]

Підготовлений персонал або ролі до виявлення підроблених компонентів системи, включаючи апаратне, програмне та мікропрограмне забезпечення

No: 2

Name: sr_11_1_odp

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які потребують підготовки для виявлення підроблених компонентів системи (включаючи апаратне, програмне та мікропрограмне забезпечення)

18.12. УТИЛІЗАЦІЯ КОМПОНЕНТУ (SR-12)

Утилізуйте [Призначення: визначені організацією дані, документація, інструменти або системні компоненти] за допомогою таких прийомів і методів: [Призначення: визначені організацією прийоми та методи].

No: 1

Name: sr_12_01

Type: string

Default: nil

Утилізуються дані, документація, інструменти або компоненти системи з використанням прийомів і методів

No: 2

Name: sr_12_odp_01

Type: string

Default: nil

Визначені дані, документація, інструменти або компоненти системи, які підлягають утилізації

No: 3

Name: sr_12_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначені методи та способи утилізації даних, документації, інструментів або компонентів системи

19. РМ

Клас заходів захисту РМ — МЕНЕДЖМЕНТ ІНФОРМАЦІЙНОЇ БЕЗПЕКИ

Цей клас визначає загальноорганізаційні заходи для ефективного управління програмами інформаційної безпеки та приватності на рівні всього підприємства.

Перелік заходів захисту: Ролі програми інформаційної безпеки (РМ-2); Ресурси забезпечення інформаційної безпеки та приватності (РМ-3); Інвентаризація системи (РМ-5); Архітектура підприємства (РМ-7); Розвантаження (РМ-7(1)); План захисту критичної інфраструктури (РМ-8); Стратегія управління ризиками (РМ-9); Процес авторизації (РМ-10); Визначення завдань та процесів (РМ-11); Програма інсайдерської загрози (РМ-12); Безпека та приватність працівників (РМ-13); Тестування, навчання та моніторинг (РМ-14); Контакти з групами та асоціаціями з питань безпеки інформації та приватності (РМ-15); Програма інформування про загрози (РМ-16); Програма інформування про загрози (РМ-16(1)); Захист публічної інформації у зовнішніх системах (РМ-17); ПРОГРАМА (КОНЦЕПЦІЯ) ЗАБЕЗПЕЧЕННЯ ПРИВАТНОСТІ (РМ-18); Керівні ролі програми приватності (РМ-19); Система записів програми приватності (РМ-20); Облік розкриття персональних даних (РМ-21); Управління якістю персональних даних (РМ-22); Орган управління персональними даними (РМ-23); Орган з питань цілісності даних (РМ-24); Мінімізація кількості персональних даних, що використовуються під час тестування, навчання та досліджень (РМ-25); Управління скаргами (РМ-26); Звітність з питань забезпечення приватності (РМ-27); Оцінка ризиків (РМ-28); Ролі керівників програми управління ризиками (РМ-29); План управління ризиками ланцюга постачання (РМ-30); План безперервного моніторингу (РМ-31); Призначення (РМ-32).

19.1. Ролі програми інформаційної безпеки (РМ-2)

Призначити старшу посадову особу служби інформаційної безпеки, яка наділена відповідними завданнями та ресурсами для здійснення координації, розробки, впровадження та підтримки програми (концепції) інформаційної безпеки.

No: 1

Name: pm_2_01

Type: list

Default: ["admin", "security_officer"]

Призначено старшу посадову особу з питань інформаційної безпеки в установі

No: 2

Name: pm_2_02

Type: list

Default: ["admin", "security_officer"]

Надано посадовій особі з інформаційної безпеки відомства повноваження та ресурси для координації загальноорганізаційної програми (концепції) з інформаційної безпеки

No: 3

Name: pm_2_03

Type: list

Default: ["admin", "security_officer"]

Має старша посадова особа з питань інформаційної безпеки відомства місію та ресурси для розробки загальноорганізаційної програми інформаційної безпеки

No: 4

Name: pm_2_04

Type: list

Default: ["admin", "security_officer"]

Забезпечено старшу посадову особу з інформаційної безпеки відомства необхідним та ресурсами для впровадження загальноорганізаційної програми інформаційної безпеки

No: 5

Name: pm_2_05

Type: list

Default: ["admin", "security_officer"]

Забезпечено старшу посадову особу з інформаційної безпеки відомства необхідним та ресурсами для підтримки загальноорганізаційної програми (концепції) з інформаційної безпеки

19.2. Ресурси забезпечення інформаційної безпеки та приватності (РМ-3)

a.

b. Запровадити процес для забезпечення того, щоб плани дій та етапи програм безпеки та приватності, програм управління ризиками ланцюга постачання і пов'язаних систем організації:

1. розроблялися та підтримувалися;
2. задокументовані корегувальні заходи захисту адекватно реагували на ризики для операцій організації і активів, фізичних осіб, інших організацій та держави;
3. оприлюднювалися відповідно до встановлених вимог до звітності. Переглядати плани дій та етапи для узгодженості з організаційною стратегією управління ризиками й організаційними пріоритетами щодо дій з реагування на ризики.

Немає параметрів для цього контролю.

19.3. Інвентаризація системи (PM-5)

Розробити, відстежувати та звітувати про результати вимірювань показників продуктивності забезпечення безпеки інформації та приватності.

No: 1

Name: pm_5_01

Type: list

Default: []

Розроблено перелік систем організації

No: 2

Name: pm_5_02

Type: list

Default: []

Оновлюється frequency>. перелік оновлення систем переліку організації систем <PM-05_ODP

No: 3

Name: pm_5_odp

Type: string

Default: "щорічно"

Визначена періодичність організації

19.4. Архітектура підприємства (PM-7)

Визначити завдання інформаційної безпеки та приватності при розробці документуванні та оновленні плану захисту критичної інфраструктури та ключових ресурсів.

No: 1

Name: pm_7_01

Type: string

Default: nil

Розроблена архітектура інформаційної безпеки; підприємства з урахуванням

No: 2

Name: pm_7_02

Type: string

Default: nil

Підтримується архітектура інформаційної безпеки; підприємства з урахуванням

No: 3

Name: pm_7_03

Type: string

Default: nil

Розроблена архітектура конфіденційності; підприємства з урахуванням

No: 4

Name: pm_7_04

Type: string

Default: nil

Підтримується архітектура конфіденційності; підприємства з урахуванням

No: 5

Name: pm_7_05

Type: string

Default: nil

Розроблена архітектура підприємства з урахуванням ризиків для діяльності та активів організації, окремих осіб, інших організацій та держави в цілому

No: 6

Name: pm_7_06

Type: string

Default: nil

Підтримується архітектура підприємства з урахуванням ризиків, що виникають в результаті цього для операцій та активів організації, окремих осіб, інших організацій та держави.,

19.4.1. РОЗВАНТАЖЕННЯ (PM-7(1))

No: 1

Name: pm_7_1_01

Type: string

Default: nil

Несуттєві функції або послуги вивантажуються на інші системи, компоненти системи або зовнішнього постачальника

No: 2

Name: pm_7_1_odp

Type: string

Default: nil

Визначені несуттєві функції або послуги, які потрібно розвантажити

19.5. ПЛАН ЗАХИСТУ КРИТИЧНОЇ ІНФРАСТРУКТУРИ (PM-8)

No: 1

Name: pm_8_01

Type: string

Default: nil

Враховані питання інформаційної безпеки при розробці плану захисту критичної інфраструктури та ключових ресурсів; PM-08[02] розглядаються питання інформаційної безпеки в документації плану захисту критичної інфраструктури та ключових ресурсів

No: 2

Name: pm_8_03

Type: string

Default: nil

Враховані питання інформаційної безпеки в оновленому плані захисту критичної інфраструктури та ключових ресурсів

No: 3
 Name: pm_8_04
 Type: string
 Default: nil

Враховані питання конфіденційності при розробці плану захисту критичної інфраструктури та ключових ресурсів

No: 4
 Name: pm_8_05
 Type: string
 Default: nil

Розглядаються питання конфіденційності в документації плану захисту критичної інфраструктури та ключових ресурсів

No: 5
 Name: pm_8_06
 Type: string
 Default: nil

Враховані питання конфіденційності в оновленому плані захисту критичної інфраструктури та ключових ресурсів

19.6. СТРАТЕГІЯ УПРАВЛІННЯ РИЗИКАМИ (РМ-9)

а. Розробити комплексну стратегію управління:

1. ризиками безпеки для операцій та активів організації, фізичних осіб, інших організацій і держави, пов'язаних з експлуатацією та використанням систем організації;
2. ризиками приватності для фізичних осіб, які можуть виникати внаслідок збирання, обміну, зберігання, передачі, використання та розпорядження персональними даними;

б. Реалізувати стратегію управління ризиками в масштабах організації.

с. Переглядати й оновлювати стратегію управління ризиками [Призначення: з визначеною організацією частотою] або, якщо потрібно, у разі змін в організації.

No: 1
 Name: pm_9_odp
 Type: list
 Default: ["admin", "security_officer"]

Визначено періодичність перегляду та оновлення стратегії управління ризиками; РМ-09а.01 розроблена комплексна стратегія управління ризиками безпеки для операцій та активів організації, окремих осіб, інших організацій та держави, пов'язаних з експлуатацією та використанням організаційних систем; РМ-09а.02 розроблена комплексна стратегія управління ризиками для приватності осіб, що виникають внаслідок санкціонованої обробки інформації, що ідентифікує особу; РМ-09б. стратегія управління ризиками послідовно впроваджується в організації; РМ-09с. переглядається та оновлюється стратегія управління ризиками частота або в міру необхідності у зв'язку з організаційними змінами

19.7. ПРОЦЕС АВТОРИЗАЦІЇ (РМ-10)

а. Управляти станом безпеки та приватності інформаційних систем організації та середовищ, у яких ці інформаційні системи експлуатуються через процедури авторизації

б. Призначити окремих осіб для виконання певних ролей і обов'язків у рамках організаційного процесу управління ризиками.

с. Інтегрувати процеси авторизації в загальноорганізаційну програму управління ризиками.

Немає параметрів для цього контролю.

19.8. ВИЗНАЧЕННЯ ЗАВДАНЬ ТА ПРОЦЕСІВ (PM-11)

Створити програму розвитку та вдосконалення спеціалістів з питань безпеки та приватності.

No: 1

Name: pm_11_odp

Type: list

Default: ["admin", "security_officer"]

Визначено періодичність перегляду завдань та бізнеспроцесів; PM-11a.[01] завдання та бізнес-процеси організації визначені з урахуванням інформаційної безпеки; PM-11a.[02] завдання та бізнес-процеси організації визначені з урахуванням права на приватність; PM-11a.[03] завдання та бізнес-процеси організації визначені з урахуванням ризиків для діяльності організації, її активів, окремих осіб, інших організацій та держави в цілому; PM-11b.[01] визначені потреби в захисті інформації, що впливають з визначених завдань та бізнес-процесів; PM-11b.[02] визначені потреби в обробці персональних впливають з визначеної місії та бізнес-процесів; PM-11c. переглядаються завдання та бізнес-процеси частота. даних, що

19.9. ПРОГРАМА ІНСАЙДЕРСЬКОЇ ЗАГРОЗИ (PM-12)

No: 1

Name: pm_12_01

Type: string

Default: nil

Впроваджено програму інсайдерської (внутрішньої) загрози, яка передбачає наявність команди з обробки інцидентів, пов'язаних з внутрішньою дисципліною

19.10. БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРАЦІВНИКІВ (PM-13)

No: 1

Name: pm_13_01

Type: string

Default: nil

Існує програма розвитку та вдосконалення спеціалістів з питань безпеки

No: 2

Name: pm_13_02

Type: string

Default: nil

Створена програма розвитку та вдосконалення спеціалістів з питань приватності

19.11. ТЕСТУВАННЯ, НАВЧАННЯ ТА МОНІТОРИНГ (РМ-14)

Запровадити програму інформування про загрози, яка містить можливості спільного обміну інформацією між організаціями для аналізу загроз.

Немає параметрів для цього контролю.

19.12. КОНТАКТИ З ГРУПАМИ ТА АСОЦІАЦІЯМИ З ПИТАНЬ БЕЗПЕКИ ІНФОРМАЦІЇ ТА ПРИВАТНОСТІ (РМ-15)

Немає параметрів для цього контролю.

19.13. ПРОГРАМА ІНФОРМУВАННЯ ПРО ЗАГРОЗИ (РМ-16)

No: 1

Name: pm_16_01

Type: string

Default: nil

Впроваджена програма інформування про загрози, яка передбачає можливість обміну інформацією між організаціями для розвідки загроз

19.13.1. ПРОГРАМА ІНФОРМУВАННЯ ПРО ЗАГРОЗИ (РМ-16(1))

No: 1

Name: pm_16_1_01

Type: string

Default: nil

Automated mechanisms are employed to maximize the effectiveness of sharing threat intelligence information

19.14. ЗАХИСТ ПУБЛІЧНОЇ ІНФОРМАЦІЇ У ЗОВНІШНІХ СИСТЕМАХ (РМ-17)

а. Розробити політику та процедури для забезпечення того, щоб вимоги до захисту публічної (некласифікованої) інформації, яка обробляється, зберігається або передається у зовнішніх системах, здійснювалися відповідно до чинного законодавства.

б. Оновлювати політику та процедури [Призначення: з визначеною організацією частотою].

No: 1

Name: pm_17_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначена періодичність перегляду та оновлення політики

No: 2

Name: pm_17_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено періодичність перегляду та оновлення процедур; РМ-17а.[01] розроблено політику, яка гарантує, що вимоги щодо захисту публічної (некласифікованої) інформації, яка обробляється, зберігається або передається в зовнішніх системах, виконуються відповідно до чинних законів, виконавчих наказів, директив, політик, нормативних актів та стандартів; РМ-17а.[02] встановлені процедури для забезпечення виконання вимог щодо захисту публічної (некласифікованої) інформації, яка обробляється, зберігається або передається в зовнішніх системах, відповідно до чинних законів, наказів, директив, політик, нормативно-правових актів та стандартів; РМ-17b.[01] переглядається та оновлюється політика частота; РМ-17b.[02] переглядаються та оновлюються процедури частота

19.15. ПРОГРАМА (КОНЦЕПЦІЯ) ЗАБЕЗПЕЧЕННЯ ПРИВАТНОСТІ (РМ-18)

а.

б. Розробити та поширити загальноорганізаційну програму (концепцію) забезпечення приватності, яка:

1. містить опис структури програми забезпечення приватності та ресурсів, призначених для її реалізації;
2. містить огляд вимог до забезпечення приватності й опис засобів управління програмою забезпечення приватності та загальних заходів захисту, встановлених або запланованих для задоволення цих вимог;
3. визначає обов'язки посадової особи щодо приватності, а також визначає обов'язки інших посадових осіб і персоналу з питань забезпечення приватності;
4. описує зобов'язання керівництва, стратегічні цілі та завдання програми забезпечення приватності;
5. відображає координацію між організаційними структурами, відповідальними за різні аспекти приватності;
6. затверджена високопосадовцем, який є відповідальним (та підзвітним) за: управління ризиками приватності, що виникають при здійсненні операцій організації (включно із завданнями, функціями, іміджем і репутацією); організаційними активами, фізичними особами, іншими організаціями та країнами. Оновлювати програму [Призначення: за визначеною організацією частотою], а також в разі змін законодавства, змін в організації і виявлення проблем в ході реалізації програми або оцінювання заходів приватності.

No: 1

Name: pm_18_odp

Type: list

Default: ["admin", "security_officer"]

Визначена періодичність (концепції) приватності; оновлення плану програми РМ-18а.[01] розроблено загальноорганізаційний план програми (концепції) приватності, який містить огляд програми приватності організації; РМ-18а.01[01] план програми (концепції) приватності містить опис структури програми конфіденційності; РМ-18а.01[02] план програми (концепції) приватності містить опис ресурсів, призначених для реалізації програми конфіденційності; РМ-18а.02[01] план програми (концепції) приватності містить огляд вимог до програми конфіденційності; РМ-18а.02[02] план програми (концепції) приватності містить опис наявних або запланова-

них засобів контролю для управління програмою (концепцією) приватності для виконання вимог програми; РМ-18a.02[03] план програми (концепції) приватності містить опис загальних засобів контролю, що діють або заплановані для виконання вимог програми конфіденційності; РМ-18a.03[01] в плані програми (концепції) приватності передбачена роль старшої посадової особи організації з питань приватності; РМ-18a.03[02] план програми (концепції) приватності включає визначення та призначення ролей інших посадових осіб і співробітників, відповідальних за забезпечення приватності, та їхні обов'язки; РМ-18a.04[01] план програми (концепції) приватності описує зобов'язання керівництва; РМ-18a.04[02] в плані програми (концепції) приватності описано дотримання вимог; РМ-18a.04[03] план програми (концепція) приватності описує стратегічні цілі та завдання програми приватності; РМ-18a.05 план програми (концепція) приватності відображає координацію між підрозділами організації, відповідальними за різні аспекти приватності; РМ-18a.06 затверджено план програми (концепцію) приватності вищою посадовою особою, яка несе відповідальність і підзвітність за ризики для приватності, яких зазнають операції організації (включно з місією, функціями, іміджем і репутацією), активи організації, окремі особи, інші організації та держава; РМ-18a.[02] поширюється план програми (концепція) приватності; РМ-18b.[01] оновлено план програми (концепцію) приватності частота; РМ-18b.[02] оновлюється план програми (концепція) приватності відповідно до змін у державному законодавстві та політиці щодо приватності; РМ-18b.[03] оновлюється план програми відповідно до змін в організації; РМ-18b.[04] оновлюється план програми (концепція) приватності забезпечення приватності для вирішення проблем, виявлених під час реалізації плану або оцінок контролю за дотриманням приватності. (концепція) приватності

19.16. КЕРІВНІ РОЛІ ПРОГРАМИ ПРИВАТНОСТІ (РМ-19)

Призначити старшу посадову особу з питань забезпечення приватності з повноваженнями, завданням, підзвітністю і ресурсами для координації, розробки та реалізації відповідних вимог забезпечення приватності й управління ризиками приватності в рамках програми забезпечення приватності всієї організації.

No: 1

Name: pm_19_01

Type: string

Default: "щорічно"

Визначена періодичність приватності; оновлення плану програми

No: 2

Name: pm_19_02

Type: string

Default: nil

Розроблено загальноорганізаційний план програми приватності, який містить огляд програми приватності для організації

No: 3

Name: pm_19_03

Type: string

Default: nil

Містить план програми приватності опис структури програми приватності

No: 4

Name: pm_19_04

Type: string

Default: nil

Містить план програми приватності опис ресурсів, призначених для реалізації програми приватності

No: 5

Name: pm_19_05

Type: string

Default: nil

Містить план програми приватності огляд вимог до програми приватності

19.17. СИСТЕМА ЗАПИСІВ ПРОГРАМИ ПРИВАТНОСТІ (PM-20)

підтримувати центральну вебсторінку ресурсу на головному загальнодоступному вебсайті організації, яка слугує центральним джерелом інформації про програму приватності організації та яка:

- a. забезпечує доступ громадськості до інформації про діяльність щодо забезпечення приватності в організації та можливість комунікації з уповноваженою посадовою особою з питань забезпечення приватності;
- b. оприлюднює організаційну політику забезпечення приватності на вебсайті організації або іншим чином;
- c. використовує публічні адреси електронної пошти та/або телефонні лінії, щоб дати можливість громадськості надавати відгуки та/або направляти запитання щодо програми приватності в організації.

No: 1

Name: pm_20_01

Type: string

Default: nil

Ведеться центральна вебсторінка загальнодоступному вебсайті організації; на головному

No: 2

Name: pm_20_02

Type: list

Default: ["admin", "security_officer"]

Слугує вебсторінка основним джерелом програму приватності організації; інформації про PM-20a.[01] забезпечує вебсторінка доступ громадськості до інформації про діяльність організації, пов'язану із захистом приватності; PM-20a.[02] забезпечує вебсторінка можливість громадськості спілкуватися з вищим посадовцем організації з питань приватності; PM-20b.[01] забезпечує вебсторінка публічний доступ до інформації організації щодо приватності; PM-20b.[02] забезпечує вебсторінка публічний доступ до звітів про приватність організації; PM-20c. є на веб-сторінці загальнодоступні адреси електронної пошти та/або номери телефонів, щоб громадськість могла надавати зворотній зв'язок та/або направляти запитання до відділів з питань приватності

19.18. ОБЛІК РОЗКРИТТЯ ПЕРСОНАЛЬНИХ ДАНИХ (PM-21)

a. Забезпечити доступ громадськості до інформації із забезпечення приватності в організації та можливість комунікації з уповноваженою посадовою особою з питань забезпечення приватності щодо:

- 1. дати, характеру та мети кожного розкриття запису;
 - 2. імені та адреси особи або організації, щодо яких було зроблено розкриття даних.
- b. Обліковувати та зберігати випадки розкриття персональних даних протягом терміну дії запису або п'яти років після розкриття інформації.
- c. Здійснювати облік випадків розкриття персональних даних, доступних особі, зазначеній у

записі за запитом.

Немає параметрів для цього контролю.

19.19. УПРАВЛІННЯ ЯКІСТЮ ПЕРСОНАЛЬНИХ ДАНИХ (РМ-22)

Розробити та задокументувати загальноорганізаційну політику та процедури, які дозволять:

- a. Проводити огляд точності, актуальності, своєчасності та повноти персональних даних протягом їх життєвого циклу;
- b. Коригувати або видаляти неточну або застарілу інформацію;
- c. Інформувати осіб або інші відповідні організації про внесення змін або видалення персональної інформації;
- d. Оскаржувати відмови на запити щодо коригування чи видалення.

No: 1

Name: pm_22_01

Type: list

Default: ["admin", "security_officer"]

Розроблені та задокументовані загальноорганізаційні політики управління якістю персональних даних

No: 2

Name: pm_22_02

Type: list

Default: ["admin", "security_officer"]

Розроблені та задокументовані загальноорганізаційні процедури управління якістю персональних даних; РМ-22a.[01] передбачено в політиці перевірку точності інформації, що ідентифікує особу, протягом усього життєвого циклу інформації; РМ-22a.[02] передбачено в політиці перегляд актуальності інформації, що ідентифікує особу, протягом життєвого циклу інформації; РМ-22a.[03] передбачено в політиці перевірку своєчасності інформації, що ідентифікує особу, протягом усього життєвого циклу інформації; РМ-22a.[04] передбачено в політиці перевірку повноти інформації, що ідентифікує особу, протягом життєвого циклу інформації; РМ-22a.[05] передбачено в процедурах перевірку точності інформації, що ідентифікує особу, протягом усього життєвого циклу інформації; РМ-22a.[06] передбачено в процедурах перегляд актуальності інформації, що ідентифікує особу, протягом усього життєвого циклу інформації; РМ-22a.[07] процедури передбачають перевірку своєчасності інформації, що ідентифікує особу, протягом усього життєвого циклу інформації; РМ-22a.[08] передбачено в процедурах перевірку повноти інформації, що ідентифікує особу, протягом життєвого циклу інформації; РМ-22b.[01] передбачено в політиці виправлення або видалення неточної або застарілої персональної інформації, що ідентифікує особу; РМ-22b.[02] передбачено в процедурах виправлення або видалення неточної або застарілої персональної інформації; РМ-22c.[01] передбачено в політиці розсилання повідомлень про виправлену або видалену персональну інформацію фізичним особам або іншим відповідним суб'єктам; РМ-22c.[02] передбачено в процедурах повідомлення про виправлення або видалення персональних даних фізичним особам або іншим відповідним суб'єктам; РМ-22d.[01] передбачено в політиці оскарження негативних рішень щодо запитів на виправлення або видалення; РМ-22d.[02] передбачені процедури оскарження негативних рішень щодо запитів на виправлення або видалення

19.20. ОРГАН УПРАВЛІННЯ ПЕРСОНАЛЬНИМИ ДАНИМИ (РМ-23)

створити орган управління персональними даними, на якого покладено [Призначення: визначені організацією функції] та виконання [Призначення: визначені організацією обов'язки].

No: 1

Name: pm_23_01

Type: string

Default: nil

Створено орган управління даними, що складається з ролей з обов'язками

No: 2

Name: pm_23_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначені ролі органу управління персональними даними

No: 3

Name: pm_23_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначені обов'язки органу управління персональними даними

19.21. ОРГАН З ПИТАНЬ ЦІЛІСНОСТІ ДАНИХ (РМ-24)

Створити орган з питань цілісності даних для здійснення:

- a. Розгляду пропозицій щодо проведення відповідної програми або участі у ній.
- b. Проведення огляду усіх поточних програм, в яких бере участь організація.

No: 1

Name: pm_24_01

Type: integer

Default: 30

Створено орган з питань цілісності даних; РМ-24a. розглядає орган з питань цілісності даних пропозиції щодо проведення або участі у відповідній програмі; РМ-24b. проводить орган з питань цілісності даних щорічну перевірку всіх програм співставлення, в яких агентство брало участь

19.22. МІНІМІЗАЦІЯ КІЛЬКОСТІ ПЕРСОНАЛЬНИХ ДАНИХ, ЩО ВИКОРИСТОВУЮТЬСЯ ПІД ЧАС ТЕСТУВАННЯ, НАВЧАННЯ ТА ДОСЛІДЖЕНЬ (РМ-25)

- a. Розробити та впровадити політики та процедури, спрямовані на врегулювання питань використання персональних даних для внутрішнього тестування, навчання та досліджень.
- b. Вжити заходи щодо обмеження або зведення до мінімуму кількості персональних даних,

які використовуються для внутрішнього тестування, навчання та досліджень.

c. Надавати дозвіл на використання персональних даних, коли така інформація вимагається для внутрішнього тестування, навчання і досліджень.

d. Здійснювати огляд та оновлення політик та процедур, спрямованих на врегулювання питань використання персональних даних для внутрішнього тестування, навчання та досліджень [Призначення: з визначеною організацією частотою].

No: 1

Name: pm_25_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено періодичність перегляду політик, які стосуються використання персональних даних для внутрішнього тестування, навчання та досліджень

No: 2

Name: pm_25_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено періодичність оновлення політик, які стосуються використання персональних даних для внутрішнього тестування, навчання та досліджень

No: 3

Name: pm_25_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначено періодичність перегляду процедур, які стосуються використання персональних даних для внутрішнього тестування, навчання та досліджень

No: 4

Name: pm_25_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено періодичність оновлення процедур, які стосуються використання персональних даних для внутрішнього тестування, навчання та досліджень; РМ-25а.[01] розроблені та задокументовані політики, які регулюють використання персональних даних для внутрішнього тестування; РМ-25а.[02] розроблені та задокументовані політики, які стосуються використання персональних даних для внутрішнього навчання РМ-25а.[03] розроблені та задокументовані політики, які регулюють використання персональних даних для внутрішніх досліджень; РМ-25а.[04] розроблені та задокументовані процедури, які стосуються використання персональних даних для внутрішнього тестування; РМ-25а.[05] розроблені та задокументовані процедури, які стосуються використання персональних даних для внутрішнього навчання; РМ-25а.[06] розроблені та задокументовані процедури, які стосуються використання персональних даних для внутрішніх досліджень; РМ-25а.[07] впроваджено політику, яка регулює використання персональних даних для внутрішнього тестування; РМ-25а.[08] впроваджуються політики, які стосуються використання персональних даних для навчання; РМ-25а.[09] впроваджуються політики, які стосуються використання персональної інформації для досліджень; РМ-25а.[10] впроваджені процедури, які стосуються використання персональних даних для внутрішнього тестування; РМ-25а.[11] впроваджені процедури, які стосуються використання персональної інформації для навчання; РМ-25а.[12] впроваджені процедури, які стосуються використання особистої інформації для досліджень; РМ-25b.[01] обмежено або зведено до мінімуму кількість персональних даних, що використовуються для цілей внутрішнього тестування; РМ-25b.[02] обмежено або зведено до мінімуму обсяг інформації, що ідентифікує особу, яка використовується для внутрішніх навчальних цілей; РМ-25b.[03] обмежено або зведено до мінімуму обсяг персональних даних, що використовуються для внутрішніх досліджень; РМ-25с.[01] дозволено використання внутрішнього тестування; персональних даних для РМ-25с.[02] дозволено використання внутрішнього навчання; персональних даних для РМ-25с.[03] дозволено необхідне використання персональних даних для внутрішніх досліджень; РМ-25d.[01] переглядаються політики частота; РМ-25d.[02] оновлюються політики частота; РМ-25d.[03] переглядаються процедури частота; РМ-25d.[04] оновлюються процедури частота

19.23. УПРАВЛІННЯ СКАРГАМИ (PM-26)

Впровадити процес отримання та реагування на скарги, проблеми чи запитання від фізичних осіб щодо організаційної практики забезпечення приватності, який охоплює:

- a. механізми, які легко використовувати та які є легкодоступними для громадськості;
- b. усю інформацію, необхідну для успішного подання скарг;
- c. механізми відстеження, що забезпечують отримання всіх скарг та їх вчасний і належний розгляд протягом [Призначення: визначений організацією період часу];
- d. підтвердження отримання скарг, заявлених проблем чи запитань від фізичних осіб протягом [Призначення: визначений організацією період часу];
- e. надання відповідей на отримані скарги, заявлені проблеми чи запитання від фізичних осіб протягом [Призначення: визначений організацією період часу].

No: 1

Name: pm_26_01

Type: string

Default: nil

Впроваджено процес отримання скарг, занепокоєнь або запитань від фізичних осіб про безпеку та конфіденційність в організації

No: 2

Name: pm_26_02

Type: integer

Default: 30

Впроваджено процес реагування на скарги, занепокоєння або запитання від фізичних осіб про безпеку та конфіденційність в організації; PM-26a.[01] включає процес управління скаргами механізми, які є простими у використанні для громадськості; PM-26c.[02] включає процес управління скаргами механізми, які є легкодоступними для громадськості; PM-26b. містить процес управління скаргами всю інформацію, необхідну для успішного подання скарг; PM-26c.[01] включає процес управління скаргами механізми відстеження, які гарантують, що всі скарги будуть розглянуті протягом періоду часу; період для підтвердження PM-26c.[02] включає процес управління скаргами механізми відстеження, щоб гарантувати, що всі скарги розглядаються протягом часового періоду; PM-26d. передбачає процес управління скаргами підтвердження отримання скарг, занепокоєнь або запитань від фізичних осіб протягом часового періоду; PM-26e. включає процес управління скаргами реагування на скарги, занепокоєння або питання від фізичних осіб протягом часового періоду

No: 3

Name: pm_26_odp_01

Type: integer

Default: 30

Визначено період часу, протягом якого мають бути розглянуті скарги (в тому числі звернення або питання) від фізичних осіб

No: 4

Name: pm_26_odp_02

Type: integer

Default: 30

Визначено період часу, протягом якого мають бути оброблені скарги (в тому числі звернення або питання) від фізичних осіб

No: 5

Name: pm_26_odp_03

Type: integer

Default: 30

Визначено часовий отримання скарг

No: 6

Name: pm_26_odp_04

Type: string

Default: nil

Визначено термін для відповіді на скарги

19.24. ЗВІТНІСТЬ З ПИТАНЬ ЗАБЕЗПЕЧЕННЯ ПРИВАТНОСТІ (РМ-27)

a. Визначити та задокументувати:

1. припущення, що впливають на оцінку ризиків, реагування на ризики та моніторинг ризиків;
2. обмеження, що впливають на оцінку ризиків, реагування на ризики та моніторинг ризиків;
3. пріоритети та компроміси, які розглядаються організацією для здійснення управління ризиками;
4. стійкість організації до ризиків.

b. Поінформувати [Призначення: визначений організацією персонал] про результати визначення ризиків.

c. Переглядати та оновлювати підходи щодо визначення ризиків [Призначення: з визначеною організацією частотою].

No: 1

Name: pm_27_odp_01

Type: string

Default: nil

Визначені звіти з питань забезпечення приватності

No: 2

Name: pm_27_odp_02

Type: string

Default: nil

Визначені органи нагляду за дотриманням приватності

No: 3

Name: pm_27_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначені посадові особи, відповідальні за контроль і дотриманням програми приватності

No: 4

Name: pm_27_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначена періодичність перегляду та оновлення звітів про приватність; РМ-27а. розроблено приватності; РМ-27а.01 передаються звіти з питань забезпечення приватності до наглядових органів, щоб продемонструвати підзвітність законодавчим, регуляторним та політичним мандатам щодо приватності; звіти з питань РМ-27а.02[01] поширюються звіти про конфіденційність серед посадових осіб; РМ-27а.02[02] поширюються звіти з питань забезпечення приватності серед іншого персоналу, відповідального за контроль за дотриманням програми конфіденційності; РМ-27b. переглядаються та оновлюються звіти з питань забезпечення приватності частота

19.25. ОЦІНКА РИЗИКІВ (PM-28)

No: 1

Name: pm_28_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал, який отримуватиме результати визначення ризиків

No: 2

Name: pm_28_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено періодичність перегляду та міркувань щодо структуризації ризиків; PM-28a.01[01] визначені та задокументовані припущення, що впливають на оцінку ризиків; PM-28a.01[02] визначені та задокументовані припущення, що впливають на реагування ризиків; PM-28a.01[03] визначені та задокументовані припущення, що впливають на моніторинг ризиків; PM-28a.02[01] визначені та задокументовані обмеження, що впливають на оцінку ризиків; PM-28a.02[02] визначені та задокументовані обмеження, що впливають на реагування на ризики; PM-28a.02[03] визначені та задокументовані обмеження, що впливають на моніторинг ризиків; оновлення PM-28a.03[01] визначені та задокументовані пріоритети, розглядаються організацією для управління ризиками; які PM-28a.03[02] визначені та задокументовані компроміси, розглядаються організацією для управління ризиками; які PM-28a.04 визначена та задокументована організаційна толерантність до ризиків; PM-28b. поширюються результати діяльності з фреймворкінгу ризиків серед персоналу ; PM-28c. переглядаються та оновлюються міркування фреймінгу ризиків частота. щодо

19.26. РОЛІ КЕРІВНИКІВ ПРОГРАМИ УПРАВЛІННЯ РИЗИКАМИ (PM-29)

- a. Розробити план управління ризиками ланцюга постачання, пов'язаного з розробкою, придбанням, обслуговуванням та утилізацією систем, компонентів системи та послуг для системи.
- b. Реалізувати план управління ризиками ланцюга постачання послідовно та наскрізно по всій організації.
- c. Переглядати й оновлювати план управління ризиками ланцюга постачання [Призначення: з визначеною організацією частотою] або, якщо потрібно, у разі змін в організації.

Немає параметрів для цього контролю.

19.27. ПЛАН УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (PM-30)

No: 1

Name: pm_30_odp

Type: list

Default: ["admin", "security_officer"]

Призначено старшу посадову особу, відповідальну за управління ризиками ланцюга постачання; PM-30a.[01] узгоджує старша посадова особа, відповідальна за управління ризиками ланцюга постачання, процеси управління інформаційною безпекою та конфіденційністю з процесами стратегічного, операційного та бюджетного планування; PM-30a.[02] створена посада (функція) ризик-менеджер; PM-30a.[03] розглядає та аналізує керівник з управління ризиками (функція) ризики з точки зору всієї організації; PM-30a.[04] забезпечує керівник

(функція) з управління ризиками узгоджене управління ризиками в межах всієї організації. РМ-30a.[05] стратегія управління ризиками ланцюга постачання враховує ризики, пов'язані з придбанням систем; РМ-30a.[06] стратегія управління ризиками ланцюга поставок враховує ризики, пов'язані з придбанням компонентів системи; РМ-30a.[07] стратегія управління ризиками ланцюга поставок враховує ризики, пов'язані з придбанням системних послуг; РМ-30a.[08] стратегія управління ризиками ланцюга поставок враховує ризики, пов'язані з обслуговуванням систем; РМ-30a.[09] стратегія управління ризиками ланцюга поставок враховує ризики, пов'язані з обслуговуванням компонентів системи; РМ-30a.[10] стратегія управління ризиками ланцюга поставок враховує ризики, пов'язані з обслуговуванням системних послуг; РМ-30a.[11] враховує стратегія управління ризиками ланцюга постачання ризики, пов'язані з утилізацією систем; РМ-30a.[12] враховує стратегія управління ризиками ланцюга постачання ризики, пов'язані з утилізацією компонентів системи; РМ-30a.[13] стратегія управління ризиками ланцюга поставок враховує ризики, пов'язані з утилізацією системних послуг; РМ-30b. стратегія управління ризиками ланцюга послідовно впроваджується в організації; РМ-30с. переглядається та оновлюється стратегія управління ризиками ланцюга постачання частота або в міру необхідності у зв'язку з організаційними змінами поставок

19.28. ПЛАН БЕЗПЕРЕРВНОГО МОНІТОРИНГУ (РМ-31)

Розробити план безперервного моніторингу в масштабах всієї організації та впровадити програми безперервного моніторингу, які включають:

- a. Встановити відповідні показники для моніторингу в масштабах всієї організації [Призначення: визначені організацією показники];
- b. Встановити [Призначення: частота, визначеної організацією] для здійснення моніторингу та [Призначення: періодичність, визначена організацією] проведення оцінки ефективності контролю;
- c. Постійний моніторинг визначених організацією показників відповідно до стратегії безперервного моніторингу;
- d. Співставлення та аналіз інформації, отриманої в результаті здійснення моніторингу, та контрольних оцінок;
- e. Заходи реагування на результати аналізу оцінок контролю та моніторингових даних;
- f. Звітування про стан безпеки та приватності систем організації перед [Призначення: визначеним організацією персоналом чи посадовою особою] [Призначення: з визначеною організацією періодичністю].

No: 1

Name: pm_31_01

Type: list

Default: ["admin", "security_officer"]

Розроблена загальноорганізаційна стратегія безперервного моніторингу; РМ-31a. впроваджуються програми безперервного моніторингу, які включають встановлення параметрів, що підлягають моніторингу; РМ-31b.[01] впроваджено програми безперервного моніторингу, які встановлюють частоту для моніторингу; РМ-31b.[02] впроваджуються програми безперервного моніторингу, які встановлюють частоту для оцінки ефективності контролю; про стан РМ-31с. впроваджуються програми безперервного моніторингу, які включають моніторинг параметрів на постійній основі відповідно до стратегії безперервного моніторингу; РМ-31d.[01] впроваджуються програми безперервного моніторингу, які включають співставлення інформації, отриманої в результаті контрольних оцінок та моніторингу; РМ-31d.[02] впроваджуються програми постійного моніторингу, які включають аналіз інформації, отриманої в результаті контрольних оцінок та моніторингу; РМ-31e.[01] впроваджуються програми безперервного моніторингу, які передбачають заходи реагування на аналіз інформації, отриманої в результаті оцінки результатів контролю; РМ-31e.[02] впроваджуються програми безперервного моніторингу, які передбачають заходи реагування на результати аналізу інформації, отриманої під час моніторингу; РМ-31f.[01] впроваджено програми безперервного моніторингу, які передбачають звітування про стан безпеки систем організації перед персоналом або ролі частота; РМ-31f.[02] впроваджені програми безперервного моніторингу, які передбачають звітування про стан конфіденційності організаційних систем перед персоналом або ролі частота

No: 2

Name: pm_31_odp_01

Type: string

Default: nil

Визначені параметри для безперервного моніторингу в масштабах всієї організації

No: 3

Name: pm_31_odp_02

Type: string

Default: "щорічно"

Визначено періодичність моніторингу

No: 4

Name: pm_31_odp_03

Type: string

Default: "щорічно"

Визначена періодичність оцінки ефективності контролю

No: 5

Name: pm_31_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі для звітування про стан безпеки систем організації

No: 6

Name: pm_31_odp_05

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі для звітування про стан конфіденційності систем організації

No: 7

Name: pm_31_odp_06

Type: string

Default: "щорічно"

Визначено періодичність звітування про стан безпеки систем організації

No: 8

Name: pm_31_odp_07

Type: string

Default: "щорічно"

Визначено періодичність звітування конфіденційності систем організації

19.29. ПРИЗНАЧЕННЯ (РМ-32)

Включіть ролі й обов'язки з безпеки та приватності в опис посади в організації.

No: 1

Name: pm_32_01

Type: string

Default: nil

Аналізуються допоміжні послуги або функції, необхідні для виконання місії, для забезпечення того, щоб інформаційні ресурси використовувалися відповідно до їхнього призначення

20. РТ

Клас заходів захисту РТ — ПОВНОВАЖЕННЯ

Цей клас фокусується на дотриманні законодавства щодо захисту персональних даних, отриманні згоди та забезпеченні прав суб'єктів даних.

Перелік заходів захисту: Рт (РТ-1); Повноваження на обробку персональних даних (РТ-2); Повноваження на тегування даних (РТ-2(1)); Повноваження автоматизація (РТ-2(2)); Цілі обробки персональних даних (РТ-3); Тегування даних (РТ-3(1)); Автоматизація (РТ-3(2)); Згода на обробку персональних даних (РТ-4); Індивідуальна згода на обробку персональних даних (РТ-4(1)); Своєчасна згода на обробку персональних даних (РТ-4(2)); Відкликання (РТ-4(3)); Повідомлення про конфіденційність (РТ-5); Повідомлення про конфіденційність повідомлення про конфіденційність (РТ-5(1)); Повідомлення про конфіденційність (РТ-5(2)); Система записів повідомлень про конфіденційність (РТ-6); Система записів повідомлень про конфіденційність звичайне використання (РТ-6(1)); (РТ-6(2)); Спеціальні категорії персональних даних (РТ-7); Спеціальні категорії персональних соціального страхування (РТ-7(1)); Інформація про першу поправку (РТ-7(2)); Вимоги до відповідності (РТ-8).

20.1. РТ (РТ-1)

а. Розробіть, задокументуйте та поширте [Призначення: персонал або ролі, визначені організацією]:

1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи], обробки персональних даних та політики прозорості, який: а) розглядає мету, сферу діяльності, ролі, відповідальність, зобов'язання керівництва, координацію між організаційними підрозділами та відповідність; б) відповідає чинним законам, розпорядженням, директивам, положенням, політикам, стандартам і рекомендаціям.

2. Процедури для реалізації політики обробки та прозорості персональних даних, а також пов'язані засоби контролю;

б. Призначте [Призначення: посадову особу, визначену організацією] для керування розробкою, документуванням і розповсюдженням політики й процедур щодо обробки персональних даних та прозорості;

с. Перегляньте та оновіть поточні процедури обробки та прозорість персональних даних:

1. Політика [Призначення: частота, визначена організацією] і наступні [Призначення: події, визначені організацією];

2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: подія, визначена організацією].

No: 1

Name: pt_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюється політика обробки персональних даних та забезпечення прозорості

No: 2

Name: pt_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури обробки персональних даних та політики прозорості

No: 3

Name: pt_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: pt_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами обробки персональних даних, а також політикою та процедурами прозорості

No: 5

Name: pt_1_odp_05

Type: list

Default: ["admin", "security_officer"]

Визначена періодичність перегляду та оновлення поточної політики обробки та прозорості інформації, що ідентифікує особу

No: 6

Name: pt_1_odp_06

Type: list

Default: ["admin", "security_officer"]

Є події, які вимагають перегляду та оновлення поточної політики обробки персональних даних та прозорості

No: 7

Name: pt_1_odp_07

Type: list

Default: ["admin", "security_officer"]

Визначена частота, з якою переглядаються та оновлюються поточні процедури обробки персональних даних та забезпечення прозорості

20.2. ПОВНОВАЖЕННЯ НА ОБРОБКУ ПЕРСОНАЛЬНИХ ДАНИХ (РТ-2)

- а. визначити та задокументувати [Призначення: повноваження, визначені організацією], які дозволяють [Призначення: обробку, визначену організацією] персональної інформації;
- б. обмежити [Призначення: обробку, визначену організацією] персональної інформації лише таким чином, яким дозволено (тільки до того, що дозволено)

No: 1

Name: pt_2_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначені повноваження щодо надання дозволу на обробку (визначені в РТ-02_ODP[02]) персональних даних

No: 2

Name: pt_2_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено тип обробки персональних даних

No: 3

Name: pt_2_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначено тип обробки підлягають обмеженню; РТ-02а. визначено та задокументовано орган, який дозволяє обробку персональних даних; РТ-02b. обробка персональних обмежується лише таким чином, яким дозволено. персональних даних, що даних,

20.2.1. ПОВНОВАЖЕННЯ НА ТЕГУВАННЯ ДАНИХ (РТ-2(1))

No: 1

Name: pt_2_1_01

Type: list

Default: ["admin", "security_officer"]

Теги даних, що містять <РТ-02(01) _ODP[01] санкціонована обробка>, прикріплені до <РТ-02(01) _ODP[02] елементів інформації, що ідентифікує особу>

20.2.2. ПОВНОВАЖЕННЯ АВТОМАТИЗАЦІЯ (РТ-2(2))

No: 1

Name: pt_2_2_01

Type: list

Default: ["admin", "security_officer"]

Управління дотриманням санкціонованої обробки персональних даних здійснюється за допомогою <РТ02(02) _ODP автоматизовані механізми обробки персональних даних>

No: 2

Name: pt_2_2_odp

Type: list

Default: ["admin", "security_officer"]

Визначені автоматизовані механізми, які використовуються для управління дотриманням санкціонованої обробки інформації, що ідентифікує особу

20.3. ЦІЛІ ОБРОБКИ ПЕРСОНАЛЬНИХ ДАНИХ (РТ-3)

- a. визначити та задокументувати [Призначення: цілі, визначені організацією] для обробки персональних даних;
- b. описати мету (цілі) у публічних повідомленнях про конфіденційність і політиках організації;
- c. обмежити [Призначення: обробку, визначену організацією] персональних даних лише тією, яка сумісна з визначеною ціллю(ями);
- d. відстежувати зміни в обробці персональних даних та впроваджувати [Завдання: визначені організацією механізми], щоб гарантувати, що будь-які зміни вносяться відповідно до [Завдання: визначені організацією вимоги].

No: 1

Name: pt_3_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено мету (цілі) обробки персональних даних

No: 2

Name: pt_3_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначена обробка персональних даних, яка підлягає обмеженню

No: 3

Name: pt_3_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначені механізми, які мають бути впроваджені для забезпечення того, щоб будь-які зміни в персональних даних, вносилися відповідно до вимог

No: 4

Name: pt_3_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначені вимоги до зміни обробки персональних даних; РТ-03а. визначено та задокументовано мету (цілі) обробки персональних даних; РТ-03б.[01] описана мета (цілі) в публічних конфіденційність організації; РТ-03б.[02] описана мета (цілі) в політиці організації; РТ-03с обробка персональних даних, обмежується лише тим, що є сумісним з визначеною метою (цілями); РТ-03д.[01] здійснюється моніторинг змін в обробці персональних даних; РТ-03д.[02] впроваджено механізми для забезпечення того, щоб будь-які зміни вносилися відповідно до вимог. повідомленнях про

20.3.1. ТЕГУВАННЯ ДАНИХ (РТ-3(1))

No: 1

Name: pt_3_1_01

Type: list

Default: ["admin", "security_officer"]

Теги даних, що містять <РТ-03(01) _ODP[01] цілі обробки>, приєднані до <РТ-03(01) _ODP[02] елементів інформації, що ідентифікує особу>

20.3.2. АВТОМАТИЗАЦІЯ (РТ-3(2))

No: 1

Name: pt_3_2_01

Type: list

Default: ["admin", "security_officer"]

Відстежуються цілі обробки персональних даних за допомогою автоматизованих механізмів

No: 2

Name: pt_3_2_odp

Type: list

Default: ["admin", "security_officer"]

Визначені автоматизовані механізми відстеження цілей обробки персональних даних

20.4. Згода на обробку персональних даних (РТ-4)

Впроваджувати [Призначення: інструменти або механізми, визначені організацією], щоб окремі особи давали згоду на обробку їх персональних даних до її збору, що полегшить прийняття обґрунтованих рішень особами.

No: 1

Name: pt_4_01

Type: list

Default: ["admin", "security_officer"]

Впроваджено інструменти або механізми для надання фізичними особами згоди на обробку їхніх персональних даних до її збору, які сприяють прийняттю фізичними особами поінформованих рішень

No: 2

Name: pt_4_odp

Type: list

Default: ["admin", "security_officer"]

Визначені інструменти або механізми, які мають бути застосовані для надання особами згоди на обробку їхніх персональних даних

20.4.1. ІНДИВІДУАЛЬНА ЗГОДА НА ОБРОБКУ ПЕРСОНАЛЬНИХ ДАНИХ (РТ-4(1))

No: 1

Name: pt_4_1_odp

Type: list

Default: ["admin", "security_officer"]

Визначені механізми адаптації для обробки окремих елементів дозволів персональних даних; РТ-04(01) передбачені механізми, які дозволяють особам пристосовувати дозволи на обробку до вибраних елементів персональних даних

20.4.2. СВОЄЧАСНА ЗГОДА НА ОБРОБКУ ПЕРСОНАЛЬНИХ ДАНИХ (РТ-4(2))

No: 1

Name: pt_4_2_01

Type: list

Default: ["admin", "security_officer"]

Надаються механізми згоди особам частота та в поєднанні з обробкою персональних даних

20.4.3. ВІДКЛИКАННЯ (РТ-4(3))

No: 1

Name: pt_4_3_01

Type: list

Default: ["admin", "security_officer"]

Впроваджено інструменти або механізми, які дозволяють фізичним особам відкликати згоду на обробку їхніх персональних даних

No: 2

Name: pt_4_3_odp

Type: list

Default: ["admin", "security_officer"]

Визначені інструменти або механізми для відкликання згоди на обробку персональних даних

20.5. ПОВІДОМЛЕННЯ ПРО КОНФІДЕНЦІЙНІСТЬ (РТ-5)

Впровадити повідомлення про конфіденційність особам, чиї персональні дані обробляються в системі, які:

- a. доступні окремим особам під час першої взаємодії з організацією, та згодом [Призначення: частота, визначена організацією];
- b. виражені простою мовою;
- c. визначають орган, який надає дозвіл на обробку персональних даних;
- d. визначають цілі, для яких мають оброблятися персональні дані;
- e. включають [Призначення: інформація, визначена організацією].

No: 1

Name: pt_5_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначена частота, з якою повідомлення надається особам на рівні первинної взаємодії з організацією

No: 2

Name: pt_5_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначена інформація, яка повинна бути включена до повідомлення про обробку персональних даних; РТ-05a.[01] направляється особам повідомлення про обробку персональних даних таким чином, щоб вони могли ознайомитися з ним при першій взаємодії з організацією; РТ-05a.[02] направляється повідомлення фізичним особам про обробку персональних даних, таким чином, щоб це повідомлення було згодом доступне фізичним особам частота; РТ-05b. направляється фізичним особам повідомлення про обробку персональних даних, яке є чітким, легким для розуміння та містить інформацію про обробку персональних даних простою мовою; РТ-05c. направляється фізичним особам повідомлення про обробку персональних даних, яке визначає орган, що надає дозвіл на обробку персональних даних; РТ-05d. направляється повідомлення фізичним особам про обробку персональних даних, в якому вказується мета, з якою буде оброблятися персональна інформація; РТ-05e. направляється повідомлення фізичним особам про обробку персональних даних, які включають інформацію

20.5.1. ПОВІДОМЛЕННЯ ПРО КОНФІДЕНЦІЙНІСТЬ ПОВІДОМЛЕННЯ ПРО КОНФІДЕНЦІЙНІСТЬ (РТ-5(1))

No: 1

Name: pt_5_1_01

Type: list

Default: ["admin", "security_officer"]

Надається повідомлення про обробку персональних даних особам у той час і в тому місці, де особа надає персональні дані, у зв'язку з якою здійснюється дія з даними, або періодичність обробки даних частота

No: 2

Name: pt_5_1_odp

Type: list

Default: ["admin", "security_officer"]

Визначена періодичність подання обробку персональних даних; повідомлення про

20.5.2. ПОВІДОМЛЕННЯ ПРО КОНФІДЕНЦІЙНІСТЬ (РТ-5(2))

No: 1

Name: pt_5_2_01

Type: string

Default: nil

Включаються повідомлення про конфіденційність у форми, які збирають інформацію, що буде зберігатися в системі записів Закону про конфіденційність, або ж заяви про конфіденційність надаються на окремих формах, які можуть зберігатися у приватних осіб

20.6. СИСТЕМА ЗАПИСІВ ПОВІДОМЛЕНЬ ПРО КОНФІДЕНЦІЙНІСТЬ (РТ-6)

для систем, які обробляють інформацію, яка зберігатиметься в системі записів Закону про конфіденційність:

- a. розробити проект системи повідомлень про записи відповідно до вказівок ОМВ і подати нову та суттєво змінену систему повідомлень про записи до ОМВ та відповідних комітетів Конгресу для попереднього розгляду;
- b. опублікувати систему записів повідомлень у Державному реєстрі;
- c. зберігати повідомлення системи записів точними, оновленими та в обсязі відповідно до впровадженої політики.

Немає параметрів для цього контролю.

20.6.1. СИСТЕМА ЗАПИСІВ ПОВІДОМЛЕНЬ ПРО КОНФІДЕНЦІЙНІСТЬ ЗВИЧАЙНЕ ВИКОРИСТАННЯ (РТ-6(1))

No: 1

Name: pt_6_1_01

Type: string

Default: "щорічно"

Переглядаються всі звичайні види використання, опубліковані в повідомленні системи записів періодичність, для забезпечення постійної точності, а також для забезпечення того, щоб звичайні види використання і надалі були сумісними з метою, для якої була зібрана інформація

No: 2

Name: pt_6_1_odp

Type: string

Default: "щорічно"

Визначено періодичність перегляду всіх звичайних видів використання, опублікованих у системі обліку повідомлень

20.6.2. (РТ-6(2))

No: 1

Name: pt_6_2_01
 Type: string
 Default: "щорічно"

Всі винятки із Закону про конфіденційність, заявлені для системи записів, переглядаються частота, щоб переконатися, що вони залишаються доречними та необхідними відповідно до закону

No: 2
 Name: pt_6_2_02
 Type: string
 Default: "щорічно"

Всі винятки із Закону про конфіденційність, заявлені для системи записів, переглядаються частота, щоб переконатися, що вони були оприлюднені як нормативні акти

No: 3
 Name: pt_6_2_03
 Type: string
 Default: "щорічно"

Всі винятки із Закону про конфіденційність, заявлені для системи записів, переглядаються частота, щоб переконатися, що вони точно описані в повідомленні про систему записів

No: 4
 Name: pt_6_2_odp
 Type: string
 Default: "щорічно"

Визначено періодичність перегляду всіх винятків із Закону про конфіденційність, заявлених для системи записів

20.7. СПЕЦІАЛЬНІ КАТЕГОРІЇ ПЕРСОНАЛЬНИХ ДАНИХ (РТ-7)

Застосувати [Призначення: умови обробки, визначені організацією] для певних категорій персональних даних.

No: 1
 Name: pt_7_01
 Type: list
 Default: ["admin", "security_officer"]

Застосовуються умови обробки до певних категорій персональних даних

No: 2
 Name: pt_7_odp
 Type: list
 Default: ["admin", "security_officer"]

Визначені умови обробки, що застосовуються до певних категорій персональних даних

20.7.1. СПЕЦІАЛЬНІ КАТЕГОРІЇ ПЕРСОНАЛЬНИХ СОЦІАЛЬНОГО СТРАХУВАННЯ (РТ-7(1))

No: 1
 Name: pt_7_1_a_01

Type: string

Default: nil

При обробці системою номерів соціального страхування усувається непотрібний збір, зберігання та використання номерів соціального страхування

No: 2

Name: pt_7_1_a_02

Type: list

Default: ["admin", "security_officer"]

Вивчаються альтернативи використанню номерів соціального страхування в якості персонального ідентифікатора, коли система обробляє їх

No: 3

Name: pt_7_1_b

Type: list

Default: ["admin", "security_officer"]

Не відмовляється система при обробці номерів соціального страхування в індивідуальних правах, пільгах або привілеях, передбачених законом, через відмову особи розкрити свій номер соціального страхування

No: 4

Name: pt_7_1_c_01

Type: list

Default: ["admin", "security_officer"]

При обробці системою номерів соціального страхування кожну особу, яку просять розкрити свій номер соціального страхування, інформують про те, чи є таке розкриття обов'язковим чи добровільним, яким законодавчим чи іншим органом запитується такий номер, і як він буде використовуватися

No: 5

Name: pt_7_1_c_02

Type: list

Default: ["admin", "security_officer"]

При обробці системою номерів соціального страхування кожну особу, яку просять розкрити свій номер соціального страхування, інформують про те, яким законодавчим чи іншим органом запитується цей номер

No: 6

Name: pt_7_1_c_03

Type: list

Default: ["admin", "security_officer"]

При обробці системою номерів соціального страхування кожну особу, яку просять розкрити свій номер соціального страхування, інформують про те, як він буде використовуватися

20.7.2. ІНФОРМАЦІЯ ПРО ПЕРШУ ПОПРАВКУ (РТ-7(2))

No: 1

Name: pt_7_2_01

Type: list

Default: ["admin", "security_officer"]

Заборонена обробка інформації, що описує, як будь-яка особа реалізує права, гарантовані Першою поправкою, за винятком випадків, коли це прямо дозволено законом або особою, або якщо вона не стосується та входить до сфери санкціонованої діяльності правоохоронних органів

20.8. ВИМОГИ ДО ВІДПОВІДНОСТІ (РТ-8)

Коли система чи організація обробляє інформацію з метою проведення програми відповідності необхідно:

- a. отримати схвалення Ради з цілісності даних для проведення програми відповідності;
- b. розробити та укласти договір комп'ютерної відповідності;
- c. незалежним чином перевіряти інформацію, надану програмою відповідності, перш ніж вживати негативних заходів проти особи;
- d. повідомляти осіб і надати їм можливість оскаржити висновки, перш ніж вживати проти них негативних заходів.

Немає параметрів для цього контролю.